ZCIE Security

ZyeemZia™ Certified Internetwork Expert — Security

Defend every layer. Trust nothing by default.



COURSE BOOK · WORKBOOK · EXAM PREPARATION

8 MODULES · 37 LESSONS · 60 EXAM QUESTIONS

COPYRIGHT © ZYEEMZIA

BEFORE YOU BEGIN

How to use this book

An expert-level network security certification: security architecture, next-generation firewalls, VPN and PKI, identity and network access control, threat detection, SASE and cloud security, SIEM/SOAR and incident response, all wrapped in zero trust.

01
Learn
Work through 37 lessons. Each ends with a knowledge check.

02
Practise
Fill in the templates, answer the scenarios and case studies, review the glossary.

03
Certify
Take the 45-question official exam at zcie-security.zyeemzia.com, graded on the ZyeemZia server. Pass mark 85%.

04
Get certified
Download your certificate online. Anyone can verify its credential ID at zcie-security.zyeemzia.com/#verify. 92%+ and the capstone earn Distinction.

Eight-week study plan

WHEN	MODULE	DO THIS	DONE
Month 1	m1 Architect	Threat model, segmentation design	☐
Month 2	m2 Perimeter	NGFW policy and TLS-inspection labs	☐
Month 3	m3 Tunnel	IPsec/IKEv2 and PKI labs	☐
Month 4	m4 Identity	802.1X, NAC and MFA labs	☐
Month 5	m5 Detect	IPS tuning, email/DNS security	☐
Month 6	m6 Cloud	SASE/SSE and cloud controls	☐
Month 7	m7 Respond	SIEM rules, SOAR playbooks, tabletop	☐
Month 8	m8 ZeroTrust	Mock lab, capstone, certification exam	☐

Learner name .....

Start date ..... Target exam date .....

ZCIE Security is an independent certification programme created and issued by ZyeemZia. It is not affiliated with, endorsed by, sponsored by or equivalent to any certification from Cisco Systems, Inc. (including CCNA®, CCNP®, CCIE® and CCDE®) or from any other vendor or certifying body. All product names and trademarks belong to their respective owners. Configuration examples use widely taught, vendor-neutral style syntax.

Copyright © ZyeemZia

CONTENTS

What you will learn

01 Architect — Security Architecture & Threat Landscape

1. Threat Actors and the Attack Lifecycle · 25 min
2. NIST CSF 2.0 and Risk-Based Prioritisation · 25 min
3. Defence in Depth and Segmentation Strategy · 28 min
4. Secure Architecture Patterns and Zero-Trust Principles · 28 min

02 Perimeter — Next-Generation Firewalls

1. Stateful Inspection, Zones and Policy Design · 28 min
2. NAT, Application Identification and User-Based Policy · 28 min
3. TLS Inspection and IPS Integration · 30 min
4. Firewall High Availability Designs · 25 min
5. Policy Hygiene, Audit and Troubleshooting · 30 min

03 Tunnel — VPN Technologies

1. IPsec and IKEv2 Fundamentals · 30 min
2. Site-to-Site VPN: Route-Based and Policy-Based · 32 min
3. Dynamic Hub-and-Spoke and Remote-Access VPN · 30 min
4. PKI for VPNs and Troubleshooting Negotiation · 32 min

04 Identity — Identity & Network Access Control

1. AAA, RADIUS and TACACS+ · 28 min
2. IEEE 802.1X and EAP Methods · 30 min
3. MAB, Dynamic Authorisation and Phased Deployment · 32 min
4. Posture, Guest and BYOD Onboarding · 28 min
5. MFA, Phishing-Resistant Authentication and Identity-Based Segmentation · 30 min

05 Detect — Detect — Threat Detection & Prevention

1. Detection Engines: IDS, IPS and How They Decide · 35 min
2. Tuning, False Positives and Detection Engineering · 40 min
3. Email Security: SPF, DKIM and DMARC · 40 min
4. Web, URL Filtering and DNS-Layer Security · 40 min
5. Endpoint Detection, XDR and Deception · 40 min

06 Cloud — Cloud — Cloud, SASE & SSE

1. Shared Responsibility and Cloud Network Controls · 40 min
2. SASE and SSE: Architecture, Secure Web Gateway and CASB · 40 min
3. ZTNA versus VPN and Branch-to-Cloud Design · 40 min
4. Securing SaaS and APIs · 40 min

07 Respond — Respond — Visibility, SIEM, SOAR & Incident Response

1. Logging Strategy and Flow Telemetry · 40 min
2. SIEM Correlation and Detection Use Cases · 40 min
3. SOAR Playbooks and Threat Hunting · 40 min
4. Incident Response Lifecycle and Evidence Handling · 45 min
5. Metrics and Continuous Improvement · 35 min

08 ZeroTrust — ZeroTrust — Zero Trust Architecture, Automation & Capstone

1. Zero Trust Architecture and NIST SP 800-207 · 40 min
2. Identity, Device and Data Controls with Micro-segmentation · 40 min
3. Zero Trust Maturity and Roadmap · 40 min
4. Security Automation, Policy-as-Code and AI-Assisted Operations · 45 min
5. Mock Expert Lab, Exam Strategy and Capstone · 50 min

Copyright © ZyeemZia

+ Glossary · Capstone guide · Practice exam & answers · Certificate · Notes

Copyright © ZyeemZia

THE FRAMEWORK

The ZCIE Security Defence-in-Depth Stack

Seven defensive layers from architecture to response, wrapped by zero trust. An attacker has to beat every layer; a defender only needs one layer to catch them.



01 Architect

Start from the threat: model attackers, prioritise by risk and design depth before buying products

02 Perimeter

Design, build and operate stateful, application- and identity-aware firewall policy that stays clean and resilient

03 Tunnel

Build, scale and troubleshoot IPsec and remote-access VPNs with strong cryptography and dependable PKI

04 Identity

Know every user and device before access: AAA, 802.1X, NAC, posture, MFA and identity-based segmentation

05 Detect

See hostile activity early and stop it with confidence: network sensors, email, web, DNS, endpoints and deception.

06 Cloud

Secure what you own in the cloud and deliver security from the cloud to every user, branch and application.

07 Respond

See everything that matters, correlate it into reliable alerts, automate with guardrails and respond with discipline.

08 ZeroTrust

Wrap every layer in per-session, evidence-based access decisions, automate policy safely and prove expert readiness.

Copyright © ZyeemZia

01

MODULE 1 · ARCHITECT

Security Architecture & Threat Landscape

Start from the threat: model attackers, prioritise by risk and design depth before buying products

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Profile likely threat actors and describe intrusions using MITRE ATT&CK tactics
- Use NIST CSF 2.0 functions and profiles to express security posture and gaps
- Prioritise security work with likelihood × impact and annualised loss estimates
- Design layered defences and a phased segmentation strategy
- Apply secure reference patterns and zero-trust principles to campus, branch, data centre and cloud

LESSONS

1. Threat Actors and the Attack Lifecycle · 25 min
2. NIST CSF 2.0 and Risk-Based Prioritisation · 25 min
3. Defence in Depth and Segmentation Strategy · 28 min
4. Secure Architecture Patterns and Zero-Trust Principles · 28 min

MODULE 1 · ARCHITECT · LESSON 1 · 25 MIN

Threat Actors and the Attack Lifecycle

Who attacks networks in 2026, what they want, and how an intrusion unfolds from first probe to impact

- Profile the main threat-actor groups by motive, capability and typical targets
- Describe an intrusion using the MITRE ATT&CK enterprise tactics at a high level
- Map each stage of an attack to the defensive layer best placed to stop or see it
- Explain why defenders must assume some controls will fail

Security architecture starts with an honest question: **who is likely to attack us, and how?** A design that is perfect against an imaginary opponent and blind to the real one is a liability. Expert engineers begin with the threat, then choose controls — never the other way round.

> DEFINITION · THREAT, VULNERABILITY, RISK
> A **threat** is an actor or event that could cause harm. A **vulnerability** is a weakness the threat could use. **Risk** is the combination of how likely that harm is and how bad it would be. Controls reduce likelihood, impact, or both — they never reduce risk to zero.

Threat-actor profiles defenders plan for

ACTOR	MAIN MOTIVE	TYPICAL CAPABILITY	WHAT THEY USUALLY GO AFTER
Financially motivated crime groups	Money: extortion, fraud, data resale	High; industrialised, uses affiliates and purchased access	Any organisation that can pay; ransomware and data-theft extortion
State-aligned groups	Espionage, pre-positioning, disruption	Very high; patient, custom tooling, long dwell times	Government, telecoms, energy, defence supply chain, research
Hacktivists	Publicity and ideology	Low to medium; DDoS, defacement, leaks	High-profile brands and public bodies during political events
Insiders (malicious or careless)	Grievance, gain, or simple mistakes	Legitimate access already granted	Data they can reach; misconfigured shares and cloud storage
Opportunistic scanners and botnets	Volume: find anything exposed	Automated, fast, low skill per target	Unpatched edge devices, exposed management ports, default credentials

> INSIGHT · THE EDGE IS THE NEW FRONT DOOR
> Recent years have shown a steady pattern: attackers increasingly gain initial access through **internet-facing appliances** — VPN concentrators, firewalls, file-transfer servers and remote-management portals — rather than only through phishing. Your perimeter devices are both controls and targets, so they need the same patching urgency and monitoring as servers. The other fast-growing entry route is **identity**: stolen session tokens, MFA-fatigue prompts, help-desk social engineering and convincing AI-generated lures (text, voice and video). Treat sign-in systems and support desks as part of the attack surface.

To discuss intrusions consistently, the industry uses **MITRE ATT&CK**, a public knowledge base of adversary behaviour observed in real incidents. Its enterprise matrix groups techniques under **tactics** — the attacker's

Copyright © ZyeemZia

goal at each point. You do not need to memorise hundreds of techniques; you do need to recognise the tactics and know which of your layers can see them.

A typical intrusion, expressed as ATT&CK tactics

01 Reconnaissance
Scan exposed services, harvest staff names, find the VPN portal

→

02 Initial Access
Exploit an edge device, use stolen credentials or deliver a phishing lure

→

03 Execution & Persistence
Run tooling and plant a way back in that survives reboots

→

04 Privilege Escalation & Credential Access
Harvest passwords and tokens, become an administrator

→

05 Discovery & Lateral Movement
Map the network and move toward valuable systems

→

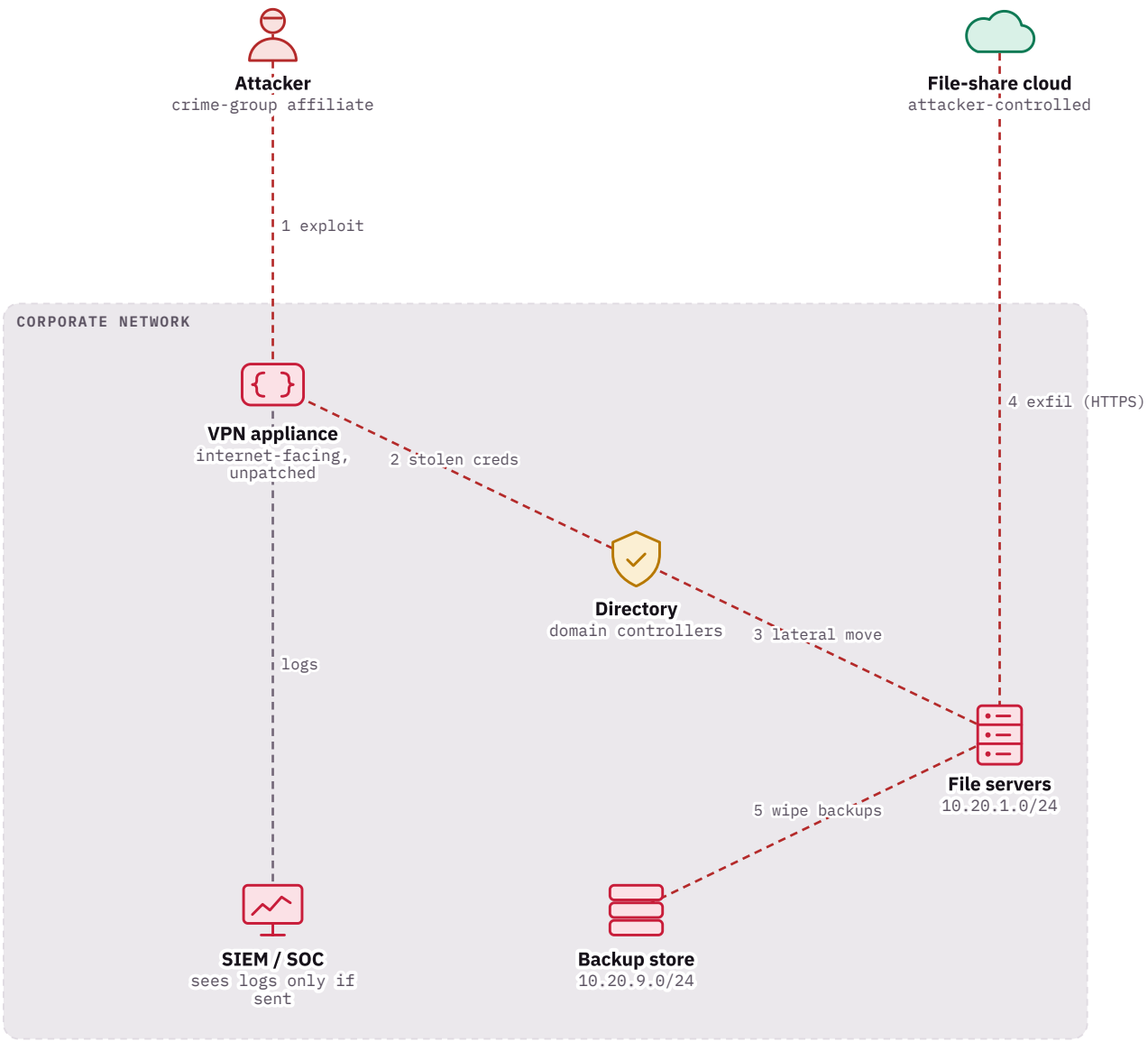
06 Collection & Exfiltration
Stage data and move it out, often over encrypted channels

→

07 Impact
Encrypt, destroy or manipulate systems and data

Copyright © ZyeemZia

One intrusion drawn as an attack path



Follow the numbered red links: each hop is a different ATT&CK tactic and a different chance to stop or see the attacker. Notice that the edge device is both a control and the first victim, so its logs must reach the SOC.

The full set of enterprise tactics (for reference)

- Reconnaissance, Resource Development
- Initial Access, Execution, Persistence
- Privilege Escalation, Defense Evasion, Credential Access
- Discovery, Lateral Movement, Collection
- Command and Control, Exfiltration, Impact

Copyright © ZyeemZia

Where each defensive layer earns its keep

ATTACK STAGE	BEST-PLACED LAYER	EXAMPLE CONTROL
Reconnaissance / Initial Access	Perimeter, Tunnel	Minimal exposed services, patched edge devices, MFA on VPN
Credential Access	Identity	Phishing-resistant MFA, no shared admin accounts, tiered admin
Lateral Movement	Architect (segmentation), Identity	Zone-to-zone firewalling, identity-based policy, east-west inspection
Command and Control	Perimeter, Detect	Egress filtering, DNS security, TLS inspection where justified
Exfiltration	Perimeter, Cloud, Detect	Egress controls, data-loss rules, flow anomaly detection
Impact	Respond	Immutable backups, tested recovery, isolation playbooks

WATCH OUT · ASSUME BREACH

Every control in this course will fail at some point — a zero-day on the firewall, a user who approves a fraudulent prompt, a misconfigured rule. Design so that a single failure gives the attacker **a foothold, not the kingdom**: limited reach, high chance of detection, fast recovery.

SCENARIO · DECIDE · CHOOSING WHAT TO FIX FIRST

A manufacturer's threat review finds: (1) the remote-access VPN portal runs a version with a publicly known critical flaw being actively exploited; (2) the guest Wi-Fi shares a VLAN with printers; (3) firewall logs are kept for only 7 days. You can fund one action this week.

- (A) Separate guest Wi-Fi from the printer VLAN
- (B) Extend log retention to 90 days
- (C) Patch or mitigate the VPN portal flaw immediately and check it for signs of compromise

Circle your choice. Answer and feedback: module answer key.

CASE STUDY · BANK BRANCH BREACH REVIEW

A regional bank discovers that an attacker spent five weeks inside its branch network. Initial access came through a branch router's exposed web management interface with a default password. From there the attacker reached the flat branch LAN, captured credentials from a teller workstation, used them to log in to a core-banking jump server at headquarters, and attempted to stage customer data for exfiltration over HTTPS. The SOC detected the activity only when an analyst noticed unusual outbound volume.

1. Map the intrusion to ATT&CK tactics.

2. Which three architectural weaknesses made the attack easy?

3. Which single control would have most likely stopped it at the start?

Copyright © ZyeemZia

4. What detection opportunities were missed before the exfiltration attempt?

Model answer: module answer key.

REFLECT

Pick one real network you know. Which threat-actor group is most likely to target it, and which ATT&CK tactic do you currently have the weakest visibility into?

Key takeaways

- Start every design from realistic threat actors and their usual methods, not from product lists.
- Internet-facing appliances and identity systems are today's most common front doors; patch and monitor them like crown-jewel servers.
- ATT&CK tactics give a shared language to map each attack stage to the layer best placed to stop or see it.
- Assume breach: design so one failed control gives a foothold, not the kingdom.

KNOWLEDGE CHECK

1. Which statement best describes an ATT&CK tactic?

   (A) A specific exploit for a named software vulnerability, such as a VPN portal flaw

   (B) The adversary's goal at a stage of the intrusion, such as Lateral Movement

   (C) A vendor detection signature that identifies one known malware family on endpoints

   (D) A compliance control from a national security framework

2. An attacker uses stolen credentials to log in to a jump server from a branch PC. Which tactic is this primarily?

   (A) Reconnaissance

   (B) Resource Development

   (C) Exfiltration

   (D) Lateral Movement

3. Why have internet-facing VPN and firewall appliances become a priority for defenders?

   (A) They are frequently exploited for access and are monitored less than servers

   (B) They are rarely reachable from the internet, so attackers hide on them for long periods

   (C) They cannot be patched in place, so they must be fully replaced every year

   (D) They matter only for state-aligned actors, not for financially motivated groups

4. What does 'assume breach' mean for architecture?

   (A) Treat every alert as a confirmed incident and isolate the whole network immediately

   (B) Stop investing in prevention controls because detection and response are always more cost-effective

   (C) Design so one failed control limits the attacker's reach and is likely to be detected

   (D) Allow only encrypted traffic so attackers cannot read any data in transit inside

Copyright © ZyeemZia

5. Which pairing of attack stage and best-placed control is correct?

(A) Impact — longer password expiry periods for all staff accounts

(B) Reconnaissance — immutable, offline backups stored at a second data centre

(C) Credential Access — phishing-resistant MFA and tiered admin accounts

(D) Exfiltration — disabling 802.1X on access ports to reduce noise

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 1 · ARCHITECT · LESSON 2 · 25 MIN

NIST CSF 2.0 and Risk-Based Prioritisation

Use a common language for security outcomes and spend effort where risk is highest

- Explain the six NIST CSF 2.0 functions and how Govern ties them together
- Build current and target profiles to show security gaps
- Score and rank risks with likelihood, impact and simple loss estimates
- Turn a risk register into a defensible, sequenced engineering roadmap

Engineers often jump to products. Leaders ask different questions: *What are we protecting? How well? What should we fix next, and why?* The **NIST Cybersecurity Framework (CSF) 2.0**, published in 2024, gives both groups a shared vocabulary. It is outcome-based: it says what good looks like, not which box to buy.

The six CSF 2.0 functions

GV
Govern
Set the strategy, roles, policy, risk appetite and supply-chain expectations. Govern sits at the centre and informs every other function.

ID
Identify
Know your assets, data, suppliers and risks, and keep improving based on lessons learned.

PR
Protect
Safeguards: identity and access control, awareness, data security, platform security and resilient infrastructure.

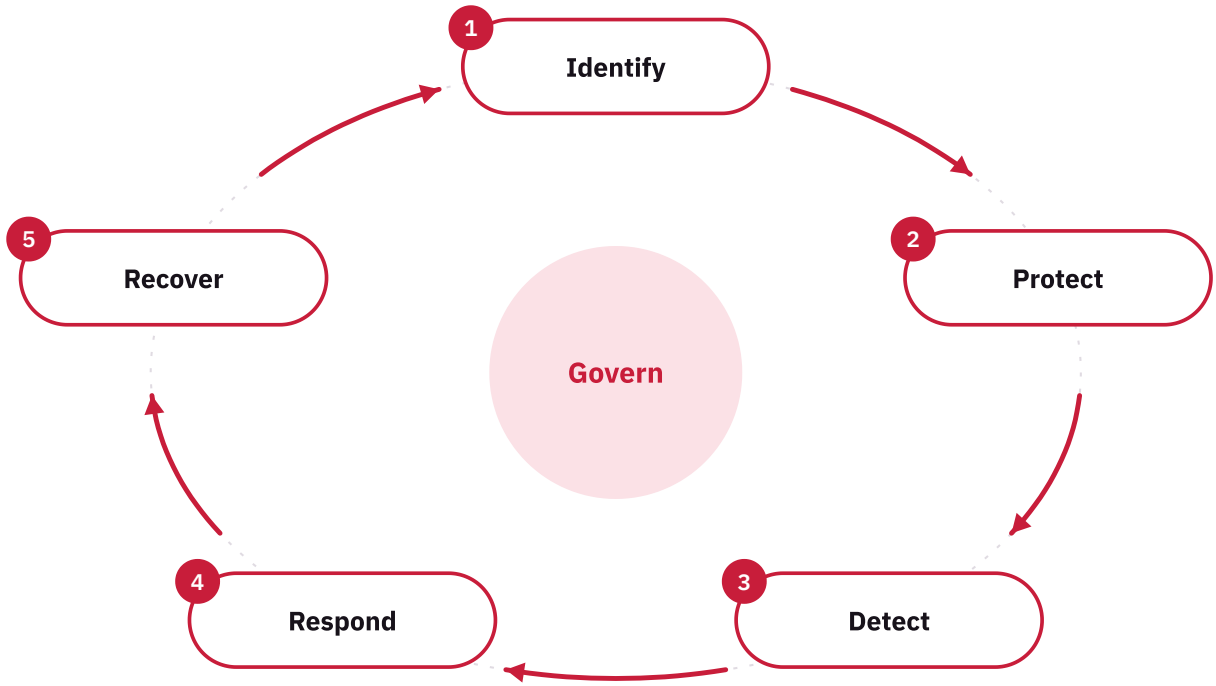
DE
Detect
Continuous monitoring and analysis of adverse events so that attacks are found quickly.

RS
Respond
Manage, analyse, contain and communicate about incidents once detected.

RC
Recover
Restore assets and operations and communicate during recovery.

Copyright © ZyeemZia

CSF 2.0: Govern at the centre of five functions



1. **Identify** — Assets, suppliers, risks and improvement lessons
2. **Protect** — Identity, data, platform and infrastructure safeguards
3. **Detect** — Continuous monitoring and analysis of adverse events
4. **Respond** — Manage, analyse, contain and report incidents
5. **Recover** — Restore operations and communicate

Govern is drawn in the middle because strategy, ownership and risk appetite steer every other function; the outer five run as a continuous loop, not a one-off project.

INSIGHT · WHY GOVERN MATTERS TO NETWORK ENGINEERS

CSF 2.0 added **Govern** as a sixth function. For a network team this is where risk appetite, ownership of firewall policy, change approval and supplier requirements live. A brilliant segmentation design without an owner and a review cycle decays within a year.

Where network-security work lands in CSF 2.0

FUNCTION	EXAMPLE CATEGORY	NETWORK-SECURITY EVIDENCE
Govern	Roles, responsibilities and authorities	Named owner for each firewall policy set and each VPN
Identify	Asset management	Inventory of edge devices, firmware versions and exposed services

Copyright © ZyeemZia

FUNCTION	EXAMPLE CATEGORY	NETWORK-SECURITY EVIDENCE
Protect	Identity management, authentication and access control	802.1X on access ports, MFA on remote access, TACACS+ for admins
Protect	Technology infrastructure resilience	Firewall HA, diverse VPN paths, segmented management plane
Detect	Continuous monitoring	Firewall, NAC and VPN logs streamed to the SIEM with alerting
Respond	Incident mitigation	Pre-approved quarantine VLAN and change-of-authorisation playbooks
Recover	Incident recovery plan execution	Golden configs and tested rebuild of edge devices

CSF 2.0 uses **Organizational Profiles** to describe posture. A **current profile** records the outcomes you achieve today; a **target profile** records the outcomes you need, given your risks and obligations. The gap between them is your work plan. CSF also offers **tiers** (Partial, Risk Informed, Repeatable, Adaptive) to describe how rigorous your risk governance and management practices are. NIST publishes free Quick-Start Guides and mappings (informative references) to other standards alongside the core.

Risk arithmetic you will actually use

MEASURE	FORMULA	WHAT IT TELLS YOU
Qualitative risk	`Risk = Likelihood × Impact`	Score each on 1–5; a 4 × 5 = 20 outranks a 3 × 3 = 9. Simple, fast and good for ranking.
Single loss expectancy	`SLE = Asset value × Exposure factor`	Expected loss from one event; e.g. a 2,000,000 asset with 30% exposure gives SLE 600,000.
Annualised loss expectancy	`ALE = SLE × ARO`	ARO is how many times per year you expect the event; 600,000 × 0.2 = 120,000 per year.
Control value	`Value = ALE before − ALE after − Annual control cost`	A positive value supports the investment case; negative means the control costs more than it saves.

WATCH OUT · NUMBERS ARE INPUTS, NOT TRUTH
Likelihood and impact scores are judgements. Write down the reasoning (threat intelligence, exposure, past incidents) next to each score so that reviewers can challenge it. A precise number with no reasoning is worse than an honest range.

Copyright © ZyeemZia

Likelihood × impact: what to do with each quadrant

IMPACT (LOW → HIGH) →

Plan, contain and insure
- Data-centre flood
- Supplier compromise
- Tested recovery and insurance

Treat now
- Exploited flaw on the VPN portal
- Flat server network + ransomware
- Emergency change, owner, date

Accept and review
- Defacement of a static brochure site
- Document acceptance within appetite

Automate and reduce
- Commodity phishing reaching inboxes
- Mass scanning of the edge
- Filtering, hardening, playbooks

LIKELIHOOD (LOW → HIGH) →

Scores rank risks, but the quadrant tells you the kind of treatment: top-right items go on this month's roadmap, while high-impact, low-likelihood risks need containment and recovery plans rather than daily effort.

From risk register to roadmap

1. **List scenarios** Write risks as scenarios: 'Crime group exploits unpatched VPN portal and deploys ransomware'.
2. **Score inherent risk** Rate likelihood and impact with today's controls, using the same scale for everyone.
3. **Choose a treatment** Mitigate, transfer (for example insurance), avoid (stop the activity) or accept within appetite.
4. **Sequence by risk reduction per effort** Quick, high-reduction actions first; large programmes split into phases.
5. **Assign owners and dates** Every action has a person, a date and a measurable outcome.
6. **Re-score and review** Update residual risk after each change and review the register at least quarterly.

TEMPLATE

Threat-model and risk register sheet

Capture each risk scenario with the reasoning behind its score and the planned treatment.

ASSET / SERVICE	THREAT SCENARIO	LIKELIHOOD (1–5)	IMPACT (1–5)	SCORE	TREATMENT AND CONTROL	OWNER / DUE
Remote-access VPN	*Crime group exploits unpatched portal, deploys ransomware*	*4*	*5*	*20*	*Mitigate: patch SLA 72h, MFA, portal hardening, alerting on new admin sessions*	*Network lead / 30 days*
Branch LAN	*Insider plugs rogue device into open port*	*3*	*3*	*9*	*Mitigate: 802.1X with MAB fallback, unused ports shut*	*NAC engineer / Q3*

Copyright © ZyeemZia

ASSET / SERVICE	THREAT SCENARIO	LIKELIHOOD (1–5)	IMPACT (1–5)	SCORE	TREATMENT AND CONTROL	OWNER / DUE

SCENARIO · DECIDE · DEFENDING THE BUDGET

The CFO asks why the security team wants to spend 80,000 per year on a managed detection service. Your estimate: a ransomware event has SLE 1,500,000 and ARO 0.15 today; with the service you expect ARO 0.05. What is the strongest argument?

- (A) ALE falls from 225,000 to 75,000, a reduction of 150,000 for an 80,000 annual cost
- (B) Peer organisations already use similar services, so we should too
- (C) Any ransomware event would be catastrophic, so cost does not matter
- (D) The framework requires a managed detection service

Circle your choice. Answer and feedback: module answer key.

REFLECT

Write one risk scenario for your organisation in the format 'actor + method + asset + consequence'. What evidence would you use to justify its likelihood score?

Key takeaways

- CSF 2.0 has six functions; Govern sets strategy, ownership and risk appetite for the other five.
- Current and target profiles turn posture into a gap list that becomes the roadmap.
- Likelihood × impact ranks risks quickly; SLE, ARO and ALE put money on them when leaders need a business case.
- Write down the reasoning behind every score so it can be challenged and re-scored after each change.

KNOWLEDGE CHECK

6. What is the role of the Govern function in CSF 2.0?

   (A) It sets strategy, roles, policy and risk appetite that guide all other functions

   (B) It replaces the Identify function that earlier framework versions used for asset inventory

   (C) It covers only supplier contracts and procurement checks

   (D) It defines technical controls such as firewall rule syntax

7. A risk has likelihood 4 and impact 3; another has likelihood 2 and impact 5. Using Likelihood × Impact, which is higher?

   (A) The second, because impact always outweighs likelihood

   (B) They are equal, because both total seven points

   (C) Neither can be ranked without monetary values

   (D) The first, scoring 12 against 10

Copyright © ZyeemZia

8. An asset worth 400,000 has an exposure factor of 25% and an ARO of 2. What is the ALE?

   (A) 100,000
   (B) 200,000
   (C) 50,000
   (D) 800,000

9. What does the gap between a current and a target CSF profile represent?

   (A) The outcomes still to be achieved, which become the improvement plan
   (B) The maturity tier that the organisation has been formally certified at by NIST
   (C) The list of vendors that must be replaced to comply
   (D) The number of incidents expected over the next year

10. Which treatment is an example of risk transfer?

    (A) Disabling a risky legacy file-transfer service entirely and permanently
    (B) Adding MFA to the remote-access VPN for all staff and contractors
    (C) Buying cyber insurance that covers part of the incident cost
    (D) Documenting acceptance of a low risk

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 1 · ARCHITECT · LESSON 3 · 28 MIN

Defence in Depth and Segmentation Strategy

Layer independent controls and divide the network so that one failure stays small

- Describe the ZCIE Security Defence-in-Depth Stack and the role of each layer
- Design a segmentation model using zones, trust levels and enforcement points
- Choose between VLAN/VRF, firewall, and identity-based segmentation techniques
- Plan a phased segmentation rollout that avoids outages

Defence in depth means stacking controls that fail independently, so an attacker must defeat several different mechanisms in sequence. The key word is *independently*: three products that all trust the same stolen password give you one layer, not three.

The ZCIE Security Defence-in-Depth Stack

ZeroTrust (wrapper)	`Never trust by location` `Verify every request` `Least privilege` `Continuous evaluation`
Respond	`SIEM and SOAR` `Incident response` `Recovery`
Cloud	`SASE / SSE` `Cloud workload controls` `ZTNA`
Detect	`IDS/IPS` `EDR/XDR` `Email, web and DNS security`
Identity	`AAA` `802.1X / NAC` `MFA`
Tunnel and Perimeter	`IPsec and TLS VPN` `Next-generation firewalls` `NAT and TLS inspection`
Architect	`Threat model` `Segmentation` `Risk-based roadmap`

INSIGHT · HOW TO READ THE STACK

Architect is the foundation: without a threat model and segmentation plan, the other layers are bolted on at random. ZeroTrust is drawn as a wrapper because it is a set of principles applied to every layer, not a product you add at the top.

Segmentation is the most powerful architectural control a network team owns. It decides **what can talk to what**, which directly limits lateral movement, the blast radius of ransomware and the scope of compliance audits.

Segmentation techniques compared

TECHNIQUE	WHAT IT SEPARATES	STRENGTH	LIMITATION
VLANs	Layer-2 broadcast domains	Cheap, universal	No policy by itself; routing between VLANs is open unless filtered
VRFs	Routing tables (macro-segments)	Strong separation of whole environments	Inter-VRF traffic needs a deliberate leak or a firewall

Copyright © ZyeemZia

TECHNIQUE	WHAT IT SEPARATES	STRENGTH	LIMITATION
Firewall zones	Traffic between trust levels	Stateful, application- and user-aware policy	Traffic inside a zone is not inspected
Identity/group-based policy	Users and devices regardless of IP	Follows the user; scales with roles	Needs strong identity, NAC and consistent tagging
Host / workload micro-segmentation	Individual servers or workloads	Finest granularity, stops east-west inside a subnet	Operational overhead; needs good application maps

Five principles for a segmentation model

S1

Classify by trust and function

Group assets by data sensitivity and role: users, servers, OT, management, guests, partners.

S2

Default deny between segments

Every inter-segment flow is explicitly justified and documented.

S3

Separate the management plane

Device management lives in its own segment or VRF, reachable only from hardened admin hosts.

S4

Enforce at the right point

Macro-segments at firewalls and VRFs; micro-segments with identity or host policy.

S5

Make it observable

Log allowed and denied inter-segment flows so you can prove the design works.

Macro- versus micro-segmentation

Macro-segmentation

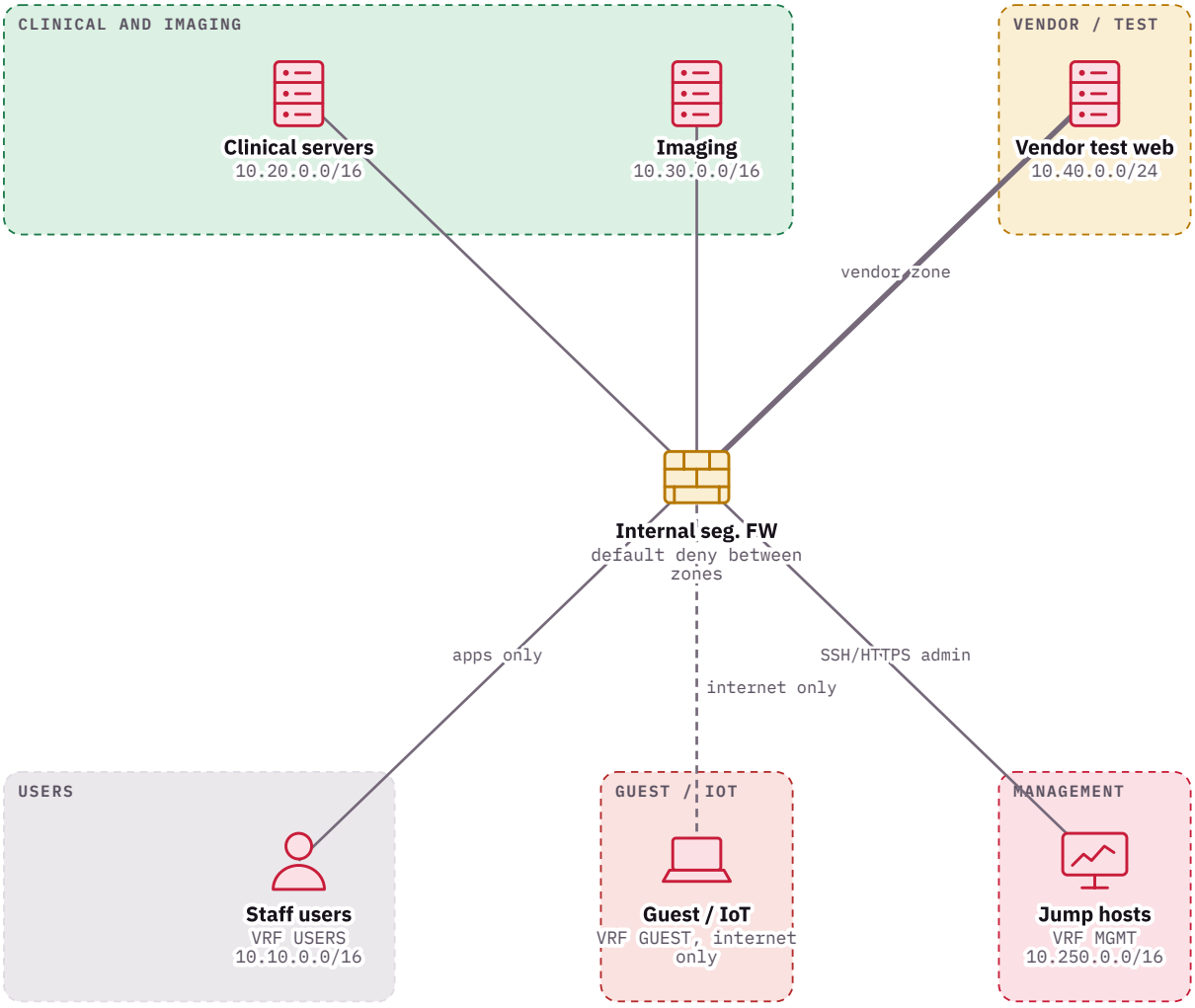
- Separates large environments (production, development, OT, guest)
- Enforced by VRFs and firewalls
- Quick to deploy, coarse grained
- Answers: which environments can talk?

Micro-segmentation

- Separates individual workloads or user groups
- Enforced by identity tags, host firewalls or workload agents
- Needs application dependency maps
- Answers: which specific systems can talk?

Copyright © ZyeemZia

Macro-segments around an internal segmentation firewall



Every zone reaches the others only through the firewall, so the vendor-exposed test server can no longer talk directly to patient records. Guest and IoT get internet only; management is reachable only from the jump hosts.

Separating the management plane with a VRF

CORE1 · IOS-style CLI

```
! Dedicated management VRF; no route leaking to user VRFs
vrf definition MGMT
 address-family ipv4
 exit-address-family
interface GigabitEthernet0/0
 description OOB management network
 vrf forwarding MGMT
 ip address 10.250.0.11 255.255.255.0
ip access-list standard ADMIN-HOSTS
 permit 10.250.10.0 0.0.0.255
line vty 0 15
 access-class ADMIN-HOSTS in vrf-also
 transport input ssh
```

The `vrf-also` *keyword lets the access class apply to SSH sessions arriving through a VRF interface.*

Copyright © ZyeemZia

Phased segmentation rollout

1. **Discover** Collect flow data (NetFlow/IPFIX or firewall logs) for several weeks to see real dependencies.
2. **Design** Define segments and an inter-segment flow matrix from that data, with business owners.
3. **Monitor mode** Deploy enforcement points in log-only or permit-and-log mode and compare against the matrix.
4. **Enforce in waves** Turn on deny for low-risk segments first, then critical ones, with a rollback plan.
5. **Operate** Review rule requests and flow logs; remove exceptions that are no longer needed.

SCENARIO · DECIDE · FLAT DATA-CENTRE NETWORK

A hospital's data centre has 400 servers in one VLAN, including the patient-records database, imaging systems and a test web server exposed to vendors. Ransomware in a peer hospital spread server-to-server in minutes. Leadership wants a quick, meaningful reduction in blast radius.

(A) Deploy host-based micro-segmentation on all 400 servers this quarter

(B) Create macro-segments (clinical, imaging, test/vendor, management) behind a firewall, using flow data to build the rules, and enforce in waves

(C) Move every server to its own VLAN with no filtering between them

(D) Rely on endpoint protection to stop ransomware spreading

Circle your choice. Answer and feedback: module answer key.

Segmentation design review

☐ Every segment has a named owner and a data-sensitivity classification
☐ Inter-segment traffic is default deny with documented exceptions
☐ Management interfaces are unreachable from user and guest segments
☐ Flow data was used to build the rules, not guesses
☐ Guest, IoT and OT segments cannot initiate connections to corporate servers
☐ Denied and allowed inter-segment flows are logged centrally
☐ A rollback plan exists for each enforcement wave

Key takeaways

- Defence in depth needs independent failure modes, not just more products.
- VLANs separate broadcast domains but enforce nothing; VRFs, firewall zones, identity policy and host policy enforce.
- Start with macro-segments and a separate management plane, then add micro-segmentation where application maps exist.
- Roll out from flow data: discover, design, monitor, enforce in waves, then operate and prune exceptions.

KNOWLEDGE CHECK

11. Why do three controls that all rely on the same password count as only one layer?

(A) Because layers must come from three different vendors

(B) Because a single stolen credential defeats all three at once

(C) Because password controls are never part of defence in depth

(D) Because only network controls count as true layers

Copyright © ZyeemZia

12. Which technique, on its own, provides NO policy enforcement between groups?

(A) Putting groups in separate firewall zones with default deny

(B) Placing groups in VRFs with no route leaking between them

(C) Applying identity-based group policy at the access-layer switches

(D) Placing groups in separate VLANs with open inter-VLAN routing

13. What is the main reason to separate the management plane?

(A) To improve routing convergence speed for user and server traffic in the core

(B) To stop compromised users or servers reaching device management interfaces

(C) To let management traffic bypass logging so the SIEM is not overloaded

(D) To make SNMP work without credentials

14. What should come FIRST in a segmentation rollout for an existing network?

(A) Enable default-deny rules between all of the new segments on day one

(B) Buy a micro-segmentation agent for every server

(C) Renumber every subnet into a new addressing plan

(D) Collect flow data to understand real application dependencies

15. Micro-segmentation is best described as:

(A) Policy between individual workloads or user groups, often via identity tags or host policy

(B) Splitting a network into separate production and development VRFs with a firewall between

(C) Using smaller subnet masks so each VLAN holds fewer hosts and less broadcast traffic

(D) Placing a perimeter firewall at each internet connection

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 1 · ARCHITECT · LESSON 4 · 28 MIN

Secure Architecture Patterns and Zero-Trust Principles

Reference patterns for campus, branch, data centre and cloud, and the zero-trust ideas that connect them

- Apply reference security patterns to campus, branch, data-centre and cloud designs
- Explain the zero-trust tenets and logical components described in NIST SP 800-207
- Identify common architectural anti-patterns and their fixes
- Document a security architecture decision with its rationale

Architecture patterns are reusable answers to recurring problems. They do not remove the need to think, but they stop teams reinventing (and re-breaking) the same designs. The patterns below are vendor-neutral; map each control to whatever platforms you operate.

Reference patterns by place in the network

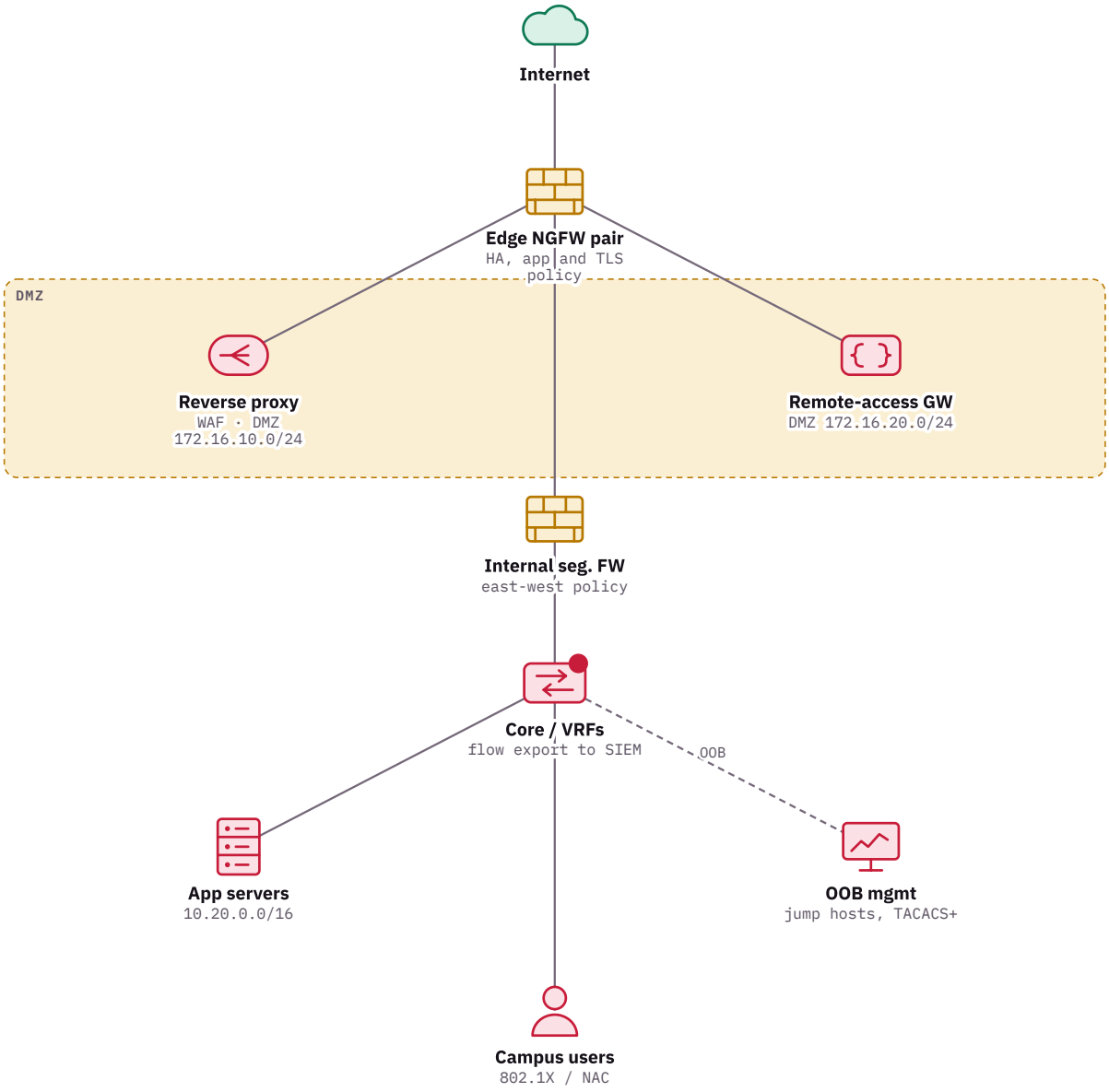
PLACE	KEY RISKS	CORE PATTERN
Campus	Rogue devices, lateral movement between users, IoT	802.1X/NAC at access ports, identity-based segmentation, guest isolation, internal firewall between users and servers
Branch	Local internet breakout, small staff, physical exposure	Branch firewall with application policy, IPsec or SD-WAN overlay to hubs, cloud-delivered web security, 802.1X or MAB on every port
Data centre	East-west spread, privileged access, high-value data	Macro-segments by tier and sensitivity, east-west firewalling, privileged access through hardened jump hosts, out-of-band management
Public cloud	Misconfiguration, over-privileged identities, exposed storage	Hub-and-spoke virtual networks with central inspection, security groups as micro-segments, least-privilege roles, logging on by default
Remote users	Stolen credentials, unmanaged devices	Phishing-resistant MFA, device posture checks, per-application access (ZTNA) rather than full network access

Campus security architecture, top to bottom

Internet edge	`NGFW pair in HA` `TLS inspection policy` `DDoS protection upstream`
Services and DMZ	`Reverse proxy and WAF` `DMZ zone per exposure type` `Remote-access VPN termination`
Core and distribution	`Internal segmentation firewall` `VRFs for macro-segments` `Flow export to SIEM`
Access	`802.1X / MAB with dynamic policy` `Port security and DHCP snooping` `Guest and IoT isolation`
Management	`Out-of-band network` `TACACS+ device admin` `Hardened jump hosts`

Copyright © ZyeemZia

Campus edge, DMZ and internal segmentation



Published services and VPN termination sit in DMZ segments behind the edge pair, never on the internal LAN. A second, internal firewall controls east-west traffic, and management lives on its own out-of-band path.

Zero trust is the idea that network location alone never grants trust. NIST SP 800-207 defines it as a set of principles that move defences from static perimeters to individual users, devices and resources. Every access request is evaluated on identity, device state and context, then granted with the least privilege needed, for a limited time.

Copyright © ZyeemZia

Zero-trust tenets in network terms

Z1
All resources are protected
Servers, SaaS, printers and OT devices all sit behind policy, not just 'critical' systems.

Z2
Location grants nothing
Being on the corporate LAN or VPN does not by itself earn access.

Z3
Per-session access
Access is granted per request or session, with least privilege.

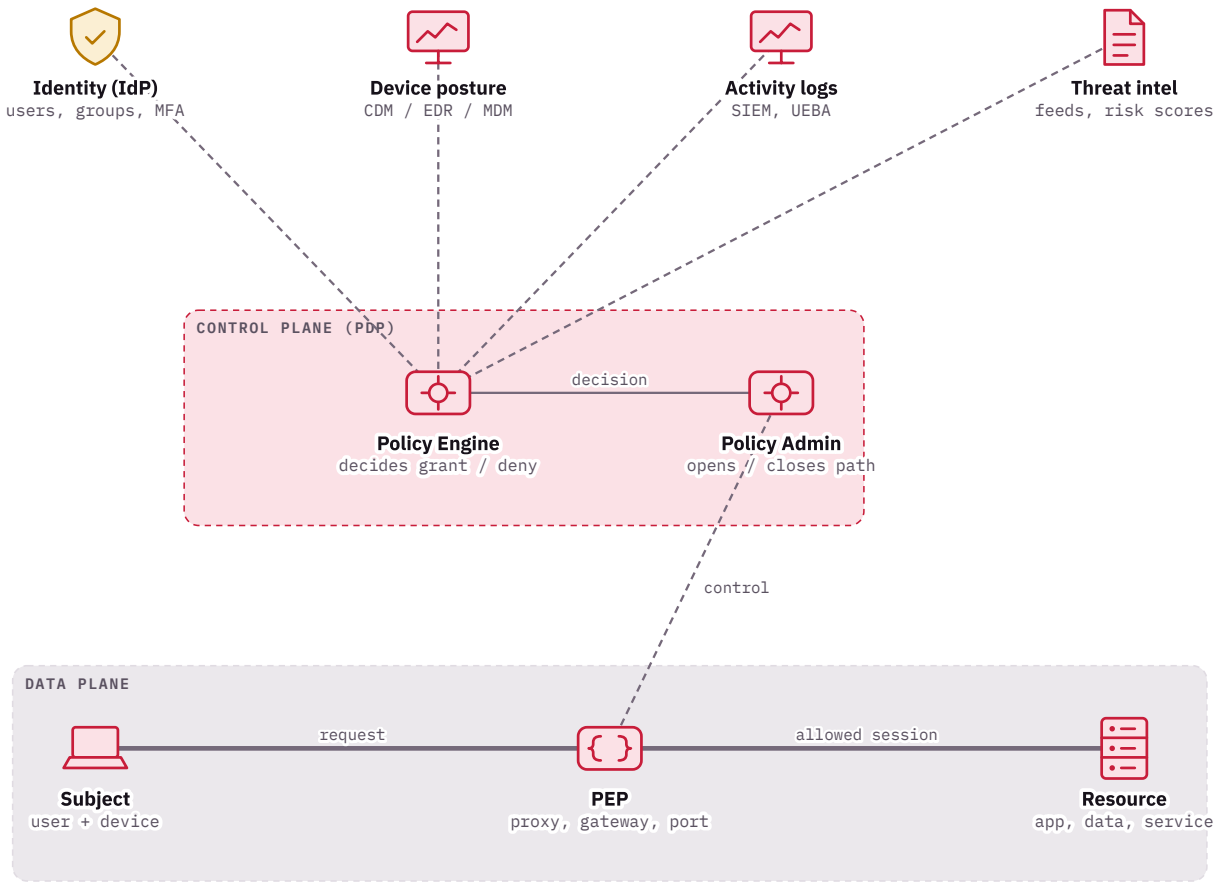
Z4
Dynamic policy
Decisions use identity, device posture, behaviour and environment signals.

Z5
Monitor asset integrity
The posture of every owned device is measured continuously.

Z6
Strict authentication
Authentication and authorisation are enforced before access and re-evaluated.

Z7
Collect and improve
Telemetry from all of this is used to improve policy over time.

NIST SP 800-207 logical components



The subject never reaches the resource directly: the PEP holds the session until the Policy Engine, fed by identity, posture, activity and threat signals, decides and the Policy Administrator tells the PEP to open the path.

Copyright © ZyeemZia

DEFINITION · PDP AND PEP

The **Policy Decision Point (PDP)** is the Policy Engine plus Policy Administrator — it decides. The **Policy Enforcement Point (PEP)** carries the decision out. In 802.1X, the NAC server is the PDP and the switch port is the PEP; on a firewall, the policy evaluation and enforcement may live in the same box.

Anti-patterns and their fixes

Anti-pattern

- Flat network behind a strong perimeter
- VPN that grants full network access to any authenticated user
- Management interfaces on user VLANs
- One shared admin account for all devices
- Firewall rules added but never removed

Better pattern

- Macro-segments with default-deny between them
- Per-application access with device posture checks
- Out-of-band or management VRF reachable only from jump hosts
- Named admin accounts via TACACS+ with command accounting
- Rule owners, expiry dates and periodic recertification

TEMPLATE

Architecture decision record

Record each significant security design decision so future teams understand why it was made.

DECISION	CONTEXT AND THREAT	OPTIONS CONSIDERED	CHOSEN OPTION	CONSEQUENCES / TRADE-OFFS	REVIEW DATE
Branch internet breakout through cloud web security	*Backhauling all web traffic to HQ adds latency; branches are phishing targets*	*Backhaul to HQ; local NGFW only; cloud-delivered web security*	*Cloud-delivered web security plus local NGFW for east-west*	*Dependency on provider; need TLS inspection policy alignment*	*12 months*

SCENARIO · DECIDE · REMOTE-ACCESS REDESIGN

A garment exporter's remote-access VPN gives every authenticated user a full Layer-3 tunnel into the head-office network. Suppliers' staff also use it to reach one order-tracking web application. An audit flags this as high risk.

(A) Give suppliers per-application access to the order-tracking app only, with MFA and device checks, and restrict staff VPN to the segments their roles need

(B) Change the VPN pre-shared key and force all users to reconnect

(C) Move the VPN to a different public IP address

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

Key terms

Defence in depth
Layering independent controls so that one failure does not lead to full compromise.

Tactic
In ATT&CK, the adversary's goal at a stage of an intrusion, such as Credential Access.

Profile (CSF)
A description of current or target cybersecurity outcomes, used to identify gaps.

Macro-segmentation
Separating large environments, such as production and guest, using VRFs or firewalls.

Blast radius
The set of systems an attacker or failure can affect from a given foothold.

Policy Enforcement Point
The component that allows or blocks a session based on a policy decision.

MITRE ATT&CK
A public knowledge base of adversary tactics and techniques observed in real intrusions.

NIST CSF 2.0
An outcome-based cybersecurity framework with six functions: Govern, Identify, Protect, Detect, Respond and Recover.

ALE
Annualised loss expectancy: single loss expectancy multiplied by the annual rate of occurrence.

Micro-segmentation
Policy between individual workloads or user groups, often using identity tags or host firewalls.

Zero trust
A security model in which no implicit trust is granted by network location; every access request is verified.

Policy Decision Point
The policy engine and administrator that evaluate requests and instruct enforcement points.

REFLECT

Which anti-pattern from this lesson exists in a network you know? Draft the first two steps to remove it without causing an outage.

Key takeaways

- Reuse reference patterns per place in the network: campus, branch, data centre, cloud and remote users.
- Publish services and terminate VPNs in a DMZ; control east-west with internal segmentation and an out-of-band management plane.
- Zero trust (NIST SP 800-207) removes trust by location: a PEP enforces each session, the PE and PA decide and instruct.
- Record significant design decisions with their trade-offs so future teams know why.

KNOWLEDGE CHECK

16. In NIST SP 800-207, which component actually allows or blocks the session?

(A) The Policy Engine
(B) The subject's endpoint agent
(C) The Policy Enforcement Point
(D) The certificate authority

Copyright © ZyeemZia

17. Which statement reflects a zero-trust principle?

(A) Users on the VPN can be trusted fully because all of their traffic is encrypted end to end

(B) Only internet-facing servers need access policy

(C) Connecting from the corporate LAN does not by itself grant access to a resource

(D) Device posture is checked once a year during audits

18. In an 802.1X deployment, which device acts as the PEP?

(A) The access switch or wireless controller enforcing the port or session

(B) The NAC server that evaluates the authorisation policy for each request

(C) The directory service holding user accounts and group memberships

(D) The SIEM collecting authentication logs

19. A branch design sends all web traffic to HQ for inspection, causing latency complaints. Which pattern addresses this while keeping inspection?

(A) Removing web inspection for branch users to cut latency entirely

(B) Adding more bandwidth to the backhaul links only

(C) Allowing direct internet access with no policy at branches

(D) Local internet breakout through cloud-delivered web security

20. What is the main purpose of an architecture decision record?

(A) To replace change-management approvals for firewall and routing changes

(B) To preserve the reasoning and trade-offs behind a security design choice

(C) To list every device serial number in the network

(D) To store device configuration backups used during disaster recovery tests

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 1 · ARCHITECT

Answer key

Knowledge checks

1. B Tactics are the 'why' (the goal at that stage); techniques are the 'how'. Exploits, signatures and compliance controls are different concepts.

2. D Moving from one compromised system to another inside the environment is Lateral Movement. Reconnaissance and Resource Development happen before access; Exfiltration is moving data out.

3. A Edge devices are exposed by design, widely targeted, and often less monitored than servers. They can be patched and are targeted by all actor types.

4. C Assume breach keeps prevention but adds containment and detection depth. It does not mean abandoning prevention or overreacting to every alert.

5. C Phishing-resistant MFA and admin tiering directly reduce credential theft and reuse. The other pairings do not address the stage named.

6. A Govern was added in 2.0 and sits across the other functions. It does not replace Identify and is not limited to suppliers or technical syntax.

7. D 4 × 3 = 12 and 2 × 5 = 10. The method multiplies rather than adds, and qualitative scores rank risks without money values.

8. B SLE = 400,000 × 0.25 = 100,000. ALE = 100,000 × 2 = 200,000.

9. A Profiles describe outcomes; the difference is the work to do. Tiers describe rigour, and CSF neither certifies nor mandates vendors.

10. C Insurance shifts part of the financial impact to another party. Disabling is avoidance, MFA is mitigation and documented acceptance is acceptance.

11. B Depth depends on independent failure modes. Vendor diversity is not the point, and identity controls are a legitimate layer.

12. D VLANs separate broadcast domains; if routing between them is unfiltered, nothing is enforced. The other options all enforce separation.

13. B Management interfaces are high-value targets; isolating them limits who can attack them. It is not about speed, bypassing logs or weakening authentication.

14. D Without dependency data, enforcement causes outages. Enforcement, tooling and renumbering come later and only if justified.

15. A Micro-segmentation controls flows between individual systems or groups. VRF splits are macro-segmentation; subnet size and perimeter firewalls are not segmentation strategies by themselves.

16. C The PEP enforces. The Policy Engine decides, and the endpoint and CA provide signals or credentials but do not enforce access.

17. C Zero trust removes implicit trust from network location and evaluates every request. Encryption is not trust, all resources need policy, and posture is checked continuously.

18. A The switch or controller enforces; the NAC server is the decision point; the directory is an identity source; the SIEM observes.

19. D Cloud-delivered security keeps inspection close to users. Removing inspection or allowing unmanaged breakout increases risk; more bandwidth may not fix latency.

20. B ADRs capture why a decision was made. They complement change control, inventories and backups but do not replace them.

Scenarios & case studies

Scenario · Choosing what to fix first

C is best. Correct. An actively exploited flaw on an internet-facing device is the highest-likelihood, highest-impact path to initial access. Also hunt for indicators, because patching does not remove an attacker already inside.

Case study · Bank branch breach review

Tactics: Initial Access (exposed management interface, default credential), Credential Access (teller workstation), Lateral Movement (branch to headquarters jump server), Collection and Exfiltration (staging, HTTPS upload). **Weaknesses:** management plane reachable from the internet; flat branch LAN with no segmentation between users and infrastructure; jump server accepting passwords without MFA from any branch address. **First-stop control:** removing internet exposure of management interfaces (management only from a dedicated out-of-band or management VRF) plus credential hygiene. **Missed detections:** admin login to the router from an unfamiliar public IP, new device logins on the jump server from a teller subnet, and east-west authentication anomalies. The lesson: the bank had perimeter controls but no **depth** behind them.

Copyright © ZyeemZia

Scenario · Defending the budget

A is best. Correct. 1,500,000 × 0.15 = 225,000; × 0.05 = 75,000. The 150,000 reduction exceeds the 80,000 cost, giving a net value of 70,000 per year, and you can show the assumptions.

Scenario · Flat data-centre network

B is best. Best. It quickly separates the highest-risk zone (vendor-exposed test) from clinical systems, is evidence-driven and avoids a big-bang outage.

Scenario · Remote-access redesign

A is best. Best. It applies least privilege and removes network-level access for third parties, the biggest exposure.

Copyright © ZyeemZia

02

MODULE 2 · PERIMETER

Next-Generation Firewalls

Design, build and operate stateful, application- and identity-aware firewall policy that stays clean and resilient

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Design zone models and least-privilege rule bases on stateful firewalls
- Configure NAT and write application- and user-based policy correctly
- Plan TLS inspection with documented privacy exceptions and integrate IPS safely
- Build and test high-availability firewall designs
- Audit rule bases and troubleshoot flows with logs, traces and packet captures

LESSONS

1. Stateful Inspection, Zones and Policy Design · 28 min
2. NAT, Application Identification and User-Based Policy · 28 min
3. TLS Inspection and IPS Integration · 30 min
4. Firewall High Availability Designs · 25 min
5. Policy Hygiene, Audit and Troubleshooting · 30 min

MODULE 2 · PERIMETER · LESSON 1 · 28 MIN

Stateful Inspection, Zones and Policy Design

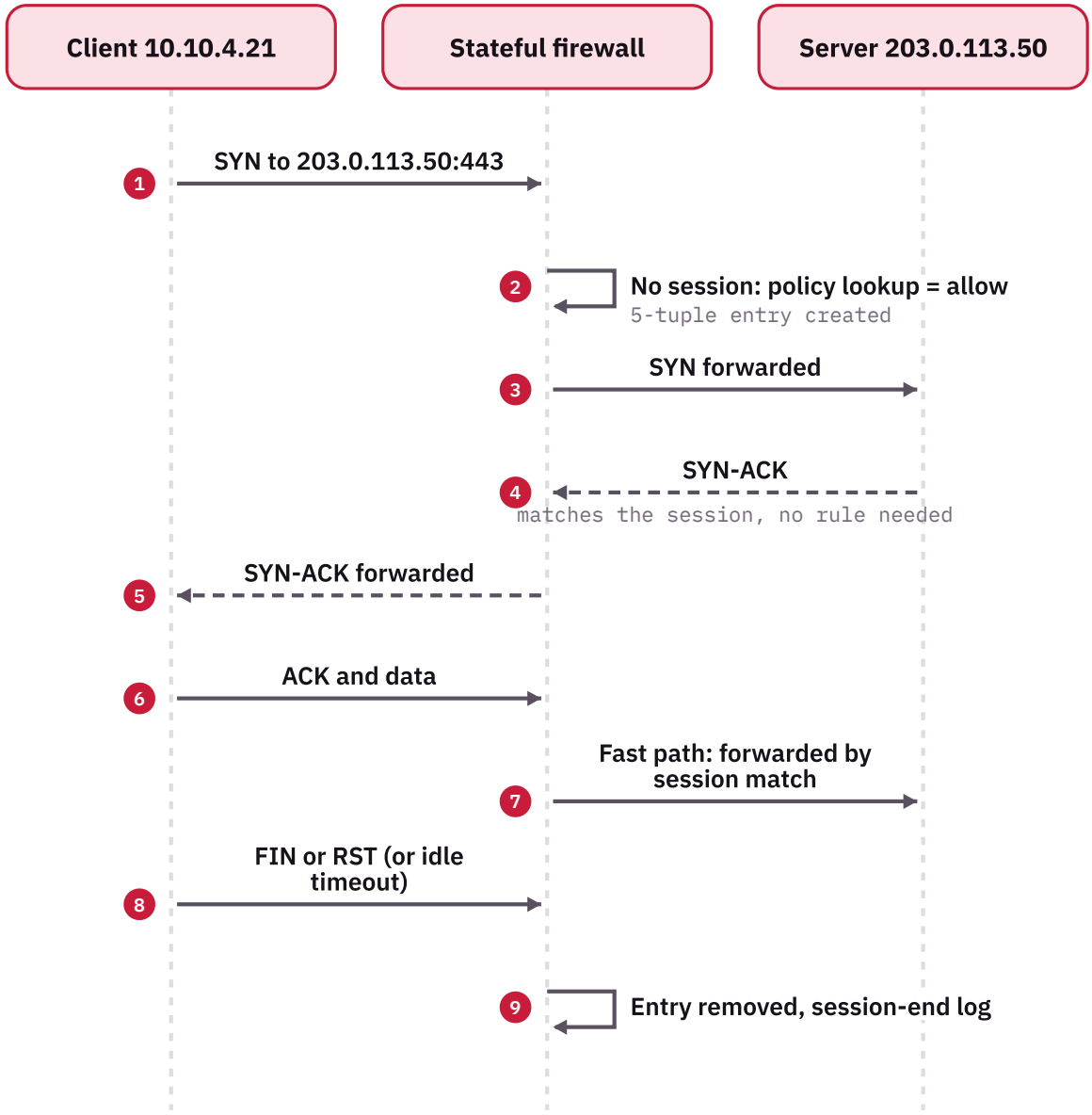
How a firewall tracks sessions, and how to build a zone model and rule base that stay clean

- Explain how stateful inspection tracks sessions and handles return traffic
- Design security zones and an inter-zone policy matrix
- Order rules correctly and apply default deny with logging
- Configure a basic zone-based policy in IOS-style syntax

A **stateful firewall** remembers connections. When an inside host opens a TCP session to a web server, the firewall records the 5-tuple (source and destination address, source and destination port, protocol), the TCP state and timers. Return packets are allowed because they match that entry — not because a rule permits them. Packets that match no session and no rule are dropped.

Copyright © ZyeemZia

Return traffic matches state, not a rule



Only the first packet is checked against the rule base; everything after it, in both directions, is forwarded because it fits the stored session. That is why no OUTSIDE-to-INSIDE rule is needed for replies.

Life of a new session through a stateful firewall

01 Packet arrives
Ingress interface identifies the source zone

→

02 Session lookup
Existing session? Fast-path forward and update state

→

03 Policy lookup
New flow: match zones, addresses, application, user, service

→

04 NAT and inspection
Apply translation, IPS and other security profiles

→

05 Session created
Entry stored with timers; return traffic matches it

→

06 Session closes
FIN/RST or idle timeout removes the entry and logs the end

Copyright © ZyeemZia

INSIGHT · STATE IS ALSO A RESOURCE

Every session consumes memory. SYN floods and scanning bursts aim to exhaust the session table. Next-generation firewalls defend with SYN cookies or SYN proxy, per-source session limits and aggressive timeouts for half-open connections — tune them before an attack, not during one.

Stateful versus stateless filtering

ASPECT	STATELESS ACL	STATEFUL FIREWALL
Return traffic	Needs an explicit reverse rule or the 'established' bit check	Allowed automatically by session match
Protocols with dynamic ports (FTP, SIP)	Hard to permit safely	Helpers open only the negotiated ports for that session
Spoofed mid-session packets	Often passed if headers match	Dropped if sequence or state does not fit
Performance	Very fast, hardware friendly	More resource use; sessions must be tracked
Typical place	Infrastructure ACLs, router edges, control-plane protection	Perimeter, internal segmentation, DMZ

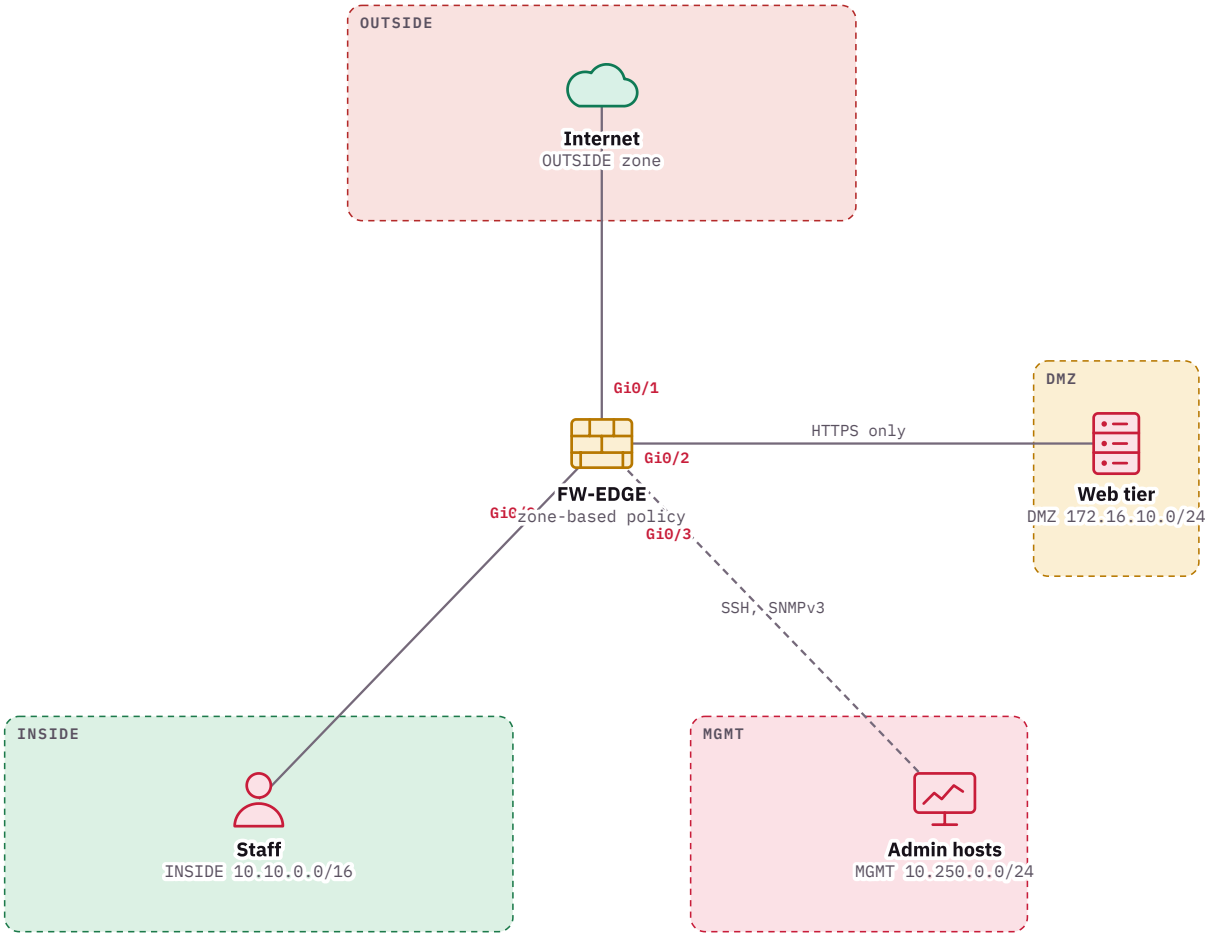
A **zone** is a group of interfaces that share a trust level. Policy is written between zones (source zone to destination zone), so adding a new interface to an existing zone automatically inherits the correct policy. Most platforms deny traffic between zones by default and allow traffic within a zone unless configured otherwise — know which applies to your platform.

Example inter-zone policy matrix

FROM ↓ / TO →	INSIDE	DMZ	OUTSIDE	MGMT
INSIDE	Intra-zone (review)	HTTPS to web tier only	Web, DNS to resolvers, approved SaaS	Deny
DMZ	Specific app ports to named servers only	Deny by default	OS updates from approved sources	Deny
OUTSIDE	Deny	HTTPS to published services	—	Deny
MGMT	SSH, SNMPv3 to devices	SSH to DMZ hosts	Updates to vendor portals	Intra-zone

Copyright © ZyeemZia

Four zones, one enforcement point



Each interface belongs to one zone and every cell of the policy matrix is a zone pair on this firewall. Adding another inside interface to INSIDE gives it the INSIDE policy automatically.

Copyright © ZyeemZia

Zone-based policy: inside users to the internet

FW-EDGE · IOS-style CLI

```
zone security INSIDE
zone security OUTSIDE
class-map type inspect match-any CM-WEB-DNS
 match protocol https
 match protocol http
 match protocol dns
policy-map type inspect PM-IN-TO-OUT
 class type inspect CM-WEB-DNS
  inspect
 class class-default
  drop log
zone-pair security ZP-IN-OUT source INSIDE destination OUTSIDE
 service-policy type inspect PM-IN-TO-OUT
interface GigabitEthernet0/0
 zone-member security INSIDE
interface GigabitEthernet0/1
 zone-member security OUTSIDE
```

No zone-pair exists from OUTSIDE to INSIDE, so unsolicited inbound traffic is dropped; return traffic for inspected sessions is permitted by state.

Rule-base design principles

R1

Most specific first

Rules are evaluated top-down, first match wins; broad rules go lower.

R2

Explicit default deny

End each zone pair with a deny-and-log rule so drops are visible.

R3

Objects, not raw IPs

Use named address and service groups so intent is readable and reusable.

R4

One purpose per rule

Each rule has a business justification, owner and ticket reference.

R5

Least privilege

Narrow sources, destinations, applications and ports; avoid 'any' in more than one field.

SCENARIO · DECIDE · INBOUND ACCESS REQUEST

An application team asks for 'any to the DMZ web server on any port' to 'make the vendor integration work'. The vendor's integration documentation lists HTTPS (TCP 443) from two published source ranges.

A Permit any source to the server on any port, then tighten later

B Permit only TCP 443 from the vendor's two published ranges to the web server, with logging and an expiry review

C Permit the vendor ranges on any port to the whole DMZ

D Refuse the request until the vendor moves to a VPN

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

REFLECT

Sketch the zone matrix of a firewall you manage. Which cell is the broadest today, and what evidence would you need to narrow it?

Key takeaways

- A stateful firewall checks the rule base for the first packet only; replies and later packets match the session entry.
- The session table is a finite resource: protect it with SYN cookies or proxy, per-source limits and short half-open timers.
- Write policy between zones, end every zone pair with deny-and-log, and use named objects.
- Every rule needs one purpose, an owner, a ticket and the narrowest sources, destinations and applications that work.

KNOWLEDGE CHECK

1. Why does a stateful firewall allow return traffic without a matching inbound rule?

   (A) Return packets match the session entry created by the outbound flow

   (B) Return traffic always uses well-known ports that are permitted by default

   (C) The firewall automatically creates a permanent reverse rule

   (D) All TCP packets with the ACK flag set are trusted

2. A new interface is added to the DMZ zone. What happens to policy?

   (A) It has no policy until a rule is written for that interface

   (B) It is automatically placed in the default inside zone

   (C) It inherits the existing policies written for the DMZ zone

   (D) All traffic to it is permitted until the next commit

3. In the IOS-style example, why is no OUTSIDE-to-INSIDE zone pair configured?

   (A) Because return traffic must be explicitly permitted by a second, separate inspect policy

   (B) Because inbound traffic is then dropped unless it returns on an inspected session

   (C) Because zone pairs can only be defined in one direction on each device

   (D) Because the class-default drop rule already permits the inbound sessions

4. Which rule-base practice best supports later audits?

   (A) Rules use raw IP addresses so that auditors can see the exact hosts involved

   (B) Rules are grouped by the date they were created

   (C) Broad rules are placed at the top for faster matching

   (D) Each rule has an owner, business justification and ticket reference

Copyright © ZyeemZia

5. Which defence helps most against session-table exhaustion from SYN floods?

(A) Increasing the TCP idle timeout for established sessions to several hours

(B) SYN cookies or SYN proxy with limits on half-open sessions per source

(C) Allowing all TCP traffic from the outside zone to the DMZ

(D) Disabling logging for denied packets to save CPU

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 2 · PERIMETER · LESSON 2 · 28 MIN

NAT, Application Identification and User-Based Policy

Translate addresses safely and write policy around applications and people instead of ports and IPs

- Configure source NAT (PAT) and static destination NAT for published services
- Explain how NAT interacts with security policy lookup
- Describe how application identification works and where it can be wrong
- Design user- and group-based firewall rules using identity sources

Network Address Translation is not a security control by design, but it shapes every firewall policy. You must know **which address the policy sees** — the original or the translated one — and that varies between platforms. Get it wrong and rules silently fail to match.

NAT types you will configure

TYPE	WHAT CHANGES	TYPICAL USE
Source NAT with port translation (PAT)	Many inside sources share one public address with unique ports	User internet access
Static source NAT (one-to-one)	A fixed inside host always appears as one public address	Servers that initiate outbound connections needing a stable IP
Destination NAT / port forward	Public address and port map to an inside server	Publishing a DMZ service
Twice NAT / policy NAT	Source and destination both change, or translation depends on the destination	Overlapping address spaces between partners
NAT exemption	No translation for selected traffic	Site-to-site VPN traffic between private networks

PAT for users and a published HTTPS server

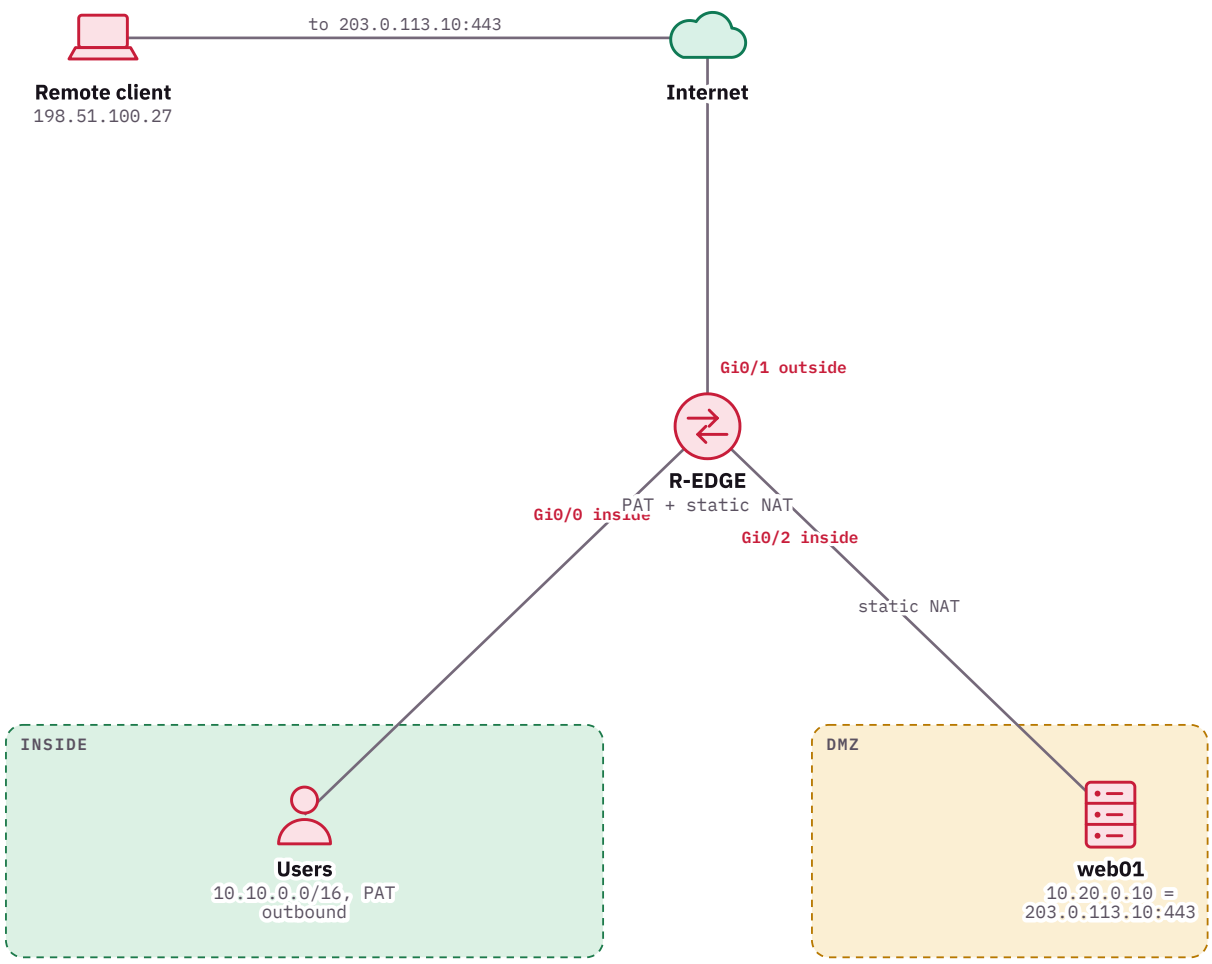
R-EDGE · IOS-style CLI

```
interface GigabitEthernet0/0
 ip nat inside
interface GigabitEthernet0/2
 ip nat inside
interface GigabitEthernet0/1
 ip nat outside
ip access-list standard NAT-USERS
 permit 10.10.0.0 0.0.255.255
ip nat inside source list NAT-USERS interface GigabitEthernet0/1 overload
! Publish DMZ web server 10.20.0.10:443 on public 203.0.113.10:443
ip nat inside source static tcp 10.20.0.10 443 203.0.113.10 443
```

The DMZ interface (Gi0/2) is also marked inside so the static translation applies to the server. Permit the inbound flow in the firewall policy as well — NAT alone does not allow it.

Copyright © ZyeemZia

PAT for users, static NAT for a published server



Outbound user sessions share the outside interface address with unique ports; inbound HTTPS to 203.0.113.10 is translated to 10.20.0.10. The translation alone permits nothing: a security rule must still allow the flow.

WATCH OUT · POLICY VERSUS TRANSLATED ADDRESS

Some platforms evaluate security rules against the **pre-NAT** (public) destination, others against the **post-NAT** (private) destination, and many use a mix (original destination address with translated zone). Before writing a rule for a published service, confirm your platform's order of operations in a lab or with a packet-trace tool.

Confirming the session and translation

FW1 · generic NGFW CLI

```
fw1> show session all filter destination 203.0.113.10
ID     App   State   Src                  Dst              Xlated-Dst       Zones
48211  ssl   ACTIVE  198.51.100.27:51522  203.0.113.10:443 10.20.0.10:443   untrust->dmz
48230  ssl   ACTIVE  192.0.2.44:60310     203.0.113.10:443 10.20.0.10:443   untrust->dmz
```

Illustrative output. The translated destination and the zone pair confirm both NAT and policy matched as intended.

Application identification classifies traffic by what it is, not by the port it uses. The firewall examines the first packets and the TLS handshake (for example the SNI and certificate), applies protocol decoders and

Copyright © ZyeemZia

signatures, and may update the classification as the session progresses. This lets you allow a collaboration suite while blocking its file-transfer feature, or block remote-access tools on port 443.

Port-based versus application-based rules

Port-based

- Allow TCP 443 to any
- Any application tunnelling over 443 passes
- Easy to write, hard to reason about
- Cannot separate features of one service

Application-based

- Allow named applications (and their default ports)
- Unknown or evasive traffic can be denied
- Needs signature updates and tuning
- Can control features such as upload or remote control

PRO TIP · APPLICATION IDENTIFICATION LIMITS

Encrypted traffic limits visibility: without TLS inspection, classification relies on SNI, certificate fields and traffic patterns. **Encrypted Client Hello (ECH)** hides the real SNI, and QUIC (HTTP/3 over UDP 443) changes the handshake. Many organisations block QUIC at the firewall so browsers fall back to TCP, where inspection is more mature — document this choice and its trade-offs.

User-based policy maps IP addresses to users and groups so rules can say 'Finance group may reach the payment system'. The mapping comes from identity sources: NAC/RADIUS accounting, directory login events, VPN logins, captive portals or agents. The rule is only as accurate as that mapping.

Identity sources for user-to-IP mapping

SOURCE	STRENGTH	WATCH OUT FOR
NAC / RADIUS accounting	Accurate for wired and wireless 802.1X sessions	Needs accounting start/stop and interim updates
VPN gateway logins	Precise for remote users	Only covers VPN-connected sessions
Directory login events	Broad coverage on managed Windows estates	Shared or multi-user hosts create wrong mappings
Captive portal	Works for unmanaged or guest devices	User friction; mapping ends at timeout
Terminal-server agents	Distinguishes many users on one IP by port ranges	Extra software on multi-user servers

SCENARIO · DECIDE · GROUP RULE NOT MATCHING

A rule allows the 'Payroll' group to reach the payroll application. A payroll clerk on a shared Citrix-style terminal server is blocked, while a call-centre user on the same server can reach payroll.

(A) The payroll application's signature is out of date

(B) Add the call-centre group to the payroll rule to make it consistent

(C) The terminal server's single IP is mapped to whoever logged in last; deploy a multi-user agent or move payroll access to per-user application access

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

Key takeaways

- NAT is not a security control, but you must know whether policy matches the pre-NAT or post-NAT address on your platform.
- Use PAT for users, static NAT for published services and NAT exemption for site-to-site VPN traffic.
- Application identification classifies by behaviour and handshake data; ECH and QUIC reduce what it can see without a full proxy.
- User-based rules are only as accurate as the user-to-IP mapping; multi-user hosts need agents or per-application access.

KNOWLEDGE CHECK

6. A user rule references the 'Engineering' group but matches nothing. Logs show traffic from the correct IPs. What is the most likely cause?

   (A) The application signature database is out of date on the firewall pair

   (B) The NAT pool has run out of public ports

   (C) The rule is placed below the explicit default-deny rule

   (D) The firewall has no current user-to-IP mapping for those addresses

7. Why must you confirm whether policy is evaluated pre-NAT or post-NAT?

   (A) A rule using the wrong destination address will not match the published service

   (B) NAT disables application identification on most current firewall platforms

   (C) Only post-NAT rules can be logged to the SIEM by the firewall's log forwarder

   (D) Pre-NAT rules cannot reference security zones, so they must be rewritten after translation

8. Which NAT type is used so site-to-site VPN traffic keeps its private addresses?

   (A) Port address translation to the outside interface address

   (B) Static destination NAT for the remote subnet

   (C) NAT exemption for traffic between the two private networks

   (D) Dynamic source NAT from a pool of public addresses at each site

9. What weakens application identification on encrypted traffic without TLS inspection?

   (A) Use of IPv4 rather than IPv6 addressing on the inside

   (B) Running applications on their default ports

   (C) Encrypted Client Hello hiding the real server name

   (D) Having many users behind a single NAT address

10. Why do many organisations block QUIC (UDP 443) at the firewall?

    (A) Browsers then fall back to TCP-based TLS, where inspection is more mature

    (B) QUIC traffic cannot be translated by NAT devices and breaks internet access

    (C) QUIC is used almost exclusively by malware families for command and control

    (D) Blocking QUIC improves video streaming quality

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 2 · PERIMETER · LESSON 3 · 30 MIN

TLS Inspection and IPS Integration

See inside encrypted traffic where it is justified, protect privacy where it is not, and tune intrusion prevention

- Explain outbound (forward proxy) and inbound TLS inspection
- Design a decryption policy with privacy and technical exceptions
- Integrate IPS profiles into firewall rules without crippling performance
- Recognise how TLS 1.3, pinning and ECH affect inspection

Most traffic is encrypted. Without inspection, malware delivery, command-and-control and data exfiltration over HTTPS look like ordinary web browsing. **TLS inspection** lets the firewall decrypt, inspect and re-encrypt — but it also breaks end-to-end trust, raises privacy and legal questions and costs significant performance. Expert design means deciding *what* to decrypt, not just *whether*.

Two inspection modes

Outbound (forward proxy)

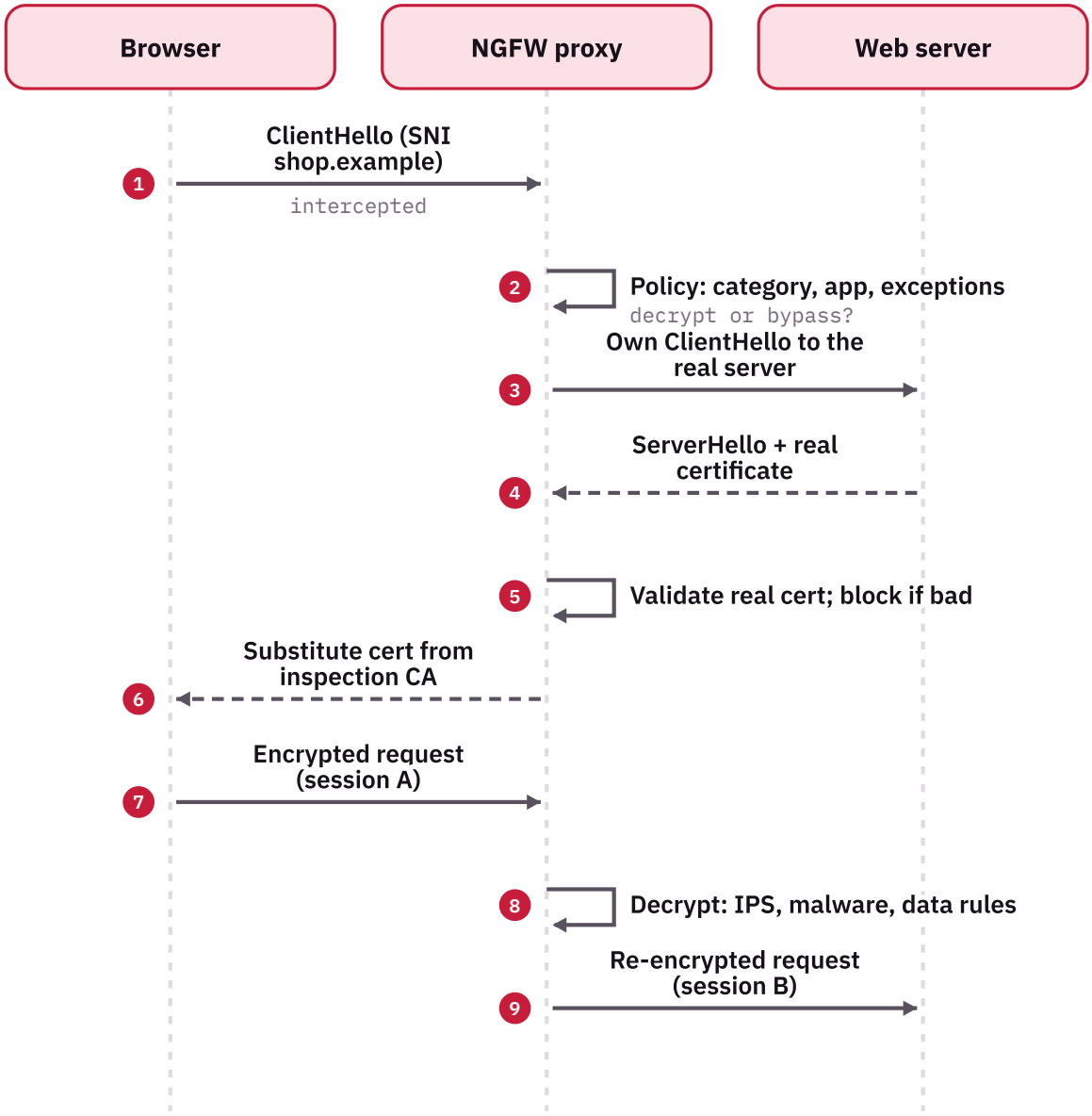
- Protects users browsing the internet
- Firewall generates a substitute certificate signed by an internal CA
- Clients must trust that internal CA
- Firewall validates the real server certificate on the user's behalf

Inbound (server protection)

- Protects your own published servers
- Firewall holds the server's certificate and private key, or terminates TLS as a reverse proxy
- No client changes needed
- Lets IPS see attacks aimed at your applications

Copyright © ZyeemZia

Outbound TLS inspection (forward proxy)



There are two separate TLS sessions: browser to proxy and proxy to server. The proxy validates the real certificate on the user's behalf, so it must block bad certificates rather than hide them.

WATCH OUT · THE FIREWALL NOW OWNS SERVER VALIDATION

Because the user's browser sees only the firewall's certificate, the firewall must **block** sessions to servers with expired, untrusted or mismatched certificates. Inspection that silently accepts bad certificates makes users less safe than no inspection at all.

Decryption exception categories

CATEGORY	REASON TO BYPASS	COMPENSATING CONTROL
Health and medical sites	Privacy and legal obligations	Category and reputation filtering without decryption
Banking and financial services	Privacy; many sites detect interception	Reputation checks, DNS security

Copyright © ZyeemZia

CATEGORY	REASON TO BYPASS	COMPENSATING CONTROL
Pinned applications (mobile apps, update services)	Certificate pinning makes interception fail	Allow by application and destination; monitor flows
Mutual-TLS client authentication	The firewall cannot present the client's certificate	Restrict destinations; inspect at the endpoint
Legally protected communications (e.g. HR, legal counsel portals)	Policy and works-council agreements	Documented exemption with owner approval

PRO TIP · GOVERNANCE FIRST

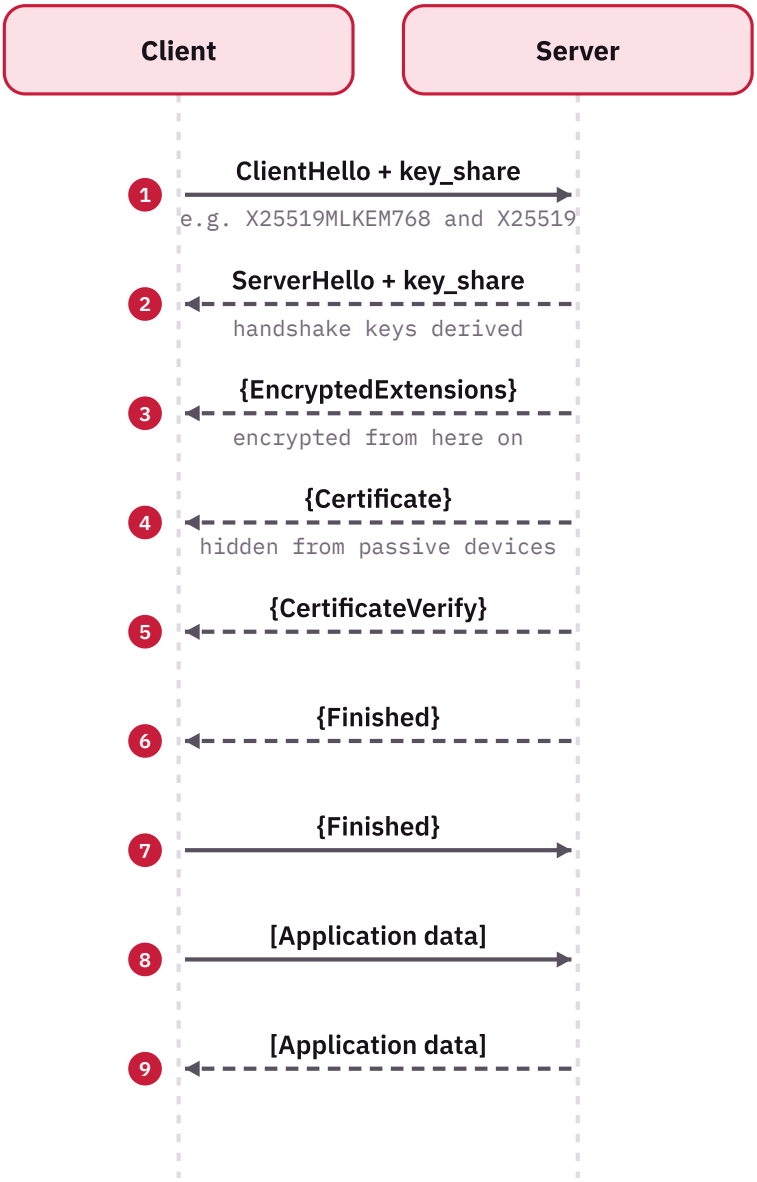
Before enabling decryption, agree a written policy with legal, HR and privacy owners: what is decrypted, who can see decrypted data, how long logs are kept and how users are informed. In many jurisdictions this is a legal requirement, not just good manners.

Modern TLS realities

DEVELOPMENT	EFFECT ON INSPECTION
TLS 1.3	Server certificate is encrypted in the handshake, so passive inspection cannot read it; full proxy is needed for content
Encrypted Client Hello (ECH)	Real server name hidden from passive observers; policy relies on DNS controls or full proxy
Certificate pinning	Apps refuse substitute certificates; they must be exempted or will break
QUIC / HTTP/3	UDP-based; many platforms inspect it less maturely, often blocked to force TCP fallback
Post-quantum hybrid key exchange	Mainstream browsers and TLS libraries now offer a hybrid group (classical X25519 combined with ML-KEM, e.g. X25519MLKEM768) by default. ClientHellos grow beyond one packet, which breaks some older middleboxes, and a proxy that only supports classical groups silently removes the post-quantum protection on the user side; check inspection devices for hybrid support

Copyright © ZyeemZia

TLS 1.3 full handshake (one round trip)



Braces mark messages already encrypted with handshake keys: the server certificate is no longer visible to passive devices, and with ECH the real server name is hidden too. Only a full proxy or the endpoint can see content.

An **intrusion prevention system (IPS)** integrated into the firewall applies signatures and protocol-anomaly checks to permitted traffic. Attach IPS profiles to *allow* rules — dropped traffic needs no inspection. Tune by risk: strict profiles on inbound DMZ traffic and server zones, balanced profiles on user browsing.

Bringing IPS into production safely

1. **Baseline** Enable the vendor-recommended profile in alert-only mode on a pilot rule set.
2. **Review** Analyse alerts for false positives against known applications for one to two weeks.
3. **Exception** Create narrow exceptions (signature + host), never disabling a whole category.
4. **Block** Switch high-confidence, high-severity signatures to block first, then expand.
5. **Maintain** Automate signature updates and review performance and exceptions monthly.

Copyright © ZyeemZia

IPS alert in the firewall threat log

FW1 · generic NGFW CLI

```
fw1> show log threat direction both severity critical last 1
time=2026-05-14T09:12:44Z rule=DMZ-WEB-IN action=reset-both
src=198.51.100.80 dst=10.20.0.10 dport=443 app=web-browsing decrypted=yes
threat="HTTP Server Remote Code Execution Attempt" id=94211 severity=critical
zone=untrust->dmz session=48912
```

Illustrative output. `decrypted=yes` *shows the inbound inspection rule made this detection possible; without it the exploit payload would have been invisible.*

SCENARIO · DECIDE · DECRYPTION ROLLOUT COMPLAINT

After enabling outbound TLS inspection for all staff, the help desk reports that a mobile banking app on company phones and the endpoint agent's update service both fail with certificate errors. The CISO asks for a fix today.

(A) Add narrow decryption exceptions for the pinned app and update-service destinations, and keep inspection for everything else

(B) Disable TLS inspection organisation-wide until the vendor releases a fix

(C) Configure the firewall to accept any server certificate to avoid errors

(D) Ask users to click through the certificate warnings

Circle your choice. Answer and feedback: module answer key.

Key takeaways

- Decide what to decrypt, not just whether: written policy with legal, HR and privacy owners comes first.
- Outbound inspection runs two TLS sessions; the proxy must validate real certificates and block bad ones.
- Exempt pinned apps, mutual-TLS services and protected categories, with compensating controls.
- TLS 1.3, ECH, QUIC and hybrid post-quantum key exchange all reduce passive visibility; check proxies support them.
- Attach IPS to allow rules, start alert-only, and move to blocking in tuned stages.

KNOWLEDGE CHECK

11. In outbound TLS inspection, what must clients trust?

(A) The public CA of every website they visit, as they always do

(B) A self-signed certificate installed on each destination web server

(C) The firewall's own management interface web certificate

(D) The internal CA that signs the firewall's substitute certificates

12. Why must a firewall performing TLS inspection block sessions to servers with invalid certificates?

(A) Invalid certificates make the firewall's CPU usage spike during decryption

(B) Users can no longer see the real certificate, so they rely on the firewall to check it

(C) IPS signatures cannot run on any session whose server presents an invalid or expired certificate

(D) Invalid certificates always indicate malware command-and-control infrastructure

13. A mobile app fails only when outbound inspection is enabled. What is the most likely reason?

(A) The app uses certificate pinning and rejects the substitute certificate

(B) The app negotiates TLS 1.2 rather than TLS 1.3 with its backend servers

(C) The app's traffic is being NATed to a public address

(D) The app requires IPv6 to function

Copyright © ZyeemZia

14. Where should IPS profiles be attached?

(A) To deny rules, so that blocked traffic is also inspected for known exploit attempts

(B) Only to the default-deny rule at the bottom

(C) To allow rules, with profiles tuned by risk

(D) Only to management-plane traffic

15. What is the safest first step when introducing IPS on a busy network?

(A) Enable every signature in block mode on all rules at once to maximise protection

(B) Run it alert-only first and review false positives

(C) Disable signature updates to keep behaviour stable

(D) Exclude encrypted traffic from the IPS permanently

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 2 · PERIMETER · LESSON 4 · 25 MIN

Firewall High Availability Designs

Keep security enforcement running through failures without creating split-brain or asymmetric traffic

- Compare active/standby and active/active firewall clustering
- Explain configuration and session synchronisation
- Design failover triggers using interface and path monitoring
- Avoid asymmetric routing and split-brain failures

A firewall is a single point of enforcement — which can also make it a single point of failure. **High availability (HA)** pairs or clusters firewalls so that a hardware, link or software failure does not stop the business. The challenge is that firewalls are stateful: a failover that loses the session table drops every active connection.

HA models

Active/standby

- One unit forwards; the peer is ready
- Simplest to operate and troubleshoot
- Half the hardware idles
- Most common for perimeter and VPN

Active/active

- Both units forward traffic
- Better use of capacity
- Risk of asymmetric flows and complex NAT
- Each unit must handle full load if the other fails

Cluster (3+ units)

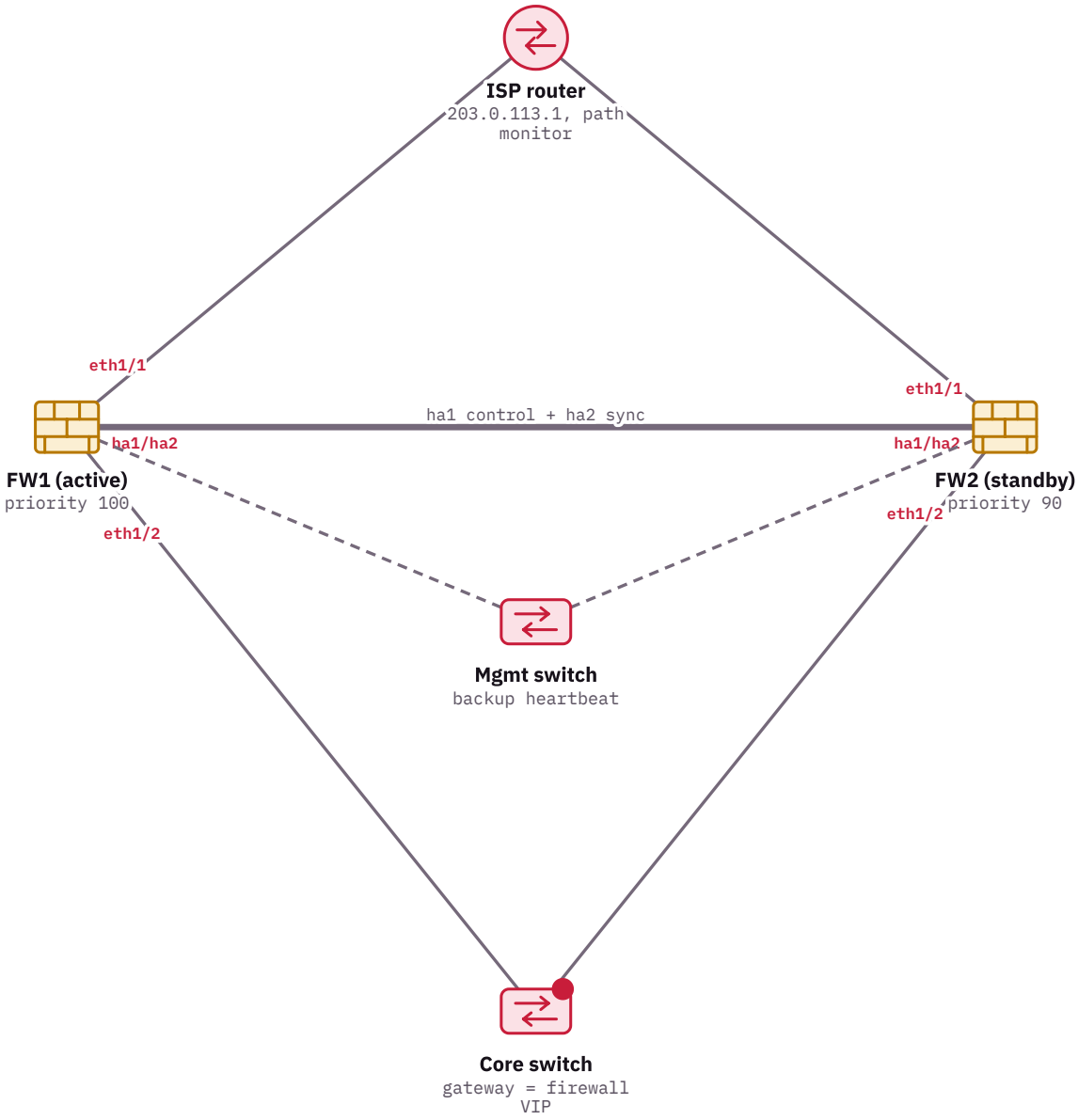
- Traffic spread across members
- Scales throughput
- Needs a cluster control link and careful load distribution
- Common in large data centres

What an HA pair synchronises

Control link	`Heartbeats` `Role election` `Priority and preemption`
Configuration sync	`Rules and objects` `NAT` `Certificates and keys`
State sync	`Session table` `NAT translations` `IPsec SAs (platform dependent)`
Data plane	`Shared virtual IP / MAC` `Gratuitous ARP on failover` `Routing adjacency handover`

Copyright © ZyeemZia

Active/standby pair with diverse heartbeats



The pair shares virtual addresses toward the ISP and the core, so a failover only moves ownership. Control and sync links run directly between the units, and a backup heartbeat over the management network prevents split-brain if both direct links fail.

Active/standby HA with link and path monitoring

FW1 · generic NGFW CLI

```
# Illustrative syntax — map to your platform
set ha mode active-passive
set ha group 10 peer-ip 169.254.10.2
set ha priority 100
set ha preempt disable
set ha control-link interface ha1 encryption enable
set ha state-sync interface ha2
set ha monitor link-group UPLINKS interfaces ethernet1/1 ethernet1/2 failure-condition all
set ha monitor path-group ISP destination 203.0.113.1 interval 1000 threshold 3
```

Preemption is disabled so the pair does not fail back automatically and cause a second disruption after a flapping recovery.

Copyright © ZyeemZia

Failover trigger design

H1
Heartbeat loss
Peer unreachable on all control links; use two diverse links to avoid split-brain.

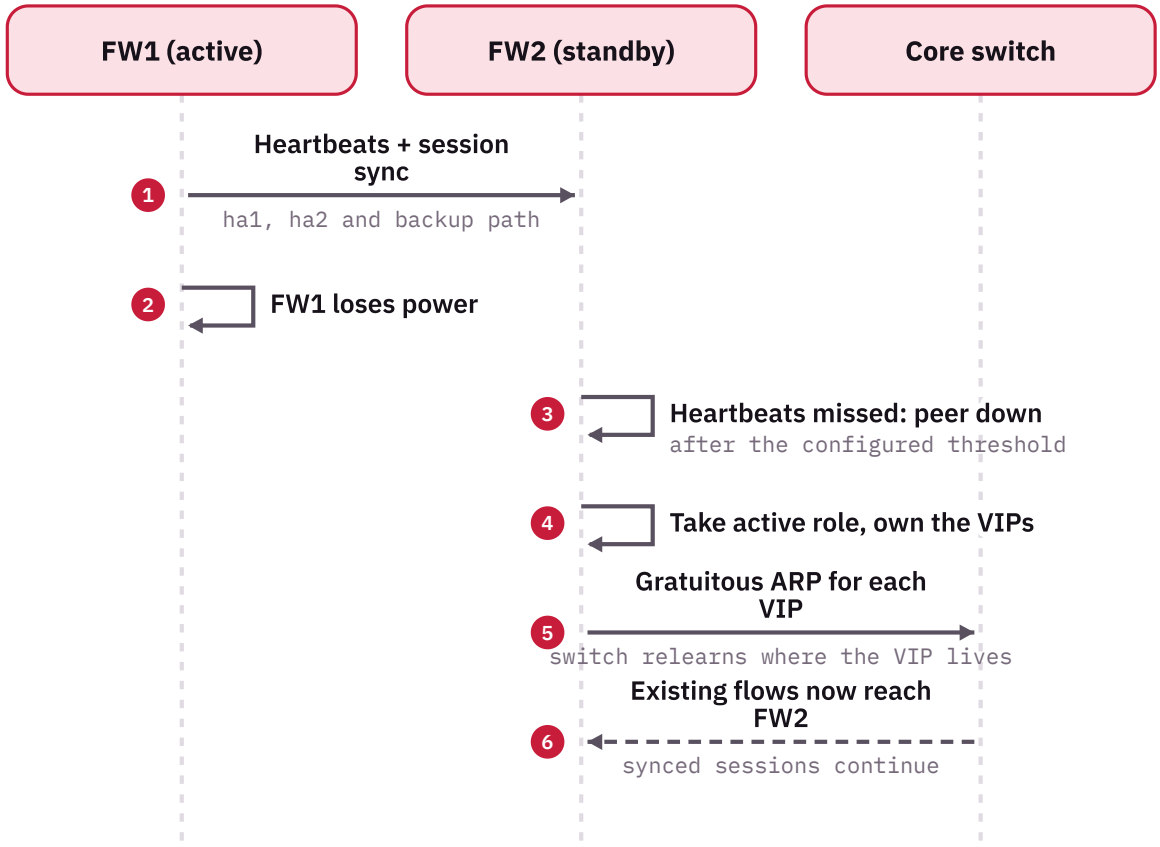
H2
Link monitoring
Fail over when critical interfaces go down; group links with any/all conditions.

H3
Path monitoring
Ping next hops or upstream targets to catch failures beyond the local link.

H4
Health of processes
Fail over on data-plane or critical daemon failure.

H5
Preemption policy
Decide deliberately whether the preferred unit reclaims the active role.

What happens during a failover



Because sessions were synchronised before the failure, FW2 can forward packets of flows it never saw start. The gratuitous ARP only moves the shared address to a new switch port; clients notice nothing.

WATCH OUT · SPLIT-BRAIN
If both control links fail but both units are healthy, each may think the other is dead and become active, with the same IP and MAC addresses — causing duplicate addresses and dropped sessions. Use at least two physically separate HA links (or a backup heartbeat over a data or management interface) and test the scenario.

Copyright © ZyeemZia

INSIGHT · ASYMMETRIC ROUTING BREAKS STATE

If a SYN leaves through firewall A and the SYN-ACK returns through firewall B, B has no session and drops the reply. In active/active designs, keep flows symmetric with routing design, session-owner forwarding between members or an external load balancer that hashes consistently.

SCENARIO · DECIDE · FAILOVER DROPS ALL VPN USERS

During a planned failover test, web sessions survive but all remote-access VPN users must reconnect. The pair is configured with state sync.

(A) Check whether the platform synchronises VPN SAs and whether that option is enabled; if not, plan maintenance windows accordingly

(B) Increase the heartbeat interval to slow failover

(C) Enable preemption so the original unit returns quickly

Circle your choice. Answer and feedback: module answer key.

HA test plan essentials

TEST	EXPECTED RESULT	EVIDENCE
Power off the active unit	Standby takes over within the target time; sessions persist	Continuous ping and long-lived TCP session survive
Unplug a monitored uplink	Failover triggered by link group	HA log shows reason 'link monitor'
Break the upstream path only	Failover triggered by path monitor	Traffic resumes via peer's uplink
Cut one HA link	No failover; alarm raised	Both units remain in correct roles
Software upgrade of standby, then failover	Upgrade without business outage	Change record with timings

REFLECT

When did your organisation last perform a real failover test of its perimeter firewalls? List the three failure scenarios you would test first and how you would prove sessions survived.

Key takeaways

- Stateful HA must synchronise sessions as well as configuration, or failover drops every connection.
- Active/standby is simplest; active/active and clusters add capacity but demand symmetric flows.
- Use link and path monitoring, diverse heartbeats and a deliberate preemption choice.
- Prove HA with planned tests (power, link, path, HA-link and upgrade) and keep the evidence.

KNOWLEDGE CHECK

Copyright © ZyeemZia

16. Why is session synchronisation important in a stateful HA pair?

(A) Without it, the configuration on the two units drifts apart and policies stop matching after changes

(B) Without it, the heartbeat link cannot elect which unit should become active

(C) Without it, NAT rules cannot be configured on the standby unit of the pair

(D) Without it, a failover drops every established session

17. Both HA control links fail but both firewalls are healthy. What risk does this create?

(A) A routing loop forming between the two firewalls' data-plane interfaces

(B) Split-brain: both units go active at once

(C) Automatic deletion of the session table on both units

(D) Loss of all configuration until manual resynchronisation

18. Why might preemption be disabled in a firewall pair?

(A) Because preemption prevents configuration synchronisation between the units

(B) Because preemption is required for active/active only

(C) Because preemption disables path monitoring

(D) Because failback would cause a second outage when the unit returns

19. In an active/active pair, return traffic arrives at the unit that did not see the SYN and is dropped. What is the root cause?

(A) Asymmetric routing across the two units

(B) The IPS profile on the return-traffic rule is still set to alert-only mode

(C) The standby unit has an older signature database

(D) Path monitoring is configured with too short an interval

20. Which HA test proves that path monitoring works?

(A) Power off the active firewall completely and time the failover

(B) Disconnect one of the HA control links and watch the role election

(C) Break connectivity beyond the local uplink while the local interface stays up

(D) Upgrade the standby unit's software and then fail over to it deliberately

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 2 · PERIMETER · LESSON 5 · 30 MIN

Policy Hygiene, Audit and Troubleshooting

Keep the rule base lean and provable, and find the real cause of a blocked flow quickly

- Identify shadowed, redundant, overly broad and unused rules
- Run a firewall rule recertification and audit process
- Troubleshoot blocked or broken flows using logs, packet traces and captures
- Interpret TCP behaviour in captures to locate the failing device

Firewall rule bases decay. Projects end but their rules remain; emergency changes are never reverted; names drift from reality. A large, messy rule base is slower to audit, easier to bypass and harder to troubleshoot. **Policy hygiene** is ongoing engineering work, not an annual clean-up.

Common rule-base problems

PROBLEM	WHAT IT LOOKS LIKE	FIX
Shadowed rule	A specific rule sits below a broader rule that already matches its traffic, so it never hits	Reorder or remove; verify intent with the owner
Redundant rule	Two rules permit the same traffic	Merge into one with clear ownership
Overly permissive rule	'Any' in source, destination and service; or whole subnets to whole subnets	Narrow using flow logs and application identification
Unused rule	Zero hits for 90+ days	Disable, monitor, then delete after a grace period
Orphaned objects	Address objects for decommissioned servers	Remove; they hide in groups and widen rules
Missing logging	Allow rules without session-end logs	Enable logging on all allow and deny rules

TEMPLATE

Firewall rule review sheet

Use during quarterly recertification; every rule must be confirmed by its owner or removed.

RULE ID / NAME	SOURCE → DESTINATION	APPLICATION / SERVICE	HIT COUNT (90 DAYS)	OWNER AND JUSTIFICATION	FINDING	DECISION
DMZ-WEB-IN-07	*Vendor ranges → web01*	*HTTPS*	*18,432*	*App team; ticket CHG-2214 vendor API*	*Correct scope*	*Keep, review in 6 months*
TEMP-ANY-DB	*10.0.0.0/8 → db-cluster*	*any*	*0*	*Unknown; created during 2024 migration*	*Overly broad and unused*	*Disable now, delete in 30 days*

Copyright © ZyeemZia

RULE ID / NAME	SOURCE → DESTINATION	APPLICATION / SERVICE	HIT COUNT (90 DAYS)	OWNER AND JUSTIFICATION	FINDING	DECISION

Quarterly recertification process

1. **Export and analyse** Pull rules with hit counts and last-hit dates; run automated shadow/redundancy analysis.
2. **Send to owners** Each owner confirms, narrows or retires their rules by a deadline.
3. **Unowned rules** No owner response means disable (not delete) with monitoring for impact.
4. **Change control** Apply changes through normal approval with rollback ready.
5. **Report** Track metrics: total rules, rules with 'any', unused rules, average age.

When a user says 'the firewall is blocking me', start from evidence. A methodical approach separates **policy** problems (a rule denies it) from **path** problems (routing, NAT, asymmetric return) and **endpoint** problems (the server is not listening).

Troubleshooting a blocked flow

01 Define the flow — Exact source, destination, port, application and time

→

02 Check the logs — Is there a deny log, an allow log or nothing at all?

→

03 Simulate — Use the platform's packet-trace or policy-lookup tool

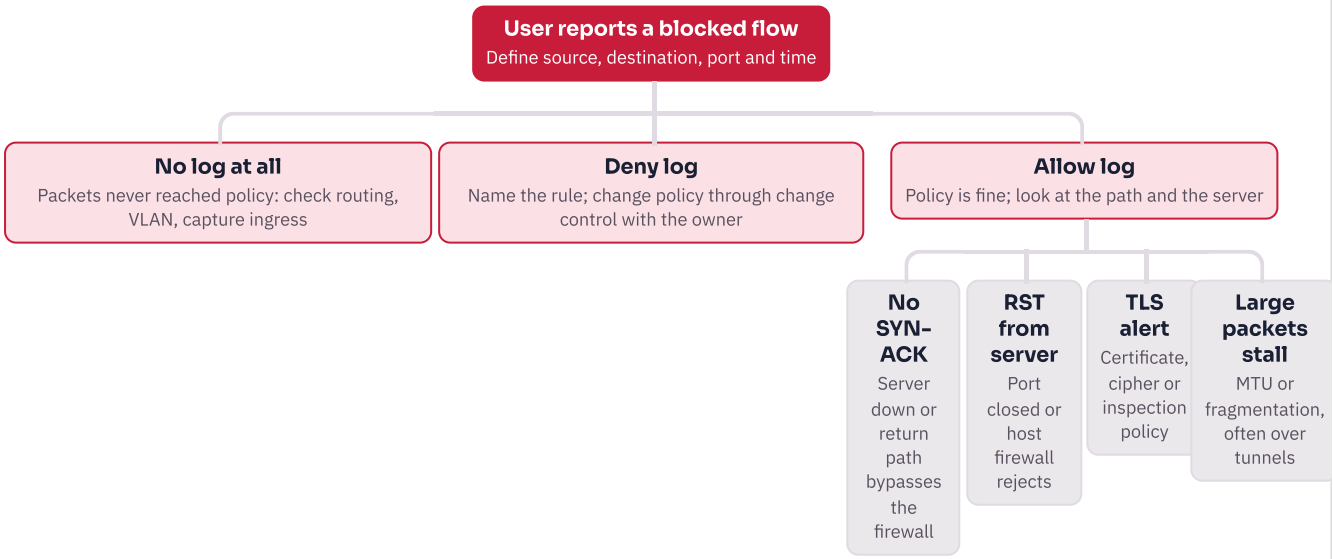
→

04 Capture — Capture on ingress and egress interfaces

→

05 Fix and verify — Change the right element; confirm with logs and the user

What the firewall logs tell you first



The type of log narrows the search before you touch any rule: no log points upstream, a deny log points at policy, and an allow log means the cause is beyond the rule base.

Copyright © ZyeemZia

Capturing on the server-side interface

Linux sensor · tcpdump

```
# tcpdump -ni eth1 host 10.20.0.15 and tcp port 8443
10:41:02.113 IP 10.10.4.21.53188 > 10.20.0.15.8443: Flags [S], seq 2918822,  win 64240
10:41:02.114 IP 10.20.0.15.8443 > 10.10.4.21.53188: Flags [R.], seq 0, ack 2918823, win 0
10:41:03.120 IP 10.10.4.21.53188 > 10.20.0.15.8443: Flags [S], seq 2918822,  win 64240
10:41:03.121 IP 10.20.0.15.8443 > 10.10.4.21.53188: Flags [R.], seq 0, ack 2918823, win 0
```

The SYN reaches the server and the server itself answers with RST: nothing is listening on 8443 (or a host firewall rejects). The network firewall is not the problem.

Reading captures quickly

WHAT YOU SEE	LIKELY MEANING
SYN on ingress, nothing on egress	Firewall dropped it (check deny logs and policy) or routing sends it elsewhere
SYN on egress, no SYN-ACK back	Server down, path beyond firewall broken, or return traffic routed around the firewall
SYN-ACK returns on a different interface or firewall	Asymmetric routing; stateful device will drop it
RST from the server	Port closed or host firewall rejecting
Handshake completes, then TLS alert	Certificate or cipher problem; check inspection policy
Large packets retransmitted, small ones fine	MTU / fragmentation issue, often over tunnels

SCENARIO · DECIDE · NO LOGS AT ALL

A user cannot reach an internal app at 10.30.5.9:443. The firewall shows no deny log and no allow log for that flow, although logging is enabled on all rules including default deny.

(A) Add an allow rule for the user to the app

(B) Restart the firewall to clear the session table

(C) Confirm the traffic actually reaches the firewall — check routing on the user's path and capture on the ingress interface

(D) Disable the IPS profile on the rule

Circle your choice. Answer and feedback: module answer key.

CASE STUDY · RETAIL CHAIN FIREWALL AUDIT

A retail chain with 220 stores has one central firewall cluster with 4,800 rules. An external audit finds 1,150 rules with zero hits in a year, 310 rules with 'any' as the service, 60 rules referencing servers that no longer exist, and no documented owners. Card-payment systems share a zone with back-office servers. The security team has two engineers and a quarter to show progress.

1. How would you prioritise the clean-up?

2. What should happen to unused rules, and how do you avoid outages?

Copyright © ZyeemZia

3. What architectural change does the audit point to?

4. Which metrics would show progress to the board?

Model answer: module answer key.

Rule-base health checklist

- ☐ Every rule has an owner, justification and ticket reference
- ☐ No allow rule has 'any' in source, destination and service together
- ☐ Rules unused for 90 days are reviewed and disabled
- ☐ Shadow and redundancy analysis runs at least quarterly
- ☐ Address objects for decommissioned systems are removed
- ☐ All allow and deny rules log to the SIEM
- ☐ Temporary rules carry an expiry date
- ☐ Default-deny rule at the end of every zone pair logs drops

Key terms

Stateful inspection
Tracking connection state so return traffic is allowed only when it matches an existing session.

PAT
Port address translation: many inside hosts share one public address using unique source ports.

Application identification
Classifying traffic by application using decoders, signatures and handshake data rather than port numbers.

Certificate pinning
An application accepting only specific certificates or keys, which causes interception to fail.

Split-brain
An HA failure in which both units believe they are active at the same time.

Asymmetric routing
Forward and return packets of one flow taking different paths, breaking stateful inspection.

Security zone
A group of interfaces sharing a trust level; policy is written between zones.

NAT exemption
A rule that prevents translation for selected traffic, typically between VPN-connected private networks.

TLS inspection
Decrypting, inspecting and re-encrypting TLS traffic at a firewall or proxy under a defined policy.

Encrypted Client Hello
A TLS extension that encrypts the server name and other handshake details from observers.

Shadowed rule
A rule that never matches because an earlier, broader rule already handles its traffic.

Copyright © ZyeemZia

Key takeaways

- Rule bases decay; find shadowed, redundant, broad, unused and orphaned rules continuously.
- Recertify quarterly with owners; disable unowned or unused rules with monitoring before deleting them.
- Troubleshoot from evidence: logs first, then packet-trace tools, then captures on ingress and egress.
- Read the TCP story in a capture to tell policy, path and endpoint problems apart.

KNOWLEDGE CHECK

21. A rule permitting HTTPS to server A never shows hits, although users reach server A over HTTPS daily. What is most likely?

(A) Server A does not support TLS 1.3, so connections are classified differently

(B) Logging is disabled on the default-deny rule

(C) It is shadowed by an earlier, broader rule that already matches the same traffic

(D) The rule uses an application object instead of a port

22. What should happen to a rule with no owner response during recertification?

(A) Disable it with monitoring, then delete it after a grace period if nothing breaks

(B) Delete it immediately to reduce the rule count before the next audit cycle

(C) Keep it permanently, because removing any rule might break an unknown dependency

(D) Convert it to 'any' service so it is easier to manage

23. A capture shows the SYN leaving the firewall's server-side interface and no reply. What is the best next check?

(A) Whether the firewall policy allows the SYN outbound on the server-side interface and zone

(B) Whether the client's browser trusts the TLS inspection CA certificate

(C) Whether the IPS signatures on the server-facing rule are fully up to date

(D) Whether the server is up and its replies return through the same firewall

24. Large file transfers over a tunnel stall while small requests work. What does this pattern suggest?

(A) A shadowed rule for the file-transfer application

(B) An MTU or fragmentation problem along the path

(C) Missing user-to-IP mapping for the sender

(D) An expired IPS licence on the firewall

25. Why are address objects for decommissioned servers a security risk?

(A) Their addresses may be reassigned to new hosts that inherit old permissions

(B) They consume licences on most firewall platforms and raise support costs

(C) They prevent configuration synchronisation between units of an HA pair

(D) They cause the firewall to drop all traffic sent to that subnet until removed

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 2 · PERIMETER

Answer key

Knowledge checks

1. A State tracking matches return packets to the session. No permanent reverse rule is created and the ACK flag alone is not trusted.

2. C Zone-based policy is written between zones, so interfaces inherit zone policy. That is a key benefit of the zone model.

3. B Without a zone pair, inter-zone traffic is denied; inspected sessions allow return packets through state. Zone pairs can be defined in either direction.

4. D Ownership and justification make rules reviewable. Objects improve readability over raw IPs, and broad rules at the top shadow specific ones.

5. B SYN protection and half-open limits protect the table. Longer timeouts and broader rules worsen exhaustion; disabling logs removes visibility.

6. D If traffic arrives but the user field is empty, identity mapping is missing. A rule below default deny would never be hit, but the user field would still show the user.

7. A Platforms differ in which address the rule sees; a mismatch makes rules silently fail. NAT does not disable application identification or logging.

8. C VPN traffic between private networks is typically exempted so the selectors match. PAT or dynamic NAT would change addresses and break the tunnel's traffic selectors.

9. C ECH removes the SNI hint that classification relies on. IP version, default ports and NAT do not materially reduce application visibility.

10. A Blocking QUIC is a visibility trade-off. QUIC works through NAT, is widely used legitimately and blocking it does not improve streaming.

11. D Clients see certificates minted by the firewall, so the internal inspection CA must be in their trust store.

12. B The firewall takes over validation from the browser. Hiding errors would remove protection from man-in-the-middle attacks.

13. A Pinned apps accept only expected certificates or keys, so interception breaks them. TLS version, NAT and IPv6 do not explain this.

14. C IPS inspects permitted traffic; blocked traffic is already stopped. Risk-based profile selection balances protection and performance.

15. B Alert-only baselining avoids outages. Blocking everything at once, freezing updates or permanently excluding traffic all reduce safety or availability.

16. D State sync preserves sessions; configuration sync and heartbeats are separate functions.

17. B Each unit assumes the peer is dead and takes the active role. Diverse HA links or backup heartbeats prevent it.

18. D Preemption causes failback; if the recovered unit is unstable this creates repeated outages. It is unrelated to config sync or monitoring.

19. A Stateful devices drop packets with no matching session; symmetric routing or owner forwarding is needed.

20. C Path monitoring detects failures beyond the link. Powering off tests heartbeat failover; cutting one HA link tests resilience of control links.

21. C Traffic works but this rule is never hit, so an earlier rule must be matching first. The other options do not explain zero hits with working traffic.

22. A Disable-then-delete balances risk and availability. Immediate deletion risks outages; keeping it forever preserves risk.

23. D The SYN already passed policy. No reply points to the server or an asymmetric return path. CA trust and IPS are not involved yet.

24. B Size-dependent failure is the classic sign of MTU problems, especially with tunnel overhead. Policy and identity issues affect all sizes.

25. A Reused IPs inherit stale access. Licensing, HA sync and blanket drops are not the concern.

Scenarios & case studies

Scenario · Inbound access request

B is best. Correct. It matches the documented need exactly and keeps the rule auditable.

Scenario · Group rule not matching

C is best. Correct. IP-to-user mapping breaks on multi-user hosts; port-range agents or per-application access fix it.

Copyright © ZyeemZia

Scenario · Decryption rollout complaint
A is best. Correct. Pinned services cannot be intercepted; exempting them by destination restores function while preserving inspection elsewhere.

Scenario · Failover drops all VPN users
A is best. Correct. Many platforms sync firewall sessions but VPN or remote-access state separately or not at all; verify and document behaviour.

Scenario · No logs at all
C is best. Correct. No log of any kind usually means the packets never arrived; the problem is upstream routing, VLAN or the client.

Case study · Retail chain firewall audit
Prioritise by risk: first, rules touching the payment zone and any 'any-service' rules from untrusted zones; second, rules referencing non-existent servers (their addresses may be reused by new hosts); third, unused rules in bulk. **Unused rules:** disable in batches with logging and a 30-day observation window, then delete; communicate the schedule to application teams. **Architecture:** move card-payment systems into their own zone (reducing compliance scope) with tightly scoped inbound and outbound rules; consider per-store templates managed centrally. **Governance:** introduce rule owners, expiry dates on new rules and quarterly recertification. **Metrics:** total rules, percentage with owners, number of 'any-service' rules, unused rules remaining, and mean time to approve a rule request.

Copyright © ZyeemZia

03

MODULE 3 · TUNNEL

VPN Technologies

Build, scale and troubleshoot IPsec and remote-access VPNs with strong cryptography and dependable PKI

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Explain IKEv2 exchanges, security associations, transforms and perfect forward secrecy
- Configure route-based and policy-based IKEv2 site-to-site VPNs correctly
- Design dynamic hub-and-spoke overlays and secure remote-access VPNs
- Run a PKI for VPN authentication with reliable revocation checking
- Troubleshoot VPN negotiation systematically from underlay to data plane

LESSONS

1. IPsec and IKEv2 Fundamentals · 30 min
2. Site-to-Site VPN: Route-Based and Policy-Based · 32 min
3. Dynamic Hub-and-Spoke and Remote-Access VPN · 30 min
4. PKI for VPNs and Troubleshooting Negotiation · 32 min

MODULE 3 · TUNNEL · LESSON 1 · 30 MIN

IPsec and IKEv2 Fundamentals

Security associations, the IKEv2 exchanges, transforms and perfect forward secrecy

- Describe the IKEv2 exchanges defined in RFC 7296 and what each establishes
- Distinguish the IKE SA from Child SAs and explain SPIs
- Choose strong, interoperable transforms and DH groups for 2026
- Explain perfect forward secrecy and when it is applied

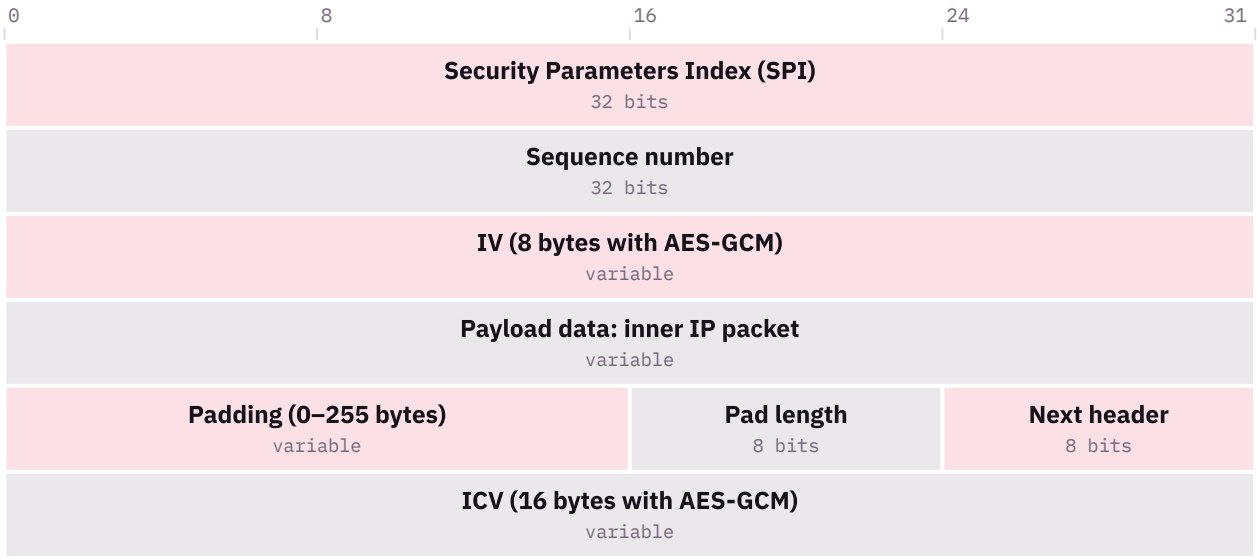
IPsec protects IP packets with confidentiality, integrity and authentication of the peer. On its own, IPsec needs keys and parameters; **IKEv2** (Internet Key Exchange version 2, RFC 7296) is the protocol that authenticates the peers, negotiates those parameters and creates the keys. Almost every modern site-to-site and many remote-access VPNs use IKEv2 with ESP.

IPsec building blocks

ELEMENT	WHAT IT IS	KEY FACTS
ESP	Encapsulating Security Payload, IP protocol 50	Provides encryption and integrity; the default choice
AH	Authentication Header, IP protocol 51	Integrity only, covers parts of the outer IP header, so it breaks through NAT; rarely used
Tunnel mode	Whole original packet encrypted inside a new IP header	Used for gateway-to-gateway VPNs
Transport mode	Only the payload is protected; original header kept	Host-to-host, or GRE-over-IPsec where GRE supplies the outer header
NAT traversal	ESP wrapped in UDP 4500	Triggered when IKEv2 detects NAT between peers
IKE ports	UDP 500, moving to UDP 4500 when NAT is detected	Both must be allowed through upstream firewalls

Copyright © ZyeemZia

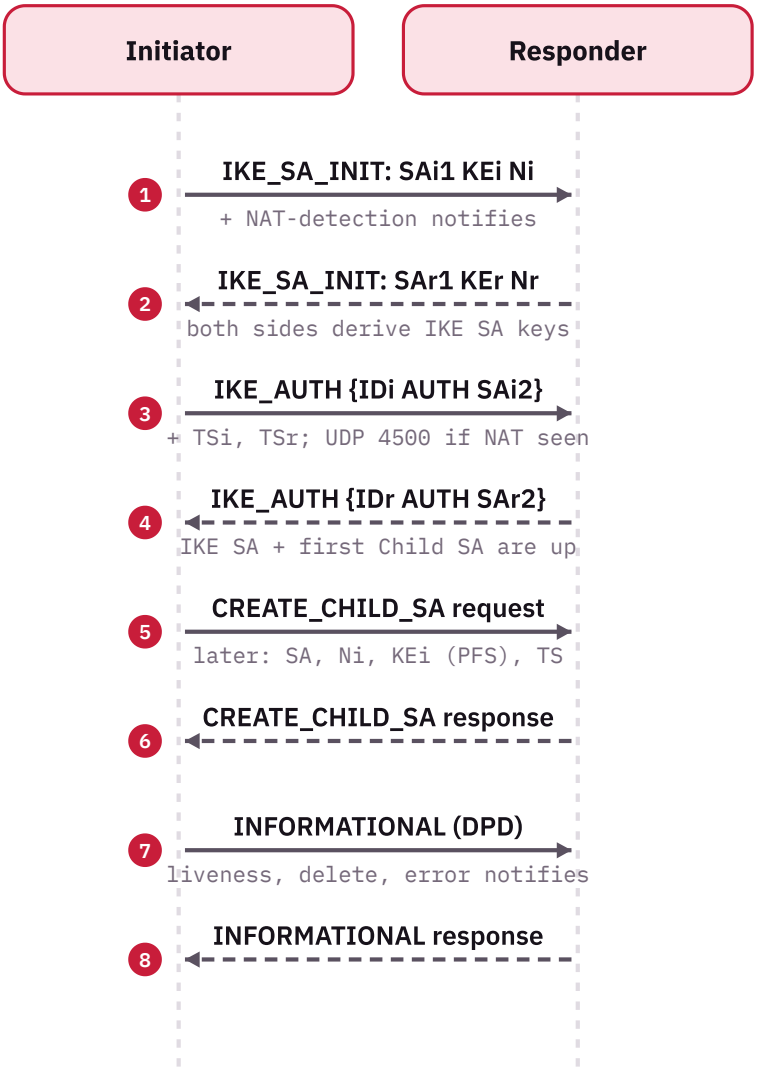
ESP packet with AES-GCM (RFC 4303, RFC 4106)



SPI and sequence number travel in clear so the receiver can find the SA and reject replays; everything from the payload to the next-header field is encrypted, and the ICV authenticates the ESP header and ciphertext. Fields marked variable depend on the algorithm or the packet and are drawn one row high.

Copyright © ZyeemZia

IKEv2 exchanges (RFC 7296)



Four messages create the IKE SA and the first Child SA; braces mark encrypted payloads. CREATE_CHILD_SA and INFORMATIONAL exchanges happen later, for rekeys, extra SAs and liveness checks.

INSIGHT · PHASE 1 AND PHASE 2 ARE IKEV1 WORDS

Engineers still say 'phase 1' for the IKE SA and 'phase 2' for the IPsec SAs. That mapping is useful, but IKEv2 is not split the same way: the first Child SA is created **inside** IKE_AUTH, so a working IKEv2 tunnel needs only four messages, compared with nine in IKEv1 main mode plus quick mode.

IKE SA versus Child SA

IKE SA

- One per peer pair (bidirectional)
- Protects IKEv2 control messages
- Created by IKE_SA_INIT and authenticated by IKE_AUTH
- Typical lifetime: hours (often 24h)

Child SA (IPsec SA)

- A pair of unidirectional SAs, one per direction
- Each direction has its own SPI
- Protects user traffic matching the traffic selectors
- Shorter lifetime (often 1h or a data volume)

Copyright © ZyeemZia

Transform choices for 2026

PURPOSE	RECOMMENDED	ACCEPTABLE FOR LEGACY INTEROP	AVOID
ESP encryption	AES-GCM-256 (AEAD; no separate integrity)	AES-CBC-256 with HMAC-SHA-256	DES, 3DES, NULL encryption
ESP integrity (non-AEAD)	HMAC-SHA-256/384/512	—	MD5, SHA-1
IKE PRF	PRF-HMAC-SHA-384 or SHA-256	—	PRF-HMAC-MD5, SHA-1
Diffie-Hellman group	19 or 20 (ECP 256/384), 31 (Curve25519)	14 (MODP 2048) minimum	1, 2, 5
Post-quantum key exchange	Hybrid: classical group plus ML-KEM as an additional key exchange (RFC 9370) where both peers support it	Classical group 19/20/31 while you plan the migration	Long-lived tunnels with no migration plan
Peer authentication	Certificates (ECDSA or RSA ≥ 3072)	Long random PSK stored in a vault	Short, shared or reused PSKs

PRO TIP · POST-QUANTUM PLANNING

NIST published its first post-quantum standards in August 2024: **FIPS 203 (ML-KEM)** for key establishment and **FIPS 204 (ML-DSA)** and **FIPS 205 (SLH-DSA)** for signatures. For IKEv2, RFC 9370 allows **multiple key exchanges**: a classical DH group is combined with a post-quantum KEM such as ML-KEM, carried in IKE_INTERMEDIATE exchanges (RFC 9242) between IKE_SA_INIT and IKE_AUTH, so the result is safe as long as either algorithm holds. Platform support is still arriving. Start now with a **crypto inventory** (which tunnels carry long-lived sensitive data, which algorithms and certificates they use) and design for **crypto agility**, because recorded traffic could be decrypted later ('harvest now, decrypt later'). Government transition deadlines for retiring RSA and elliptic-curve algorithms are being set for the early-to-mid 2030s; check the current official timetable for your sector.

DEFINITION · PERFECT FORWARD SECRECY (PFS)

With **PFS**, each new Child SA key is derived from a fresh Diffie-Hellman exchange, so compromising one key (or the long-term authentication secret) does not expose traffic protected by other keys. In IKEv2 the first Child SA reuses keying material from IKE_SA_INIT; the configured PFS group is applied when Child SAs are **rekeyed** with CREATE_CHILD_SA.

Copyright © ZyeemZia

SCENARIO · DECIDE · TUNNEL DROPS EVERY HOUR

A new IKEv2 tunnel between two sites comes up instantly and passes traffic, but exactly 60 minutes later it fails and re-establishes after a minute. Logs at the drop show a failed CREATE_CHILD_SA exchange.

(A) Increase the IKE SA lifetime from 24 hours to 48 hours

(B) Check that both peers configure the same PFS group for the Child SA; a mismatch only appears at the first rekey

(C) Change the pre-shared key on both peers

(D) Switch from tunnel mode to transport mode

Circle your choice. Answer and feedback: module answer key.

REFLECT

List the transforms currently used on your organisation's VPNs. Which tunnels still use groups or algorithms from the 'avoid' column, and what blocks their upgrade?

Key takeaways

- IKEv2 needs four messages to build the IKE SA and the first Child SA; later exchanges rekey and check liveness.
- Use ESP with AEAD (AES-GCM), strong DH groups and certificates; retire DES, 3DES, MD5, SHA-1 and groups 1, 2 and 5.
- A Child SA is a pair of one-way SAs, each with its own SPI; PFS applies at Child SA rekeys.
- Plan post-quantum migration now: inventory tunnels and algorithms, and adopt hybrid ML-KEM key exchange as platforms support it.

KNOWLEDGE CHECK

1. How many messages does IKEv2 need to establish the IKE SA and the first Child SA?

   (A) Six messages of main mode followed by three of quick mode

   (B) Two messages, because IKEv2 combines all negotiation into one exchange

   (C) Four: two IKE_SA_INIT and two IKE_AUTH messages

   (D) Eight messages, including two separate CREATE_CHILD_SA exchanges

2. Why is AH rarely used in modern VPNs?

   (A) It is limited to IPv6 traffic and cannot carry IPv4 packets in tunnel mode

   (B) It offers no encryption, and its integrity check breaks whenever NAT alters the outer header

   (C) It requires certificates and cannot be used with pre-shared key authentication

   (D) It runs over TCP and therefore suffers from head-of-line blocking on lossy WAN links

Copyright © ZyeemZia

3. What identifies each direction of a Child SA?

(A) The remaining lifetime counter of the parent IKE SA

(B) The Diffie-Hellman group number agreed during IKE_SA_INIT

(C) The serial number of the peer's certificate used in IKE_AUTH for that tunnel

(D) A separate SPI for each unidirectional SA

4. Which ESP transform needs NO separate integrity algorithm?

(A) AES-CBC, because cipher block chaining includes a built-in checksum

(B) AES-GCM, an authenticated encryption mode

(C) 3DES, because it encrypts three times

(D) NULL encryption, because it relies on IKE integrity

5. When does the configured PFS group take effect in IKEv2?

(A) Only during IKE_SA_INIT, when the IKE SA keys are first derived

(B) Only for IKEv1 peers in aggressive mode

(C) Every time a dead peer detection liveness check is exchanged

(D) When Child SAs are rekeyed or created later

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 3 · TUNNEL · LESSON 2 · 32 MIN

Site-to-Site VPN: Route-Based and Policy-Based

Choose the right model and build a correct, maintainable IKEv2 site-to-site tunnel

- Compare route-based (VTI) and policy-based (crypto ACL) VPN designs
- Configure an IKEv2 site-to-site VPN with a virtual tunnel interface
- Run dynamic routing over tunnels and handle MTU correctly
- Verify a tunnel using SA state and packet counters

There are two ways to decide which traffic enters a tunnel. **Policy-based** VPNs use an access list (crypto ACL) that defines exactly which source and destination subnets are encrypted. **Route-based** VPNs create a tunnel interface; anything routed into that interface is encrypted. For anything beyond a simple pair of subnets, route-based designs are easier to operate.

Policy-based versus route-based

Policy-based (crypto ACL)

- Traffic selected by an ACL of subnet pairs
- Each subnet pair can create its own Child SA
- No routing protocol over the tunnel
- Adding a subnet means changing both peers' ACLs exactly
- Common with older or third-party peers

Route-based (VTI)

- Traffic selected by routing into a tunnel interface
- Selectors usually 0.0.0.0/0 to 0.0.0.0/0
- Supports dynamic routing (BGP, OSPF) and failover
- Interface counters, QoS and policy apply per tunnel
- Preferred for hub designs and cloud gateways

IKEv2 proposal, keyring and profile (branch side)

BR-R1 · IOS-style CLI

```
crypto ikev2 proposal PROP-GCM256
 encryption aes-gcm-256
 prf sha384
 group 20
crypto ikev2 policy POL-GCM256
 proposal PROP-GCM256
crypto ikev2 keyring KR-HQ
 peer HQ
  address 203.0.113.1
  pre-shared-key <long-random-key-from-vault>
crypto ikev2 profile PROF-HQ
 match identity remote address 203.0.113.1 255.255.255.255
 authentication remote pre-share
 authentication local pre-share
 keyring local KR-HQ
 dpd 10 3 on-demand
```

With an AEAD cipher (AES-GCM) the IKEv2 proposal specifies a PRF but no separate integrity algorithm.

Copyright © ZyeemZia

IPsec profile and virtual tunnel interface

BR-R1 · IOS-style CLI

```
crypto ipsec transform-set TS-GCM256 esp-gcm 256
 mode tunnel
crypto ipsec profile IPSEC-HQ
 set transform-set TS-GCM256
 set pfs group20
 set ikev2-profile PROF-HQ
interface Tunnel10
 ip address 172.16.10.2 255.255.255.252
 ip mtu 1400
 ip tcp adjust-mss 1360
 tunnel source GigabitEthernet0/1
 tunnel destination 203.0.113.1
 tunnel mode ipsec ipv4
 tunnel protection ipsec profile IPSEC-HQ
```

Lowering the tunnel MTU and clamping TCP MSS prevents fragmentation caused by ESP overhead.

Routing over the tunnel with BGP

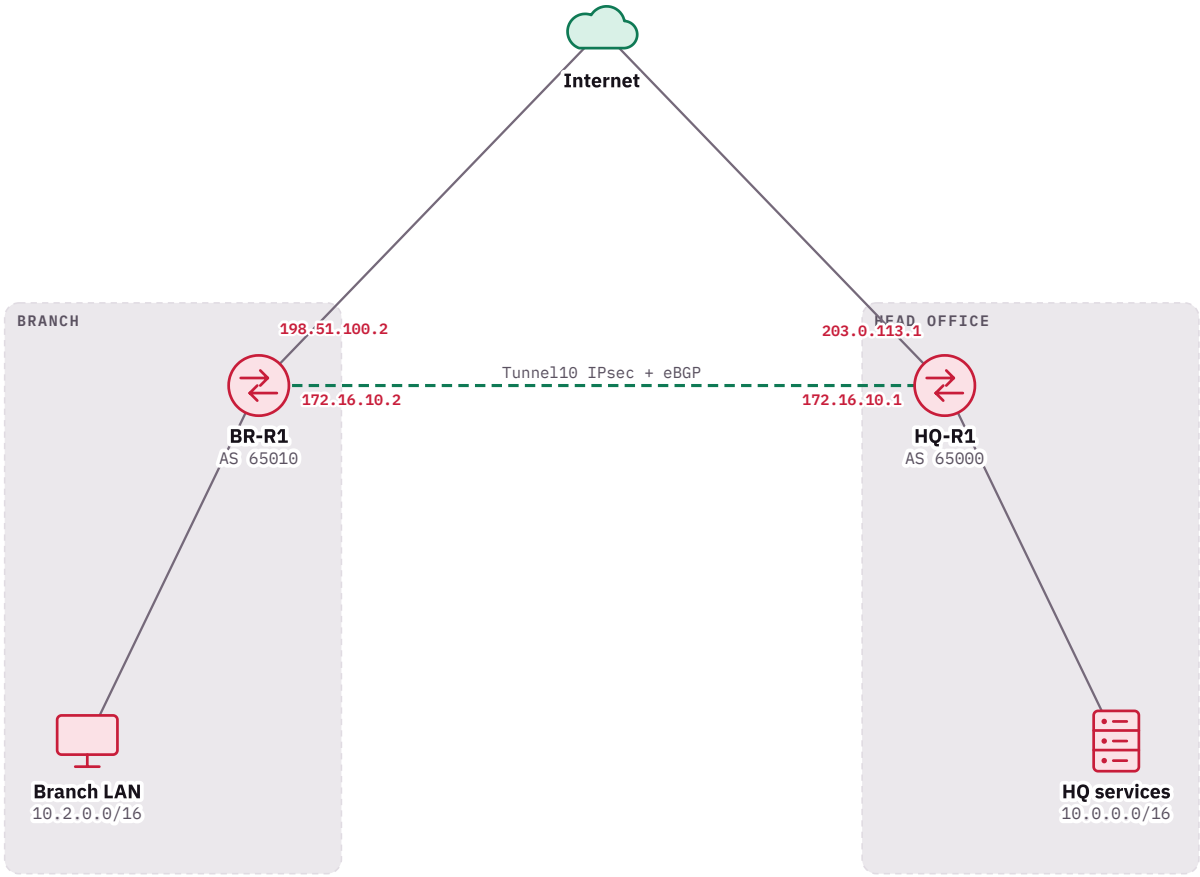
BR-R1 · IOS-style CLI

```
router bgp 65010
 neighbor 172.16.10.1 remote-as 65000
 address-family ipv4
  network 10.2.0.0 mask 255.255.0.0
  neighbor 172.16.10.1 activate
ip route 10.2.0.0 255.255.0.0 Null0 250
```

The floating Null0 route lets BGP advertise the branch aggregate. The hub learns the branch subnets dynamically, so adding a subnet needs no crypto change.

Copyright © ZyeemZia

Route-based VPN with BGP over a VTI



The tunnel is just another routed link (172.16.10.0/30) riding over the internet underlay between the two public addresses. BGP over it advertises 10.2.0.0/16 to HQ, so new subnets need routing changes only, not crypto changes.

Policy-based equivalent with a crypto map

BR-R2 · IOS-style CLI

```
ip access-list extended VPN-TO-PARTNER
 permit ip 10.3.0.0 0.0.255.255 192.168.50.0 0.0.0.255
crypto map CMAP-PARTNER 10 ipsec-isakmp
 set peer 198.51.100.20
 set transform-set TS-GCM256
 set pfs group20
 set ikev2-profile PROF-PARTNER
 match address VPN-TO-PARTNER
interface GigabitEthernet0/1
 crypto map CMAP-PARTNER
```

The partner must configure the mirror image of this ACL; mismatched selectors cause TS_UNACCEPTABLE errors. Exempt this traffic from NAT.

Copyright © ZyeemZia

Verifying the tunnel

BR-R1 · IOS-style CLI

```
BR-R1# show crypto ikev2 sa
Tunnel-id Local              Remote             fvrf/ivrf  Status
1         198.51.100.2/500   203.0.113.1/500    none/none  READY
      Encr: AES-GCM, keysize: 256, PRF: SHA384, Hash: None, DH Grp:20, Auth sign: PSK, Auth verify:
PSK
      Life/Active Time: 86400/1220 sec
BR-R1# show crypto ipsec sa interface Tunnel10 | include pkts
    #pkts encaps: 48210, #pkts encrypt: 48210, #pkts digest: 48210
    #pkts decaps: 0, #pkts decrypt: 0, #pkts verify: 0
```

The IKE SA is READY and packets are being encrypted, but nothing is decrypted: the peer is not sending traffic back into the tunnel, or ESP is blocked on the return path.

Reading the IPsec counters

ENCAPS	DECAPS	MOST LIKELY SITUATION
Increasing	Increasing	Tunnel healthy in both directions
Increasing	Zero	Peer has no route back into the tunnel, peer's selectors differ, or ESP/UDP 4500 is filtered on the return path
Zero	Increasing	Local routing does not send traffic into the tunnel, or a local NAT rule translates it first
Zero	Zero	No interesting traffic yet, or the Child SA never formed

TEMPLATE

VPN parameter sheet

Agree every value with the remote party before the change window; mismatches cause most first-time failures.

PARAMETER	LOCAL SITE	REMOTE SITE	AGREED VALUE / NOTES
Peer public IP	*198.51.100.2*	*203.0.113.1*	*Static on both sides; NAT-T expected: no*
IKE proposal	*AES-GCM-256 / PRF SHA-384 / group 20*	*Same*	*IKE SA lifetime 86,400 s; DPD 10 s*
Child SA	*ESP AES-GCM-256, PFS group 20*	*Same*	*Lifetime 3,600 s; route-based, selectors 0.0.0.0/0*

Copyright © ZyeemZia

PARAMETER	LOCAL SITE	REMOTE SITE	AGREED VALUE / NOTES

SCENARIO · DECIDE · ADDING A NEW SUBNET

A partner connected by a policy-based VPN adds a new subnet, 192.168.60.0/24. Users in that subnet cannot reach your servers, while the original subnet still works. Your peer logs show TS_UNACCEPTABLE.

(A) Change the DH group on both peers

(B) Restart the IKE SA to force renegotiation

(C) Add the matching subnet pair to both crypto ACLs (mirrored) and to the NAT exemption, then retest

(D) Increase the tunnel MTU

Circle your choice. Answer and feedback: module answer key.

Key takeaways

- Policy-based VPNs select traffic with mirrored crypto ACLs; route-based VPNs select it by routing into a tunnel interface.
- Prefer route-based VTIs with dynamic routing for anything beyond one subnet pair.
- Lower the tunnel MTU and clamp TCP MSS to absorb ESP overhead.
- Read encaps and decaps counters together to locate the failing direction.

KNOWLEDGE CHECK

6. What is the main operational advantage of a route-based VPN?

(A) It lets routing pick what is encrypted, with no crypto ACL edits

(B) It needs no IKE negotiation because the tunnel interface is always up

(C) It supports only one subnet pair, which makes every tunnel simpler to audit

(D) It removes the need for any MTU or TCP MSS adjustments because tunnel interfaces fragment automatically

7. Counters show encaps increasing and decaps at zero. What should you check first?

(A) Whether the local routing table actually sends user traffic into the tunnel interface

(B) Whether the IKE proposal uses the correct PRF on both peers

(C) Whether the peer routes replies back and ESP is allowed in

(D) Whether the local TCP MSS clamp is configured on the tunnel

8. Why are `ip mtu 1400` and `ip tcp adjust-mss 1360` applied to a tunnel interface?

(A) To increase throughput by allowing jumbo frames

(B) To force IKEv2 to use UDP 4500 instead of UDP 500 for NAT traversal

(C) To leave room for ESP and tunnel overhead so packets are not fragmented

(D) To make PFS rekeys happen more frequently

Copyright © ZyeemZia

9. A partner's logs show TS_UNACCEPTABLE. What does this usually mean?

   (A) The proposed traffic selectors do not match the peer's protected subnets

   (B) The peer's certificate has expired and failed validation in IKE_AUTH

   (C) The Diffie-Hellman groups offered by the two peers do not overlap at all

   (D) The pre-shared keys configured on each side differ

10. Why must site-to-site VPN traffic usually be exempted from NAT?

    (A) NAT cannot operate on any interface that also has a crypto map or tunnel protection applied

    (B) ESP packets are always dropped by NAT devices, even with NAT traversal on

    (C) NAT exemption makes IKE authentication faster and reduces rekey failures

    (D) Translated packets fall outside the tunnel's protected subnets

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 3 · TUNNEL · LESSON 3 · 30 MIN

Dynamic Hub-and-Spoke and Remote-Access VPN

Scale site-to-site with on-demand spoke tunnels, and choose the right remote-access model

- Explain how mGRE, NHRP and IPsec combine into a dynamic hub-and-spoke VPN
- Describe spoke-to-spoke shortcut tunnels and their routing requirements
- Compare TLS-based and IKEv2-based remote-access VPNs
- Design remote-access policy with MFA, posture and least privilege

With 200 branches, a full mesh of static tunnels means nearly 20,000 tunnel configurations. A **dynamic hub-and-spoke VPN** avoids this: every spoke builds one permanent tunnel to the hub, and spokes build direct tunnels to each other **on demand** when traffic needs it. The usual building blocks are multipoint GRE (mGRE), the Next Hop Resolution Protocol (NHRP, RFC 2332) and IPsec protection.

Dynamic hub-and-spoke building blocks

Routing	`BGP or OSPF over the overlay` `Hub advertises summaries or full routes`
NHRP	`Spokes register tunnel-to-public address mappings with the hub` `Resolution requests find other spokes` `Redirect and shortcut for spoke-to-spoke`
mGRE	`One tunnel interface, many peers` `Supports multicast for routing protocols`
IPsec	`Protects GRE in transport mode` `IKEv2 with certificates scales best`

Hub tunnel interface

HUB-R1 · IOS-style CLI

```
interface Tunnel0
 ip address 10.255.0.1 255.255.255.0
 ip mtu 1400
 ip tcp adjust-mss 1360
 ip nhrp network-id 100
 ip nhrp map multicast dynamic
 ip nhrp redirect
 tunnel source GigabitEthernet0/1
 tunnel mode gre multipoint
 tunnel key 100
 tunnel protection ipsec profile IPSEC-OVERLAY
```


Copyright © ZyeemZia

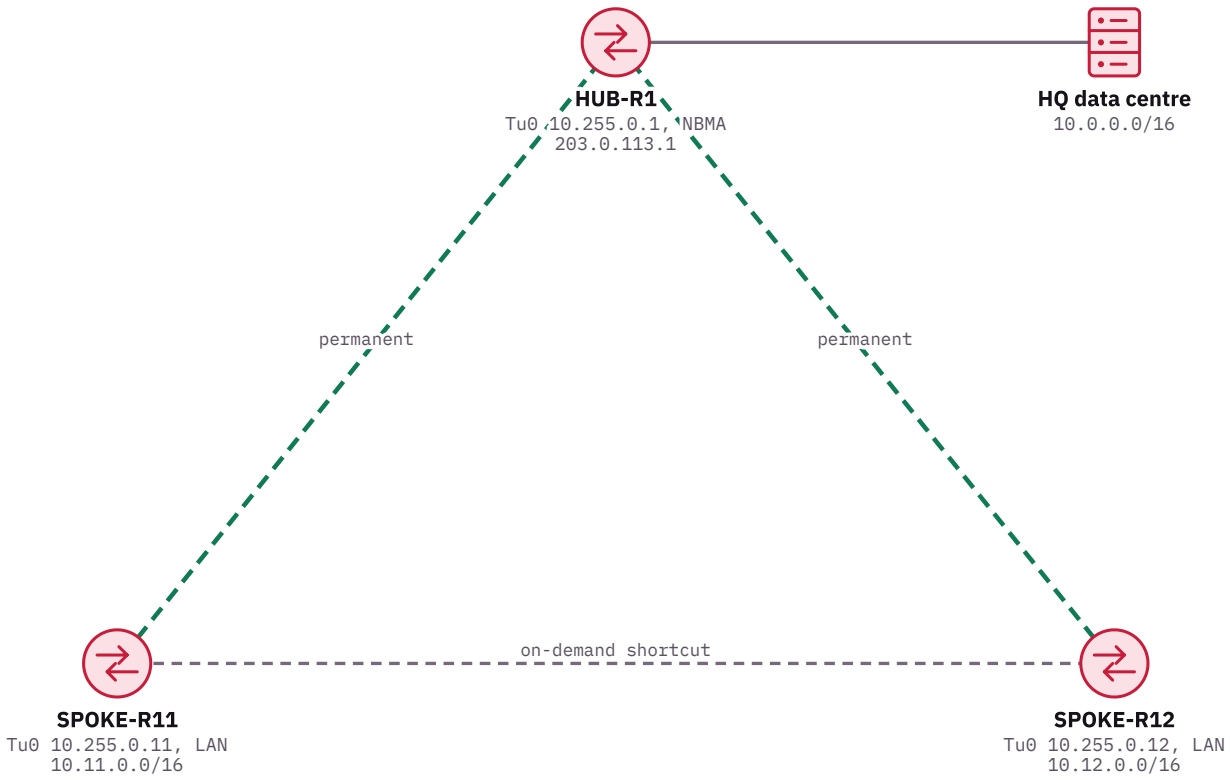
Spoke tunnel interface

SPOKE-R11 · IOS-style CLI

```
interface Tunnel0
 ip address 10.255.0.11 255.255.255.0
 ip mtu 1400
 ip tcp adjust-mss 1360
 ip nhrp network-id 100
 ip nhrp nhs 10.255.0.1 nbma 203.0.113.1 multicast
 ip nhrp shortcut
 tunnel source GigabitEthernet0/1
 tunnel mode gre multipoint
 tunnel key 100
 tunnel protection ipsec profile IPSEC-OVERLAY
```

The spoke knows only the hub's addresses. Other spokes are discovered through NHRP when traffic flows.

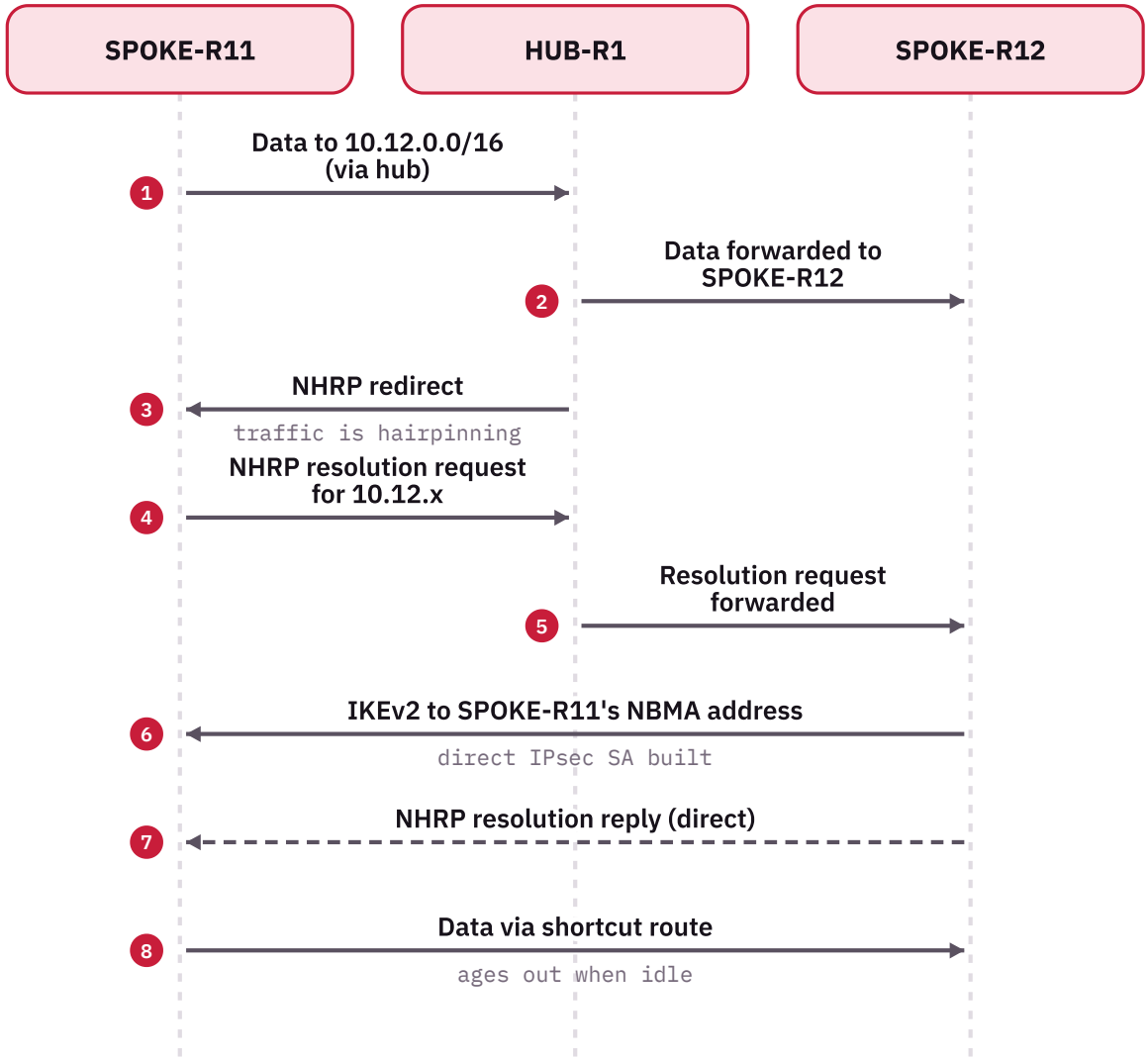
Dynamic hub-and-spoke overlay



Every spoke keeps one permanent protected tunnel to the hub and registers its public (NBMA) address there. Spoke-to-spoke tunnels exist only while traffic needs them, so 200 branches need 200 configurations, not 20,000.

Copyright © ZyeemZia

Spoke-to-spoke shortcut with NHRP



The first packets travel through the hub, which tells the sender a better path exists. Once SPOKE-R12 answers over a new direct IPsec SA, traffic bypasses the hub until the shortcut idles out.

WATCH OUT · SPOKES BEHIND NAT AND SECURITY OF THE OVERLAY

Spoke-to-spoke tunnels need spokes to reach each other's public addresses on UDP 500/4500. Spokes behind NAT or carrier-grade NAT may fall back to the hub path. Use **certificate authentication** so a single compromised shared key does not let an attacker join the entire overlay.

Remote-access VPNs connect individual users rather than sites. Two families dominate: **TLS-based** clients (often over TCP or DTLS on port 443) and **IKEv2 clients** with EAP or certificate authentication. Both can be secure; the bigger design decisions are what the user can reach and how strongly the user and device are verified.

Copyright © ZyeemZia

Remote-access VPN choices

TLS/DTLS VPN client

- Port 443 passes most hotel and guest networks
- Often includes posture and per-group policy features
- Gateway web portal is a common attack surface; keep it patched and minimal
- DTLS (UDP) preferred for performance, TLS fallback

IKEv2 client

- Standards-based; built into many operating systems
- EAP methods or certificates for authentication
- UDP 500/4500 may be blocked on restrictive networks
- MOBIKE (RFC 4555) keeps tunnels up when the client changes address

Remote-access design decisions

DECISION	SECURE DEFAULT	WHY
Authentication	Phishing-resistant MFA plus device certificate	Stolen passwords alone should never grant network access
Tunnel mode	Full tunnel for managed devices, or split with cloud web security	Balance visibility against bandwidth and user experience
Access scope	Group-based ACLs per role, not the whole network	Limits blast radius of a compromised account
Posture	Check managed state, disk encryption and EDR health before full access	Unhealthy devices get remediation-only access
Always-on	Enable on managed laptops	Policy and inspection apply even off-site
Future direction	Per-application access (ZTNA) for third parties first	Removes network-level access entirely

SCENARIO · DECIDE · VPN GATEWAY UNDER ATTACK

Threat intelligence reports active exploitation of a critical flaw in the web portal of the TLS VPN product your company uses. The vendor's patch is released, and your gateway serves 3,000 users.

(A) Apply the patch or vendor mitigation as an emergency change, then hunt for indicators of compromise and rotate credentials and secrets stored on the gateway

(B) Wait for the monthly maintenance window to avoid disrupting users

(C) Patch the gateway and close the incident

(D) Block the portal from the internet permanently

Circle your choice. Answer and feedback: module answer key.

Key takeaways

- mGRE, NHRP and IPsec give one hub configuration for many spokes plus on-demand spoke-to-spoke tunnels.
- Spokes behind carrier-grade NAT may not form shortcuts; plan for the hub path.
- Use per-device certificates so one leaked secret cannot admit an attacker to the whole overlay.
- VPN gateways are prime targets: patch as emergency changes, hunt after exposure and move third parties to per-application access.

Copyright © ZyeemZia

KNOWLEDGE CHECK

11. In a dynamic hub-and-spoke VPN, what does NHRP provide?

(A) Encryption and integrity protection of the GRE packets between hub and spokes

(B) Mapping overlay addresses to public addresses

(C) Election of a designated router on the overlay network

(D) Assignment of client IP addresses to remote users

12. Why is certificate authentication recommended for large hub-and-spoke overlays?

(A) One leaked shared key would otherwise let an attacker join the entire overlay network

(B) Certificates make the GRE header smaller and reduce per-packet overhead

(C) Pre-shared keys cannot be used with multipoint GRE tunnels in any design

(D) Certificates remove the need for a routing protocol across the overlay network

13. Spoke-to-spoke tunnels never form for one branch, though its hub tunnel works. The branch is behind carrier-grade NAT. What is the likely reason?

(A) Its routing protocol is not advertising the hub's summary route

(B) Its tunnel key differs from the tunnel key configured on the hub router

(C) Other spokes cannot reach it on UDP 500/4500 through carrier NAT

(D) Its IPsec profile uses AES-GCM, which other spokes reject for spoke-to-spoke tunnels

14. What does MOBIKE add to IKEv2 remote access?

(A) It adds a second authentication factor to the IKE exchange for each user

(B) It keeps the tunnel alive when the client's IP address changes networks

(C) It encrypts DNS queries that the operating system sends outside the tunnel on public Wi-Fi

(D) It enables automatic fallback to TLS over TCP 443 when UDP ports are blocked

15. Which remote-access design best limits the impact of a stolen user account?

(A) Full network access for all users, combined with a longer and more complex password policy

(B) Split tunnelling so that less traffic passes through the gateway

(C) A shorter idle timeout on the VPN portal web page for all users

(D) Role-scoped access plus phishing-resistant MFA and posture checks

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 3 · TUNNEL · LESSON 4 · 32 MIN

PKI for VPNs and Troubleshooting Negotiation

Run certificates that do not cause outages, and find the exact point where a tunnel fails

- Design a PKI hierarchy for VPN authentication with reliable revocation checking
- Configure certificate-based IKEv2 authentication in IOS-style syntax
- Troubleshoot IKEv2 failures using error notifications and logs
- Build a troubleshooting sequence from underlay to Child SA

Certificates scale VPN authentication: each device proves its identity with its own key pair, and a compromised device can be revoked without touching hundreds of others. But a PKI that is badly run causes outages — expired certificates, unreachable revocation servers and clocks out of sync are among the most common VPN failures.

A two-tier PKI for network devices

Offline root CA	`Kept offline, used rarely` `Long validity` `Signs issuing CAs only`
Issuing CA	`Online, signs device certificates` `Publishes CRLs and runs OCSP` `Supports automated enrolment`
Revocation services	`CRL distribution points (HTTP)` `OCSP responder` `Must be reachable by every VPN peer`
End entities	`Routers, firewalls, VPN clients` `Short-lived certificates, auto-renewed` `Identity in subject and SAN`

Revocation checking options

METHOD	HOW IT WORKS	OPERATIONAL RISK
CRL	Peer downloads a signed list of revoked serial numbers from the CDP URL	Large lists; stale if not refreshed; peer must reach the CDP
OCSP	Peer asks a responder for the status of one certificate	Responder must be highly available and reachable; note that public web PKI is moving back to CRLs (OCSP became optional for public CAs), but private VPN PKIs can still run OCSP
None	No revocation check	A revoked or stolen device certificate still authenticates — avoid
Fallback chain	Try OCSP, then CRL, then optionally none	'None' as a last fallback silently disables revocation during outages

Copyright © ZyeemZia

Certificate-based IKEv2 on a branch router

BR-R1 · IOS-style CLI

```
crypto key generate rsa label BR-R1-KEY modulus 3072
crypto pki trustpoint CORP-ISSUING-CA
 enrollment url http://10.0.0.50:80
 subject-name CN=br-r1.branch.corp.example,O=Example Corp
 revocation-check crl
 rsakeypair BR-R1-KEY
crypto pki authenticate CORP-ISSUING-CA
crypto pki enroll CORP-ISSUING-CA
crypto ikev2 profile PROF-HQ-CERT
 match identity remote fqdn hub1.corp.example
 identity local fqdn br-r1.branch.corp.example
 authentication local rsa-sig
 authentication remote rsa-sig
 pki trustpoint CORP-ISSUING-CA
```

Check the issuing CA's fingerprint out of band when `crypto pki authenticate` *displays it. Make sure the router's clock is synchronised with NTP before enrolment.*

WATCH OUT · TIME IS A SECURITY DEPENDENCY

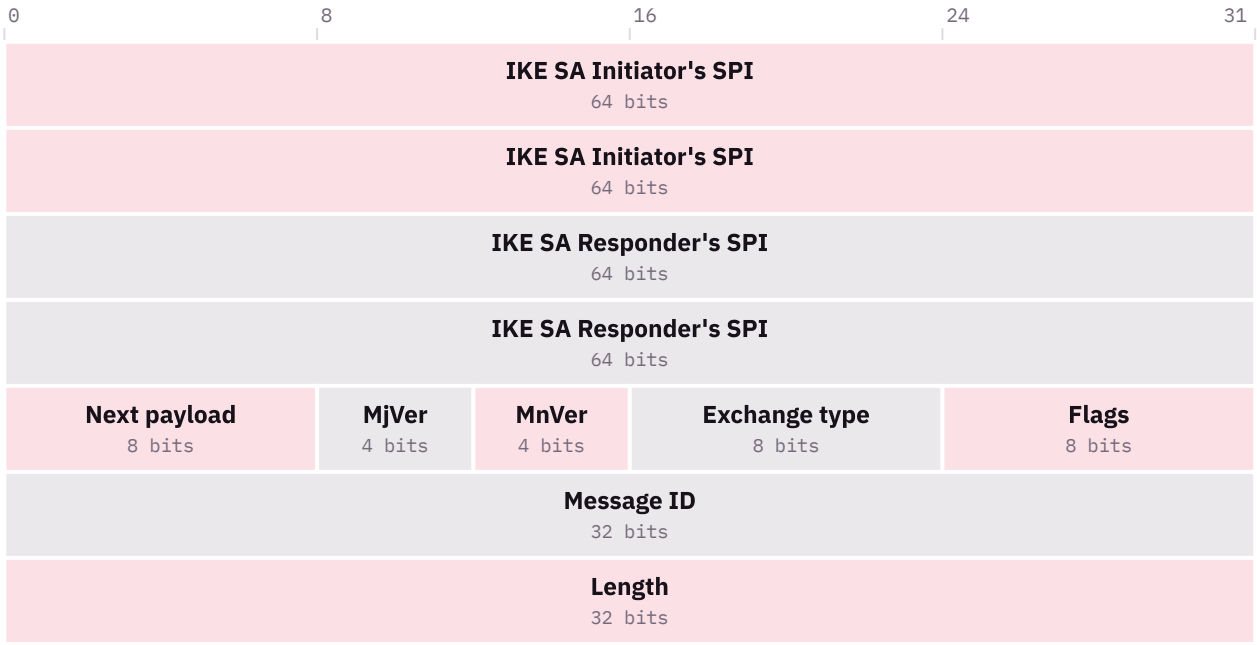
Certificates are valid only between their 'not before' and 'not after' times. A router whose clock reset to a default date after a power loss will reject every valid certificate. Run authenticated NTP from reliable sources and alert on clock offset.

INSIGHT · AUTOMATE CERTIFICATE LIFE CYCLES

Public TLS certificate lifetimes are shrinking across the industry (for example, the maximum validity for publicly trusted server certificates is 200 days from March 2026, falling further in later years). Private VPN PKIs are not bound by those rules, but the lesson applies: use automated enrolment and renewal (SCEP, EST or ACME) and monitor expiry dates centrally.

Copyright © ZyeemZia

IKEv2 header (RFC 7296)



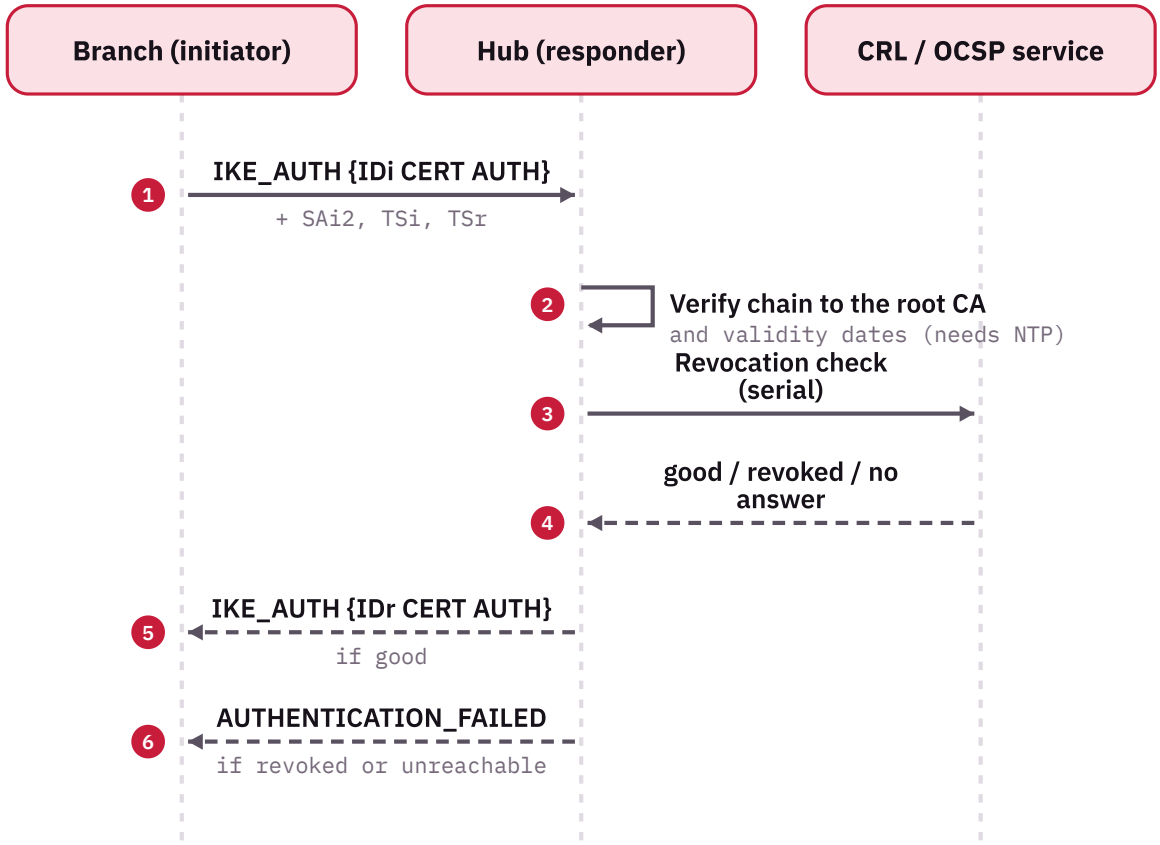
Every IKEv2 message starts with these 28 bytes. In a capture, a responder SPI of zero means IKE_SA_INIT has not been answered yet, and the exchange type tells you which stage failed.

Common IKEv2 failures and their signatures

SYMPTOM OR NOTIFY	TYPICAL CAUSE	FIX
No response to IKE_SA_INIT	UDP 500/4500 blocked, wrong peer address, peer not configured	Capture on the outside interface; check ACLs and upstream firewalls
NO_PROPOSAL_CHOSEN	No overlap in encryption, PRF, integrity or DH group	Compare proposals line by line against the parameter sheet
INVALID_KE_PAYLOAD	Initiator guessed a DH group the responder will not use	Normally self-corrects by retrying with the requested group; persistent if no common group
AUTHENTICATION_FAILED	PSK mismatch, wrong identity, untrusted or revoked certificate	Check identities and trust chain; verify revocation reachability
TS_UNACCEPTABLE	Traffic selectors do not match	Mirror the crypto ACLs or use 0.0.0.0/0 selectors on VTIs
Tunnel up, traffic fails	Routing, NAT before encryption, MTU or filtered ESP	Check counters, routes, NAT exemption and MSS

Copyright © ZyeemZia

Certificate authentication inside IKE_AUTH



The responder validates the chain and dates, then asks the revocation service before trusting the peer. If that service cannot be reached the tunnel fails even though the certificate is good, which is exactly what the log below shows.

Negotiation log excerpt

HUB-R1 · syslog (illustrative)

```
IKEv2: Received IKE_SA_INIT from 198.51.100.77:500
IKEv2: Selected proposal AES-GCM-256/PRF-SHA384/DH-20
IKEv2: Received IKE_AUTH, peer identity FQDN br-r7.branch.corp.example
IKEv2: Certificate chain verified to CORP-ROOT-CA
IKEv2: Revocation check: CRL fetch from http://pki.corp.example/issuing.crl failed (timeout)
IKEv2: Sending notify AUTHENTICATION_FAILED to 198.51.100.77
```

Negotiation and the chain are fine; authentication fails because the hub cannot reach the CRL distribution point. Fix reachability or CRL caching rather than disabling revocation.

Troubleshooting order: bottom up

1. **Underlay** Can the peers ping each other's public addresses? Is UDP 500/4500 (and ESP if no NAT) permitted?
2. **IKE_SA_INIT** Do proposals overlap? Look for NO_PROPOSAL_CHOSEN or no response.
3. **IKE_AUTH** Do identities match the profile? Is the PSK or certificate chain valid, current and not revoked?
4. **Child SA** Do traffic selectors and PFS settings match? Look for TS_UNACCEPTABLE or rekey failures.
5. **Data plane** Are encaps/decaps counters increasing both ways? Check routing, NAT exemption and MTU.
6. **Stability** Check DPD settings, lifetimes and whether both sides initiate at the same time.

Copyright © ZyeemZia

CASE STUDY · GARMENT EXPORTER'S VPN OUTAGE

A garment exporter in Chattogram connects 14 factory sites to its Dhaka head office with certificate-based IKEv2 tunnels. On a Monday morning, nine factories lose their tunnels within two hours; five stay up. The network team's first move was to disable revocation checking on the hub, which restored the tunnels. Investigation later shows the issuing CA's CRL had expired on Sunday night because the scheduled publication job failed, and the five surviving tunnels simply had not yet re-authenticated.

1. Why did only some tunnels fail at first?

2. What was the risk of the team's quick fix?

3. How should the PKI and monitoring be changed?

4. What would a better emergency response have looked like?

Model answer: module answer key.

VPN go-live checklist

☐ Parameter sheet agreed and signed off by both parties
☐ UDP 500, UDP 4500 and ESP permitted on every firewall in the path
☐ NTP synchronised and authenticated on all VPN peers
☐ Certificate chain, CRL and OCSP reachability tested from each peer
☐ Certificate and CRL expiry monitored with alerts
☐ NAT exemption in place for protected traffic
☐ Tunnel MTU and TCP MSS adjusted and tested with large transfers
☐ DPD configured and failover path tested
☐ VPN logs forwarded to the SIEM, including authentication failures

Key terms

IKEv2
The Internet Key Exchange protocol version 2 (RFC 7296), which authenticates peers and negotiates IPsec security associations.

Security association (SA)
A set of agreed keys and parameters protecting traffic in one direction (Child SA) or the IKE control channel (IKE SA).

SPI
Security Parameter Index: a value in each ESP packet identifying which SA protects it.

ESP
Encapsulating Security Payload, IP protocol 50, providing confidentiality and integrity.

Copyright © ZyeemZia

NAT-T
NAT traversal: wrapping ESP in UDP 4500 so it can pass NAT devices.

Traffic selector
The address and port ranges a Child SA is permitted to protect.

NHRP
Next Hop Resolution Protocol, used to map overlay tunnel addresses to underlay public addresses.

OCSP
Online Certificate Status Protocol: a real-time query for the revocation status of one certificate.

PFS
Perfect forward secrecy: deriving each new key from a fresh DH exchange so one compromise does not expose other sessions.

VTI
Virtual tunnel interface: a routable interface whose traffic is protected by IPsec.

CRL
Certificate revocation list: a signed list of revoked certificate serial numbers published by a CA.

DPD
Dead peer detection: liveness checks that remove SAs to an unreachable peer.

REFLECT

If your issuing CA's CRL expired tonight, which tunnels or services would fail first, and who would notice? Write the alert you wish existed.

Key takeaways

- Run a two-tier PKI with an offline root and automated enrolment and renewal for every VPN peer.
- Revocation services and accurate time are hard dependencies: monitor CRL next-update, OCSP health and clock offset.
- Never 'fix' a revocation outage by permanently disabling revocation; republish the CRL or restore OCSP.
- Troubleshoot bottom-up: underlay, IKE_SA_INIT, IKE_AUTH, Child SA, then data-plane counters.

KNOWLEDGE CHECK

16. A tunnel fails with NO_PROPOSAL_CHOSEN in IKE_SA_INIT. What is the first thing to compare?

(A) The traffic selectors and protected subnets configured on both peers
(B) The crypto proposal lists configured on both peers
(C) The certificate serial numbers on both peers
(D) The tunnel MTU and TCP MSS on both peers

17. Logs show the certificate chain verifies but authentication fails after a CRL fetch timeout. What is the best fix?

(A) Disable revocation checking permanently on the hub so it cannot happen again
(B) Replace the device certificate on the remote peer
(C) Change the DH group to a stronger elliptic curve
(D) Restore access to the CRL distribution point

18. After a power cut, a router rejects every certificate as 'not yet valid'. What is the likely cause?

(A) Its clock was reset and NTP has not yet resynchronised it
(B) The issuing CA revoked all device certificates
(C) The router's RSA key was deleted during the outage
(D) The peers switched from IKEv2 to IKEv1

Copyright © ZyeemZia

19. Why is 'none' as the final revocation fallback risky?

(A) It makes every IKE negotiation slower by several seconds while it times out

(B) It forces peers to fall back from certificates to pre-shared key authentication

(C) Revoked certificates would be silently accepted during an outage

(D) It prevents automatic certificate renewal through enrolment

20. What is the correct order for troubleshooting a site-to-site tunnel?

(A) Data-plane counters first, then certificates, then underlay reachability last

(B) Child SA settings first, because most tunnel failures happen at that stage

(C) Underlay, IKE_SA_INIT, IKE_AUTH, Child SA, then data-plane counters

(D) Firewall rules for user traffic first, then the IKE and IPsec settings on both peers

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 3 · TUNNEL

Answer key

Knowledge checks

1. C IKEv2 uses IKE_SA_INIT and IKE_AUTH (four messages) and builds the first Child SA inside IKE_AUTH. Six plus three describes IKEv1.

2. B AH protects parts of the outer IP header and offers no confidentiality, so NAT breaks it. It works with IPv4 and any IKE authentication method, and it is not TCP.

3. D Child SAs are pairs of unidirectional SAs, each with its own SPI. The other values are unrelated to identifying the SA.

4. B AEAD modes such as AES-GCM provide confidentiality and integrity together. CBC and 3DES need HMAC; NULL provides no confidentiality.

5. D The first Child SA uses keys from the initial exchange; later Child SAs use a fresh DH exchange when PFS is configured.

6. A VTIs let routing decide what is encrypted. They still use IKE, support many subnets and still need MTU care.

7. C Local encryption works; the missing direction is the return. A PRF problem would stop the IKE SA forming; local routing is clearly working.

8. C Encapsulation adds overhead; reducing MTU and MSS prevents oversized packets. It has no effect on ports or rekeying.

9. A TS_UNACCEPTABLE concerns traffic selectors. Certificate and PSK issues give authentication failures; DH mismatches give INVALID_KE_PAYLOAD or NO_PROPOSAL_CHOSEN.

10. D Translation changes the source address so it falls outside the selectors. NAT can coexist with crypto, and NAT-T handles ESP through NAT.

11. B NHRP resolves overlay-to-underlay addresses. IPsec encrypts, routing protocols handle adjacencies and address pools serve remote users.

12. A Per-device certificates can be revoked individually. PSKs are technically possible but scale poorly and fail open on leak.

13. C Inbound reachability through CGNAT is the classic blocker. A wrong tunnel key or profile would break the hub tunnel too.

14. B MOBIKE (RFC 4555) handles address changes. MFA, DNS privacy and TLS fallback are separate features.

15. D Least privilege plus strong authentication limits what an attacker can reach. Password length, split tunnelling and timeouts do not limit reach.

16. B NO_PROPOSAL_CHOSEN in IKE_SA_INIT means no common crypto suite. Selectors, certificates and MTU are checked later in the sequence.

17. D The failure is revocation-service reachability. Disabling revocation removes protection; the certificate and DH group are not at fault.

18. A 'Not yet valid' points to a clock earlier than the certificate's start time. Revocation and key loss give different errors.

19. C A fallback to none quietly disables revocation exactly when you cannot see it. It does not change authentication method or renewal.

20. C Working bottom-up avoids chasing symptoms; each stage depends on the one below it.

Scenarios & case studies

Scenario · Tunnel drops every hour
B is best. Correct. The initial Child SA is built in IKE_AUTH without a separate DH exchange, so PFS mismatches surface at rekey time, here the 1-hour lifetime.

Scenario · Adding a new subnet
C is best. Correct. In a policy-based VPN the selectors must match on both sides; the new subnet is not covered.

Scenario · VPN gateway under attack
A is best. Best. Patching closes the hole; hunting and rotation address the possibility that exploitation happened before you patched.

Copyright © ZyeemZia

Case study · Garment exporter's VPN outage

Partial failure: tunnels re-authenticate when IKE SAs are re-established, rekeyed with reauthentication, or after drops; the nine sites happened to re-authenticate first and hit the expired CRL, the rest were still running on established SAs. **Risk of the quick fix:** disabling revocation means a stolen or revoked device certificate would be accepted — and the change was not time-limited or documented, so it might stay forever. **Changes:** monitor CRL `next update` times and alert well before expiry; publish CRLs with overlap (new CRL issued well before the old one expires); add an OCSP responder with high availability; make the CDP reachable over redundant paths; include PKI services in the change and incident runbooks. **Better response:** publish a fresh CRL manually from the issuing CA (minutes of work), confirm the tunnels recover, and if revocation must be relaxed, do it as a documented, time-boxed emergency change with an owner.

Copyright © ZyeemZia

04

MODULE 4 · IDENTITY

Identity & Network Access Control

Know every user and device before access: AAA, 802.1X, NAC, posture, MFA and identity-based segmentation

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Choose and harden RADIUS and TACACS+ for network access and device administration
- Design 802.1X with the right EAP methods and secure supplicant configuration
- Deploy MAB, dynamic authorisation and change of authorisation through phased rollout
- Build posture, guest and BYOD flows and a NAC policy matrix
- Apply phishing-resistant MFA and identity-based segmentation

LESSONS

1. AAA, RADIUS and TACACS+ · 28 min
2. IEEE 802.1X and EAP Methods · 30 min
3. MAB, Dynamic Authorisation and Phased Deployment · 32 min
4. Posture, Guest and BYOD Onboarding · 28 min
5. MFA, Phishing-Resistant Authentication and Identity-Based Segmentation · 30 min

MODULE 4 · IDENTITY · LESSON 1 · 28 MIN

AAA, RADIUS and TACACS+

Authentication, authorisation and accounting for network access and for device administration

- Explain the three A's and where each is enforced
- Compare RADIUS and TACACS+ and choose the right one for each use
- Configure TACACS+ device administration with command authorisation and accounting
- Harden RADIUS against known protocol weaknesses

Identity is the layer that turns 'a device on port 14' into 'Rahim's managed laptop, compliant, in the Finance role'. Every identity control in this module rests on **AAA**: authentication (who are you?), authorisation (what may you do?) and accounting (what did you do?).

The three A's

A1

Authentication

Proves identity with passwords, certificates, tokens or biometrics; the result is accept or reject.

A2

Authorisation

Decides what an authenticated subject may do: VLAN, ACL, group tag, privilege level or allowed commands.

A3

Accounting

Records sessions and actions: start, stop, duration, bytes, commands entered. Essential for forensics and audits.

RADIUS versus TACACS+

RADIUS (RFC 2865/2866)

- UDP 1812 (auth) and 1813 (accounting)
- Authentication and authorisation combined in Access-Accept
- Only the User-Password attribute is hidden; other attributes in clear
- Carries EAP for 802.1X; supports change of authorisation (RFC 5176)
- Primary use: network access (802.1X, MAB, VPN, Wi-Fi)

TACACS+ (RFC 8907)

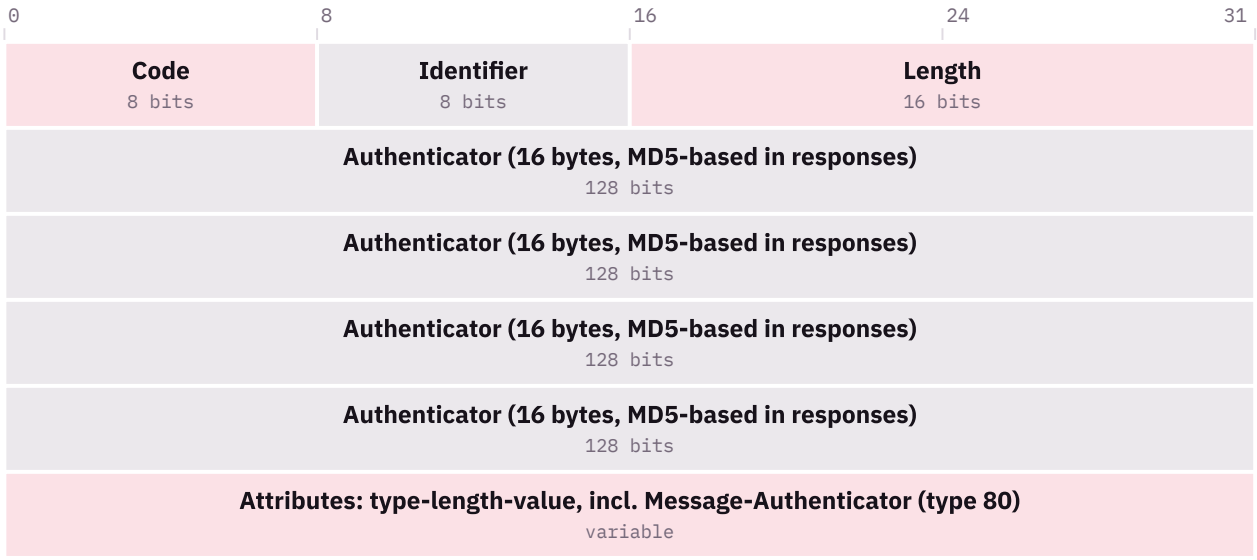
- TCP 49
- Authentication, authorisation and accounting are separate exchanges
- Whole packet body obfuscated with the shared key (not strong encryption)
- Per-command authorisation and command accounting
- Primary use: device administration (who may run which commands)

WATCH OUT · RADIUS PROTOCOL WEAKNESSES

RADIUS integrity relies on MD5-based authenticators. In 2024 researchers showed that an on-path attacker could forge an Access-Accept for some non-EAP authentication types by exploiting MD5 collisions (known as **BlastRADIUS**). Mitigations: update servers and clients, **require the Message-Authenticator attribute** on all requests and responses, keep RADIUS on protected management networks, and move to **RADIUS over TLS (RadSec)** where supported, because TLS protects the whole exchange instead of relying on MD5. Use long, unique shared secrets per client.

Copyright © ZyeemZia

RADIUS packet (RFC 2865)



The 16-byte Response Authenticator is an MD5 hash over the packet and the shared secret, which is the weakness BlastRADIUS exploits. The Message-Authenticator attribute adds an HMAC over the whole packet, so requiring it closes the gap.

TACACS+ device administration with command authorisation

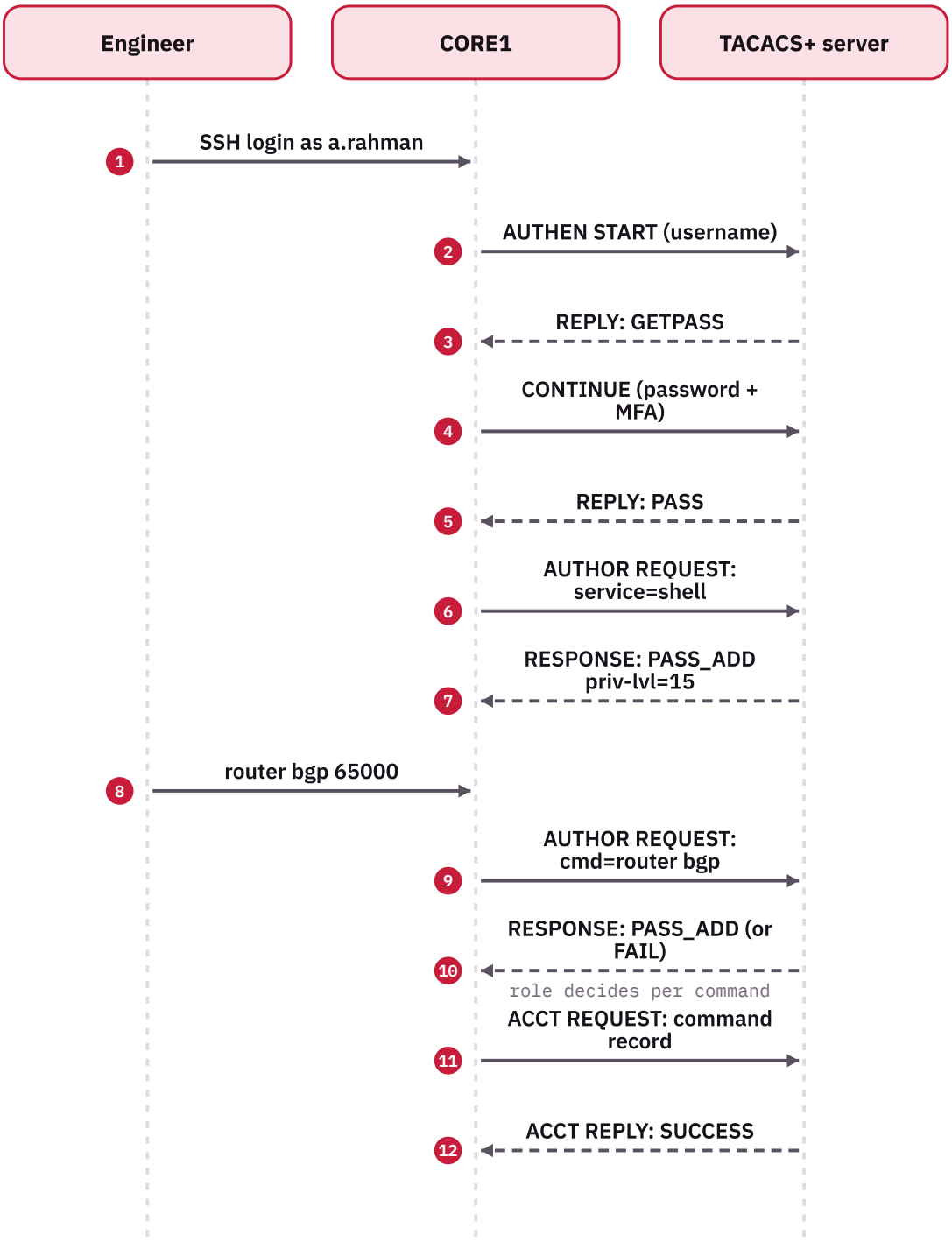
CORE1 · IOS-style CLI

```
aaa new-model
tacacs server TAC-1
 address ipv4 10.250.0.20
 key <unique-secret-from-vault>
aaa group server tacacs+ TAC-SERVERS
 server name TAC-1
aaa authentication login ADMIN group TAC-SERVERS local
aaa authorization exec ADMIN group TAC-SERVERS local if-authenticated
aaa authorization commands 15 ADMIN group TAC-SERVERS local if-authenticated
aaa accounting commands 15 ADMIN start-stop group TAC-SERVERS
line vty 0 15
 login authentication ADMIN
 authorization exec ADMIN
 authorization commands 15 ADMIN
 accounting commands 15 ADMIN
 transport input ssh
```

The `local` fallback is used only if no TACACS+ server responds. Keep one break-glass local account with a vaulted password and alert whenever it is used.

Copyright © ZyeemZia

TACACS+: separate authentication, authorisation and accounting



Each A is its own exchange over TCP 49, so the server can approve the shell but still refuse an individual command, and every command lands in an accounting record outside the device.

Device-administration roles

ROLE	PRIVILEGE	EXAMPLE AUTHORISED COMMANDS	APPROVAL
NOC read-only	Show and ping only	show *, ping, traceroute	Standing
Network engineer	Configure interfaces and routing	interface, router, ip route; not aaa or crypto key	Standing, reviewed quarterly

Copyright © ZyeemZia

ROLE	PRIVILEGE	EXAMPLE AUTHORISED COMMANDS	APPROVAL
Security engineer	AAA, crypto and firewall policy	aaa, crypto, access-list, zone	Standing, reviewed quarterly
Break-glass	Full	All	Emergency only; dual control and alert

PRO TIP · ACCOUNTING IS EVIDENCE

Command accounting gives you a tamper-resistant record of who changed what and when, outside the device itself. During an incident, it answers 'did the attacker change configuration?' within minutes. Stream it to the SIEM and protect it from deletion by network administrators.

SCENARIO · DECIDE · CHOOSING THE PROTOCOL

A university wants to (1) authenticate students on Wi-Fi with 802.1X and (2) restrict which engineers can change routing on core routers, with a full record of commands.

(A) TACACS+ for both, because it encrypts the whole packet

(B) RADIUS for Wi-Fi 802.1X and TACACS+ for device administration with command authorisation and accounting

(C) RADIUS for both, with privilege levels sent in Access-Accept

Circle your choice. Answer and feedback: module answer key.

REFLECT

Who can log in to your core network devices today, how are their commands authorised, and where is the record of what they did? Note any shared accounts you find.

Key takeaways

- Authentication proves who, authorisation decides what, accounting records what happened.
- Use RADIUS for network access (it carries EAP and supports CoA) and TACACS+ for device administration.
- Mitigate BlastRADIUS: patch, require Message-Authenticator, keep RADIUS on protected networks and prefer RADIUS over TLS.
- Named admin accounts, per-command authorisation and protected command accounting turn administration into evidence.

KNOWLEDGE CHECK

Copyright © ZyeemZia

1. Which statement about RADIUS is correct?

   (A) It returns authentication and authorisation in one Access-Accept

   (B) It uses TCP port 49 and obfuscates the entire packet body with the key

   (C) It is mainly used for per-command authorisation and command accounting on routers and switches

   (D) It cannot carry EAP and is therefore not used for 802.1X authentication

2. Why is TACACS+ preferred for device administration?

   (A) It uses strong modern encryption for the whole packet, which RADIUS lacks

   (B) It is the only protocol that supports multi-factor authentication

   (C) It runs over UDP, so it is faster than RADIUS

   (D) It authorises and accounts for individual commands in separate AAA exchanges

3. Which mitigation directly addresses the 2024 RADIUS forgery weakness?

   (A) Moving RADIUS from UDP 1812 to the legacy port 1645 on every client

   (B) Requiring Message-Authenticator on all requests and responses

   (C) Increasing the RADIUS server timeout to ten seconds and the retry count to five

   (D) Disabling RADIUS accounting messages on all network access devices

4. What is the role of the `local` keyword at the end of an AAA method list?

   (A) It is used only when no AAA server responds

   (B) It is tried first, before any of the AAA servers are contacted

   (C) It is used when the AAA server rejects the password

   (D) It replaces TACACS+ for all console logins

5. What should happen whenever the break-glass local account is used?

   (A) Nothing, because local accounts are not logged by design on network devices

   (B) The account is automatically deleted from all devices once the session ends

   (C) An alert fires and the use is reviewed as an emergency event

   (D) Command accounting is disabled for the duration so that the emergency fix is not slowed down

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 4 · IDENTITY · LESSON 2 · 30 MIN

IEEE 802.1X and EAP Methods

How port-based access control works, and how to choose an EAP method that resists credential theft

- Identify the supplicant, authenticator and authentication server roles
- Trace an 802.1X exchange from EAPOL to RADIUS and back
- Compare EAP-TLS, PEAP, EAP-TTLS and TEAP
- Explain why server-certificate validation on the client is critical

IEEE 802.1X is port-based network access control. Until a device proves its identity, the switch port or Wi-Fi association allows only authentication traffic. It works the same way on wired and wireless networks and is the foundation of modern NAC.

The three 802.1X roles

SUP

Supplicant

Software on the endpoint that presents credentials (built into all major operating systems).

AUTH

Authenticator

The switch or wireless controller/access point that controls the port and relays EAP; it never sees the credentials inside the TLS tunnel.

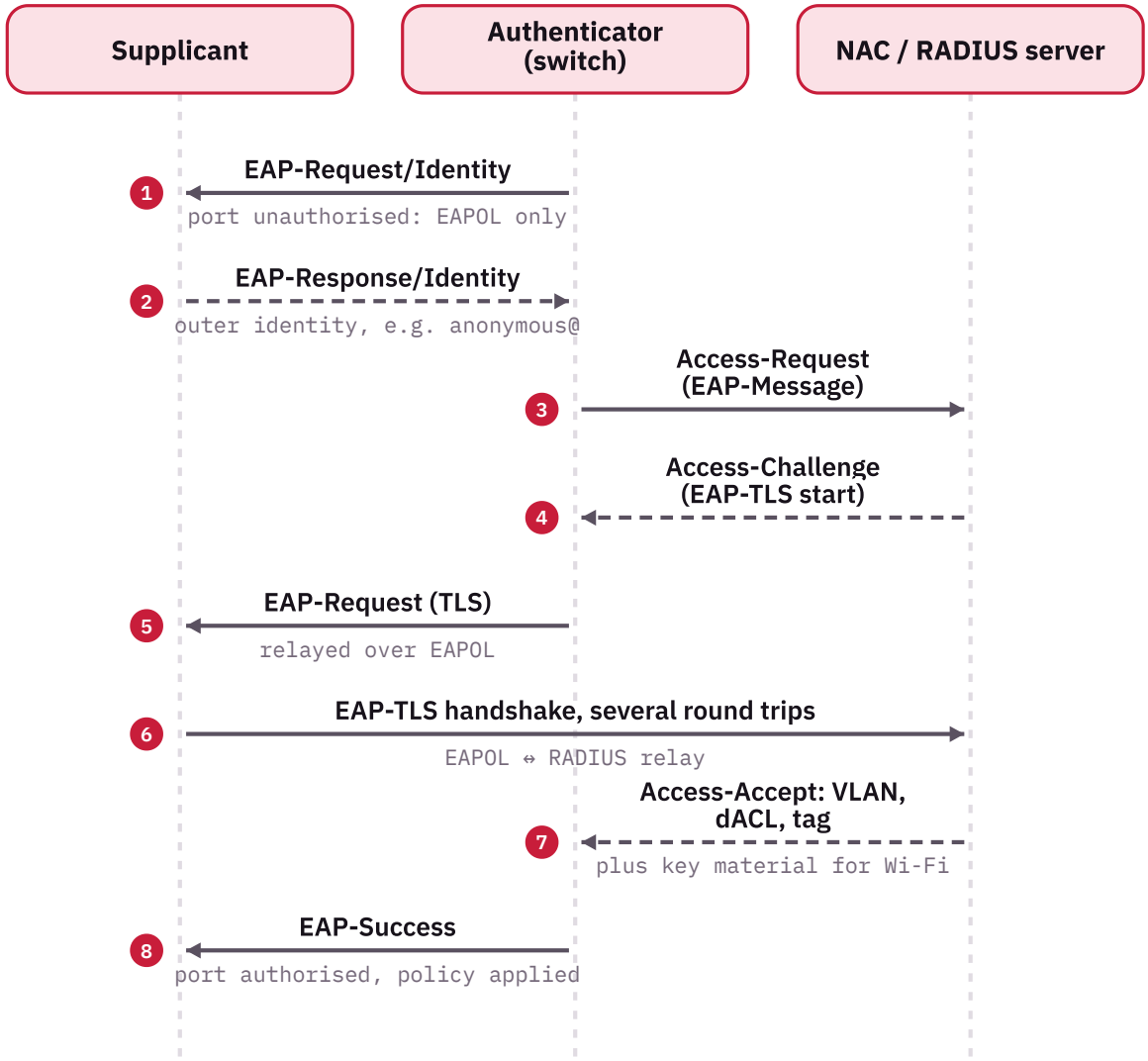
AS

Authentication server

The NAC/RADIUS server that validates credentials and returns the authorisation decision.

Copyright © ZyeemZia

An 802.1X exchange with EAP-TLS



The switch only relays: EAP rides in EAPOL frames (EtherType 0x888E) toward the endpoint and inside RADIUS toward the server. The credentials sit inside the TLS tunnel, and the decision arrives as attributes in Access-Accept.

EAPOL frame carrying an EAP packet (IEEE 802.1X)

0 – 7	8 – 15	16 – 23	24 – 31
EAPOL version 8 bits	**Packet type (0 = EAP)** 8 bits	**Packet body length** 16 bits	
EAP code 8 bits	**Identifier** 8 bits	**EAP length** 16 bits	
Type (13 = EAP-TLS) 8 bits	**Type data** variable		

On the wire toward the endpoint, EAP rides directly in an Ethernet frame with EtherType 0x888E; the switch copies the same EAP packet into a RADIUS EAP-Message attribute toward the server. Codes 1 to 4 are Request, Response, Success and Failure.

Copyright © ZyeemZia

INSIGHT · KEYS FOR WIRELESS

On Wi-Fi, a successful EAP method also produces keying material. The RADIUS server sends it to the access point, and the 4-way handshake derives the per-session encryption keys. This is why WPA2/WPA3-Enterprise gives every user a unique key, unlike a shared passphrase.

EAP methods compared

METHOD	CLIENT CREDENTIAL	SERVER CREDENTIAL	STRENGTH	WEAKNESS
EAP-TLS	Client certificate	Server certificate	Mutual certificate authentication; no password to phish	Needs certificate issuance to every device
PEAP (inner MSCHAPv2)	Username and password	Server certificate	Easy to deploy with a directory	Password-based; if the client does not validate the server, credentials can be captured and cracked. Modern operating systems increasingly block saved MSCHAPv2 credentials under built-in credential protection, which pushes migration to certificates
EAP-TTLS	Password or inner EAP	Server certificate	Flexible inner methods	Same server-validation risk as PEAP
TEAP (RFC 7170)	Machine and user credentials, chained	Server certificate	Authenticates both device and user in one session	Newer; check supplicant and server support

WATCH OUT · VALIDATE THE SERVER, ALWAYS

Password-based tunnelled methods are only as safe as the client's server validation. If supplicants accept any certificate, an attacker with a fake access point ('evil twin') can terminate the tunnel and harvest credential exchanges. Push profiles that **pin the trusted CA and the exact server name**, and never let users click 'trust' on an unknown certificate.

Choosing a method

Prefer EAP-TLS when

- Devices are managed and can receive certificates automatically
- You want phishing-resistant network authentication
- You need to separate machine and user identities clearly

Accept PEAP/TTLS temporarily when

- Devices are unmanaged and certificate enrolment is not yet possible
- Server validation is enforced through managed profiles
- There is a dated plan to migrate to certificates

Copyright © ZyeemZia

NAC server authentication log (EAP-TLS)

NAC-1 · authentication log (illustrative)

```
2026-03-02 08:14:51 RADIUS Access-Request from 10.10.1.5 (SW-ACC-07) port Gi1/0/10
  Calling-Station-Id=3C-22-FB-10-4A-7E  NAS-Port-Type=Ethernet
  EAP method=EAP-TLS  outer identity=anonymous@corp.example
  Client cert CN=LT-0457.corp.example issuer=CORP-ISSUING-CA  revocation=good (OCSP)
  Policy matched: Wired-Corp-Managed  -> Authz profile: EMPLOYEE-ACCESS
  Access-Accept: Tunnel-Private-Group-ID=20, Filter-Id=EMPLOYEE-ACL
```

An anonymous outer identity hides the real identity from anyone watching the cleartext part of the exchange; the real identity is inside the TLS tunnel.

SCENARIO · DECIDE · EVIL-TWIN RISK

A penetration test shows that 40% of staff laptops connect to a fake corporate SSID and send PEAP exchanges to the tester's server, because the Wi-Fi profiles were configured manually by users years ago.

(A) Force all staff to change their passwords

(B) Hide the corporate SSID so attackers cannot copy it

(C) Switch the SSID to WPA3-Personal with a strong passphrase

(D) Push managed Wi-Fi profiles that pin the CA and server name, and plan migration to EAP-TLS with automatic certificate enrolment

Circle your choice. Answer and feedback: module answer key.

REFLECT

Which EAP method does your organisation use on wired and on Wi-Fi? How do you know clients really validate the server certificate?

Key takeaways

- 802.1X has three roles: supplicant, authenticator (which relays) and authentication server (which decides).
- Until authorised, a closed-mode port passes only EAPOL; the result arrives as RADIUS attributes.
- EAP-TLS is the target: mutual certificates and no password to phish; TEAP chains machine and user.
- Password-based tunnelled methods are safe only if every client pins the CA and server name.

KNOWLEDGE CHECK

6. In 802.1X, which component relays EAP between the endpoint and the RADIUS server?

(A) The supplicant software running on the endpoint operating system

(B) The authenticator, such as an access switch

(C) The directory service that stores the user and computer accounts

(D) The certificate authority that issued the RADIUS server's certificate

Copyright © ZyeemZia

7. Before authentication succeeds, what traffic does an 802.1X-controlled port accept?

   (A) DHCP and DNS only, so that the device can locate the NAC server
   (B) All traffic but at reduced bandwidth
   (C) Only traffic to the default gateway
   (D) Only EAPOL frames (closed mode)

8. Which EAP method provides mutual certificate-based authentication with no user password?

   (A) PEAP with MSCHAPv2
   (B) EAP-TLS
   (C) EAP-TTLS with PAP
   (D) MAC authentication bypass

9. Why must supplicants pin the trusted CA and server name for PEAP?

   (A) Otherwise the RADIUS shared secret is sent across the network in clear text
   (B) Otherwise the switch cannot assign a dynamic VLAN to the session
   (C) Otherwise accounting records are not generated
   (D) Otherwise a rogue server can terminate the tunnel and capture the credential exchange

10. What advantage does TEAP offer over PEAP?

    (A) It chains machine and user authentication
    (B) It removes the need for any server certificate on the RADIUS server
    (C) It works without a RADIUS server
    (D) It uses the MAC address as a second factor

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 4 · IDENTITY · LESSON 3 · 32 MIN

MAB, Dynamic Authorisation and Phased Deployment

Handle devices without supplicants, push per-session policy, and roll out NAC without outages

- Configure 802.1X with MAB fallback on an access switch
- Assign dynamic VLANs, ACLs and downloadable ACLs from the NAC server
- Use change of authorisation to update sessions in real time
- Plan monitor, low-impact and closed deployment phases

Printers, cameras, badge readers and medical devices often cannot run a supplicant. **MAC Authentication Bypass (MAB)** lets the switch send the device's MAC address to the NAC server as its identity. It is convenient — and weak, because MAC addresses are easily spoofed. Treat MAB sessions as low-trust and authorise them narrowly.

802.1X versus MAB

802.1X

- Cryptographic credential (certificate or password)
- Strong identity of user and/or device
- Needs a supplicant and configuration
- Suitable for full corporate access

MAB

- MAC address only
- Easily spoofed; strengthen with profiling
- Works for any device that sends traffic
- Use narrow, device-type-specific authorisation

Global AAA and RADIUS for NAC

SW-ACC-07 · IOS-style CLI

```
aaa new-model
radius server NAC-1
 address ipv4 10.250.0.10 auth-port 1812 acct-port 1813
 key <unique-secret-from-vault>
aaa group server radius NAC-SERVERS
 server name NAC-1
aaa authentication dot1x default group NAC-SERVERS
aaa authorization network default group NAC-SERVERS
aaa accounting dot1x default start-stop group NAC-SERVERS
aaa server radius dynamic-author
 client 10.250.0.10 server-key <unique-secret-from-vault>
radius-server vsa send authentication
dot1x system-auth-control
```

`aaa server radius dynamic-author` *lets the NAC server send change-of-authorisation requests (RFC 5176) to the switch.*

Copyright © ZyeemZia

Access port: 802.1X first, MAB fallback, low-impact mode

SW-ACC-07 · IOS-style CLI

```
ip access-list extended PRE-AUTH
 permit udp any any eq bootps
 permit udp any any eq domain
 deny ip any any
interface GigabitEthernet1/0/10
 switchport mode access
 switchport access vlan 20
 ip access-group PRE-AUTH in
 authentication host-mode multi-auth
 authentication order dot1x mab
 authentication priority dot1x mab
 authentication port-control auto
 authentication open
 mab
 dot1x pae authenticator
 dot1x timeout tx-period 10
 spanning-tree portfast
```

`authentication open` *with a pre-auth ACL is low-impact mode: only DHCP and DNS pass before authorisation. Remove* `authentication open` *for closed mode.*

Authorisation results the NAC server can return

RESULT	HOW IT IS SIGNALLED	USE
Dynamic VLAN	Tunnel-Type = VLAN (13), Tunnel-Medium-Type = 802 (6), Tunnel-Private-Group-ID = VLAN	Place devices into the right segment
Named ACL	Filter-Id = name of an ACL pre-configured on the switch	Apply consistent per-role filtering
Downloadable ACL	Vendor-specific attributes; switch downloads ACL entries from the server	Central policy without touching each switch
Group tag	Vendor-specific attribute carrying a numeric group identifier	Identity-based segmentation independent of IP
Session timeout / reauthentication	Session-Timeout and Termination-Action	Force periodic re-evaluation
URL redirect	Vendor-specific redirect URL and ACL	Guest portal, posture or onboarding

Copyright © ZyeemZia

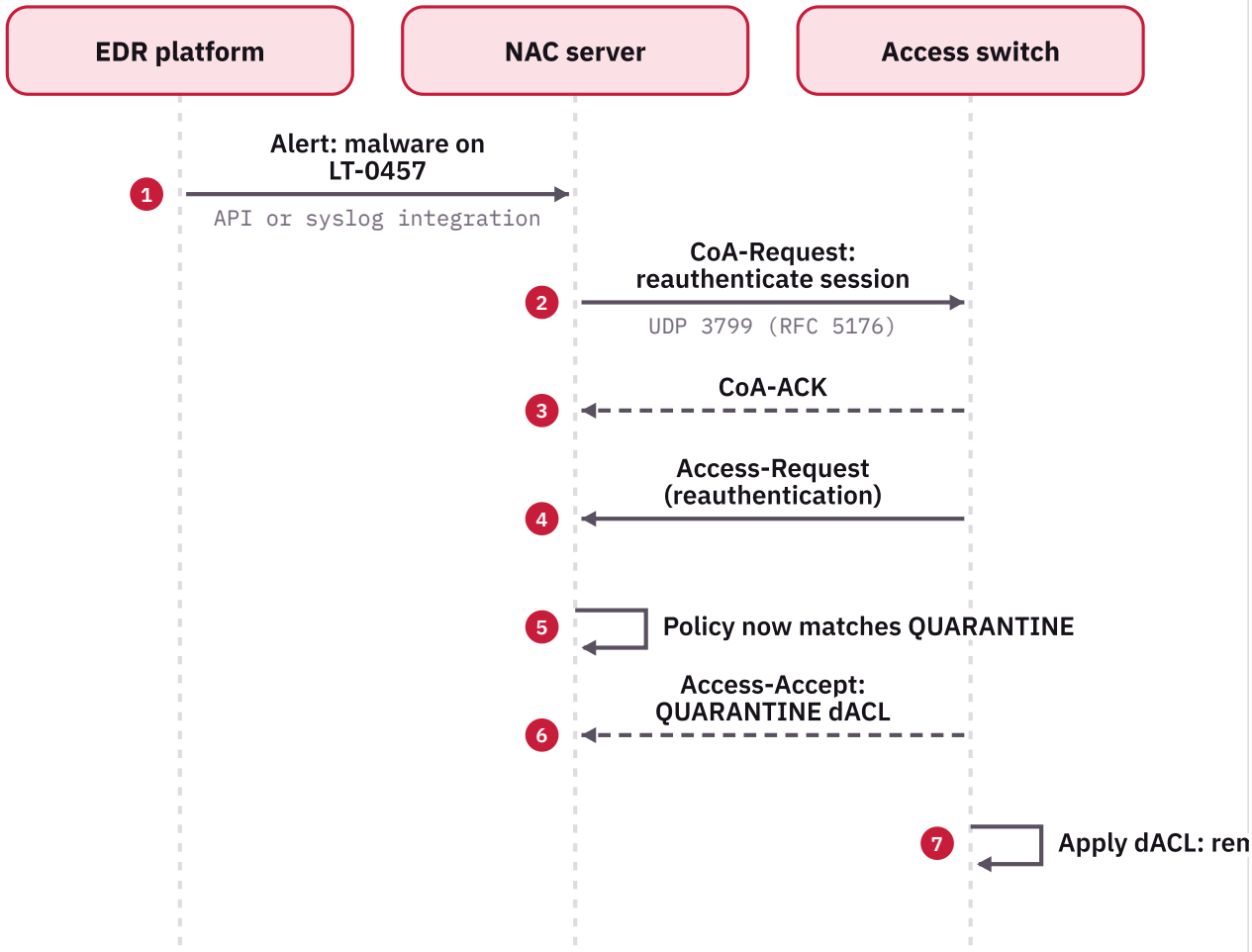
Verifying the session on the switch

```
SW-ACC-07 · IOS-style CLI

SW-ACC-07# show authentication sessions interface Gi1/0/10 details
            Interface:  GigabitEthernet1/0/10
          MAC Address:  3c22.fb10.4a7e
            User-Name:  host/LT-0457.corp.example
               Status:  Authorized
       Oper host mode:  multi-auth
     Server Policies:
           Vlan Group:  Vlan: 20
    Downloaded ACL:  DACL-IP-EMPLOYEE-6631a1b2
  Method status list:
       dot1x            Authc Success
       mab              Not run
```

The downloadable ACL name and VLAN confirm that the NAC server's authorisation was applied.

Change of authorisation (CoA) in action



The NAC server, not the endpoint, starts the change: it tells the switch to re-run authorisation, and the new decision restricts the laptop within seconds, without a site visit or a cable pull.

Copyright © ZyeemZia

Phased deployment

PHASE	PORT BEHAVIOUR	GOAL	EXIT CRITERION
Monitor (open)	All traffic allowed; authentication logged	Find every device and failure without impact	95%+ of sessions authenticate as expected
Low-impact	Pre-auth ACL limits traffic before authorisation	Enforce for known devices, minimal risk	Unknown devices identified and profiled
Closed	Only EAPOL until authorised	Full enforcement	Ongoing operations with exception process

SCENARIO · DECIDE · MONITOR MODE SURPRISES

After two weeks in monitor mode on a hospital floor, logs show 300 MAB attempts from infusion pumps and patient monitors that fail authentication because their MACs are not in the NAC database.

(A) Move to closed mode now so unregistered devices are blocked

(B) Profile and register the medical devices, create a narrow device-type policy for them, and only then move the floor to low-impact mode

(C) Disable NAC on the medical-device floor permanently

(D) Configure the switch to accept any MAC address that fails MAB

Circle your choice. Answer and feedback: module answer key.

Key takeaways

- MAB is a weak, MAC-based identity: profile devices and give them narrow, device-type policy.
- The NAC server returns VLANs, named or downloadable ACLs, tags, timers and redirects as RADIUS attributes.
- CoA lets the NAC server change an active session immediately when posture or threat signals change.
- Roll out in phases (monitor, low-impact, closed) and leave each phase only when its exit criterion is met.

KNOWLEDGE CHECK

11. Why should MAB sessions receive narrow authorisation?

(A) Because MAB sessions cannot be assigned to any VLAN other than the default

(B) Because MAB uses an unencrypted EAP method

(C) Because MAC addresses are easily spoofed

(D) Because MAB requires a supplicant on the device

12. Which RADIUS attributes assign a dynamic VLAN?

(A) Filter-Id, Session-Timeout and Class

(B) NAS-IP-Address, NAS-Port, NAS-Port-Type and Called-Station-Id

(C) Tunnel-Type, Tunnel-Medium-Type and Tunnel-Private-Group-ID together

(D) Framed-IP-Address, Framed-MTU and Idle-Timeout

13. What does `authentication open` with a pre-auth ACL achieve?

(A) Low-impact mode: DHCP and DNS only before auth

(B) Closed mode: only EAPOL frames are accepted on the port before authorisation

(C) MAB is disabled so only 802.1X is attempted

(D) Accounting is disabled until the session is authorised

Copyright © ZyeemZia

14. An EDR platform reports malware on an authorised laptop. Which mechanism lets NAC restrict it immediately?

(A) A new DHCP lease forced by the laptop's operating system

(B) An SNMP trap sent from the access switch to the NAC server for that port

(C) A periodic reauthentication timer expiring after eight hours

(D) A change-of-authorisation request sent by the NAC server

15. What is the main purpose of monitor mode?

(A) To enforce access only for guest devices

(B) To find problems before enforcing

(C) To collect user credentials so they can be migrated into the new directory

(D) To test switch hardware performance under load

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 4 · IDENTITY · LESSON 4 · 28 MIN

Posture, Guest and BYOD Onboarding

Check device health before access, and give guests and personal devices safe, convenient paths

- Design posture policies with compliant, non-compliant and unknown states
- Build guest access flows with isolation and accountability
- Onboard personal devices with certificates instead of shared passwords
- Write a NAC policy matrix covering users, devices and conditions

Authentication answers *who*; **posture** answers *is this device healthy enough?* Posture assessment checks conditions such as operating-system patch level, disk encryption, firewall state and endpoint-protection health before granting full access — and re-checks them over time.

Posture flow

01 Authenticate — Device passes 802.1X; posture status is unknown

→

02 Limited access — Redirect or restricted ACL lets the agent reach the posture service

→

03 Assess — Agent (or MDM/EDR integration) reports patch, encryption and protection state

→

04 Decide — Compliant, non-compliant or still unknown after a timeout

→

05 CoA — Server updates the session to full, remediation or restricted access

Posture states and outcomes

STATE	TYPICAL CAUSE	ACCESS GRANTED
Compliant	All checks passed	Role-based access
Non-compliant	Missing patches, encryption off, EDR unhealthy	Remediation servers only, with user notification
Unknown	No agent, agent cannot report, unmanaged device	Internet-only or guest-like access

PRO TIP · USE SIGNALS YOU ALREADY HAVE

Agent-based posture is precise but adds software. Many organisations combine **MDM compliance** for mobile devices and **EDR health** for laptops, fed to the NAC server through APIs. Whatever the source, define what happens when the signal is missing — 'unknown' must not quietly mean 'compliant'.

Guest access models

Self-registration

- Guest enters details on a portal; credentials sent by SMS or email
- Low friction for visitors
- Accountability via verified contact

Sponsored

- An employee creates or approves the guest account
- Clear accountability
- Good for contractors and longer stays

Hotspot (accept terms)

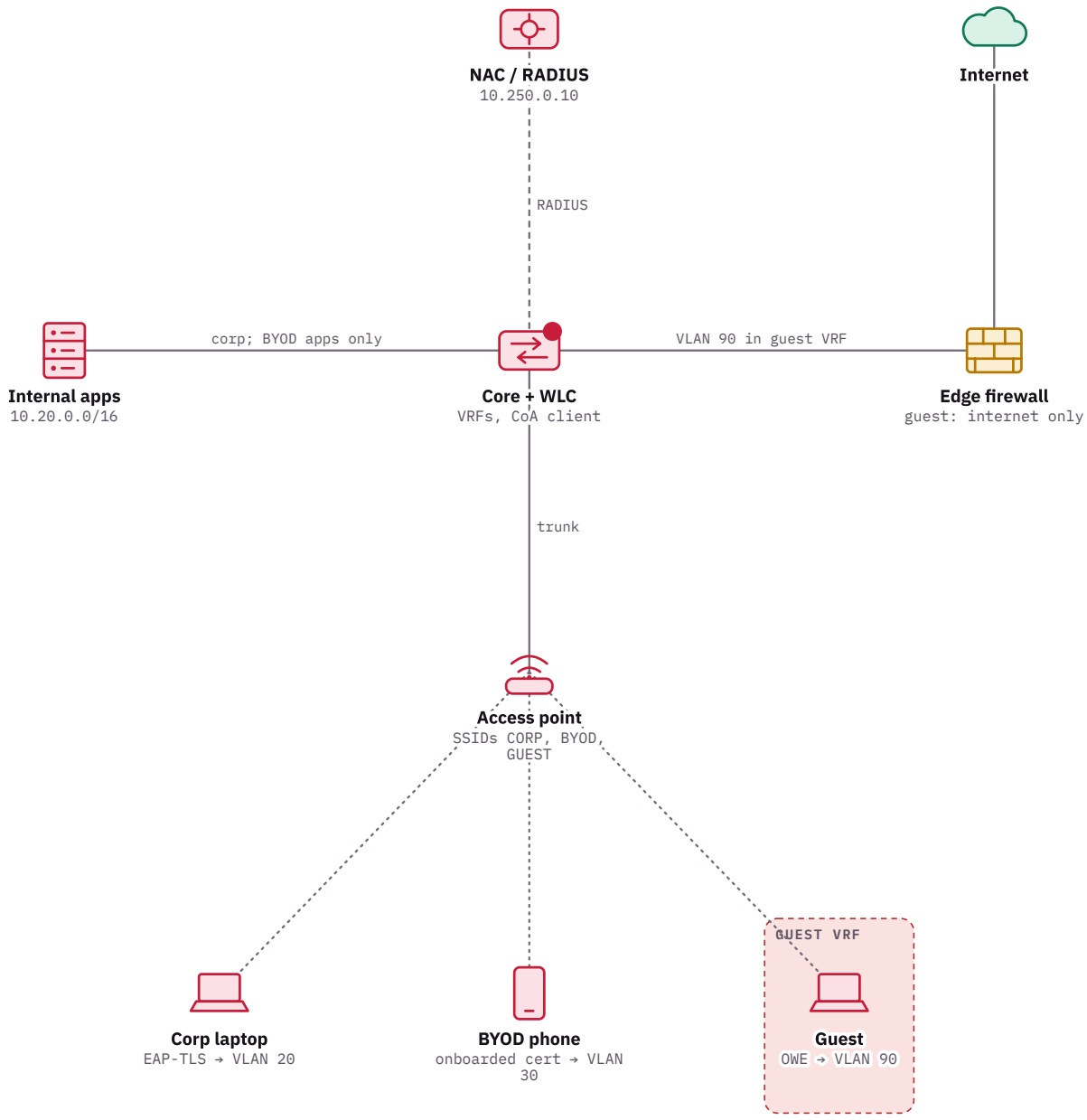
- No identity, only acceptance of terms
- Least friction
- Least accountability; isolate strictly

Copyright © ZyeemZia

Guest network design rules

- Separate SSID or VLAN with internet-only access; no routes to internal networks
- Client isolation so guests cannot reach each other
- Use encryption even on open networks (Opportunistic Wireless Encryption, 'Enhanced Open')
- Rate limits and content filtering according to policy
- Log associations and DHCP leases for accountability under local law
- Expire accounts automatically

One access layer, three trust levels



All three SSIDs share the same access points, but each lands in a different segment: managed laptops reach internal apps, onboarded personal phones reach only approved apps, and guests are carried in their own VRF straight to the internet edge.

Copyright © ZyeemZia

BYOD onboarding

01 Connect to onboarding SSID
Restricted access to the onboarding portal only

→

02 Authenticate user
Corporate credentials with MFA

→

03 Register device
Device is linked to the user; MDM enrolment if required

→

04 Provision
Portal installs a certificate (for example via SCEP) and a Wi-Fi profile pinning the server

→

05 Reconnect
Device joins the secure SSID with EAP-TLS and receives a BYOD role

TEMPLATE NAC policy matrix

Define, for each combination of identity, device type and condition, the exact authorisation result.

WHO / WHAT	DEVICE TYPE	AUTH METHOD	POSTURE / CONDITION	AUTHORISATION RESULT	SEGMENT / TAG
Employee	*Corporate laptop*	*EAP-TLS (machine + user)*	*Compliant*	*VLAN 20, EMPLOYEE dACL*	*Tag EMP*
Employee	*Personal phone (BYOD)*	*EAP-TLS (onboarded cert)*	*MDM compliant*	*Internet + email and collaboration apps only*	*Tag BYOD*

CASE STUDY · UNIVERSITY WI-FI 802.1X ROLLOUT

A university with 25,000 students and 3,000 staff runs a single PEAP SSID using directory passwords. Students configure devices themselves; many accept any server certificate. Credential phishing of student accounts is rising, and shared accounts are used to reach lab systems. The IT team wants stronger security without overwhelming the help desk at the start of term.

1. What target design would you propose?

2. How would you onboard 25,000 personal devices without a help-desk crisis?

3. How should labs, IoT and guest traffic be handled?

Copyright © ZyeemZia

4. How would you phase the migration?

Model answer: module answer key.

SCENARIO · DECIDE · UNKNOWN POSTURE

The NAC server cannot reach the MDM platform due to an API outage. All mobile devices now return posture 'unknown'. The policy maps 'unknown' to internet-only, and executives complain that email on phones has stopped.

(A) Change the policy permanently so 'unknown' is treated as compliant

(B) Disable NAC for all mobile devices until further notice

(C) Keep the policy, restore the API integration urgently, and consider a documented, time-limited exception for email access only

Circle your choice. Answer and feedback: module answer key.

Key takeaways

- Posture answers whether a device is healthy enough; re-check it over time, not only at connect.
- 'Unknown' posture must never mean full access; fix integrations instead of failing open.
- Guests get internet-only access, client isolation, OWE encryption, logging and automatic expiry.
- Onboard BYOD with a certificate and a pinned Wi-Fi profile, then authorise a narrow BYOD role.

KNOWLEDGE CHECK

16. What should a posture state of 'unknown' normally lead to?

(A) Limited access, such as internet-only, never full access

(B) Full access, because the device has already passed 802.1X authentication

(C) Immediate disconnection and permanent blocking of the device

(D) Automatic reclassification as compliant after one minute

17. Which mechanism moves a device from restricted to full access after it passes posture?

(A) The user unplugging and re-plugging the cable

(B) A DHCP lease renewal on the client

(C) Change of authorisation (CoA)

(D) A spanning-tree topology change

18. Why does BYOD onboarding install a certificate and a Wi-Fi profile?

(A) So the device can bypass MFA on all future corporate application logins

(B) So the device can use EAP-TLS and automatically validate the RADIUS server

(C) So the user's directory password is stored in the profile for convenience

(D) So the device can join the guest network without terms

19. What does Opportunistic Wireless Encryption add to an open guest network?

(A) User authentication against the corporate directory service

(B) Automatic posture checks for guest devices

(C) Content filtering of guest web traffic

(D) Per-client over-the-air encryption without a password

Copyright © ZyeemZia

20. A sponsored guest model is best suited when:

(A) Thousands of anonymous visitors need instant access at a stadium event

(B) Accountability matters, as for long-stay contractors

(C) No employee is available to approve requests

(D) Guests must reach internal servers without restrictions

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 4 · IDENTITY · LESSON 5 · 30 MIN

MFA, Phishing-Resistant Authentication and Identity-Based Segmentation

Make credentials hard to steal and use identity, not IP addresses, to decide what talks to what

- Distinguish phishable from phishing-resistant authenticators
- Apply MFA to VPN, device administration and privileged access
- Design group-based segmentation with tags and a policy matrix
- Connect identity controls to zero-trust architecture

Attackers rarely break cryptography — they log in. Stolen passwords, intercepted one-time codes and users tricked into approving push prompts are behind a large share of intrusions. **Multi-factor authentication (MFA)** is essential, but not all MFA is equal.

Authenticator strength

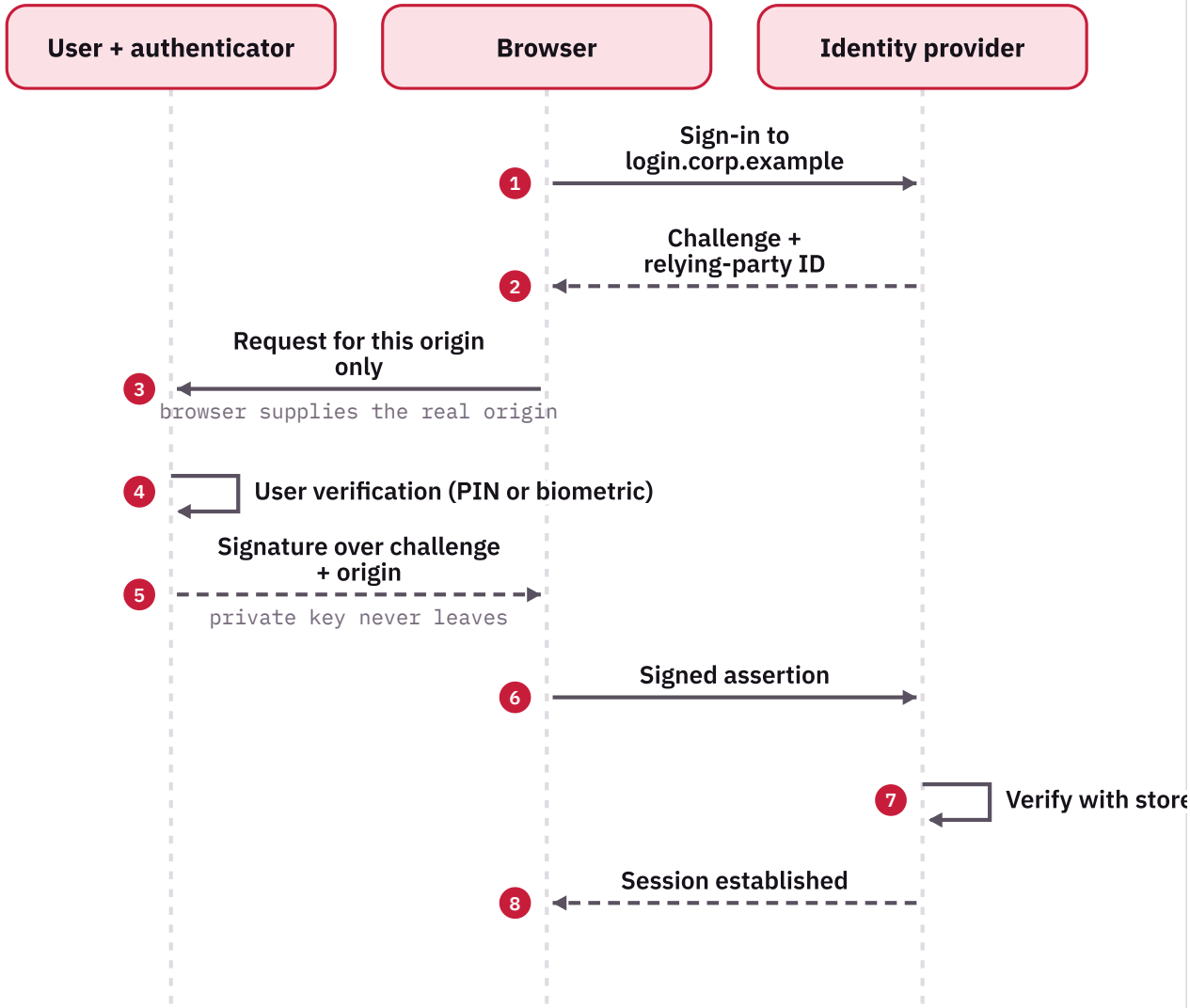
AUTHENTICATOR	PHISHING RESISTANT ?	MAIN WEAKNESS	USE
Password only	No	Phished, reused, sprayed	Never alone for remote or privileged access
SMS or voice one-time code	No	SIM swap, interception, real-time relay	Legacy fallback only
Authenticator-app one-time code	No	Real-time relay through a fake login page	Better than SMS, still phishable
Push approval with number matching	No (reduced fatigue risk)	Relay attacks still possible	Acceptable interim step
Passkey or FIDO2 security key (WebAuthn)	Yes	Recovery and enrolment processes; synced passkeys inherit the security of the sync account, so use device-bound keys for admins	Preferred for all users
Smart card / certificate (PKI-based)	Yes	Card and certificate management overhead	Privileged and high-assurance users

DEFINITION · PHISHING RESISTANCE

An authenticator is **phishing resistant** when it cryptographically binds the login to the genuine service, so credentials captured by a fake site are useless. FIDO2/WebAuthn achieves this by tying each key pair to the legitimate origin; certificate-based mutual TLS achieves it by proving possession of a private key to a verified server. NIST's digital identity guidelines (SP 800-63B, revision 4 finalised in 2025) describe this property and accept syncable passkeys at moderate assurance, with device-bound authenticators for the highest assurance.

Copyright © ZyeemZia

Why a passkey cannot be phished



The authenticator signs the challenge together with the origin the browser actually visited. A look-alike site has a different origin, so no matching credential exists and nothing replayable is produced.

WATCH OUT · MFA FATIGUE AND HELPDESK SOCIAL ENGINEERING

Attackers bombard users with push prompts until one is approved, or call the help desk pretending to be a user who lost a phone. Use number matching, limit prompt rates, alert on repeated denials and require strong identity verification before any MFA reset.

PRO TIP · IDENTITY THREAT DETECTION AND RESPONSE (ITDR)

Phishing-resistant MFA protects the sign-in, but attackers now steal what comes after it: session cookies and refresh tokens lifted by infostealer malware, rogue OAuth consent grants and new MFA methods added to a hijacked account. Treat the identity provider as a monitored system: alert on token reuse from a new device or network, impossible travel, MFA-method and admin-role changes and unusual consent grants. Response playbooks must **revoke sessions and refresh tokens**, not just reset passwords, and short token lifetimes, device-bound sessions and continuous access evaluation reduce the value of anything stolen.

Copyright © ZyeemZia

Where network teams must enforce MFA

- Remote-access VPN and ZTNA portals — preferably phishing-resistant
- Device administration through TACACS+ or a privileged access gateway
- Firewall, NAC, SIEM and cloud management consoles
- Jump hosts and bastions for data-centre and OT access
- Break-glass account use through dual control rather than shared passwords

Identity-based segmentation assigns each user or device a group identifier (a tag) at authentication time. Enforcement points then apply a **group-to-group policy matrix**, independent of IP address or VLAN. When a user moves from Wi-Fi to wired, or from one building to another, the policy follows the identity.

Group-based policy architecture

Policy	`Group-to-group matrix defined centrally on the NAC server` `Owned by security architecture`
Classification	`Tag assigned at 802.1X/MAB authorisation` `Static tags for servers and subnets`
Propagation	`Carried inline in frame or overlay headers where supported` `Or shared as IP-to-tag mappings with enforcement points`
Enforcement	`Group ACLs on switches` `Tag-aware firewall rules`

Example group policy matrix

SOURCE GROUP ↓ / DESTINATION →	FINANCE SERVERS	HR SERVERS	PRINTERS	INTERNET
Finance staff	Permit HTTPS	Deny	Permit print	Permit
HR staff	Deny	Permit HTTPS	Permit print	Permit
Contractors	Deny	Deny	Deny	Permit web
IoT cameras	Deny	Deny	Deny	Permit to video cloud only
Quarantine	Deny	Deny	Deny	Remediation only

INSIGHT · IDENTITY IS THE NEW PERIMETER — AND IT NEEDS DEPTH TOO

Identity-based segmentation only works if identities are trustworthy. Weak MAB entries, PEAP without server validation or shared accounts let attackers inherit the wrong tag. Strong authentication (module 4) and segmentation (module 1) depend on each other — and both feed the zero-trust wrapper covered in module 8.

Copyright © ZyeemZia

SCENARIO · DECIDE · PUSH-BOMBING ATTEMPT

The SOC sees 27 denied VPN push prompts for a finance user within 10 minutes from an overseas IP, then one approval. A VPN session is now active.

(A) Terminate the session, disable the account's sessions and tokens, contact the user out of band, and move the user to phishing-resistant MFA

(B) Leave the session up and monitor it to gather intelligence

(C) Reset the user's password and close the ticket

(D) Block the overseas country at the VPN gateway and take no further action

Circle your choice. Answer and feedback: module answer key.

Key terms

AAA
Authentication, authorisation and accounting: the framework for controlling and recording access.

TACACS+
A TCP-based AAA protocol (RFC 8907) that separates authentication, authorisation and accounting; used for device administration.

Authenticator
The switch or wireless controller that controls the port and relays EAP to the authentication server.

PEAP
An EAP method that builds a TLS tunnel with a server certificate and carries an inner, usually password-based, method.

Change of authorisation (CoA)
A RADIUS extension (RFC 5176) that lets the server change or end an active session.

Posture assessment
Checking an endpoint's security state before and during network access.

Group tag
A numeric identifier assigned at authentication and used to enforce group-to-group policy.

RADIUS
A UDP-based AAA protocol (RFC 2865) used mainly for network access, including 802.1X.

Supplicant
The endpoint software that presents credentials in 802.1X.

EAP-TLS
An EAP method using certificates on both client and server for mutual authentication.

MAB
MAC Authentication Bypass: using a device's MAC address as its identity when it cannot run 802.1X.

Downloadable ACL
An access list defined on the NAC server and pushed to the switch for a specific session.

Phishing-resistant MFA
Authentication that cryptographically binds to the genuine service so captured credentials cannot be replayed.

Copyright © ZyeemZia

Identity layer readiness checklist

☐ Device administration uses named TACACS+ accounts with command accounting
☐ RADIUS servers and clients are patched and require Message-Authenticator
☐ 802.1X supplicant profiles pin the trusted CA and server name
☐ EAP-TLS migration plan exists for managed devices
☐ MAB devices are profiled and receive device-type-specific policy
☐ CoA is configured and tested on every access switch
☐ Posture 'unknown' never maps to full access
☐ Phishing-resistant MFA protects VPN and privileged access
☐ Group policy matrix is owned, reviewed and logged

REFLECT

Which group of users in your organisation would gain the most from moving to phishing-resistant MFA first, and what is the biggest obstacle?

Key takeaways

- Most intrusions log in rather than break in: protect every remote, admin and console login with MFA.
- Only origin-bound authenticators (passkeys, FIDO2 keys, certificates) are phishing resistant; codes and pushes can be relayed.
- Defend the help desk and the session: verify identity before MFA resets and revoke tokens during response.
- Identity-based segmentation applies a group-to-group matrix that follows the user, but only if identities are strong.

KNOWLEDGE CHECK

21. Which authenticator is phishing resistant?

(A) A time-based one-time code from a mobile authenticator app
(B) A push approval with number matching
(C) A one-time code sent by SMS
(D) A FIDO2 key bound to the origin

22. What is the main defence against MFA fatigue attacks?

(A) Number matching, prompt rate limits and alerts on repeated denials
(B) Shortening the password expiry period for every remote-access user
(C) Sending each push prompt to two of the user's devices at once
(D) Allowing SMS as a fallback when push fails

Copyright © ZyeemZia

23. In identity-based segmentation, when is the group tag usually assigned?

(A) When the DHCP server assigns the device its first IP address lease

(B) When the firewall first sees the device's traffic

(C) At authorisation time, by the NAC server after 802.1X

(D) Manually by an engineer on each switch port

24. Why does identity-based policy follow a user who moves from Wi-Fi to a wired port?

(A) The user keeps the same IP address in every building and on every network

(B) Wired and wireless traffic share one physical switch

(C) The policy follows the user's group tag, not a VLAN or IP address

(D) Firewalls cache the user's last known MAC address for the day

25. A strong group policy matrix is undermined most by which weakness?

(A) Weak identities, such as unprofiled MAB entries

(B) Using numeric rather than human-readable named group identifiers in the matrix

(C) Placing printers in their own group

(D) Logging matrix denies to the SIEM

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 4 · IDENTITY

Answer key

Knowledge checks

1. A RADIUS combines authentication and authorisation in its response and carries EAP for 802.1X. TCP 49 and per-command authorisation describe TACACS+.

2. D Per-command authorisation and accounting are the key benefits. TACACS+ body obfuscation is not strong encryption, MFA is possible with both, and it runs over TCP.

3. B Message-Authenticator provides an HMAC over the packet, blocking the forgery. Port, timeout and accounting changes do not help.

4. A Local is a fallback for unreachable servers. A reject from the server ends the attempt; it does not fall through to local.

5. C Break-glass use should be rare and visible. Silent use, automatic deletion or disabling accounting all undermine control.

6. B The authenticator relays EAP over EAPOL on one side and RADIUS on the other. The supplicant presents credentials; the directory and CA are back-end services.

7. D In closed mode, only EAPOL passes until authorisation. Allowing DHCP or DNS before authentication is a deliberate low-impact choice, not the default.

8. B EAP-TLS uses certificates on both sides. PEAP and TTLS typically carry passwords, and MAB uses the MAC address.

9. D Server validation protects the inner credentials. The shared secret, VLAN assignment and accounting are unrelated to client-side validation.

10. A TEAP supports credential chaining of device and user. It still uses a server certificate and RADIUS, and does not use MACs as factors.

11. C MAB identity is just a MAC address. MAB can assign VLANs, does not use EAP methods and exists precisely for devices without supplicants.

12. C The three Tunnel attributes signal VLAN assignment. Filter-Id applies a named ACL; NAS and Framed attributes describe the session.

13. A Open authentication plus a restrictive ACL is the low-impact model. Closed mode removes `authentication open`.

14. D CoA (RFC 5176) lets the server push a new policy now. DHCP renewals and timers are not immediate; SNMP traps go the other direction.

15. B Monitor mode logs results without blocking, so problems are fixed before enforcement.

16. A Unknown means health cannot be confirmed. Granting full access fails open; blocking permanently is excessive.

17. C CoA updates the session in place. Re-plugging may work but is not the design; DHCP and spanning tree are unrelated.

18. B Certificates remove passwords from Wi-Fi authentication and the profile enforces server validation. Storing passwords or bypassing MFA weakens security.

19. D OWE (Enhanced Open) encrypts traffic on open networks. It does not authenticate users, check posture or filter content.

20. B Sponsorship ties each guest to an employee. Anonymous high-volume access suits hotspot or self-registration; guests should never get unrestricted internal access.

21. D FIDO2 binds credentials to the real origin, so fake sites cannot use them. Codes and push approvals can be relayed in real time.

22. A These controls stop blind approvals and flag the attack. Password expiry and SMS fallback do not address push bombing; two devices doubles exposure.

23. C The NAC server returns the tag in the authorisation result. DHCP and the firewall do not classify identity; manual port tagging defeats the purpose.

24. C Tags are assigned per session from identity, so policy is location-independent. IP, hardware and MAC caching are not the mechanism.

25. A If identity can be spoofed or stolen, an attacker inherits a valid tag. Numeric IDs, printer groups and logging are normal good practice.

Scenarios & case studies

> **Scenario · Choosing the protocol**
> **B** is best. Correct. RADIUS carries EAP and returns network authorisation; TACACS+ separates authorisation per command and logs each command.

> **Scenario · Evil-twin risk**
> **D** is best. Best. It fixes the immediate validation gap and removes passwords from Wi-Fi authentication over time.

Copyright © ZyeemZia

Scenario · Monitor mode surprises
B is best. Correct. Monitor mode exists to find exactly this; enforcing before fixing would disconnect clinical devices.

Case study · University Wi-Fi 802.1X rollout
Target design: EAP-TLS for staff managed devices via automatic certificate enrolment; for students, a self-service onboarding portal (with MFA) that installs a per-device certificate and a profile pinning the RADIUS server name and CA. Role-based authorisation returns student, staff, researcher and contractor roles with different ACLs or group tags. **Onboarding at scale:** open the portal weeks before term, publish short guides per operating system, staff 'onboarding desks' in the first week and keep PEAP with enforced server validation as a time-limited fallback. **Other traffic:** a separate guest SSID with Enhanced Open and internet-only access; lab systems reachable only by authorised groups; IoT devices on MAB with profiling and narrow device-type policies in their own segments. **Phasing:** monitor and pilot with IT staff, then staff, then new students at the start of term, then remaining students; retire the legacy PEAP SSID on a published date. Measure success by onboarding completion, help-desk tickets and reduction in compromised accounts.

Scenario · Unknown posture
C is best. Best. The policy behaves as designed; fix the dependency and grant a narrow, temporary exception if the business needs it.

Scenario · Push-bombing attempt
A is best. Correct. The approval after repeated denials is a classic fatigue compromise; contain first, then fix the authenticator weakness.

Copyright © ZyeemZia

05

MODULE 5 · DETECT

Detect — Threat Detection & Prevention

See hostile activity early and stop it with confidence: network sensors, email, web, DNS, endpoints and deception.

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Design IDS and IPS deployments that balance visibility, blocking, latency and failure behaviour.
- Measure and tune detections using precision, recall and documented use-case cards.
- Protect domains with SPF, DKIM and DMARC and defend against lookalike phishing.
- Apply URL filtering, selective decryption and protective DNS, and detect DNS abuse.
- Use EDR, XDR and deception to catch threats the network cannot see.

LESSONS

1. Detection Engines: IDS, IPS and How They Decide · 35 min
2. Tuning, False Positives and Detection Engineering · 40 min
3. Email Security: SPF, DKIM and DMARC · 40 min
4. Web, URL Filtering and DNS-Layer Security · 40 min
5. Endpoint Detection, XDR and Deception · 40 min

MODULE 5 · DETECT · LESSON 1 · 35 MIN

Detection Engines: IDS, IPS and How They Decide

Passive versus inline sensing, the four detection methods and where each one fails

- Contrast IDS and IPS deployments by visibility, blocking ability, latency and failure behaviour.
- Explain signature, anomaly, behavioural and reputation detection and the blind spots of each.
- Read and reason about site-specific rules and the alerts they generate.

The **Detect** layer of the ZCIE Security Defence-in-Depth Stack assumes that something has already slipped past the perimeter, the tunnel and the identity checks you built in Modules 2 to 4. Its job is to notice hostile activity quickly and, where confidence is high enough, stop it in-line. Expert engineers are judged less on whether they can switch a sensor on and more on whether they can explain **what it can see, what it will miss and what happens when it breaks**.

IDS versus IPS

Intrusion detection system (IDS)

- Receives a **copy** of traffic from a SPAN port, TAP or packet broker
- Cannot drop packets; it raises alerts for people or automation to act on
- Zero added latency and no outage if the sensor fails
- Ideal for new rule sets, forensic visibility and noisy segments
- Response is always after the fact, even if only by seconds

Intrusion prevention system (IPS)

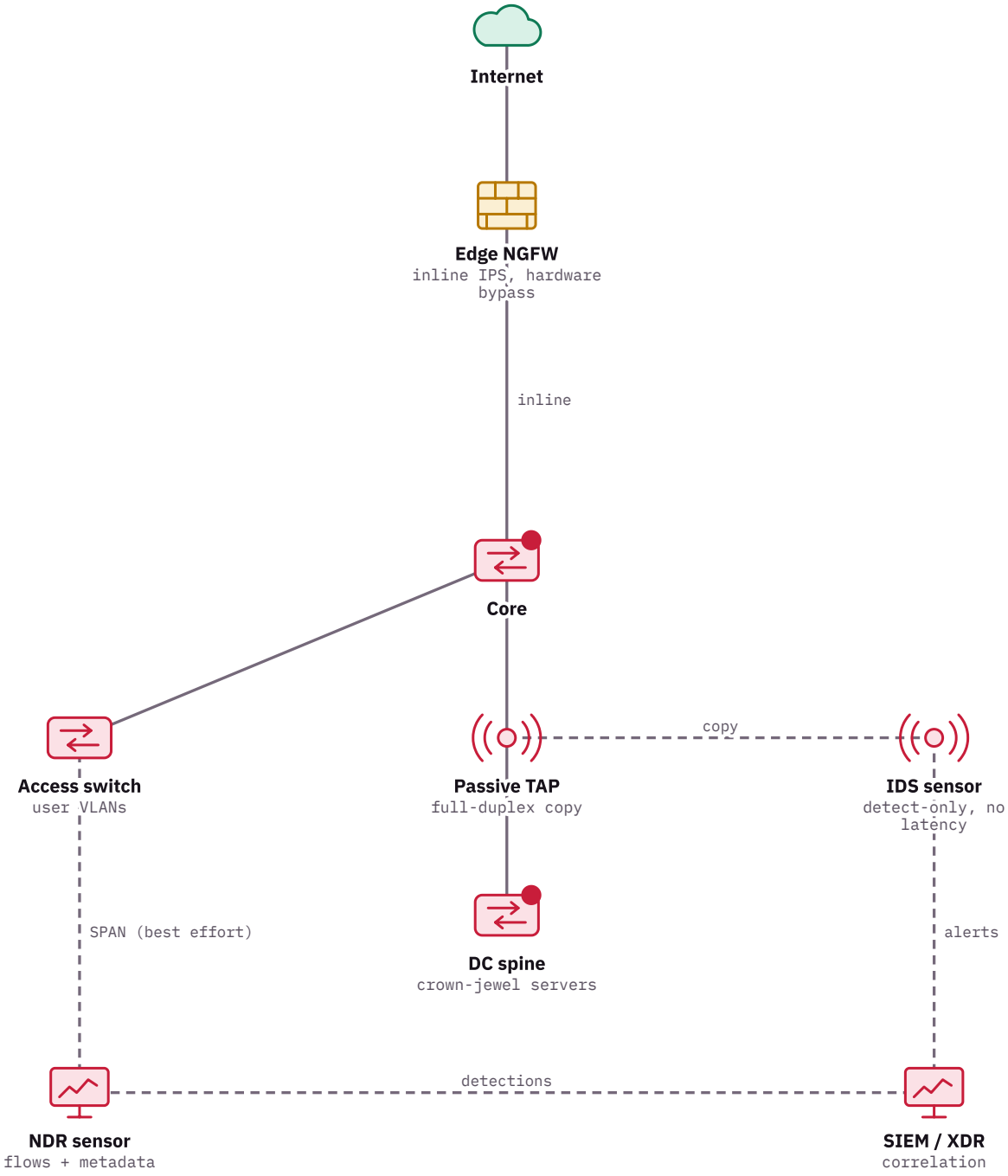
- Sits **in the forwarding path** as a bridge, routed hop or NGFW engine
- Can drop, reset or rewrite traffic before it reaches the target
- Adds latency and becomes a failure point; needs bypass design
- Should block only on high-confidence signatures
- A false positive becomes a self-inflicted outage

Sensor deployment modes

MODE	WHAT IT SEES	CAN BLOCK?	MAIN RISK
SPAN / mirror port	Copied frames, may drop under load	No	Oversubscription silently loses packets
Passive network TAP	Every frame on the link, both directions	No	Extra hardware and cabling per link
Inline layer-2 bridge	All traffic crossing the bridge	Yes	Outage on failure unless bypass is fitted
Engine inside an NGFW	Traffic matched by the firewall policy	Yes	Throughput drops sharply with full inspection
Host-based sensor	Decrypted traffic and process context	Yes, on that host	Coverage gaps on unmanaged devices

Copyright © ZyeemZia

Where sensors sit and what they risk



Blocking happens only on the inline path at the edge, where a bypass design decides what failure means. Inside, a TAP gives the IDS a lossless copy of data-centre traffic, while the SPAN copy feeding NDR is cheaper but can drop frames under load.

Copyright © ZyeemZia

Four ways a sensor decides

SIG

Signature

Matches known patterns such as byte strings, protocol fields or certificate attributes. Precise and explainable, but blind to anything it has never seen.

ANOM

Anomaly

Builds a statistical baseline (volume, ports, peers, timing) and flags deviation. Finds the unknown but needs a clean baseline and produces more noise.

BEH

Behavioural

Looks for sequences of actions that together indicate an attacker goal, for example scanning followed by remote service creation. Strong against tool changes.

REP

Reputation

Scores destinations, files and certificates using threat intelligence. Cheap and fast, but stale feeds create both misses and false blocks.

How an inline engine reaches a verdict

01
Capture
Packet arrives on the inline pair or tap

→

02
Decode
Layer-2 to layer-4 headers parsed and validated

→

03
Reassemble
IP fragments and TCP streams rebuilt and normalised

→

04
Parse
Application protocol identified regardless of port

→

05
Match
Rules, models and reputation evaluated

→

06
Verdict
Pass, alert, drop or reset, then log the event

Site-specific rules in an open-source IDS/IPS

Sensor S1 · Suricata rules (local.rules)

```
# Local SID range 1000000-1999999 keeps site rules apart from vendor feeds
alert dns $HOME_NET any -> any any (msg:"ZZ-LOCAL lookup of blocklisted update domain"; dns.query;
content:"update-check.badsite.example"; nocase; endswith; classtype:trojan-activity; sid:1000101;
rev:2;)
drop tls $HOME_NET any -> $EXTERNAL_NET any (msg:"ZZ-LOCAL TLS to retired file-share service";
tls.sni; content:"files.legacyshare.example"; nocase; endswith; classtype:policy-violation;
sid:1000102; rev:1;)
alert tcp $HOME_NET any -> $EXTERNAL_NET 3389 (msg:"ZZ-LOCAL outbound RDP to internet";
flow:to_server; flags:S; classtype:policy-violation; sid:1000103; rev:1;)
# Resulting alert in eve.json (trimmed)
{"timestamp":"2026-03-
14T09:12:44.118+0000","event_type":"alert","src_ip":"10.20.4.57","dest_ip":"10.0.0.53","proto":"UDP
","app_proto":"dns","alert":{"action":"allowed","signature_id":1000101,"rev":2,"severity":1}}
```

A `drop` rule only blocks when the engine runs in inline (IPS) mode; in IDS mode it is logged as an alert. The alert shows `action: allowed` because the rule is alert-only, and severity 1 comes from the class type priority.

Copyright © ZyeemZia

WATCH OUT · ENCRYPTION IS THE SENSOR'S BIGGEST BLIND SPOT

TLS 1.3 encrypts the server certificate, QUIC moves web traffic to UDP 443 and Encrypted Client Hello hides the real server name. A network sensor that cannot decrypt is left with flow metadata, JA4-style client fingerprints, IP reputation and timing. Plan detection for encrypted traffic on purpose: decrypt selectively at the secure web gateway, push detection to endpoints, and treat SNI-based rules as a shrinking asset. This is the job of **encrypted traffic analysis** inside network detection and response (NDR) tools: they model handshake fingerprints, certificate metadata, packet sizes and timing, and peer relationships to spot beacons and tunnels without decrypting anything.

Placement rules of thumb

- Put an **IDS** where you need visibility without risk: east-west core links, data-centre spines, cloud traffic mirrors.
- Put an **IPS** where blocking pays for its latency: internet edge, partner links and in front of crown-jewel segments.
- Fit hardware **bypass** or clustering on every inline sensor and decide fail-open versus fail-closed per link, in writing.
- Monitor sensor health (drops, CPU, rule-load errors) as carefully as you monitor its alerts.
- Start every new inline deployment in detect-only mode and promote rules to blocking deliberately.

SCENARIO · DECIDE · PROTECTING A LATENCY-SENSITIVE TRADING SEGMENT

A brokerage wants intrusion prevention between its order-entry gateways and the internet. The application team says any extra delay above 200 microseconds or any outage during market hours is unacceptable. What is the strongest design?

(A) Deploy inline with every vendor rule set to drop from day one, because the segment is business-critical and must have the strongest possible protection.

(B) Mirror the traffic to a passive IDS only, and never consider prevention because any inline device will break trading.

(C) Deploy inline with a fail-open hardware bypass, run detect-only while tuning, then block only on a small set of high-confidence signatures.

(D) Move inspection to the endpoints on the order gateways and remove all network sensors because hosts see decrypted traffic.

Circle your choice. Answer and feedback: module answer key.

Key terms

Intrusion prevention system (IPS)
An inline inspection engine that can drop, reset or modify traffic in real time based on rules, models or reputation.

Behavioural detection
Detection based on sequences of actions that indicate attacker intent, rather than on a single known pattern.

Fail-open
A failure mode in which an inline device passes traffic uninspected when it fails, protecting availability at the cost of security.

Copyright © ZyeemZia

Key takeaways

- An IDS watches a copy and cannot block; an IPS sits in the path, adds latency and becomes a failure point.
- Signature, anomaly, behavioural and reputation methods each have blind spots, so combine them.
- Decide fail-open or fail-closed per inline link in writing, fit bypass and test it.
- Encryption pushes detection toward metadata, fingerprints, NDR analytics, selective decryption and endpoints.

KNOWLEDGE CHECK

1. A sensor connected to a switch SPAN port reports far fewer sessions than the firewall during peak hours. What is the most likely cause?

   (A) The sensor is running in inline mode and is blocking most of the peak traffic

   (B) The SPAN session is oversubscribed and the switch is dropping mirrored frames

   (C) The firewall is double-counting sessions because of asymmetric return routing

   (D) The detection rules are filtering out sessions that do not match a signature

2. Which detection method is most likely to catch a brand-new remote access tool used to create services on many servers in sequence?

   (A) Signature detection using the vendor's latest file-hash content updates

   (B) Reputation scoring of the destination addresses the servers communicate with

   (C) Behavioural detection that correlates remote service creation across hosts

   (D) Port-based allow lists that permit only approved management protocols

3. An inline sensor has a `drop` rule, yet the matching traffic still reaches the server and eve.json records the event. What explains this?

   (A) The engine is running in IDS mode, where drop rules are logged but not enforced

   (B) The rule needs a higher revision number before the engine will enforce drops

   (C) Drop rules only work for TCP, so the matching UDP traffic is always allowed

   (D) The rule must also include a threshold keyword before blocking is enabled

4. Why is a false positive more expensive on an IPS than on an IDS?

   (A) Because the IPS stores more packet data, so each alert costs more disk space

   (B) Because the IPS requires a licence per alert, so noise increases the subscription

   (C) Because the IPS cannot be tuned, so every false positive must be reported to the vendor

   (D) Because the IPS blocks legitimate traffic, so the error becomes an outage

5. Your web traffic is moving to TLS 1.3 with Encrypted Client Hello. Which detection approach loses the most value?

   (A) Endpoint telemetry that records which process opened each connection

   (B) Network rules that match the server name in the TLS handshake

   (C) Flow analytics that measure byte counts, timing and peer relationships

   (D) Selective decryption at a secure web gateway for high-risk categories

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 5 · DETECT · LESSON 2 · 40 MIN

Tuning, False Positives and Detection Engineering

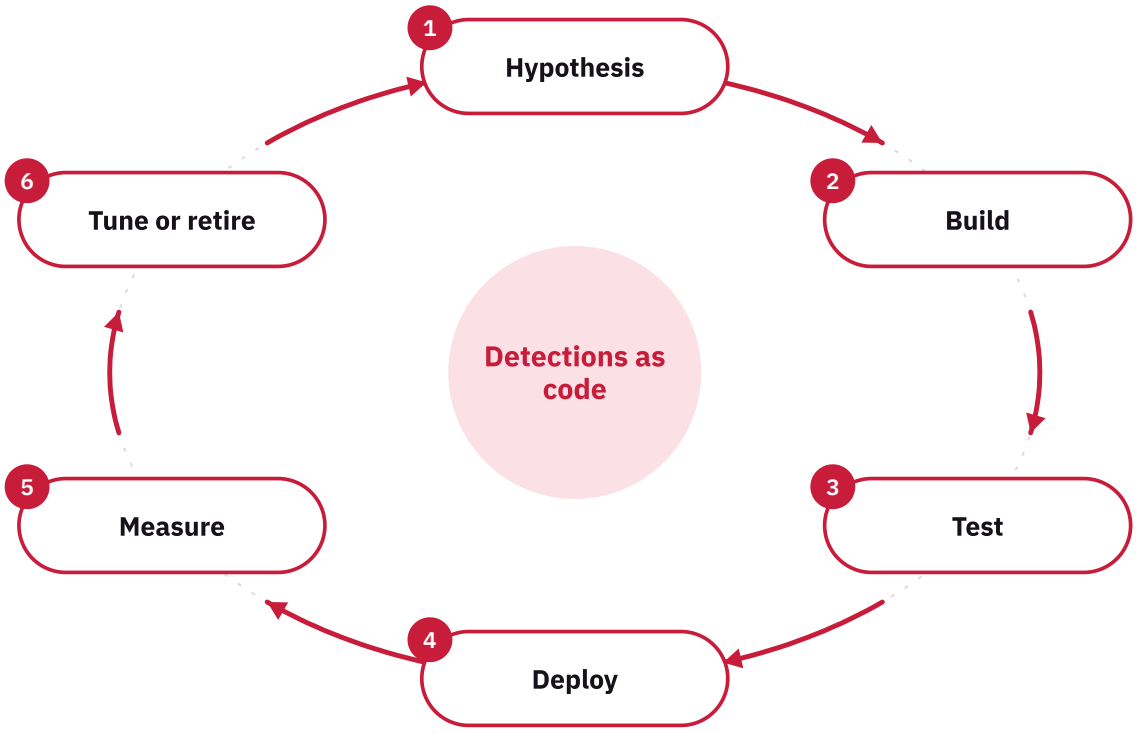
Turn a noisy sensor into a trusted one with measurement, disciplined tuning and use-case cards

- Measure detection quality with precision, recall and false-positive rate.
- Choose between rewriting, scoping, thresholding, suppressing and disabling a noisy rule.
- Explain the role of malware analysis sandboxes and their limits.
- Document detections as reviewable use-case cards.

A detection that fires 4,000 times a day is not a control; it is background noise that hides the one alert that matters. **Detection engineering** treats rules like code: each has a purpose, an owner, test data, a measured error rate and a review date. Tuning is not about making the console quiet. It is about raising the share of alerts that deserve a human's attention without losing the ones that catch real attacks.

Copyright © ZyeemZia

The detection-engineering loop



1. **Hypothesis** — Threat behaviour to catch, mapped to ATT&CK
2. **Build** — Rule logic, data sources and use-case card
3. **Test** — Replay known-bad data and benign baselines
4. **Deploy** — Peer review, version control, staged rollout
5. **Measure** — Precision, recall, volume and analyst verdicts
6. **Tune or retire** — Narrowest fix, then re-test; retire if obsolete

Treat each rule like software: it has a reason to exist, tests that prove it works, measurements in production and a scheduled review. Tuning feeds straight back into new tests.

The four outcomes of every detection decision

OUTCOME	REALITY	SENSOR SAID	COST
True positive (TP)	Malicious	Alert	The value you are paying for
False positive (FP)	Benign	Alert	Analyst time, fatigue and, on an IPS, outages
True negative (TN)	Benign	Silent	None
False negative (FN)	Malicious	Silent	The breach you find months later

Copyright © ZyeemZia

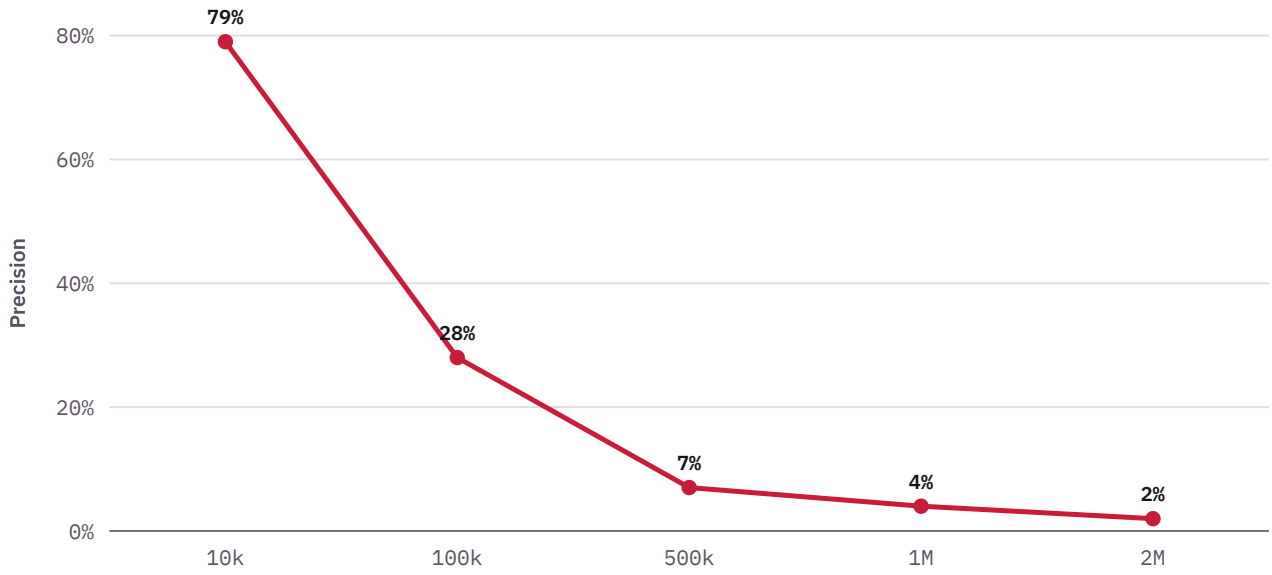
Measuring a detection

MEASURE	FORMULA	WHAT IT TELLS YOU
Precision	`TP / (TP + FP)`	Share of alerts that are real. Low precision causes alert fatigue.
Recall (detection rate)	`TP / (TP + FN)`	Share of real attacks that were caught. Measure it with purple-team tests and replayed captures.
False-positive rate	`FP / (FP + TN)`	Share of benign events wrongly flagged. Even 0.1% is huge when the denominator is millions of events a day.

EXAMPLE · WHY BASE RATES MATTER

A rule examines 2,000,000 benign DNS queries and 20 malicious ones per day. It catches 19 of the 20 attacks and has a false-positive rate of only 0.05%. That still produces 1,000 false alerts, so precision is 19 / (19 + 1,000), under 2%. An analyst will learn to ignore it. Good recall alone is not enough when the benign population is enormous.

Precision collapses as benign volume grows



Illustrative values calculated from the worked example: the rule's error rate never changes, but as daily benign events grow from 10,000 to 2,000,000 the same 19 true alerts drown in false ones.

A disciplined tuning workflow

1. **Baseline** Rank rules by alert volume and by analyst disposition (true, false, benign-but-expected) over the last 30 days.
2. **Find the root cause** Is the rule wrong, the network variables wrong, or the activity genuinely expected (a scanner, a backup job)?
3. **Fix the environment first** Correct `$HOME_NET`, server groups and asset tags; many false positives vanish without touching a rule.
4. **Pick the narrowest action** Rewrite, scope to hosts, threshold, suppress for one source, and only then disable.
5. **Peer review and ticket** Every change has a reason, an approver and an expiry or review date.

Copyright © ZyeemZia

6. **Regression test** Replay known-bad captures to prove the rule still fires after tuning.

Tuning actions compared

ACTION	USE WHEN	RISK IF MISUSED
Rewrite the rule	The logic is too broad or matches benign content	Breaking detection of the original threat
Scope by variables or asset groups	Rule is right but applied to the wrong hosts	Wrong groups hide real targets
Threshold or rate-limit	Repeated identical alerts from one source	Low-and-slow activity stays under the count
Suppress for a specific source	One known, approved system triggers the rule	That system becomes an invisible pivot point
Disable	Rule is irrelevant to your environment	You lose coverage if the environment changes

Documented tuning in threshold.config

Sensor S1 · Suricata threshold.config

```
# CHG-2291 vulnerability scanner 10.9.0.15 trips scan rule; owner: VM team; review 2026-09-30
suppress gen_id 1, sig_id 1000201, track by_src, ip 10.9.0.15
# CHG-2305 one alert per source per 10 minutes for a noisy policy rule
threshold gen_id 1, sig_id 1000104, type limit, track by_src, count 1, seconds 600
# CHG-2311 alert only after 20 failed logins from one source within 60 seconds
threshold gen_id 1, sig_id 1000204, type threshold, track by_src, count 20, seconds 60
```

Suppression is scoped to one source address, never to the whole rule. Comments tie each line to a change ticket, an owner and a review date so the file can be audited.

INSIGHT · MALWARE ANALYSIS SANDBOXES IN ONE PARAGRAPH

A sandbox **detonates** suspicious files or URLs in an instrumented virtual machine and records what they do: processes spawned, files written, registry changes, network callbacks. Verdicts and extracted indicators then feed the email gateway, web gateway, IPS and EDR. Sandboxes complement but never replace other layers, because some malware checks for analysis environments, waits before acting or needs user interaction, and encrypted or password-protected archives may never be opened.

Static versus dynamic analysis

Static analysis

- Examines a file without running it
- Hashes, strings, headers, imports, embedded macros
- Fast and safe at scale
- Defeated by packing and obfuscation

Dynamic analysis (sandbox)

- Runs the sample in an isolated, instrumented environment
- Observes real behaviour and network callbacks
- Slower and resource-heavy
- Can be evaded by environment checks and delays

TEMPLATE

Detection use-case card

Capture every detection as a reviewable engineering artefact rather than an unexplained rule in a console.

Copyright © ZyeemZia

USE CASE AND ID	ATT&CK TECHNIQUE	DATA SOURCES	LOGIC SUMMARY	KNOWN FALSE POSITIVES AND TUNING	RESPONSE AND OWNER	LAST TESTED / REVIEW
UC-NET-014 Outbound RDP to internet	*T1021.001 Remote Desktop Protocol (outbound misuse)*	*Firewall logs, IPS sid 1000103, flow records*	*TCP SYN from internal hosts to external port 3389*	*Approved vendor jump host 10.40.2.8 excluded by asset tag*	*Tier 1 validates user and host; SOC lead owns the rule*	*Purple test 2026-05-02 / review 2026-11-02*

SCENARIO · DECIDE · A RULE THAT FIRES 4,000 TIMES A DAY

A data-exfiltration rule alerts about 4,000 times a day, and almost every alert comes from the nightly backup server sending large encrypted archives to the cloud backup provider. The rule also fired once last quarter on a genuine incident. What should you do?

(A) Disable the rule entirely, because 99.9% of its alerts are false positives and the analysts on shift already ignore it anyway.

(B) Confirm the backup flow is approved, then suppress the rule for that source and destination only, with a ticket and expiry.

(C) Leave the rule as it is and ask Tier 1 analysts to close backup-server alerts in bulk every morning.

(D) Raise the rule's threshold for all hosts so it only alerts above 50 GB per hour of outbound transfer.

Circle your choice. Answer and feedback: module answer key.

Key terms

Precision
The proportion of alerts that turn out to be true positives: TP / (TP + FP).

Detonation
Running a suspicious file or URL inside an isolated sandbox to observe its behaviour.

Suppression
A tuning entry that silences a specific rule for a specific source or destination while leaving it active elsewhere.

Key takeaways

- Measure every detection: precision tells you how much noise it makes, recall tells you how much it misses.
- With huge benign volumes, even a tiny false-positive rate destroys precision.
- Fix variables and asset groups first, then use the narrowest tuning action: rewrite, scope, threshold, suppress, and only then disable.
- Sandboxes add behavioural verdicts but can be evaded; document every rule as a tested, owned use-case card.

Copyright © ZyeemZia

KNOWLEDGE CHECK

6. A rule has 95% recall in purple-team tests but analysts close 98% of its alerts as benign. What does this tell you?

   (A) It catches most attacks but has very low precision, so it needs tuning to stay useful

   (B) It is both accurate and efficient, so the analysts are closing real attacks by mistake

   (C) It has a high false-negative rate, so it misses most attacks and should be rewritten

   (D) It is behaving normally for a signature, so no action is needed beyond retraining staff

7. A vulnerability scanner triggers dozens of IPS rules every week. What is the most appropriate tuning?

   (A) Disable the affected rules globally because they only ever fire during authorised scans

   (B) Move the scanner into the same subnet as the sensor management interface to hide it

   (C) Raise the severity of the rules so that scanner alerts stand out in the console more

   (D) Suppress the rules for the scanner's source address only, with a ticket and review date

8. Why should many false positives be fixed by correcting `$HOME_NET` and server group variables before touching rules?

   (A) The variables control licensing, so wrong values cause rules to load in a reduced mode

   (B) The variables set alert severity, so wrong values make benign alerts appear critical

   (C) Rules depend on those variables, so wrong values make correct rules match the wrong traffic

   (D) The variables decide which vendor feed is used, so wrong values pull an outdated feed

9. A sandbox returns a clean verdict for an attachment that later proves malicious. Which explanation is most plausible?

   (A) The sandbox only performs static analysis, so it never runs attachments of that type

   (B) Clean verdicts always mean the file was encrypted with the recipient's public key

   (C) The email gateway must have stripped the payload before the sandbox could analyse it

   (D) The sample detected the analysis environment or waited before acting, so it showed nothing

10. What makes a detection use-case card more valuable than the rule text alone?

    (A) It replaces the need to test the rule because the logic is described in plain language

    (B) It allows the rule to run without any data sources because the logic is documented

    (C) It records purpose, technique, data sources, known false positives, owner and test date

    (D) It is required by the sensor to compile the rule into its running configuration

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 5 · DETECT · LESSON 3 · 40 MIN

Email Security: SPF, DKIM and DMARC

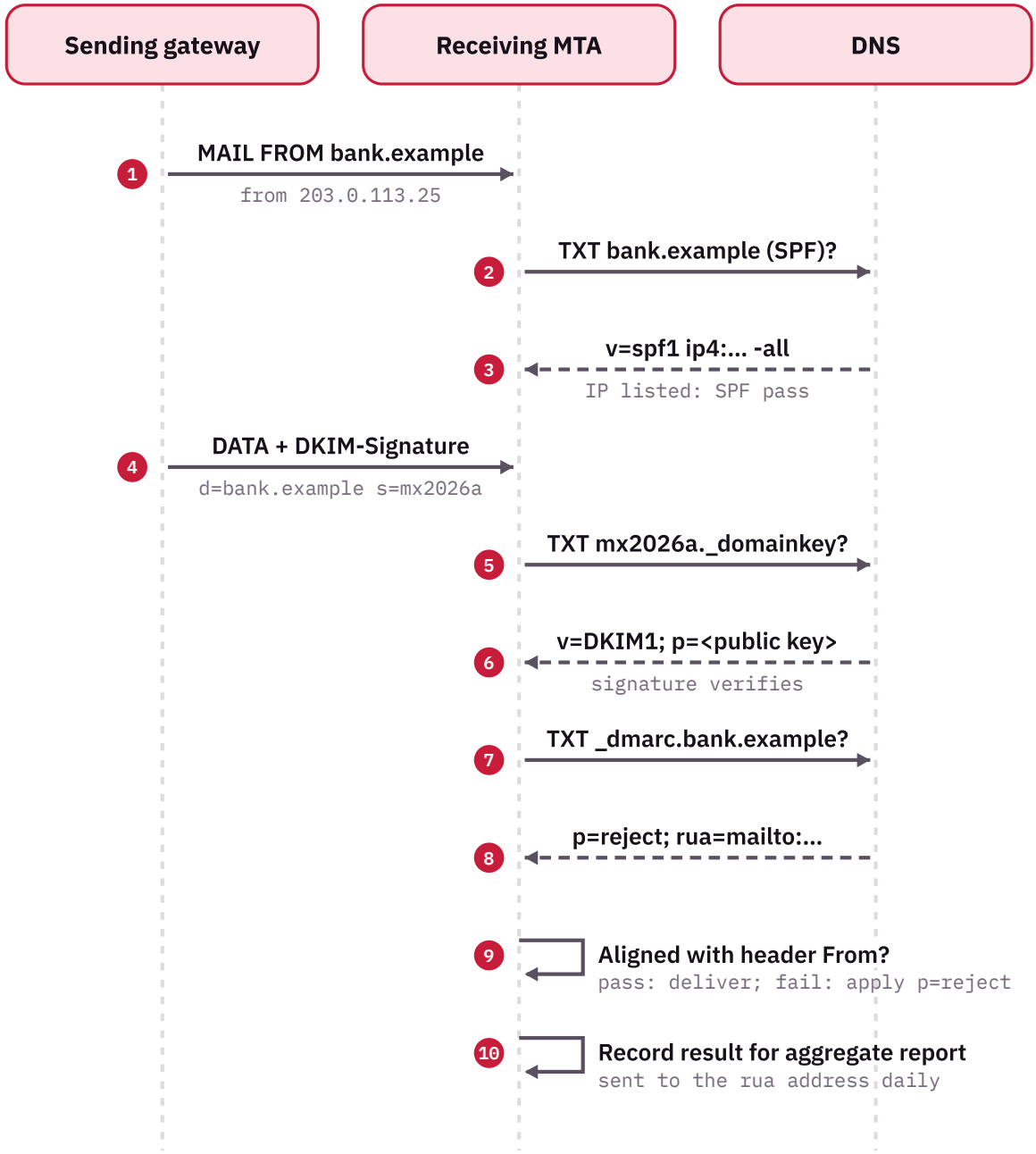
Authenticate your domains, read authentication results and stop the phishing that authentication cannot

- Explain what SPF, DKIM and DMARC each verify and how alignment ties them to the visible From address.
- Write and review SPF, DKIM and DMARC DNS records for active and parked domains.
- Plan a safe DMARC rollout from monitoring to reject.
- Combine authentication with layered controls against lookalike-domain phishing.

Phishing remains the most common initial-access technique (ATT&CK **T1566**). Email authentication protects **your** domain from being forged, and it gives receivers evidence about everyone else's mail. It does not judge intent: a criminal who registers a lookalike domain can publish perfect SPF, DKIM and DMARC records. Expert design therefore combines authentication with content, link and user-behaviour controls.

Copyright © ZyeemZia

How a receiver evaluates an inbound message



SPF checks the connecting IP against the envelope domain and DKIM checks the signature with a key from DNS; DMARC then asks whether a passing result aligns with the visible From domain and applies the owner's policy.

SPF, DKIM and DMARC compared

ASPECT	SPF	DKIM	DMARC
Verifies	Sending IP is authorised for the envelope domain	Message signed by the d= domain and unaltered	SPF or DKIM pass **and** align with header From
Identifier	RFC5321.MailFrom (envelope)	d= in the DKIM-Signature header	RFC5322.From (what users see)
Survives forwarding?	Usually not; the forwarder's IP is not listed	Yes, unless the body or signed headers change	Yes if DKIM survives

Copyright © ZyeemZia

ASPECT	SPF	DKIM	DMARC
Common pitfall	More than 10 DNS lookups causes a permanent error	Weak 1024-bit keys and never-rotated selectors	Stuck at p=none forever

Authentication records for an active and a parked domain

DNS zone · bank.example

```
# SPF: only the two outbound gateways and the payroll provider may send as bank.example
bank.example.                   3600 IN TXT "v=spf1 ip4:203.0.113.25 ip4:203.0.113.26
include:_spf.payroll-provider.example -all"
# DKIM public key under a dated selector (key shortened for print)
mx2026a._domainkey.bank.example. 3600 IN TXT "v=DKIM1; k=rsa;
p=MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEA...IDAQAB"
# DMARC: reject unaligned mail, strict DKIM alignment, aggregate reports
_dmarc.bank.example.            3600 IN TXT "v=DMARC1; p=reject; sp=reject; adkim=s; aspf=r;
rua=mailto:dmarc-agg@bank.example"
# Parked domain that never sends or receives mail
bank-loans.example.             3600 IN MX  0 .
bank-loans.example.             3600 IN TXT "v=spf1 -all"
_dmarc.bank-loans.example.      3600 IN TXT "v=DMARC1; p=reject"
```

`-all` *hard-fails unlisted senders.* `sp=reject` *covers subdomains. The null MX (* `MX 0 .` *) declares that the parked domain accepts no mail, and* `v=spf1 -all` *says it sends none.*

Reading the headers of a reported phish

Mail headers · message reported by a teller

```
Authentication-Results: mx1.bank.example;
  spf=pass smtp.mailfrom=notify@bank-secure-login.example;
  dkim=pass header.d=bank-secure-login.example;
  dmarc=pass header.from=bank-secure-login.example
From: "Bank IT Service Desk" <notify@bank-secure-login.example>
Subject: Action required: re-verify your MFA device today
```

Everything passes because the attacker owns the lookalike domain. Authentication proved who sent it, not that the sender is trustworthy. Detection must come from domain age, lookalike matching, link analysis and user reports.

Rolling DMARC out without breaking legitimate mail

1. **Inventory senders** List every system and provider that sends as your domain: gateways, CRM, HR, ticketing, marketing.
2. **Publish p=none with reporting** Collect aggregate reports for at least two to four weeks to see who really sends as you.
3. **Fix legitimate sources** Add them to SPF within the 10-lookup limit or, better, have them DKIM-sign with your domain.
4. **Move to quarantine** Unaligned mail goes to junk; watch reports and helpdesk tickets.
5. **Move to reject** Unaligned mail is refused. Add `sp=reject` and protect parked domains the same way.
6. **Keep operating it** Rotate DKIM keys, review reports monthly and onboard new senders through change control.

Copyright © ZyeemZia

WATCH OUT · FORWARDING AND MAILING LISTS

Forwarders break SPF because their IP is not in your record, and mailing lists that add footers or subject tags break DKIM. Authenticated Received Chain (ARC) lets trusted intermediaries record the authentication results they saw, and receivers may honour it. Do not respond to forwarding complaints by weakening your policy to p=none.

INSIGHT · AUTHENTICATION IS NOW A DELIVERY REQUIREMENT

Since 2024 the largest mailbox providers require bulk senders (thousands of messages a day to their users) to publish SPF and DKIM, have at least a DMARC policy with alignment, offer one-click unsubscribe and keep complaint rates low; unauthenticated bulk mail is throttled or rejected. Treat any business system that sends at volume as in scope for the DMARC inventory. The DMARC specification itself is also being revised at the IETF (often called DMARCbis), which simplifies some tags and how the organisational domain is found; check the current standard before using new tags.

Layered controls beyond authentication

- Cloud email security that inspects content, sender history and conversation context
- URL rewriting with **time-of-click** checks, because links are often weaponised after delivery
- Attachment sandboxing and stripping of risky file types and macros
- Lookalike and newly registered domain detection, plus external-sender banners
- A one-click report button wired to automated triage and **post-delivery removal**
- Phishing-resistant MFA, as covered in the Identity module, so stolen passwords and codes are not enough

CASE STUDY · PHISHING WAVE AT A REGIONAL BANK

A regional bank with 3,200 staff already enforces `p=reject` on its own domain. At 08:40 on a Monday, 140 employees receive an 'MFA device re-verification' email from `bank-secure-login.example`, a domain registered four days earlier. Within 20 minutes nine people click and two enter their username, password and one-time code on a reverse-proxy page that relays them to the real login portal. The SOC learns of it from three user reports.

1. Why did the bank's DMARC policy not block this campaign?
2. What should the SOC do in the first hour, in order?
3. Which detections would have caught the campaign earlier?
4. Which longer-term control removes the value of the stolen credentials?

Model answer: module answer key.

Copyright © ZyeemZia

SCENARIO · DECIDE · A NEW MARKETING PLATFORM WANTS TO SEND AS THE BANK

Marketing has signed with a bulk-email provider and wants campaigns to show `From: offers@bank.example`. The domain is at `p=reject` and SPF already uses nine DNS lookups. What is the best approach?

(A) Have the provider DKIM-sign with a bank.example selector you publish, or send from a subdomain with its own SPF, DKIM and DMARC.

(B) Lower the policy to p=none until the campaign ends, then return to reject once the vendor's mail is no longer needed for marketing.

(C) Add the provider's include to SPF anyway, because receivers rarely enforce the ten-lookup limit in practice.

(D) Ask the provider to use its own domain in the From header and add the bank's logo so customers trust it.

Circle your choice. Answer and feedback: module answer key.

Email authentication health check

☐ SPF ends in `-all` and stays under 10 DNS lookups

☐ Every legitimate sender DKIM-signs with your domain using keys of at least 2048 bits

☐ DKIM selectors are rotated on a schedule and old keys are removed

☐ DMARC is at `p=reject` with `sp=reject` for subdomains

☐ Aggregate reports are parsed and reviewed at least monthly

☐ Parked domains publish null MX, `v=spf1 -all` and DMARC reject

☐ Lookalike-domain monitoring is in place for your main brands

Key terms

SPF

Sender Policy Framework: a DNS TXT record listing the hosts authorised to send mail for an envelope domain.

DKIM

DomainKeys Identified Mail: a cryptographic signature over selected headers and the body, verified with a public key published in DNS.

DMARC alignment

The requirement that the domain validated by SPF or DKIM matches the domain in the visible From header.

Key takeaways

- SPF authorises sending IPs for the envelope domain; DKIM signs content with a key in DNS; DMARC requires one of them to pass in alignment with the visible From.
- Roll DMARC out from p=none with reports to quarantine and reject, and protect parked domains with null MX, SPF -all and DMARC reject.
- Prefer DKIM alignment for third-party senders: it survives forwarding and avoids the SPF ten-lookup limit.
- Lookalike domains pass every check, so layer link analysis, new-domain detection, user reporting and phishing-resistant MFA.

KNOWLEDGE CHECK

Copyright © ZyeemZia

11. A message shows `spf=pass` for `mailer.crm-provider.example` and `dkim=none`, with a From address at `bank.example`. The bank publishes `p=reject`. What happens at a DMARC-enforcing receiver?

    (A) DMARC passes because SPF passed and DKIM is optional when SPF succeeds

    (B) DMARC fails because the passing SPF domain does not align with the From domain

    (C) DMARC passes because the CRM provider is a trusted sender for the bank

    (D) DMARC is skipped because DKIM returned none rather than an explicit fail

12. Which record correctly states that a parked domain sends no email?

    (A) v=spf1 -all

    (B) v=spf1 +all

    (C) v=spf1 ~all mx

    (D) v=DKIM1; p=none

13. Why is DKIM alignment usually preferred over SPF alignment for third-party senders?

    (A) DKIM encrypts the message body, so content is protected from inspection

    (B) DKIM is checked before SMTP starts, so rejected mail never uses bandwidth

    (C) DKIM survives forwarding and avoids consuming the SPF ten-lookup budget

    (D) DKIM records do not need DNS, so they cannot be broken by zone changes

14. A phishing email from a newly registered lookalike domain passes SPF, DKIM and DMARC. Which control is best placed to catch it?

    (A) Raising the bank's own DMARC policy from quarantine to reject

    (B) Adding the lookalike domain's IP address to the bank's SPF record

    (C) Shortening the TTL on the bank's DMARC record to 300 seconds

    (D) Lookalike and new-domain detection combined with link analysis

15. During DMARC rollout, what is the main purpose of starting at `p=none` with a `rua` address?

    (A) To stop spoofed mail immediately while allowing legitimate mail through

    (B) To discover every legitimate sender before enforcement can block their mail

    (C) To encrypt aggregate reports so only the domain owner can read them

    (D) To satisfy receivers that will not accept quarantine as a first policy

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 5 · DETECT · LESSON 4 · 40 MIN

Web, URL Filtering and DNS-Layer Security

Control where users and workloads can go, and use DNS as an early, cheap and universal checkpoint

- Design a URL category and reputation policy with a sensible decryption strategy.
- Deploy protective DNS with a response policy zone and control encrypted DNS bypass.
- Recognise DNS patterns that indicate tunnelling, generated domains and command-and-control.

Most attacks touch the web or DNS at some point: delivering a payload, harvesting credentials, calling home or leaking data. Web and DNS controls see those moments. Module 6 covers the cloud-delivered secure web gateway as part of SSE; here we focus on **policy**: what to allow, block, isolate and decrypt, and how to make DNS itself a detection and prevention layer.

Web and DNS defence stack

User and browser	`Managed browser policies` `Extension control` `Remote browser isolation for risky sites`
URL policy	`Categorisation` `Allow, block, warn, isolate` `Per-group exceptions`
Reputation and intelligence	`Domain age` `Threat feeds` `Lookalike detection`
Selective TLS inspection	`Decrypt by risk` `Do-not-decrypt for privacy categories` `Pinning exceptions`
Content inspection	`Anti-malware` `Sandbox` `Data loss prevention`
DNS layer	`Protective resolver` `Response policy zone` `Query logging`

A starting URL category policy

CATEGORY	ACTION	RATIONALE
Malware, phishing, command-and-control	Block	No business need and high risk
Newly registered domains (under 30 days)	Block or isolate	Most new domains used in attacks are very young
Uncategorised	Isolate or warn	Unknown risk; isolation preserves productivity
Personal webmail and file sharing	Allow, block uploads	Reduces data loss without blocking access
Finance, health, government	Allow, do not decrypt	Privacy and legal obligations
Software updates and sanctioned SaaS	Allow, do not decrypt where pinned	Avoids breaking apps that pin certificates

Copyright © ZyeemZia

WATCH OUT · DECRYPT BY RISK, NOT BY DEFAULT

TLS inspection is powerful but raises privacy, legal and works-council questions, breaks applications that pin certificates, and turns the inspection CA into a crown jewel. Write a decryption policy that names the categories you decrypt, the ones you never decrypt, who approves exceptions and how the signing key is protected. Log the decision for every session so audits can prove the policy was followed.

DNS-layer security uses a protective resolver to refuse or redirect lookups for known-bad or high-risk domains. It acts before any connection is attempted, applies to every protocol and port, needs no decryption and is cheap to run. Its limits are equally clear: malware that connects to hard-coded IP addresses or uses its own encrypted DNS bypasses it, so you must also enforce **which** resolvers devices may use.

Protective DNS with a response policy zone

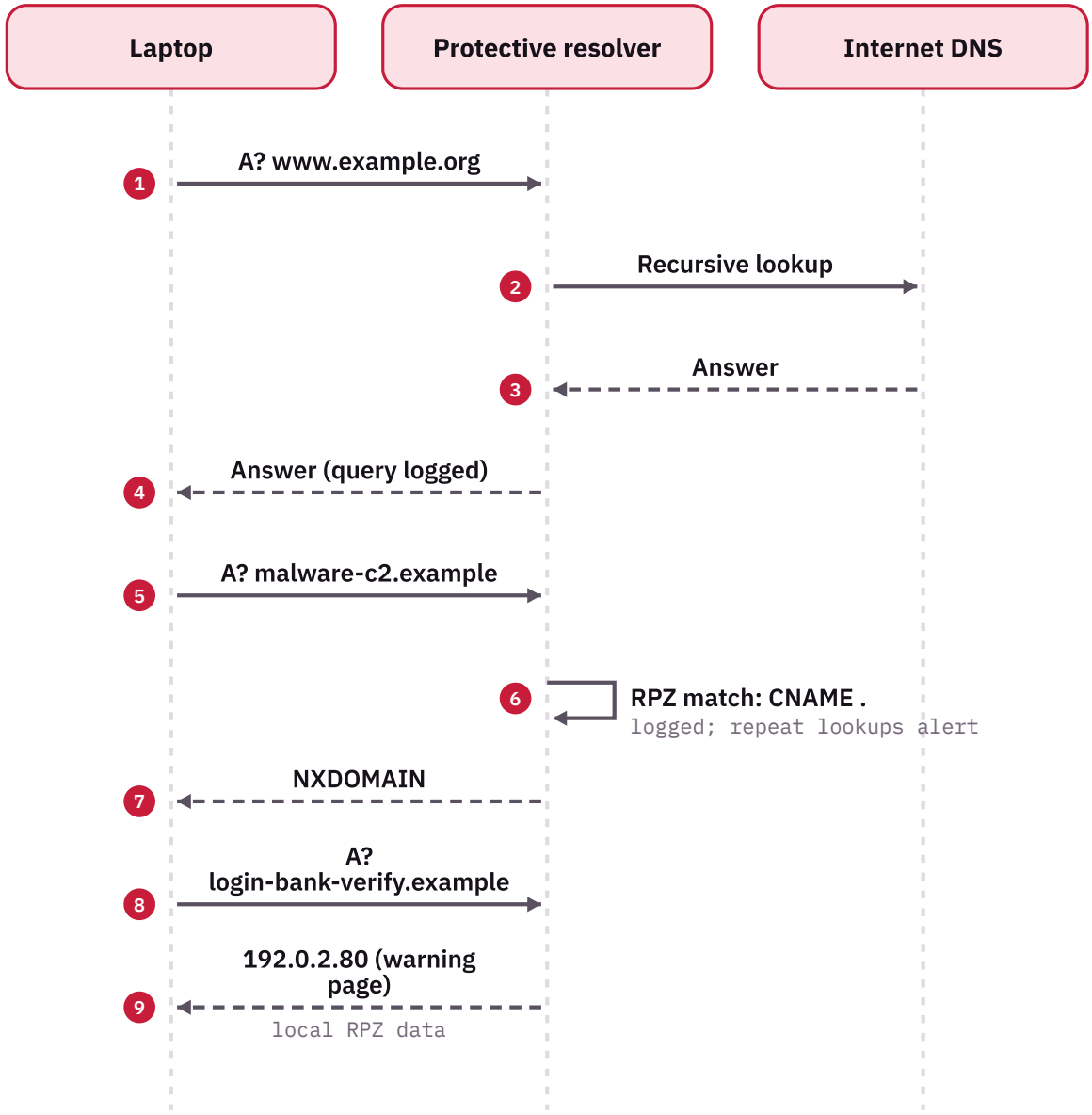
Resolver NS1 · BIND-style configuration

```
# named.conf: attach the policy zone to the resolver
options { response-policy { zone "rpz.corp.example"; }; };
zone "rpz.corp.example" { type primary; file "db.rpz.corp.example"; };
# db.rpz.corp.example (SOA and NS records omitted)
malware-c2.example             CNAME .
*.malware-c2.example           CNAME .
login-bank-verify.example      A     192.0.2.80
*.parked-ads.example           CNAME *.
updates.trusted-vendor.example CNAME rpz-passthru.
```

`CNAME .` *returns NXDOMAIN,* `CNAME *.` *returns an empty answer (NODATA), an A record redirects to a sinkhole or warning page, and* `rpz-passthru.` *exempts a name from later rules. Wildcards must be listed separately to cover subdomains.*

Copyright © ZyeemZia

Three lookups through a protective resolver



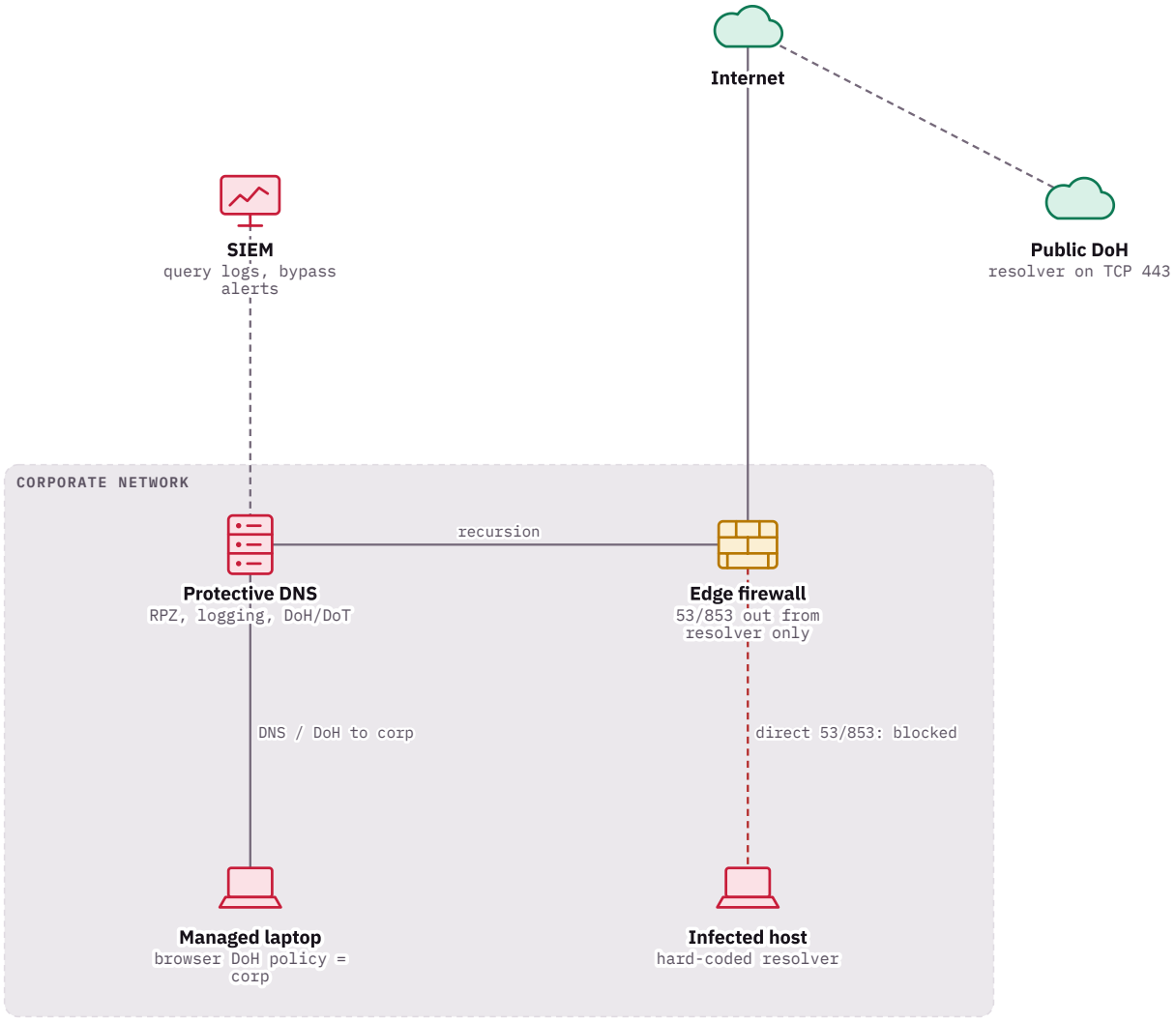
Normal names resolve as usual, a blocked name gets a rewritten NXDOMAIN and a phishing name is steered to a warning page. Every query is logged, so the same resolver is also a detection sensor.

Stopping encrypted DNS from bypassing your controls

1. **Allow port 53 only to your resolvers** Block outbound DNS from every other internal host at the edge firewall.
2. **Block DNS over TLS** Deny TCP 853 to the internet except from approved resolvers.
3. **Control DNS over HTTPS** Block known public DoH endpoints with the web gateway's category and set managed browsers to use the corporate resolver.
4. **Answer the browser canary** Return NXDOMAIN for `use-application-dns.net` so browsers that honour it disable automatic DoH.
5. **Alert on bypass** Flag hosts that resolve nothing internally yet open many outbound connections.
6. **Encrypt to your own resolver** Offer DoH or DoT on the corporate resolver itself and advertise it (for example with Discovery of Designated Resolvers, RFC 9462) so clients gain privacy without leaving your policy.

Copyright © ZyeemZia

Keeping every lookup on the protective resolver



Managed devices resolve only through the protective resolver, which is the only host allowed to send DNS to the internet. Direct port 53 and 853 attempts die at the firewall, and public DoH endpoints are blocked by category at the web gateway, which turns bypass attempts into alerts.

DNS signals worth detecting

- Bursts of **NXDOMAIN** answers from one host, typical of domain generation algorithms
- Long, high-entropy subdomains and heavy TXT or NULL queries to one domain, typical of DNS tunnelling (T1071.004)
- First-seen and newly registered domains, especially right after an email click
- Hosts querying external resolvers directly instead of the corporate resolver
- Regular, clock-like lookups of the same name from one host, typical of beaconing

Copyright © ZyeemZia

Hunting for tunnelling in DNS logs

Analyst workstation · Zeek dns.log

```
$ zeek-cut ts id.orig_h query qtype_name rcode_name < dns.log | awk 'length($3) > 60'
1773480011.21  10.20.7.44  mzxw6ytboi2dqnbsgezdgnjwg44dsmjqgeztk.t.cdn-sync.example  TXT  NOERROR
1773480011.73  10.20.7.44  nbswy3dpeb3w64tmmqqgczlomrqw45lsfzxgk4tf.t.cdn-sync.example  TXT
NOERROR
1773480012.25  10.20.7.44  orsxg5dfeb3w64tmmrxgk5dpnvxwg2lt.t.cdn-sync.example  TXT  NOERROR
$ zeek-cut id.orig_h query < dns.log | grep -c 'cdn-sync.example'
48213
```

One host, one parent domain, long base32-looking labels, TXT records and tens of thousands of queries: classic tunnelling indicators. Confirm with the endpoint process that issued them before declaring an incident.

SCENARIO · DECIDE · POSSIBLE DNS TUNNELLING

The hunt above shows workstation 10.20.7.44 sending about two TXT queries per second with encoded subdomains to `cdn-sync.example` for three days. No other host queries the domain. What is the best next action?

(A) Reimage the workstation immediately so the tunnelling software is removed before it can send anything more.

(B) Keep watching for another week to see what data is being sent before taking any action.

(C) Email the user to ask whether they installed any unusual software recently, and wait for their reply before acting.

(D) Block the domain at the RPZ, contain the host through EDR, preserve DNS and endpoint data, and search for any other host that has queried the domain.

Circle your choice. Answer and feedback: module answer key.

Key terms

Protective DNS
A recursive resolver that refuses or redirects lookups for malicious or high-risk domains and logs every query.

Response policy zone (RPZ)
A DNS zone whose records instruct a resolver to rewrite answers, for example to NXDOMAIN or a sinkhole address.

Key takeaways

- Write URL policy by category and risk: block, isolate, warn or allow, with uploads controlled separately.
- Decrypt by risk under a written policy; never decrypt privacy categories or pinned applications.
- Protective DNS acts before any connection on any port, but only if every device is forced to use it.
- NXDOMAIN bursts, long high-entropy labels, TXT floods and clock-like lookups point to DGA, tunnelling and beaconing.

KNOWLEDGE CHECK

16. In a response policy zone, what is the effect of the record `phish.example CNAME .`?

(A) The resolver returns NXDOMAIN for phish.example

(B) The resolver returns an empty answer for phish.example

(C) The resolver forwards phish.example to the root servers

(D) The resolver exempts phish.example from all other policy

Copyright © ZyeemZia

17. Why does DNS-layer blocking provide protection for protocols the web gateway never sees?

(A) The resolver decrypts all application traffic after resolving the destination name

(B) DNS blocking installs a host firewall rule on each endpoint that resolves a name

(C) The resolver acts as a transparent proxy for every connection that follows the lookup

(D) Every protocol that uses a domain name must resolve it first, whatever port it uses

18. Which pattern most strongly suggests a domain generation algorithm on an infected host?

(A) A steady daily lookup of the same software update domain at the same hour

(B) Hundreds of NXDOMAIN answers for random-looking domains in a short period

(C) Several lookups of the corporate intranet name immediately after logon

(D) Queries for internal service records issued by the domain controllers

19. Which action best prevents managed browsers from silently bypassing the protective resolver?

(A) Block all outbound HTTPS traffic except connections to sanctioned SaaS providers

(B) Lower the TTL of every record on the corporate resolver to under 60 seconds

(C) Set browser policy to use the corporate resolver and block public DoH endpoints

(D) Publish DNSSEC signatures for every internal zone so browsers trust the resolver

20. Why should finance and health categories usually be excluded from TLS inspection?

(A) Decrypting them raises privacy and legal concerns that usually outweigh the benefit

(B) These sites never carry malware, so inspecting them only wastes gateway capacity

(C) Their certificates cannot be re-signed because they use stronger key lengths

(D) Inspection of these categories is technically impossible with TLS 1.3

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 5 · DETECT · LESSON 5 · 40 MIN

Endpoint Detection, XDR and Deception

Use endpoint telemetry, cross-domain correlation and decoys to catch what the network cannot see

- Distinguish endpoint protection, EDR and XDR by data, analytics and response scope.
- Map key endpoint telemetry to ATT&CK techniques and graduated response actions.
- Explain deception and honeytokens at concept level, with the guardrails they need.

Encryption and remote work have moved the best vantage point from the wire to the **endpoint** and the **identity provider**. Endpoint detection and response records what processes do, who launched them and what they touched, and it lets responders act on a host in seconds. Extended detection and response (XDR) correlates that with identity, email, network and cloud signals so one incident is shown as one story rather than fifty alerts.

EPP, EDR and XDR

Endpoint protection (EPP)

- Prevents known malware and exploits
- Signatures, reputation, machine-learning file scoring
- Mostly block-or-allow decisions
- Little investigation history

Endpoint detection and response (EDR)

- Continuous recording of process, file, registry and network events
- Behavioural detections mapped to ATT&CK
- Host isolation and remote investigation
- Searchable history for hunting

Extended detection and response (XDR)

- Adds identity, email, network and cloud telemetry
- Correlates alerts into incidents across domains
- Coordinated response across several control points
- Value depends on how many sources it really integrates

How XDR fuses telemetry

Response	`Isolate host` `Revoke session` `Purge email` `Block indicator`
Correlation and analytics	`Entity graph of user, host and process` `Incident grouping` `Risk scoring`
Normalised data store	`Common schema` `Hot retention for hunting`
Telemetry sources	`Endpoint` `Identity provider` `Email` `Network detection (NDR)` `Cloud and SaaS`

Endpoint telemetry that pays for itself

TELEMETRY	EXAMPLE SIGNAL	ATT&CK TECHNIQUE
Process creation with command line	Script interpreter launched by an office application	T1059.001 PowerShell
Access to the credential store process	Unexpected process reading LSASS memory	T1003.001 LSASS Memory
Persistence locations	New registry run key or scheduled task	T1547.001 / T1053.005
Recovery tampering	Shadow copies deleted or backups disabled	T1490 Inhibit System Recovery

Copyright © ZyeemZia

TELEMETRY	EXAMPLE SIGNAL	ATT&CK TECHNIQUE
Mass file modification	Hundreds of files rewritten and renamed per minute	T1486 Data Encrypted for Impact
Network connection by process	Unsigned binary beaconing every 60 seconds	T1071 Application Layer Protocol

A critical EDR alert

EDR console · alert export (JSON)

```
{
  "alert": "Shadow copy deletion by child of document viewer",
  "host": "HR-LT-0193", "user": "CORP\\j.mendes",
  "process": "vssadmin.exe", "cmdline": "vssadmin delete shadows /all /quiet",
  "parent": "cmd.exe", "grandparent": "invoice_viewer.exe",
  "attack": ["T1490"], "severity": "critical",
  "response": "host isolated by policy auto-contain-critical"
}
```

Process lineage is the story: a document viewer spawning a shell that deletes recovery points is a classic precursor to ransomware encryption. Automatic isolation buys time; the analyst now scopes the user, host and any lateral movement.

Graduated endpoint response actions

1. **Isolate** Cut the host off from everything except the EDR management channel.
2. **Stop** Kill the malicious process tree and quarantine the files involved.
3. **Collect** Pull a triage package: running processes, memory image if needed, event logs, autoruns.
4. **Block** Push the hash, domain or certificate as an indicator across the fleet.
5. **Remediate** Remove persistence, roll back changes where supported, or reimage.
6. **Release** Return the host to the network only after validation and a monitoring period.

> **PRO TIP · PROTECT THE SENSOR ITSELF**
> Attackers try to stop or blind endpoint agents. Enable tamper protection, require a secret or approval to uninstall, alert when an agent goes silent or its policy changes, and report coverage weekly against the asset inventory. A missing agent is a finding, not a footnote.

Deception places assets that no legitimate user or process should ever touch: decoy servers, fake credentials cached on endpoints, canary documents and unused DNS names. Because there is no legitimate reason to interact with them, any interaction is a high-fidelity signal, often appearing early in lateral movement when attackers enumerate and test what they find.

Deception building blocks

DCY
Decoy systems
Low-interaction hosts or services that look like real servers on internal segments and alert on any connection.

TOK
Honeytokens
Fake credentials, API keys or database rows planted where an attacker would harvest them; any use triggers an alert.

DOC
Canary documents
Files that signal home when opened, placed in sensitive shares to reveal browsing and theft.

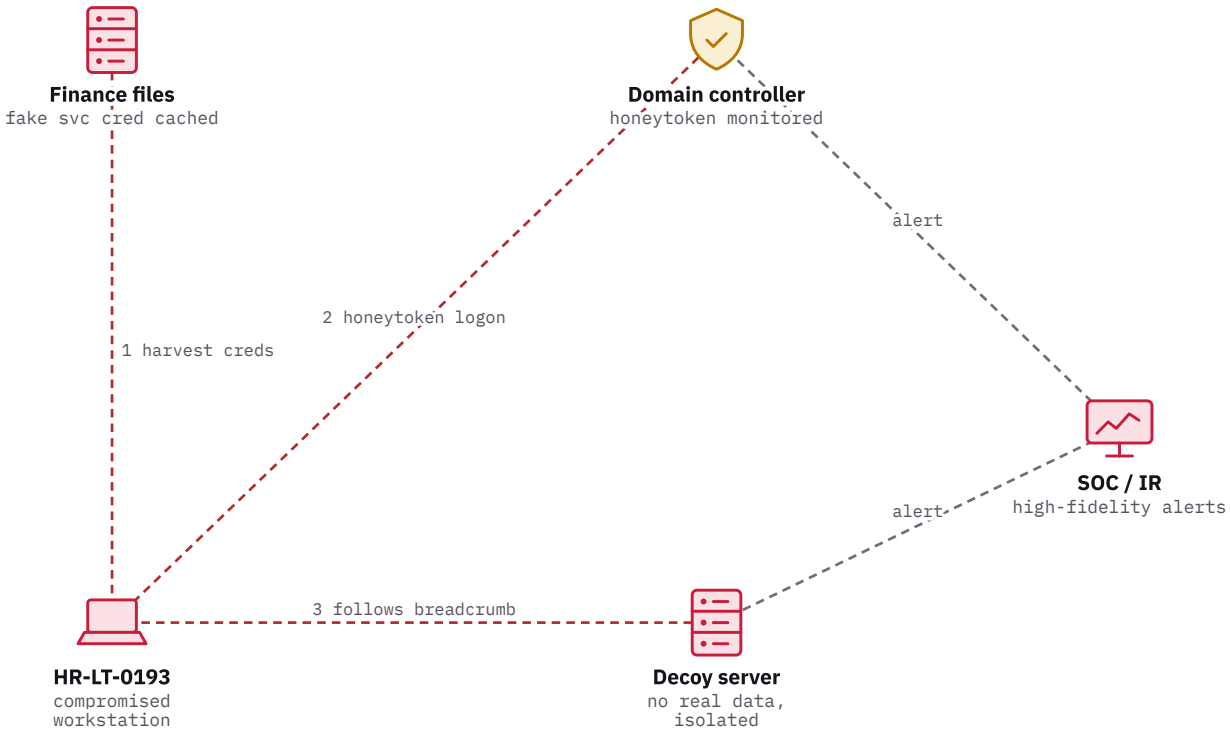
Copyright © ZyeemZia

BRD

Breadcrumbs

Pointers such as saved connections or config entries that lead an intruder towards decoys rather than real assets.

Deception on an attacker's path



The intruder cannot tell real from fake: the harvested service credential and the breadcrumb both lead to traps. Any use of either is an alert with almost no false positives, raised early in lateral movement.

WATCH OUT · GUARDRAILS FOR DECEPTION

Isolate decoys so they can never be used as a stepping stone, keep them free of real data, agree the programme with legal, HR and privacy teams, document who may know where decoys are, and route alerts straight to incident response. Deception is a detection control; it never authorises any action against the intruder's own systems.

Copyright © ZyeemZia

SCENARIO · DECIDE · A HONEYTOKEN FIRES AT 02:10

A fake service-account credential that exists only in the cached credentials of a finance file server is used to attempt a logon to a domain controller from workstation 10.30.2.77 at 02:10. What should the SOC do?

(A) Reset the fake account's password and close the alert, because the account has no real privileges anywhere.

(B) Treat it as a confirmed intrusion: contain the source host, find how the credential was harvested and scope lateral movement.

(C) Open a low-priority ticket for the morning shift, because nothing was actually accessed with the credential.

(D) Ask the finance team whether anyone was testing scripts overnight before deciding whether to investigate.

Circle your choice. Answer and feedback: module answer key.

Endpoint and XDR coverage review

☐ Agent installed and reporting on every managed server, laptop and VDI image

☐ Tamper protection enabled and agent-silence alerts routed to the SOC

☐ Command-line and script-block logging enabled on all hosts

☐ Isolation tested quarterly on a sample of hosts per business unit

☐ Identity, email and cloud sources connected to the XDR or SIEM

☐ Decoys and honeytokens documented, isolated and owned by incident response

REFLECT

Which of your critical segments could an attacker cross today without generating a single high-fidelity alert? Which combination of endpoint telemetry, network sensing and deception would change that?

Key terms

EDR
Endpoint detection and response: continuous recording of endpoint activity with behavioural detection and remote response actions.

XDR
Extended detection and response: correlation and response across endpoint, identity, email, network and cloud telemetry.

Honeytoken
A fake credential, key or record with no legitimate use, planted so that any attempt to use it reveals an intruder.

Copyright © ZyeemZia

Key takeaways

- EPP blocks known bad, EDR records and responds on the host, XDR correlates endpoint, identity, email, network and cloud.
- Process lineage and ATT&CK-mapped telemetry turn single events into an attack story.
- Respond in graduated steps (isolate, stop, collect, block, remediate, release) and protect the agent from tampering.
- Deception gives high-fidelity alerts because nothing legitimate touches decoys; isolate them and route alerts straight to IR.

KNOWLEDGE CHECK

21. What most clearly distinguishes EDR from traditional endpoint protection?

(A) Continuous recording of activity with investigation and response actions
(B) The ability to block known malware by file hash before it executes
(C) A larger library of antivirus signatures updated several times a day
(D) Scanning removable media automatically when it is first connected

22. An XDR platform is connected only to endpoints. What is the main consequence?

(A) It cannot isolate hosts because isolation requires a network sensor
(B) It cannot use ATT&CK mappings because those need email telemetry
(C) It cannot keep any historical data without a separate SIEM licence
(D) It cannot join identity, email or cloud events into one incident

23. A document viewer spawns `cmd.exe`, which runs `vssadmin delete shadows /all /quiet`. Which technique is this?

(A) T1003 OS Credential Dumping
(B) T1566.001 Spearphishing Attachment
(C) T1490 Inhibit System Recovery
(D) T1021 Remote Services

24. Why do honeytokens produce high-fidelity alerts?

(A) They are protected by stronger encryption than real credentials
(B) No legitimate user or process has any reason to use them
(C) They are monitored by a separate SOC with more experienced staff
(D) They only trigger when malware with a known signature uses them

25. Which practice is essential when deploying decoy servers?

(A) Copying real customer data into them so the decoys look convincing
(B) Announcing their addresses to all staff so nobody connects by mistake
(C) Isolating them so they cannot be used as a stepping stone to real systems
(D) Configuring them to scan back any host that connects to them

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 5 · DETECT

Answer key

Knowledge checks

1. B Mirror ports are best-effort; when the mirrored links exceed the destination port's capacity, frames are dropped silently. A passive TAP or packet broker avoids this. A SPAN-attached sensor cannot block, and rules do not change session counts.

2. C A new tool has no signature or hash yet and may use internal addresses with no reputation. The behaviour of creating services across many hosts in a short time remains suspicious whichever tool performs it.

3. A Enforcement depends on the engine running in inline (IPS) mode. In passive mode a drop rule behaves like an alert. Revision numbers and thresholds do not enable blocking, and drop works for UDP too.

4. D An IDS false positive wastes analyst time; an IPS false positive drops real business traffic. That is why prevention policies are narrower and promoted only after tuning.

5. B Encrypted Client Hello hides the real server name, so SNI-matching rules become far less useful. Endpoint telemetry, flow analytics and gateway decryption are unaffected or still workable.

6. A High recall means few misses; a 98% benign closure rate means precision around 2%. The rule works but drowns analysts, so the fix is tuning, not removal and not blaming staff.

7. D Suppressing per source removes known noise while keeping the rules for everyone else. Global disabling loses coverage, and hiding the scanner or raising severity does nothing for quality.

8. C Rule direction and scope are written in terms of these variables. If internal ranges or server groups are wrong, otherwise correct rules fire on, or miss, the wrong flows.

9. D Environment checks and delayed execution are well-known reasons for clean sandbox verdicts. That is why sandboxes are one layer among several and why endpoint detection remains essential.

10. C The card makes the rule reviewable and maintainable: why it exists, what it maps to, what feeds it, how it was tuned, who owns it and when it was last proven to work.

11. B DMARC needs SPF or DKIM to pass **with alignment** to the header From domain. SPF passed for an unrelated domain and there is no DKIM, so DMARC fails and the reject policy applies.

12. A `v=spf1 -all` authorises no senders and hard-fails everything. `+all` authorises everyone, `~all mx` permits the MX hosts, and an empty DKIM key is not an SPF statement.

13. C A DKIM signature stays valid across most forwarding and does not count against SPF's DNS lookup limit. DKIM signs, it does not encrypt, and its keys live in DNS.

14. D The bank's own records do not govern another domain's mail. Domain-age and lookalike analysis plus URL inspection target exactly this pattern.

15. B `p=none` takes no action on failures; it exists to collect aggregate reports so you can fix legitimate senders before quarantine and reject.

16. A `CNAME .` means NXDOMAIN, `CNAME *.` means NODATA and `rpz-passthru.` exempts the name. There is no forwarding to the root servers.

17. D Resolution happens before a connection on any port. A resolver neither decrypts nor proxies traffic, which is also why direct-to-IP connections bypass it.

18. B DGA malware tries many generated names until one is registered, producing bursts of NXDOMAIN. The other patterns are normal operational traffic.

19. C DoH runs over HTTPS, so you control it with browser policy plus endpoint blocking. Blocking all HTTPS is impractical, and TTLs and DNSSEC do not stop bypass.

20. A The exclusion is a privacy and legal decision. Any site can host malware, key length does not prevent re-signing and TLS 1.3 can be inspected by a forward proxy.

21. A Hash blocking, signature libraries and removable-media scanning are EPP features. EDR adds the recorded history, behavioural detection and host-level response.

22. D XDR's value is cross-domain correlation. With only endpoint data it behaves like EDR; host isolation and ATT&CK mapping still work.

23. C Deleting shadow copies removes recovery points, mapped to T1490 and often seen just before encryption (T1486).

24. B Fidelity comes from the absence of legitimate use. Any interaction is suspicious by design, whatever tool the intruder uses.

25. C Decoys must never become a pivot, must contain no real data and must not take action against connecting hosts. Their location is need-to-know.

Copyright © ZyeemZia

Scenarios & case studies

Scenario · Protecting a latency-sensitive trading segment
C is best. Best. It respects the availability requirement, measures real latency before blocking, and limits drop actions to rules whose false-positive rate you have proven.

Scenario · A rule that fires 4,000 times a day
B is best. Best. The narrowest change removes the known noise and preserves the rule's demonstrated value everywhere else.

Case study · Phishing wave at a regional bank
DMARC protects only the bank's own domain; the attacker used a different domain with valid authentication, so every check passed. In the first hour: pull the message from all mailboxes by sender and subject, block the domain and its URLs at the email gateway, web gateway and protective DNS, identify every clicker from proxy and DNS logs, revoke sessions and tokens and reset credentials for the two victims, check sign-in logs for logins from unusual locations and new MFA registrations, and preserve message samples and logs. Earlier detection would come from newly registered and lookalike-domain rules, link analysis at delivery and click time, and correlation of several user reports within minutes. Longer term, phishing-resistant MFA (FIDO2 or certificate-based) defeats relay pages because the authenticator is bound to the real site's origin.

Scenario · A new marketing platform wants to send as the bank
A is best. Best. DKIM alignment avoids the SPF lookup limit, and a subdomain isolates marketing reputation from transactional mail.

Scenario · Possible DNS tunnelling
D is best. Best. It stops the channel, keeps evidence, limits spread and checks scope across the estate in one coordinated response.

Scenario · A honeytoken fires at 02:10
B is best. Best. A honeytoken has no legitimate use, so this is a high-fidelity indicator that someone harvested credentials from the server.

Copyright © ZyeemZia

06

MODULE 6 · CLOUD

Cloud — Cloud, SASE & SSE

Secure what you own in the cloud and deliver security from the cloud to every user, branch and application.

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Allocate cloud security responsibilities correctly and design layered cloud network controls.
- Use posture management and guardrails to find and prevent misconfiguration.
- Design SASE and SSE services, choosing steering methods and CASB modes for each risk.
- Replace network-level remote access with ZTNA and redesign branches for direct-to-cloud.
- Protect SaaS tenants and APIs against misconfiguration, consent abuse and authorisation flaws.

LESSONS

1. Shared Responsibility and Cloud Network Controls · 40 min
2. SASE and SSE: Architecture, Secure Web Gateway and CASB · 40 min
3. ZTNA versus VPN and Branch-to-Cloud Design · 40 min
4. Securing SaaS and APIs · 40 min

MODULE 6 · CLOUD · LESSON 1 · 40 MIN

Shared Responsibility and Cloud Network Controls

Know exactly what you own in each service model, then build and police cloud network boundaries

- Allocate security duties correctly across IaaS, PaaS and SaaS.
- Contrast security groups and network ACLs and combine them in a tiered design.
- Explain how cloud posture management finds and prevents misconfiguration.

In the cloud the provider secures the infrastructure you cannot touch, and you secure everything you configure. Most cloud breaches are not provider failures; they are customer misconfigurations such as a public storage bucket, an over-privileged role or a management port open to the world. The **Cloud** layer of the stack starts with an exact map of who owns what.

Shared responsibility by service model

LAYER	IAAS	PAAS	SAAS
Data and its classification	Customer	Customer	Customer
Identities, roles and access policy	Customer	Customer	Customer
Application code and configuration	Customer	Customer	Provider code, customer settings
Guest operating system and patching	Customer	Provider	Provider
Virtual network controls	Customer	Shared	Provider
Hypervisor, hardware, physical sites	Provider	Provider	Provider

INSIGHT · THREE THINGS NEVER MOVE TO THE PROVIDER

Whatever the model, you always own your **data**, your **identities** and your **configuration choices**. A provider can give you encryption, logging and guardrails, but you decide whether they are switched on and who can change them.

Security groups versus network ACLs

Security group

- Attached to an instance or network interface
- **Stateful**: return traffic is allowed automatically
- Typically allow rules only; anything unmatched is denied
- All rules evaluated together
- Can reference other groups instead of IP ranges

Network ACL

- Applied at the subnet boundary
- **Stateless**: return traffic needs its own rule, often ephemeral ports
- Allow **and** deny rules
- Evaluated in numbered order, first match wins
- Good for coarse blocks such as denying a hostile range

DEFINITION · A NOTE ON PROVIDERS

The comparison above describes the most common cloud model. Some providers let security groups include deny rules and priorities, or call them network security groups. Always confirm statefulness, evaluation order and default behaviour in the platform you are designing for.

Copyright © ZyeemZia

A three-tier boundary as provider-neutral policy

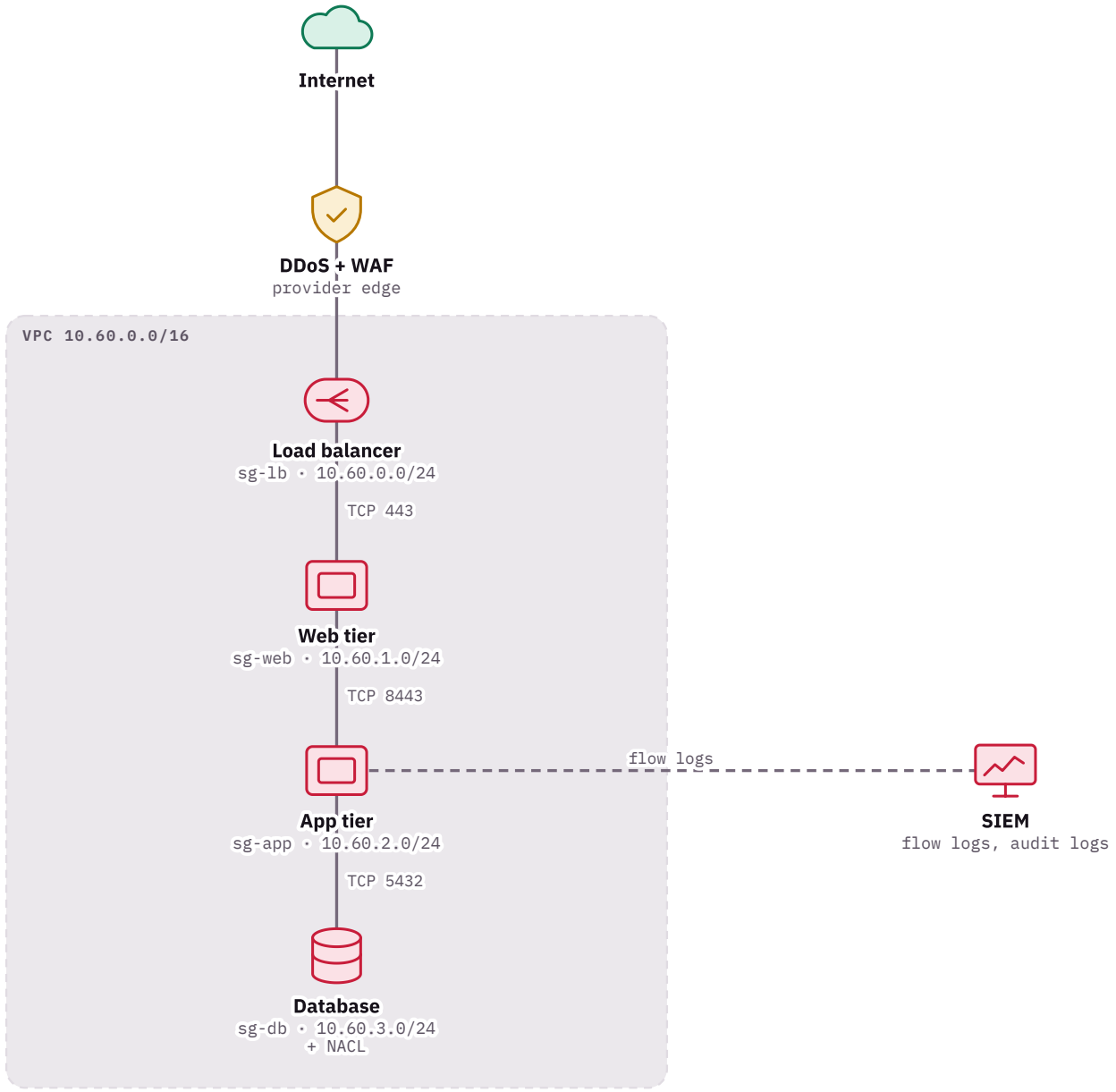
Cloud policy file · network.yaml (illustrative)

```
security_groups:
  sg-web: { ingress: [ {proto: tcp, port: 443, source: sg-lb} ] }
  sg-app: { ingress: [ {proto: tcp, port: 8443, source: sg-web} ] }
  sg-db:  { ingress: [ {proto: tcp, port: 5432, source: sg-app} ] }
network_acls:
  nacl-db-subnet:
    inbound:
      - {rule: 100, proto: tcp, port: 5432, cidr: 10.60.2.0/24, action: allow}
      - {rule: 900, proto: all, cidr: 0.0.0.0/0, action: deny}
    outbound:
      - {rule: 100, proto: tcp, ports: 1024-65535, cidr: 10.60.2.0/24, action: allow}
      - {rule: 900, proto: all, cidr: 0.0.0.0/0, action: deny}
```

Security groups chain tiers by group reference, so scaling out never requires an IP change. The stateless subnet ACL needs an explicit outbound rule for return traffic on ephemeral ports back to the app subnet.

Copyright © ZyeemZia

Inbound path to a three-tier cloud workload



Each tier admits only the tier above it by security-group reference, so scaling out changes nothing. The stateless subnet ACL around the database is a second, coarse filter, and flow logs leave the VPC for the SIEM.

Cloud security posture management (CSPM) continuously reads the configuration of every account and subscription and compares it with policy and benchmarks: public storage, unencrypted volumes, missing logging, open management ports, unused keys. Mature programmes go further, scanning infrastructure-as-code before deployment and applying **preventive guardrails** at the organisation level so certain mistakes cannot be made at all. Platforms that merge these functions are often called cloud-native application protection platforms (CNAPP).

Copyright © ZyeemZia

The cloud posture family

CAPABILITY	FOCUS	TYPICAL FINDING
CSPM	Configuration of cloud resources	Storage bucket readable by anyone
CIEM	Cloud identities and entitlements	Role with wildcard permissions unused for 90 days
CWPP	Workloads: VMs, containers, serverless	Container image with a critical vulnerability
IaC scanning	Templates before deployment	Template opens port 22 to 0.0.0.0/0
DSPM	Where sensitive data lives and who can reach it	Customer records copied into a test account

A posture finding

Posture console · finding export (JSON)

```
{
  "finding": "Object storage allows public read",
  "resource": "bucket/hr-exports-2026", "account": "prod-hr",
  "severity": "high", "control": "DS-03 Data stores must not be public",
  "first_seen": "2026-06-02T07:14:00Z", "data_classification": "confidential",
  "remediation": "Enable account-level public access block; remove public grant"
}
```

SCENARIO · DECIDE · SSH OPEN TO THE WORLD

A developer opened TCP 22 from 0.0.0.0/0 on a production security group to troubleshoot a failing deployment. The posture tool flagged it 30 minutes later. What is the best response?

(A) Remove the rule, give engineers brokered just-in-time access, and add a guardrail that blocks internet-facing management ports.

(B) Leave the rule but restrict it to the developer's current home IP address so troubleshooting can continue.

(C) Delete the developer's cloud access and report the incident to HR as a policy violation.

(D) Raise the posture tool's alert threshold so that temporary troubleshooting rules no longer generate any high-severity findings at all.

Circle your choice. Answer and feedback: module answer key.

Cloud network baseline

☐ No management ports (22, 3389, database ports) reachable from the internet

☐ Security groups reference other groups rather than broad CIDR ranges

☐ Flow logs enabled on every production network and sent to the SIEM

☐ Organisation-level guardrails block public storage and unencrypted volumes

☐ Infrastructure-as-code scanned in the pipeline before deployment

☐ Posture findings have owners and remediation deadlines by severity

Key terms

Shared responsibility model
The division of security duties between a cloud provider and its customer, which varies by IaaS, PaaS and SaaS.

Security group
A stateful, per-interface virtual firewall in a cloud network, usually allow-only.

Copyright © ZyeemZia

CSPM
Cloud security posture management: continuous comparison of cloud configuration with policy and benchmarks.

CNAPP
Cloud-native application protection platform: a consolidated platform combining posture, workload, identity and code-scanning functions.

Key takeaways

- You always own your data, identities and configuration, whatever the service model.
- Security groups are stateful per-interface filters; network ACLs are stateless subnet filters that need return rules.
- Chain tiers by group reference and keep management ports off the internet.
- Posture tools (CSPM, CIEM, CWPP, DSPM, IaC scanning) find mistakes; organisation guardrails prevent them.

KNOWLEDGE CHECK

1. A database subnet's network ACL allows inbound TCP 5432 from the app subnet but has no outbound allow rule. Security groups are correct. What happens?
   - (A) Connections fail because the stateless ACL drops the database's return traffic
   - (B) Connections succeed because the security group's state covers the subnet ACL as well
   - (C) Connections succeed because ACLs only evaluate traffic from the internet
   - (D) Connections fail because security groups cannot reference database ports
2. In a PaaS database service, who is normally responsible for patching the database engine's operating system?
   - (A) The customer
   - (B) The provider
   - (C) The customer's auditor
   - (D) The application developer
3. Why should tiers be linked by security group references rather than IP ranges?
   - (A) Group references are evaluated before network ACLs
   - (B) Group references encrypt traffic between the tiers
   - (C) Group references remove the need for any subnet ACLs
   - (D) Rules stay valid as instances scale and move
4. Which control prevents a misconfiguration rather than only detecting it?
   - (A) A posture scan that reports public storage within thirty minutes
   - (B) An organisation guardrail that denies creating public storage
   - (C) A monthly report of every storage bucket and its access settings
   - (D) A SIEM alert raised when a public bucket is read by an outsider
5. A posture tool flags a role with wildcard permissions that has not been used for 90 days. Which capability produced the finding?
   - (A) CWPP
   - (B) DSPM
   - (C) WAAP
   - (D) CIEM

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 6 · CLOUD · LESSON 2 · 40 MIN

SASE and SSE: Architecture, Secure Web Gateway and CASB

Deliver security as a cloud service close to users, and govern how they use SaaS

- Distinguish SASE from SSE and list the services each includes.
- Choose traffic-steering methods for a cloud secure web gateway.
- Select CASB API, forward-proxy and reverse-proxy modes for specific risks.
- Capture a SASE design in a reusable design sheet.

When users, applications and data left the data centre, the old model of hauling all traffic back to a central firewall stack became slow and expensive. **Secure access service edge (SASE)** converges wide-area networking with cloud-delivered security so policy is applied at a nearby point of presence. **Security service edge (SSE)** is the security half of SASE on its own, for organisations that keep their existing WAN or buy networking separately.

SASE versus SSE

SASE

- Networking **and** security as one service
- SD-WAN, routing and WAN optimisation
- Plus SWG, CASB, ZTNA, FWaaS and DLP
- One policy model from branch to cloud
- Best fit for WAN refresh or greenfield sites

SSE

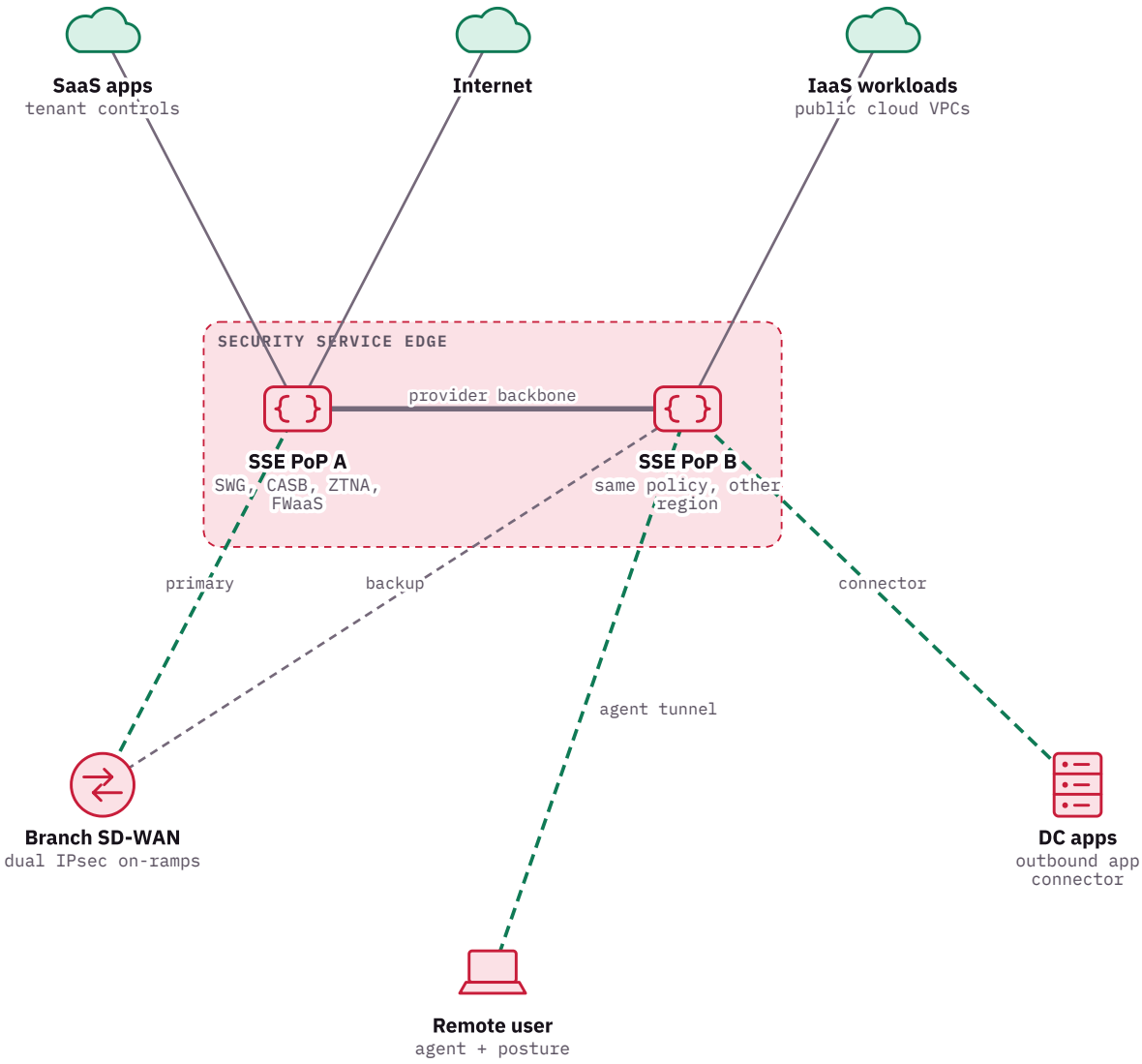
- Security services only
- SWG, CASB, ZTNA, usually FWaaS and DLP
- Works with any existing WAN or SD-WAN
- Faster to adopt for remote users
- Common first step towards full SASE

SASE reference architecture

Policy and analytics	`Single policy engine` `Unified logging` `Risk scoring`
Security service edge	`Secure web gateway` `CASB` `ZTNA` `Firewall as a service` `Data loss prevention`
Global points of presence	`Inspection close to users` `Dedicated egress IPs` `Peering with SaaS providers`
Networking	`SD-WAN` `Path selection` `WAN optimisation`
On-ramps	`Endpoint agent` `Branch tunnels` `App connectors` `Proxy settings`

Copyright © ZyeemZia

SASE: security delivered from points of presence



Every on-ramp (branch tunnels, the user agent and the outbound data-centre connector) terminates at the nearest PoP, where one policy applies before traffic reaches SaaS, the internet, IaaS or private apps. Notice that no on-ramp needs an inbound port at the data centre.

Steering traffic to a cloud secure web gateway

METHOD	STRENGTH	LIMITATION
Endpoint agent	Follows the user anywhere; steers all ports; reports device posture	Needs deployment on every managed device
IPsec or GRE tunnel from the branch	No endpoint change; covers IoT and guests	Only protects users while they are on site
PAC file or explicit proxy	Simple and agentless for browsers	Non-browser apps often ignore it; easy to bypass

Copyright © ZyeemZia

METHOD	STRENGTH	LIMITATION
Proxy chaining from an on-premises proxy	Reuses existing investment during migration	Hides the real client IP unless headers are forwarded
Enterprise (managed) browser	Enforces policy inside the browser on managed or unmanaged devices; no network change	Covers browser traffic only; another app or browser bypasses it

A proxy auto-configuration file

PAC file · proxy.pac

```
function FindProxyForURL(url, host) {
  if (isPlainHostName(host) || dnsDomainIs(host, ".corp.example"))
    return "DIRECT";
  if (isInNet(host, "10.0.0.0", "255.0.0.0"))
    return "DIRECT";
  return "PROXY gw1.sse.example:8080; PROXY gw2.sse.example:8080";
}
```

Internal names and private addresses go direct; everything else uses the nearest gateway, falling back to a second point of presence. A PAC file only steers applications that honour it, which is why agents or tunnels are preferred for full coverage.

CASB deployment modes

API mode (out of band)

- Connects to sanctioned SaaS through the provider's API
- Scans data at rest and sharing settings
- Works for any device, no latency
- Acts after the fact, not in real time

Inline forward proxy

- Traffic from managed devices via agent or tunnel
- Real-time control of uploads and downloads
- Sees unsanctioned (shadow) SaaS
- Requires TLS inspection

Inline reverse proxy

- Identity provider redirects sessions to the proxy
- Controls unmanaged devices on sanctioned apps
- No agent needed
- URL rewriting can break complex apps

What a CASB is used for

USE CASE	TYPICAL CONTROL
Shadow IT discovery	Analyse proxy and firewall logs to find unsanctioned apps and rate their risk
Data protection	DLP on uploads, downloads and sharing; label-aware policies
Tenant restriction	Allow the corporate tenant of a SaaS app but block personal tenants of the same app
Threat protection	Detect impossible travel, mass downloads and malware in shared files
Compliance	Report on data location, sharing and admin activity

PRO TIP · TENANT RESTRICTIONS CLOSE A COMMON GAP

Blocking a file-sharing domain is easy; allowing the corporate tenant while blocking personal accounts on the **same** domain is harder. Inline proxies solve it by inserting tenant-restriction headers or inspecting login requests, so staff cannot copy data from the corporate tenant to a personal one through an approved app.

Copyright © ZyeemZia

SCENARIO · DECIDE · CONTRACTORS ON UNMANAGED LAPTOPS

Two hundred contractors must use the corporate CRM from their own laptops. Security wants them to view and edit records but never download customer exports. No agent can be installed. What is the best control?

(A) Rely on API-mode CASB to find exported files in the CRM and delete them after each download.

(B) Require contractors to connect through the corporate remote-access VPN and inspect traffic at the data centre.

(C) Use identity-provider conditional access to route contractor sessions through a reverse-proxy CASB that allows browsing and blocks downloads.

(D) Publish a policy forbidding downloads and ask each contractor to sign it before access is granted.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **SASE design sheet**

Record, per user group or site, how traffic reaches the security edge and which services and policies apply.

USER GROUP OR SITE	ON-RAMP	SERVICES APPLIED	POINT OF PRESENCE AND EGRESS	KEY POLICIES	FALLBACK IF THE POP FAILS
Branch retail stores (120 sites)	*Dual IPsec tunnels from SD-WAN edge*	*SWG, FWaaS, DNS security, IPS*	*Two nearest PoPs; dedicated egress IP pair*	*Block uncategorised; POS VLAN allowed to payment processor only*	*Fail over to second PoP; fail closed for POS VLAN*

Key terms

SASE
Secure access service edge: wide-area networking and security delivered together as a cloud service.

CASB
Cloud access security broker: visibility and control over SaaS use through API integration and inline proxies.

SSE
Security service edge: the cloud-delivered security services of SASE (SWG, CASB, ZTNA, often FWaaS and DLP) without the networking.

Copyright © ZyeemZia

Key takeaways

- SASE converges SD-WAN and cloud-delivered security; SSE is the security half on its own.
- Choose on-ramps per group: agents for roaming devices, tunnels for sites, connectors for private apps, browser controls for unmanaged devices.
- Use CASB API mode for data at rest, forward proxy for managed devices in real time and reverse proxy for unmanaged devices.
- Tenant restrictions stop corporate data moving to personal accounts on the same SaaS domain.

KNOWLEDGE CHECK

6. A company is keeping its existing SD-WAN contract for five more years but needs cloud-delivered web security and ZTNA now. What should it adopt?

   (A) Full single-vendor SASE, replacing the SD-WAN
   (B) A larger data-centre firewall cluster
   (C) SSE, integrated with the existing SD-WAN
   (D) Remote-access VPN with split tunnelling

7. Which steering method best protects laptops when users work from hotels and homes?

   (A) An endpoint agent tunnelling to the nearest PoP
   (B) IPsec tunnels from every branch office router to two PoPs
   (C) A PAC file hosted on an internal web server
   (D) Proxy chaining from the data-centre proxy

8. You need to find sensitive files already shared publicly in the corporate SaaS storage. Which CASB mode fits best?

   (A) Forward proxy, inspecting new uploads in real time
   (B) Reverse proxy, rewriting the app's URLs per session
   (C) API mode, scanning data at rest and its sharing
   (D) Packet capture at the internet edge firewall

9. What does a tenant-restriction control achieve?

   (A) It limits each user to a fixed number of SaaS applications per working day
   (B) It allows the corporate instance of a SaaS app while blocking personal instances
   (C) It forces SaaS providers to store tenant data in the customer's own region
   (D) It prevents administrators from creating new tenants in the identity provider

10. Why is a PAC file alone insufficient for full SWG coverage?

    (A) Many non-browser apps ignore proxy settings and connect directly
    (B) PAC files cannot list more than one proxy server for failover purposes
    (C) PAC files force all traffic through the proxy, including internal sites
    (D) PAC files only work with IPv6 destinations and modern browsers

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 6 · CLOUD · LESSON 3 · 40 MIN

ZTNA versus VPN and Branch-to-Cloud Design

Replace network-level remote access with per-application access, and redesign branches for a cloud-first world

- Contrast ZTNA with remote-access VPN on exposure, trust and lateral-movement risk.
- Describe the ZTNA connection flow and write an application access policy.
- Design branch-to-cloud connectivity with local breakout through a security edge.

A remote-access VPN puts a device **on the network**; after login it can usually reach far more than its user needs, and the concentrator itself must listen on the internet. Zero trust network access (ZTNA) inverts this: users are connected to **specific applications**, never to networks, and applications are reached through connectors that only make outbound connections. Module 3 covered VPN design in depth; here we decide when ZTNA should replace it.

Remote-access VPN versus ZTNA

Remote-access VPN

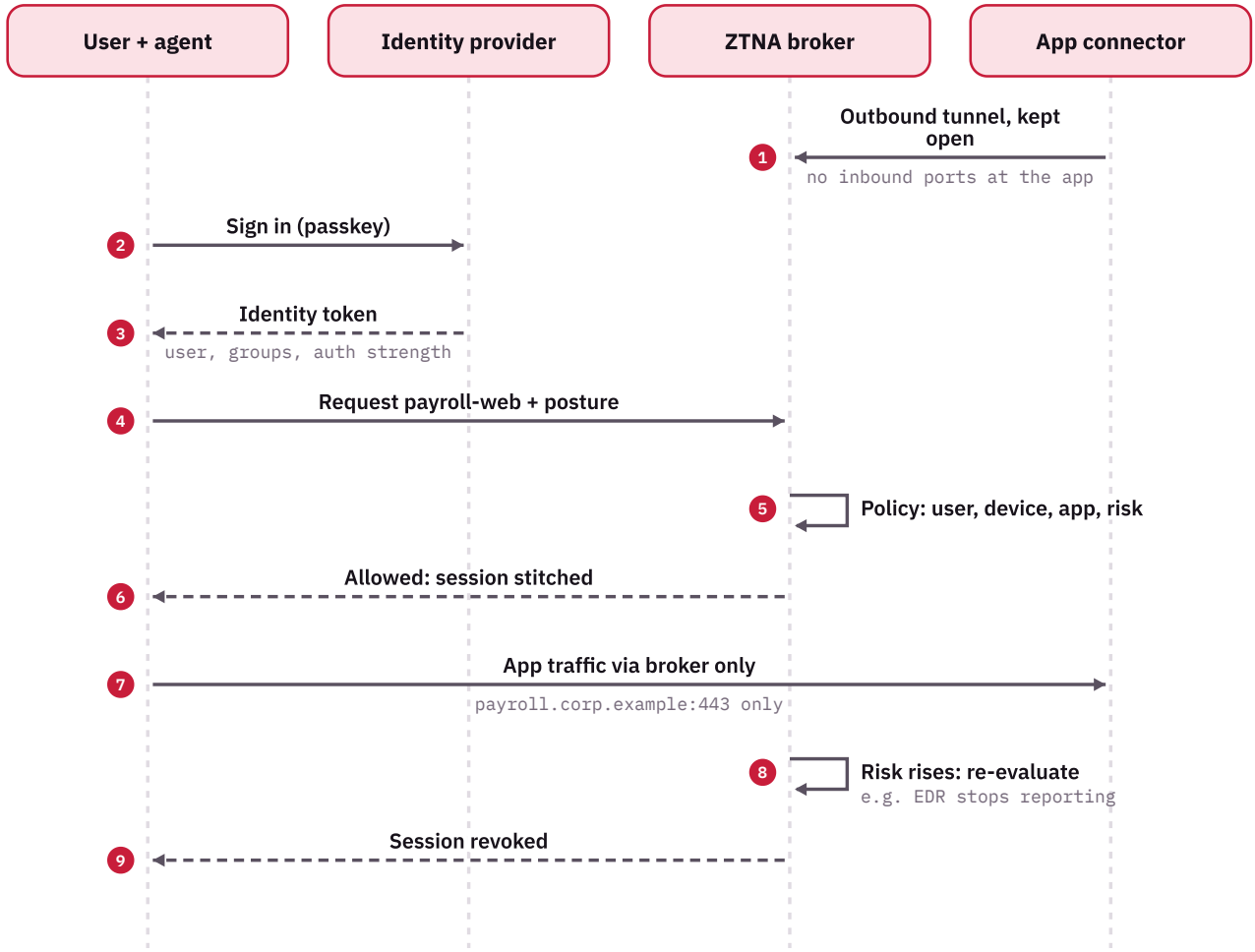
- Grants network-level access after login
- Concentrator exposed on the internet
- Lateral movement possible within allowed subnets
- Trust decided mostly at connection time
- Familiar, works for any protocol

ZTNA

- Grants access to named applications only
- Applications hidden behind outbound-only connectors
- No network presence to move laterally from
- Identity, device and context checked per request
- Some legacy and peer-to-peer protocols need extra work

Copyright © ZyeemZia

A ZTNA session from request to revocation



The user never joins a network: the broker joins one user session to one application over the connector's outbound tunnel, and keeps re-checking signals so it can cut the session mid-way.

ZTNA delivery models

MODEL	BEST FOR	WATCH OUT FOR
Agent-based	Managed devices; any TCP or UDP application; strong posture checks	Agent rollout and support effort
Agentless (browser-based)	Web apps, SSH or RDP in browser, unmanaged and partner devices	Limited posture data; browser-only protocols
Self-hosted broker	Data-sovereignty or air-gapped requirements	You operate availability and scaling yourself

Copyright © ZyeemZia

A per-application access policy

ZTNA policy · payroll.yaml (illustrative)

```
application: payroll-web
  fqdn: payroll.corp.example
  port: 443
  connector_group: dc-east-connectors
access_rules:
  - name: payroll-staff
    allow_groups: [hr-payroll]
    require:
      mfa: phishing_resistant
      device: {managed: true, disk_encrypted: true, edr_running: true}
    session: {max_hours: 8, reevaluate_on_risk_change: true}
  - name: default
    action: deny
```

Access names an application, a group and conditions, never a subnet. The final default-deny rule makes the policy explicit and auditable.

Branch-to-cloud architecture

Destinations	SaaS · IaaS workloads · Data-centre apps via connectors
Security edge PoPs	SWG · CASB · FWaaS · ZTNA broker · DNS security
Transport	Dual internet links · Cellular backup · Optional private circuit
Branch edge	SD-WAN appliance · Local breakout policy · Segmented VLANs
Users and devices	Staff · Guests · IoT and point-of-sale

Moving a branch estate from backhaul to direct-to-cloud

1. **Measure flows** Classify branch traffic into SaaS, general internet, private apps and real-time media.
2. **Define breakout classes** SaaS and internet go to the nearest PoP; private apps go through ZTNA; trusted media may go direct but logged.
3. **Build redundant on-ramps** Two tunnels from each branch to two PoPs, with health checks and tested failover.
4. **Replace site-to-DC routing** Publish data-centre apps through connectors instead of routing branches into the DC.
5. **Pilot and phase** Start with a few low-risk sites, measure user experience, then roll out in waves.
6. **Retire legacy** Decommission backhaul circuits and VPN concentrators once usage reaches zero.

> **WATCH OUT · WHAT USUALLY BREAKS**
> SaaS apps that allow-list source IPs need your **dedicated egress addresses**; geolocation may show the PoP's country rather than the user's; voice and video suffer if forced through inspection; split DNS must resolve private names for ZTNA and public names for the gateway. Discover these in the pilot, not during the cut-over weekend.

Copyright © ZyeemZia

SCENARIO · DECIDE · FORTY BRANCHES, ONE DATA CENTRE

A retailer backhauls 40 branches over private circuits to one data centre, where a firewall stack inspects all internet traffic. Seventy per cent of traffic is SaaS, users complain of slow video calls, and the circuits are up for renewal. What is the best direction?

(A) Renew the private circuits at higher bandwidth and add a second firewall cluster in the data centre.

(B) Give every branch direct internet access with a basic router and rely on endpoint antivirus for all of its protection needs.

(C) Move all branch users onto remote-access VPN clients that connect to the data centre.

(D) Adopt SD-WAN with local breakout to a security edge, publish data-centre apps through ZTNA, and retire most private circuits.

Circle your choice. Answer and feedback: module answer key.

ZTNA readiness

☐ Application inventory with owners, users and protocols
☐ Identity provider with phishing-resistant MFA for all ZTNA users
☐ Device posture signals available (management, encryption, EDR, patch level)
☐ Connectors deployed in pairs per site with outbound-only connectivity
☐ Default-deny policy with per-application allow rules reviewed by owners
☐ Plan for legacy, server-initiated and peer-to-peer protocols

REFLECT

List three applications your users reach today through a remote-access VPN. For each, would ZTNA, a reverse proxy or keeping the VPN be the right answer, and why?

Key terms

ZTNA
Zero trust network access: brokered, per-application access granted after identity, device and context checks, with applications hidden from the internet.

Local breakout
Sending branch traffic for internet and SaaS directly from the branch, usually to a nearby security edge, instead of backhauling it.

App connector
A lightweight component near private applications that makes outbound-only connections to a ZTNA broker.

Copyright © ZyeemZia

Key takeaways

- A VPN puts a device on the network; ZTNA connects a user to named applications only.
- App connectors make outbound-only connections, so private apps have no internet-facing listener.
- Policies name applications, groups and conditions (MFA strength, device state) and end in explicit default deny.
- Branch-to-cloud moves inspection to nearby PoPs; plan egress IPs, geolocation, media and split DNS in the pilot.

KNOWLEDGE CHECK

11. Why does ZTNA reduce lateral-movement risk compared with a remote-access VPN?

(A) ZTNA encrypts traffic with stronger ciphers, so attackers cannot read data on the network

(B) ZTNA requires a faster internet link, so attackers cannot keep a stable connection

(C) ZTNA logs every packet, so attackers are always detected before they can move

(D) Users reach named apps, so a compromised device has no network presence to move from

12. Why do ZTNA app connectors make only outbound connections?

(A) So the private applications need no inbound internet exposure at all

(B) So the connectors can bypass the data-centre firewall's inspection rules

(C) So users can connect directly to connectors without authenticating first

(D) So connectors can run without any network connectivity to the apps

13. A SaaS provider allow-lists your old data-centre public IPs. After moving branches to a security edge, access fails. What is the fix?

(A) Disable inspection for that SaaS application at every point of presence

(B) Register the edge's dedicated egress IPs with the SaaS provider

(C) Route that SaaS application's traffic back through a remote-access VPN

(D) Ask users to sign in again so the SaaS provider refreshes its records

14. Which delivery model best fits partners using their own laptops to reach one internal web portal?

(A) Agent-based ZTNA with full posture

(B) Site-to-site IPsec to each partner

(C) Full-tunnel remote-access VPN

(D) Agentless browser-based ZTNA

15. In the access policy example, what is the purpose of the final `default` rule with `action: deny`?

(A) It allows every user who is not in the payroll group to log in

(B) It records denied attempts but still allows the session to start

(C) It makes default-deny explicit so anything unmatched is refused

(D) It sets the default session length for users of the payroll app

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 6 · CLOUD · LESSON 4 · 40 MIN

Securing SaaS and APIs

Govern SaaS configuration, sharing and third-party apps, and protect the APIs your business runs on

- Identify the main SaaS risks and the controls that address them.
- Apply the OWASP API Security Top 10 to gateway and application design.
- Investigate and contain a SaaS data exposure.

SaaS moved the data centre into other people's applications, and APIs became the way every system talks to every other. Both are attacked through **configuration and authorisation** rather than through classic network exploits: an over-shared folder, a third-party app with excessive consent, an API that trusts a customer ID in the URL. Network controls still help, but most protection here comes from identity, posture and application logic.

SaaS risks and their controls

RISK	EXAMPLE	CONTROL
Misconfiguration	Guest access enabled tenant-wide	SaaS security posture management (SSPM)
Over-sharing	Folder shared as 'anyone with the link'	Sharing restrictions plus API-mode DLP
Risky third-party apps	Unvetted app granted read access to all mail	Admin consent workflow and app governance
Account takeover	Session token stolen and replayed	Phishing-resistant MFA, token binding, session risk detection
Insider data theft	Leaver bulk-downloads customer files	Behaviour analytics and download controls
Shadow SaaS	Teams adopt tools without review	Discovery from SWG logs and a fast approval path

WATCH OUT · CONSENT PHISHING SURVIVES A PASSWORD RESET

In consent phishing the victim approves a malicious application, which receives **OAuth tokens** to read mail or files (ATT&CK T1528, Steal Application Access Token). Resetting the password does not revoke those grants. Response must remove the application's consent and revoke its tokens, and prevention requires admin approval for apps requesting sensitive permissions.

OWASP API Security Top 10 (2023)

API1

Broken object level authorisation

The API returns or changes an object without checking that the caller may access that specific object.

API2

Broken authentication

Weak token validation, credential stuffing or missing protection on authentication endpoints.

API3

Broken object property level authorisation

Clients can read or set fields they should not, such as a role or price.

Copyright © ZyeemZia

API4
Unrestricted resource consumption
No limits on rate, payload size or costly operations.

API5
Broken function level authorisation
Ordinary users can call administrative functions.

API6
Unrestricted access to sensitive business flows
Automated abuse of flows such as purchasing or account creation.

API7
Server-side request forgery
The API fetches a user-supplied URL without validation.

API8
Security misconfiguration
Verbose errors, permissive CORS, missing hardening.

API9
Improper inventory management
Old, undocumented or test API versions left reachable.

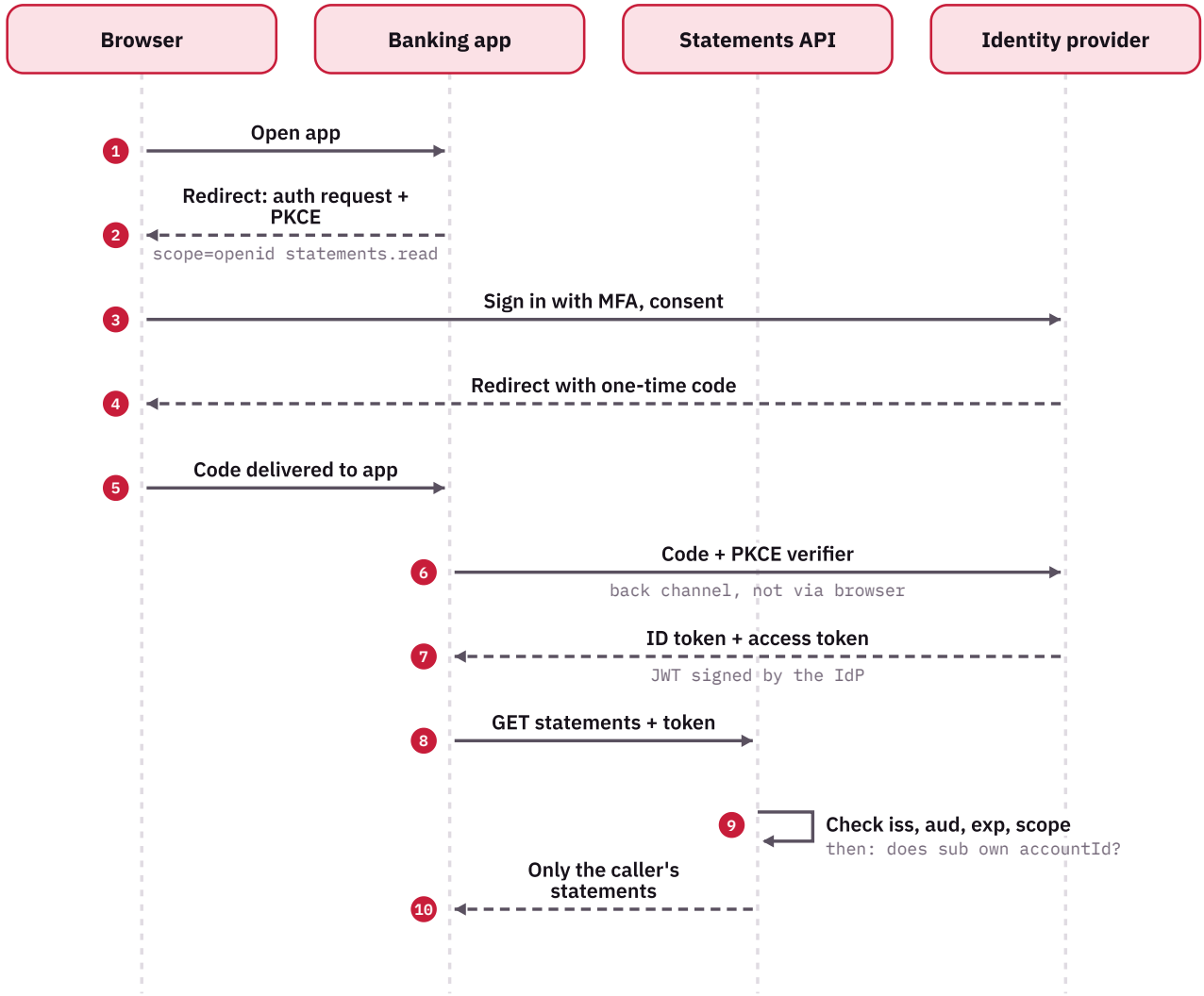
API10
Unsafe consumption of APIs
Blindly trusting data returned by third-party APIs.

Layers of API protection

Monitoring	`Per-client baselines` `Enumeration and scraping detection` `Logs to SIEM`
Application authorisation	`Object-level ownership checks` `Field-level filtering` `Function-level roles`
API gateway	`Token validation` `Scopes` `Rate and size limits` `Schema validation`
Edge	`WAF and bot protection` `DDoS mitigation` `TLS`
Inventory	`Discovered endpoints` `Versions and owners` `Retirement plan`

Copyright © ZyeemZia

OpenID Connect authorisation-code flow with PKCE



Tokens never travel in the browser's address bar: the code is swapped for tokens on a back channel, bound to the app by PKCE. The API trusts the token's identity and scope, but must still check object ownership itself.

Gateway policy for a statements API

API gateway · route policy (illustrative YAML)

```
route: /v2/accounts/{accountId}/statements
methods: [GET]
auth:
  jwt:
    issuer: https://idp.corp.example
    audiences: [statements-api]
    algorithms: [RS256]
    required_scopes: [statements.read]
rate_limit: {per_client: 100/minute, burst: 20}
request_validation: {schema: openapi/statements-v2.yaml, reject_unknown_fields: true}
logging: {fields: [client_id, sub, route, status, latency_ms], redact: [authorization]}
```

*The gateway proves **who** is calling and **what scope** they hold. It cannot know whether the token's subject owns `accountId`; that object-level check must happen in the service on every request.*

Copyright © ZyeemZia

SCENARIO · DECIDE · STATEMENTS BELONGING TO SOMEONE ELSE

A bug-bounty researcher reports that changing `accountId` in `/v2/accounts/{accountId}/statements` returns other customers' statements. The token is valid and has the `statements.read` scope. What is the correct fix?

(A) Replace numeric account IDs with random identifiers so that other customers' accounts cannot be guessed.

(B) Lower the gateway rate limit to ten requests per minute per client so that scraping other customers' statements becomes too slow to matter.

(C) Enforce an object-level check in the service that the caller owns the requested account, and detect callers enumerating many IDs.

(D) Add a WAF rule that blocks requests where the accountId differs from the one in the previous request.

Circle your choice. Answer and feedback: module answer key.

CASE STUDY · SAAS DATA LEAK AT A LOGISTICS FIRM

A logistics company learns from a customer that a spreadsheet of 18,000 customer contacts and contract values is reachable through a public link. Investigation shows a sales engineer shared a folder as 'anyone with the link' eight months ago for a trade show. The same folder is also readable by a third-party 'slide designer' app that the engineer authorised with full read access to their files. SaaS audit logs are retained for 180 days.

1. What are the immediate containment steps?

2. How do you determine who accessed the data, and what limits that answer?

3. Which preventive controls would have stopped or shortened the exposure?

4. Who needs to be involved beyond the security team?

Model answer: module answer key.

SaaS security baseline

1. **Single sign-on everywhere** Federate every SaaS app and disable local passwords except break-glass accounts.
2. **Posture management** Run SSPM against a baseline for sharing, guest access, logging and admin roles.
3. **Control sharing** Default to internal sharing; external links expire and are monitored.
4. **Govern third-party apps** Require admin approval for sensitive scopes and review grants quarterly.
5. **Centralise logs** Send SaaS audit logs to the SIEM and extend retention where the platform allows.
6. **Offboard completely** Revoke sessions, tokens and app grants when people leave, not just passwords.

Copyright © ZyeemZia

API security review

☐ Every API endpoint and version is in an owned inventory
☐ Tokens validated for issuer, audience, signature algorithm and expiry
☐ Object-level and function-level authorisation enforced in the service
☐ Rate, payload and pagination limits set per client
☐ Requests validated against a schema; unknown fields rejected
☐ Sensitive headers and fields redacted from logs
☐ Old versions retired on a published schedule

Key terms

SSPM
SaaS security posture management: continuous checking of SaaS tenant settings against a security baseline.

BOLA
Broken object level authorisation: an API flaw where the server does not verify that the caller may access the specific object requested.

Consent phishing
Tricking a user into granting a malicious application OAuth permissions to their data.

Key takeaways

- SaaS and APIs are attacked through configuration and authorisation, not classic exploits.
- OAuth consent grants survive password resets: revoke consent and tokens, and require admin approval for sensitive scopes.
- Use the OWASP API Security Top 10 (2023); broken object level authorisation is fixed only in the service.
- Gateways validate issuer, audience, expiry, scope, rate and schema; keep an owned inventory and retire old versions.

KNOWLEDGE CHECK

16. A user who approved a malicious mail-reading app has had their password reset. The app keeps reading mail. Why?

(A) The password reset failed to replicate to the mail service before the app connected again
(B) The app is reading a cached copy of the mailbox stored on the user's laptop
(C) The mail service ignores password resets for accounts that have MFA enabled
(D) The app holds OAuth tokens from the consent grant, which a password reset does not revoke

17. Which OWASP API risk describes a normal user calling `/admin/users/delete` successfully?

(A) API5 Broken function level authorisation
(B) API1 Broken object level authorisation
(C) API3 Broken object property level authorisation
(D) API9 Improper inventory management

18. Why can an API gateway not fully prevent broken object level authorisation?

(A) Gateways cannot validate JWT signatures or token expiry
(B) Gateways only inspect traffic on non-standard ports
(C) Only the service knows which caller owns which object
(D) Gateways cannot read the URL path of HTTPS requests

Copyright © ZyeemZia

19. An old `/v1` API, undocumented and unpatched, is still reachable and is abused. Which risk category applies most directly?

    (A) API7 Server-side request forgery
    (B) API9 Improper inventory management
    (C) API2 Broken authentication
    (D) API6 Unrestricted access to sensitive business flows

20. Which control best reduces the risk of employees approving risky third-party SaaS apps?

    (A) An admin consent workflow for apps that request sensitive permissions
    (B) A quarterly reminder email explaining the dangers of third-party apps
    (C) Blocking all third-party apps for every user with no exception process
    (D) Requiring users to change their passwords after approving any app

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 6 · CLOUD

Answer key

Knowledge checks

1. A ACLs are stateless, so the reply on ephemeral ports needs an explicit outbound rule. Security group state does not extend to the subnet ACL.

2. B In PaaS the provider runs and patches the platform. The customer still owns data, access policy and service configuration.

3. D Referencing a group follows its members wherever they are and however many there are. It neither changes evaluation order nor adds encryption.

4. B Guardrails stop the change from being made. Scans, reports and alerts all act after the exposure already exists.

5. D Cloud infrastructure entitlement management analyses identities and permissions, including unused privilege. CWPP protects workloads, DSPM tracks data and WAAP protects web apps and APIs.

6. C SSE delivers the security services without replacing networking, which fits an organisation committed to its current WAN.

7. A Only the agent travels with the device. Branch tunnels cover on-site users, and an internal PAC file is unreachable off network.

8. C Existing data at rest is only visible through the provider API. Inline modes see new traffic, and the edge sees encrypted sessions only.

9. B Tenant restriction distinguishes tenants on the same domain, closing a path for copying corporate data to personal accounts.

10. A Proxy auto-configuration is honoured mainly by browsers. PAC files can list fallbacks and send internal traffic direct, as the example shows.

11. D The key difference is the access model: application-level brokering instead of network-level connectivity. Encryption strength and logging are not the main reason.

12. A Outbound-only connectors let you close inbound ports, hiding applications from internet scanning.

13. B Traffic now egresses from the PoP, so the allow list must include your dedicated PoP egress addresses.

14. D You cannot install agents on partner devices, and network-level access is excessive for one portal. Browser-based ZTNA publishes just that app.

15. C An explicit catch-all deny documents the intended behaviour and protects against platform defaults that might allow unmatched requests.

16. D Delegated consent issues tokens to the app. They remain valid until the grant is removed and tokens revoked.

17. A Calling an administrative function without the right role is function-level authorisation. BOLA concerns access to specific objects.

18. C The gateway can validate identity and scope but not business ownership of records, which lives in the application's data.

19. B Forgotten versions left exposed are an inventory failure, even if other weaknesses are then exploited through them.

20. A Admin consent puts a review step exactly where the risk arises. A blanket block drives shadow IT, and awareness alone is weak.

Scenarios & case studies

Scenario · SSH open to the world
A is best. Best. It fixes the exposure, meets the real need for access through a controlled path, and prevents the same mistake recurring.

Scenario · Contractors on unmanaged laptops
C is best. Best. Reverse proxy needs no agent, applies in real time and is designed for exactly this unmanaged-device case.

Scenario · Forty branches, one data centre
D is best. Best. It removes the hairpin for the dominant SaaS traffic, keeps inspection, and narrows data-centre access to named applications.

Scenario · Statements belonging to someone else
C is best. Best. This is broken object level authorisation (API1). Only the service knows ownership, and monitoring catches enumeration attempts.

Copyright © ZyeemZia

Case study · SaaS data leak at a logistics firm

Contain by removing the public link and external sharing on the folder, revoking the third-party app's consent and tokens tenant-wide, and checking whether other files share the same link settings. Use SaaS audit logs and the API-mode CASB to list anonymous and app access to the folder, noting that only the last 180 days are available, so earlier access cannot be ruled out; record that gap honestly. Prevention: restrict anonymous links or give them expiry dates, scan for sensitive data with API-mode DLP, require admin consent for apps requesting broad file access, and run SSPM to flag tenant-wide sharing settings. Involve legal and privacy (possible notification duties), the data owner in sales, communications and the customer relationship team, and record the incident under the response process covered in Module 7.

Copyright © ZyeemZia

07

MODULE 7 · RESPOND

Respond — Visibility, SIEM, SOAR & Incident Response

See everything that matters, correlate it into reliable alerts, automate with guardrails and respond with discipline.

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Design a question-driven logging and flow telemetry strategy with integrity and tiered retention.
- Build SIEM correlation rules and use cases, and monitor the health of every source.
- Automate repeatable response with SOAR guardrails and run ATT&CK-mapped threat hunts.
- Lead incidents through the response lifecycle with sound evidence handling.
- Measure detection and response with clearly defined metrics and drive improvement.

LESSONS

1. Logging Strategy and Flow Telemetry · 40 min
2. SIEM Correlation and Detection Use Cases · 40 min
3. SOAR Playbooks and Threat Hunting · 40 min
4. Incident Response Lifecycle and Evidence Handling · 45 min
5. Metrics and Continuous Improvement · 35 min

MODULE 7 · RESPOND · LESSON 1 · 40 MIN

Logging Strategy and Flow Telemetry

Decide what to collect, how long to keep it and how to make it trustworthy, then add flow visibility

- Build a logging strategy driven by detection and investigation questions.
- Set retention tiers and integrity controls that satisfy operations and regulation.
- Configure flow export and explain what NetFlow and IPFIX can and cannot show.

The **Respond** layer of the stack can only be as good as the evidence it receives. Logging everything is unaffordable and still leaves gaps; logging by default settings leaves out the events you will need most. An expert logging strategy starts from questions: *Who signed in, from where, with which factor? Which process opened this connection? What did this host resolve before it called out?* Then it collects exactly the sources that answer them, keeps them long enough and protects them from tampering.

High-value log sources

SOURCE	KEY EVENTS	ANSWERS THE QUESTION
Identity provider	Sign-ins, MFA changes, token grants, admin actions	Who accessed what, from where and how?
EDR	Process, file, registry, network events	What actually ran on the host?
DNS resolver	Every query and answer	Where did this host try to go?
Web gateway and firewall	Allowed and denied sessions, URLs, threat events	What crossed the boundary?
Cloud control plane	API calls that create, change or delete resources	Who changed the cloud and when?
SaaS audit logs	Sharing, downloads, admin and app-consent events	What happened to our data in SaaS?
DHCP and asset inventory	Lease and ownership records	Which device and owner had this IP at that time?

INSIGHT · COLLECT FOR QUESTIONS, NOT FOR VOLUME

For every source, write down the use cases it feeds and the investigation questions it answers. A source with no use case is a cost; a use case with no source is a blind spot. Review both lists after every major incident.

Five principles of trustworthy logs

TIME

Synchronised time

All devices use NTP from redundant internal sources, and logs record time zone or UTC with millisecond precision.

ID

Consistent identity

Hostnames, usernames and asset IDs are normalised so events from different sources join correctly.

INT

Integrity

Logs leave the device quickly over a reliable transport and land in storage that operators cannot silently alter.

Copyright © ZyeemZia

COV

Measured coverage

Every expected source is inventoried and monitored for silence.

RET

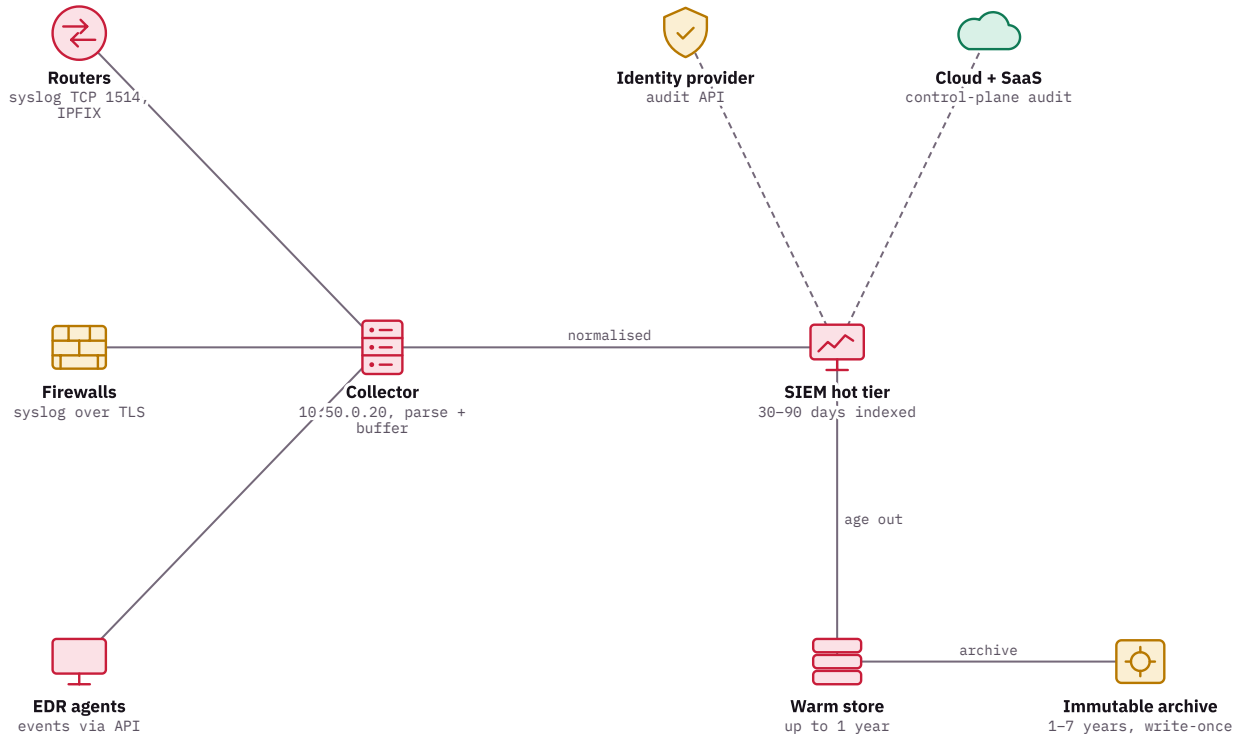
Tiered retention

Retention is set by investigation need and regulation, not by default disk size.

Retention tiers

TIER	TYPICAL DURATION	PURPOSE
Hot (indexed, fast search)	30 to 90 days	Alerting, triage and most investigations
Warm (searchable, slower)	90 days to 1 year	Hunting and late-discovered incidents
Cold or archive (immutable)	1 to 7 years, per regulation	Legal, regulatory and long-dwell investigations

Logging pipeline with tiered retention



Device logs travel over reliable, protected transports to a collector that parses and buffers them; API sources feed the SIEM directly. Data then ages from fast, expensive hot storage to cheap, write-once archive sized by regulation.

Copyright © ZyeemZia

Device logging baseline

Router R1 · IOS-style CLI

```
clock timezone UTC 0 0
ntp server 10.50.0.11 prefer
ntp server 10.50.0.12
service timestamps log datetime msec show-timezone
logging source-interface Loopback0
logging host 10.50.0.20 transport tcp port 1514
logging trap informational
archive
 log config
  logging enable
  notify syslog
```

UTC with milliseconds makes cross-device timelines reliable. A fixed source interface keeps the sender identity stable. The archive log config section records who changed the configuration and sends it to syslog. Use TLS-protected syslog where the platform supports it.

Flow telemetry records who talked to whom, when, on which ports and how much, without payload. NetFlow version 9 and its standards-track successor **IPFIX** export these records from routers, switches, firewalls and cloud networks. Flows keep working when traffic is encrypted, scale to large networks and are ideal for spotting lateral movement, beaconing and unusual data volumes. They cannot tell you what was inside the session.

Flexible flow export with IPFIX

Router R1 · IOS-style CLI

```
flow record ZZ-REC
 match ipv4 source address
 match ipv4 destination address
 match ipv4 protocol
 match transport source-port
 match transport destination-port
 collect counter bytes long
 collect counter packets long
 collect timestamp absolute first
 collect timestamp absolute last
flow exporter ZZ-EXP
 destination 10.50.0.20
 transport udp 4739
 export-protocol ipfix
flow monitor ZZ-MON
 record ZZ-REC
 exporter ZZ-EXP
 cache timeout active 60
interface GigabitEthernet0/1
 ip flow monitor ZZ-MON input
```

The `match` fields form the flow key; `collect` fields are accumulated per flow. A 60-second active timeout exports long-lived sessions regularly so beacons and large transfers appear quickly. UDP 4739 is the registered IPFIX port.

Copyright © ZyeemZia

Logs, flows and packets

Event logs

- Rich application and identity context
- Depend on each source being configured
- Moderate volume

Flow records

- Every conversation, no payload
- Work with encrypted traffic
- Low volume, long retention is affordable

Full packet capture

- Complete content for deep forensics
- Very high storage cost
- Little value for encrypted sessions

SCENARIO · DECIDE · HALF THE LOGGING BUDGET

The CFO cuts the SIEM budget by half. Today all sources are kept hot for 90 days. What is the best way to protect detection and investigation capability?

(A) Cut hot retention for every source from 90 days to 45 days so that no data source is dropped from the SIEM entirely.

(B) Keep identity, EDR, DNS and cloud audit logs hot; move firewall allow logs and flows to cheaper warm storage.

(C) Stop collecting DNS logs, because they are the highest-volume source in most environments.

(D) Sample one in ten events from every source so total volume falls by ninety per cent.

Circle your choice. Answer and feedback: module answer key.

Key terms

IPFIX
IP Flow Information Export: the IETF standard protocol for exporting flow records, evolved from NetFlow version 9.

Hot retention
The period during which logs are fully indexed and quickly searchable for alerting and investigation.

Key takeaways

- Collect for investigation questions, not for volume: every source should feed a use case.
- Trustworthy logs need synchronised UTC time, consistent identities, integrity, monitored coverage and tiered retention.
- Flow records (NetFlow v9, IPFIX) show who talked to whom even when traffic is encrypted, but never the content.
- When budgets shrink, keep identity, EDR, DNS and cloud audit logs hot and move bulky sources to cheaper tiers.

KNOWLEDGE CHECK

1. Investigators cannot line up firewall, EDR and identity events for an incident; the same session appears minutes apart. What is the most likely root cause?

   (A) The SIEM is sampling events from each source at different rates during busy periods

   (B) Firewall logs are sent over UDP, so they always arrive several minutes late

   (C) Devices lack a common time source or record inconsistent time zones

   (D) EDR agents batch events daily, so their timestamps reflect upload time only

Copyright © ZyeemZia

2. What can flow records **not** tell an investigator?

   (A) How many bytes moved between two hosts in an hour

   (B) Which internal hosts contacted a given external address

   (C) When a long-lived connection began and when it ended

   (D) Which file was transferred inside an encrypted session

3. Why set a short active timeout, such as 60 seconds, on a flow monitor?

   (A) So the router deletes its flow cache before memory runs out on busy links

   (B) So long-lived connections are exported regularly instead of only when they end

   (C) So the collector can decrypt traffic inside each flow during the timeout window

   (D) So each flow record includes the full packet payload for the first minute

4. Which tier is most appropriate for logs that regulation requires you to keep for five years but which are rarely searched?

   (A) Hot, fully indexed storage

   (B) Cold, immutable archive

   (C) Local disk on each device

   (D) The analysts' own workstations

5. Why should DHCP lease logs be part of a security logging strategy?

   (A) They contain the full DNS history of every device on the network

   (B) They show which processes on each host opened network connections

   (C) They map an IP address at a given time to a specific device and owner

   (D) They record the user's MFA method for every successful sign-in

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 7 · RESPOND · LESSON 2 · 40 MIN

SIEM Correlation and Detection Use Cases

Turn normalised events into reliable alerts with correlation rules, risk scoring and health monitoring

- Describe the SIEM pipeline from collection to feedback.
- Choose the right correlation rule type for a detection goal.
- Write and read portable detection rules and correlation queries.
- Onboard log sources with documented owners, parsers and health checks.

A security information and event management (SIEM) platform collects events, normalises them into a common schema, enriches them with context and runs correlation logic that raises alerts and cases. Its value depends far more on **data quality and use-case engineering** than on the product. The same principles apply whether the SIEM is a cloud data lake, a commercial platform or an open-source stack.

The SIEM pipeline

01 Collect — Agents, syslog, APIs and cloud connectors →

02 Parse and normalise — Fields mapped to a common schema →

03 Enrich — Asset owner, criticality, identity, threat intelligence →

04 Correlate — Rules, sequences, baselines and risk scores →

05 Alert and case — Prioritised work for analysts or automation →

06 Feedback — Dispositions tune rules and reveal gaps

Correlation rule types

TYPE	LOGIC	EXAMPLE
Single event	One event matches conditions	Service installed from a user-writable path
Threshold	Count exceeds a limit within a window	15 or more users fail sign-in from one IP in an hour
Sequence	Events occur in order within a window	Spray failures, then a success, then an MFA method added
Absence	Expected events stop arriving	No firewall logs from a site for 30 minutes
Baseline	Deviation from learned behaviour	User downloads ten times their 30-day average
Risk-based	Entity risk accumulates across many weak signals	Alert when a user's risk score passes 80 in 24 hours

Copyright © ZyeemZia

A portable detection rule in Sigma format

Detection repository · sigma rule (YAML)

```
title: Service Installed From User-Writable Path
status: experimental
description: Detects a new Windows service whose binary sits in a user-writable folder
logsource:
  product: windows
  service: system
detection:
  selection:
    Provider_Name: 'Service Control Manager'
    EventID: 7045
    ImagePath|contains:
      - '\AppData\'
      - '\Users\Public\'
  condition: selection
falsepositives:
  - Poorly packaged software that installs services from user profiles
level: high
tags:
  - attack.persistence
  - attack.t1543.003
```

Sigma is an open, vendor-neutral rule format that converts into many SIEM query languages, so detections can live in version control and be reviewed like code.

A threshold-and-sequence query: spray then success

SIEM · SQL-style correlation query

```
-- Password spraying (T1110.003) followed by a valid login (T1078)
SELECT src_ip,
       COUNT(DISTINCT CASE WHEN result = 'failure' THEN user_name END) AS users_failed,
       COUNT(CASE WHEN result = 'success' THEN 1 END) AS successes
FROM signin_events
WHERE event_time > NOW() - INTERVAL '1 hour'
GROUP BY src_ip
HAVING COUNT(DISTINCT CASE WHEN result = 'failure' THEN user_name END) >= 15
   AND COUNT(CASE WHEN result = 'success' THEN 1 END) >= 1;
```

*Counting **distinct users** rather than total failures is what separates spraying (few attempts against many accounts) from brute force against one account.*

A sequence rule watching one source

09:00–09:45
1,800 failures
1,200 different users from one IP: spraying (T1110.003)

09:46
One success
r.karim signs in: valid account (T1078)

09:48
New MFA method
Attacker adds an authenticator for persistence

09:49
Rule fires
Spray, success and MFA change inside one hour

Each event alone is weak or noisy; the ordered combination from one source within one window is a high-confidence alert worth waking someone for.

Copyright © ZyeemZia

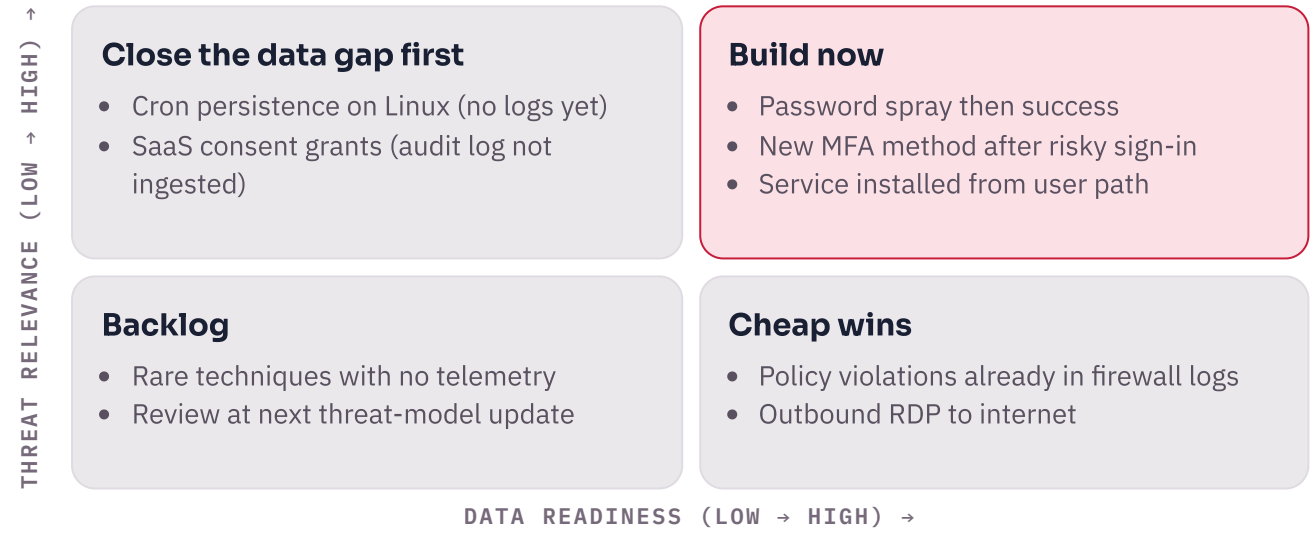
PRO TIP · RISK-BASED ALERTING CUTS NOISE

Instead of alerting on every weak signal, add points to the user or host involved: an unusual country, a new MFA device, a mass download. Alert when the entity's total passes a threshold. Analysts see one rich alert about a risky entity rather than ten thin ones, and weak signals still contribute.

Building a use case end to end

1. **Start from a threat** Pick an ATT&CK technique relevant to your threat model and crown jewels.
2. **Check the data** Confirm the required events are collected, parsed and complete.
3. **Write the logic** Draft the rule and its expected false positives.
4. **Test with emulation** Run a safe, authorised simulation of the technique and confirm the alert fires.
5. **Tune and document** Measure precision on real data and record the use-case card.
6. **Hand over** Give the SOC a triage guide and link the alert to a response playbook.

Which use cases to build next



Rank candidate detections by how much they matter in your threat model and whether the data already flows. High-relevance ideas without data become logging projects, not rules that can never fire.

WATCH OUT · SILENCE IS THE MOST DANGEROUS SIGNAL

A rule cannot fire on data that never arrives. Parsers break after upgrades, agents stop, firewall syslog is misrouted after a change. Every critical source needs an **absence** rule and an owner, and detection coverage reports should only count use cases whose data actually flowed in the last day.

TEMPLATE Log source onboarding sheet

Bring every new source into the SIEM with an owner, a parser, a health check and a purpose.

SOURCE	OWNER	TRANSPORT AND PARSER	KEY NORMALISED FIELDS	EXPECTED VOLUME PER DAY	RETENTION TIER	HEALTH CHECK
Branch NGFW cluster EU-2	*Network security team*	*Syslog over TLS; NGFW parser v4*	*src_ip, dst_ip, dst_port, action, rule, app, user*	*38 GB*	*Hot 90 days, cold 3 years*	*Alert if no events for 15 minutes*

Copyright © ZyeemZia

SOURCE	OWNER	TRANSPORT AND PARSER	KEY NORMALISED FIELDS	EXPECTED VOLUME PER DAY	RETENTION TIER	HEALTH CHECK

SCENARIO · DECIDE · THREE SILENT DAYS

During an investigation you discover that firewall logs from the Manila office stopped reaching the SIEM three days ago after a firewall upgrade. Nobody noticed. What should you change first?

(A) Add absence rules for every critical source with a named owner, and report detection coverage only for sources that are actually flowing.

(B) Ask the network team to email the SOC before every upgrade so analysts can watch for problems.

(C) Buy a second SIEM to receive a copy of every log in case the first one misses events.

(D) Increase hot retention so that missing logs can be recovered from the SIEM after the fact.

Circle your choice. Answer and feedback: module answer key.

Key terms

Normalisation
Mapping fields from different log formats into one common schema so events can be searched and correlated together.

Risk-based alerting
Accumulating risk points on users or hosts from many weak signals and alerting when a threshold is exceeded.

Correlation rule
SIEM logic that combines one or more events, counts, sequences or baselines to decide when to raise an alert.

Key takeaways

- SIEM value comes from data quality and use-case engineering: collect, normalise, enrich, correlate, alert, feed back.
- Pick the rule type for the goal: single event, threshold, sequence, absence, baseline or risk-based.
- Keep detections as code (for example Sigma) with tests, owners and triage guides.
- Every critical source needs an absence rule; coverage counts only use cases whose data is flowing.

KNOWLEDGE CHECK

6. Which correlation logic best separates password spraying from brute force against one account?

(A) Count total failed sign-ins per username over the last 24 hours

(B) Alert on any single failed sign-in from an external IP address

(C) Alert when one account's password is changed twice in a day

(D) Count distinct usernames with failures per source over a time window

Copyright © ZyeemZia

7. A rule should alert when no events arrive from the core firewalls for 30 minutes. Which rule type is this?

   (A) Absence
   (B) Sequence
   (C) Baseline
   (D) Single event

8. What is the main benefit of writing detections in an open rule format kept in version control?

   (A) Rules can be reviewed, tested and converted for different SIEM platforms
   (B) Rules no longer need any log sources because the format includes sample data
   (C) Rules automatically gain higher precision when converted between platforms
   (D) Rules are executed by the endpoint agents rather than by the SIEM itself

9. In the SIEM pipeline, which stage adds the asset owner and business criticality to an event?

   (A) Collection
   (B) Correlation
   (C) Enrichment
   (D) Feedback

10. A use case shows as 'covered' on the dashboard, but its data source has been silent for a week. What does this reveal?

    (A) The rule must be rewritten in a different query language to work again
    (B) Coverage reporting must confirm that the data is actually flowing
    (C) Coverage is accurate because the rule logic itself has not been changed
    (D) The SIEM has corrupted the rule and needs to be restored from backup

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 7 · RESPOND · LESSON 3 · 40 MIN

SOAR Playbooks and Threat Hunting

Automate the repeatable with guardrails, and hunt for what no rule has caught yet

- Decide which response tasks to automate fully, partly or not at all.
- Read and design a SOAR playbook with approval gates.
- Run hypothesis-driven, ATT&CK-mapped threat hunts and convert findings into detections.

Security orchestration, automation and response (SOAR) connects the SIEM, EDR, email, identity and network controls through APIs so that repeatable steps run in seconds and consistently. **Threat hunting** is the opposite discipline: human-led, hypothesis-driven searching for activity that existing rules missed. Mature SOCs use both, and each feeds the other: hunts produce new detections, and automation frees time to hunt.

What to automate

TASK	AUTOMATION LEVEL	HUMAN GATE
Enrichment (whois, reputation, asset owner)	Full	None
Phishing report triage	High	Analyst reviews borderline scores
Block indicator at gateway and DNS	High	Protected allow list for own and partner domains
Isolate an endpoint	Conditional	Automatic only for critical, high-confidence alerts; else approval
Disable a user account	Conditional	Approval for executives and service accounts
Purge email from all mailboxes	Partial	Approval before tenant-wide deletion

Copyright © ZyeemZia

A phishing triage playbook

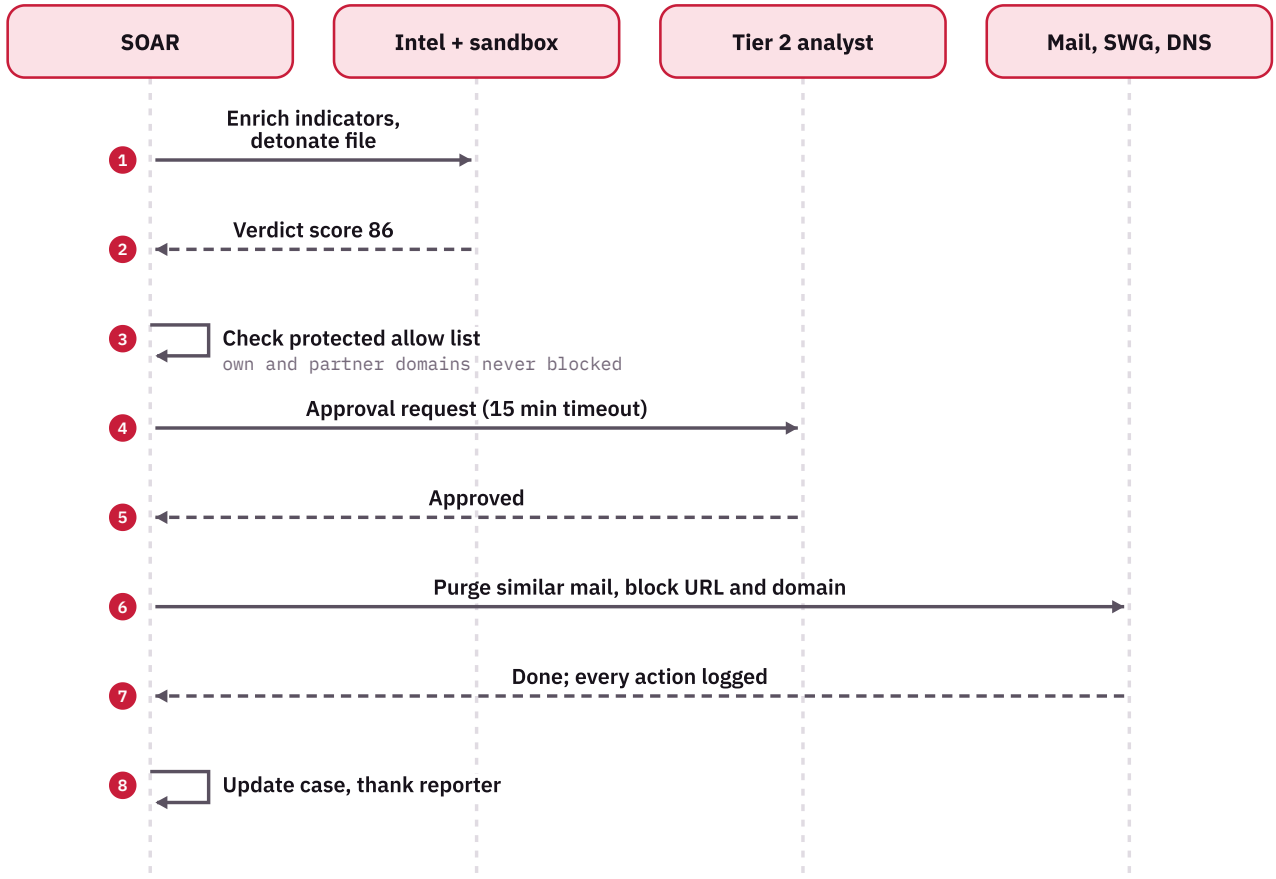
SOAR · playbook definition (illustrative YAML)

```
playbook: phishing-report-triage
trigger: {source: mailbox, address: report-phish@corp.example}
steps:
  - id: extract
    action: email.parse_indicators
  - id: enrich
    action: intel.lookup
    input: "{{ extract.indicators }}"
  - id: detonate
    action: sandbox.submit
    when: "{{ extract.attachments | length > 0 }}"
  - id: score
    action: verdict.combine
  - id: contain
    when: "{{ score.value >= 80 }}"
    approval: {required: true, group: soc-tier2, timeout_minutes: 15}
    actions: [email.purge_similar, swg.block_url, dns.block_domain]
  - id: close_loop
    action: case.update_and_reply_to_reporter
```

Enrichment and detonation run automatically; destructive actions wait for a Tier 2 approval with a timeout. Replying to the reporter keeps users motivated to report.

Copyright © ZyeemZia

Automation with an approval gate



Read-only steps run at machine speed; the destructive steps wait for a named human and are checked against an allow list first. Every action is logged with its inputs so it can be audited and rolled back.

WATCH OUT · GUARDRAILS FOR AUTOMATED RESPONSE

Protect critical assets with allow lists so automation never blocks your own domains, identity providers or domain controllers. Rate-limit destructive actions, require approvals where impact is high, log every automated action with its inputs, and build a tested rollback. A playbook that can isolate 500 hosts in a minute because of one bad indicator is itself a risk.

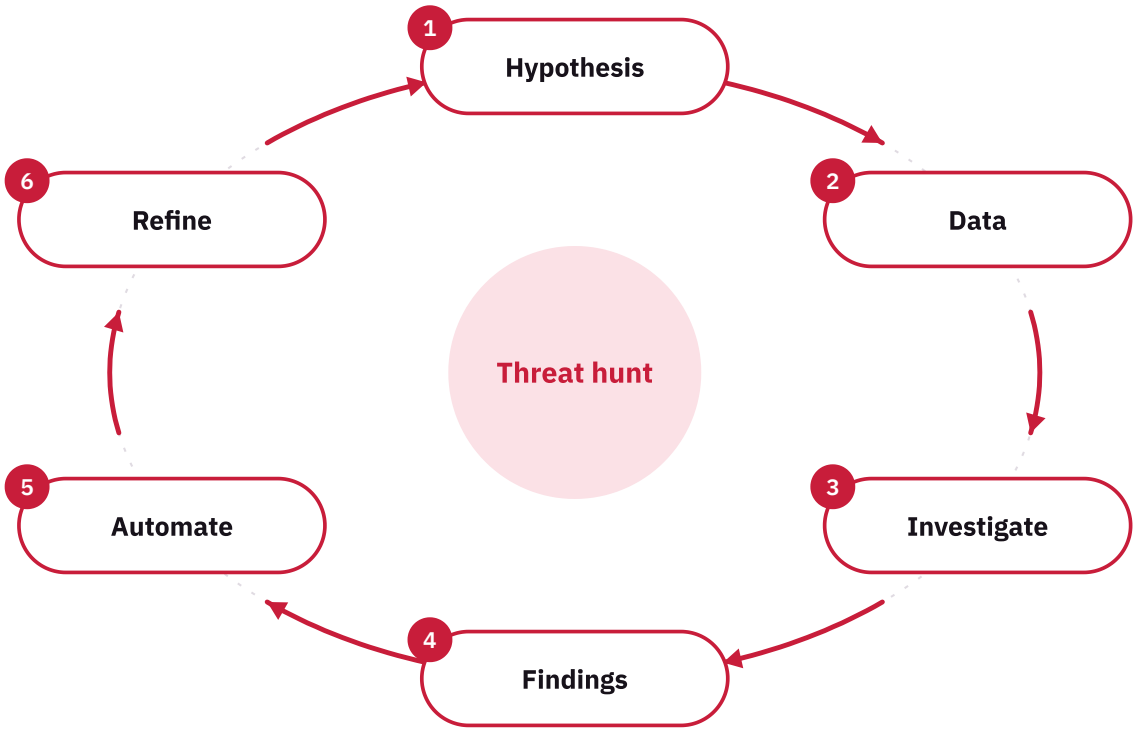
PRO TIP · AI-ASSISTED TRIAGE, UNDER HUMAN CONTROL

SOC platforms increasingly use language models to summarise alerts, draft hunt queries, explain scripts and suggest a disposition. Treat the model as a fast junior analyst: it may recommend, but containment and closure stay behind the same approval gates as any playbook. Measure its suggestions against analyst verdicts, log every prompt and output, keep sensitive data inside approved services, and remember that log fields are attacker-controlled, so text planted in a hostname, email subject or command line can try to steer the model (prompt injection).

Threat hunting assumes that some compromise has already evaded detection. A hunt starts with a **hypothesis**: a specific, testable statement about attacker behaviour in your environment, usually tied to an ATT&CK technique. The hunter then checks whether the data exists, searches it, and ends with one of three results: evidence of malicious activity (escalate to incident response), a new or improved detection, or a documented data gap.

Copyright © ZyeemZia

The hunting loop



1. **Hypothesis** — Specific, testable, mapped to ATT&CK
2. **Data** — Confirm sources and time range
3. **Investigate** — Query, pivot, stack and compare
4. **Findings** — Malicious, benign or data gap
5. **Automate** — Turn the logic into a detection
6. **Refine** — Update the threat model and the next hypotheses

A hunt is never a one-off search: every pass ends by feeding detections, data-gap fixes or new hypotheses back into the next round.

Example hypotheses

HYPOTHESIS	ATT&CK	DATA	WHAT TO LOOK FOR
An implant is beaconing to the internet over HTTPS	T1071.001 Web Protocols	Proxy or flow logs	Regular intervals, low jitter, consistent request sizes
Attackers persist with scheduled tasks on servers	T1053.005 Scheduled Task	EDR, task-creation events	Tasks running binaries from user-writable paths
Stolen credentials are used from unusual places	T1078 Valid Accounts	Identity provider logs	New country, new device and new MFA method together
Data is staged for upload to cloud storage	T1567.002 Exfiltration to Cloud Storage	Web gateway and EDR	Large archives created then uploaded to unsanctioned storage

Copyright © ZyeemZia

HYPOTHESIS	ATT&CK	DATA	WHAT TO LOOK FOR
RDP is used for lateral movement	T1021.001 Remote Desktop Protocol	Windows logon events, flows	Workstation-to-workstation RDP sessions

Hunting for beaconing in proxy logs

SIEM · SQL-style hunt query

```
-- Many connections with almost constant spacing suggest automated beaconing
WITH c AS (
  SELECT src_ip, dest_host,
         EXTRACT(EPOCH FROM event_time - LAG(event_time)
           OVER (PARTITION BY src_ip, dest_host ORDER BY event_time)) AS gap_s
  FROM proxy_events
  WHERE event_time > NOW() - INTERVAL '24 hours')
SELECT src_ip, dest_host, COUNT(*) AS hits,
       ROUND(AVG(gap_s)) AS mean_gap_s, ROUND(STDDEV(gap_s), 1) AS sd_gap_s
FROM c WHERE gap_s IS NOT NULL
GROUP BY src_ip, dest_host
HAVING COUNT(*) > 200 AND STDDEV(gap_s) < 0.1 * AVG(gap_s)
ORDER BY hits DESC;
```

Expect benign hits such as update checkers and monitoring agents; stack them by destination and exclude known software before investigating the remainder.

SCENARIO · DECIDE · A BEACON WITH A TEN-DAY-OLD DOMAIN

Your hunt finds one workstation contacting `stats-cdn.example` every 300 seconds, with a standard deviation of two seconds, for six days. The domain was registered ten days ago and no other host uses it. What do you do?

A. Add the domain to the DNS block list and close the hunt, because the beacon can no longer reach its server.

B. Keep the hunt open for another month to collect more data before telling anyone.

C. Ask the user whether they recognise the website and close the hunt if they say yes.

D. Escalate to incident response with your evidence, scope the estate for the domain and related indicators, and turn the pattern into a detection.

Circle your choice. Answer and feedback: module answer key.

What a good hunt leaves behind

- A written hypothesis, the queries used and the time range searched
- Findings classified as malicious, benign or inconclusive
- At least one new or improved detection, or a reason why none is possible
- Documented data gaps with an owner to close them
- Benign patterns recorded so the next hunter does not repeat the work

Key terms

SOAR
Security orchestration, automation and response: tooling that executes response playbooks across security systems through APIs.

Playbook
A defined sequence of response steps, with conditions and approvals, for a specific type of alert or incident.

Copyright © ZyeemZia

Threat hunting
Proactive, hypothesis-driven searching for malicious activity that existing detections have not flagged.

Key takeaways

- Automate read-only and repeatable steps fully; put approvals, rate limits and allow lists around destructive actions.
- AI assistants can speed up triage, but humans approve actions and model output is measured, logged and guarded against prompt injection.
- Hunts start from a specific, testable, ATT&CK-mapped hypothesis and end in escalation, a new detection or a documented data gap.
- Likely malicious findings go to incident response immediately; hunting is never a reason to delay containment.

KNOWLEDGE CHECK

11. Which response action is most suitable for full automation without any human approval?

(A) Disabling the account of a senior executive flagged for impossible travel
(B) Purging a suspected phishing email from every mailbox in the tenant
(C) Isolating a production database server after a medium-severity alert
(D) Enriching an alert with asset owner, reputation and geolocation data

12. A SOAR playbook automatically blocked the company's own identity provider domain after a misclassified indicator. Which guardrail was missing?

(A) A longer timeout before the sandbox returns its verdict on the indicator
(B) A requirement that all indicators come from at least one commercial feed
(C) A rule that playbooks may only run during normal business hours
(D) A protected allow list of critical domains automation may never block

13. What distinguishes a good hunting hypothesis?

(A) It is specific, testable with available data and behaviour-based
(B) It is broad enough to cover every technique in the ATT&CK matrix at once
(C) It is based only on indicators of compromise from the latest threat report
(D) It is designed to confirm that the environment is free of compromise

14. In the beaconing query, why compare the standard deviation of the gap to its mean?

(A) High variation relative to the average indicates a human browsing interactively
(B) Low variation relative to the average interval indicates automated, regular traffic
(C) The ratio estimates how many bytes were transferred in each beacon session
(D) The ratio identifies which beacons use encrypted rather than plain HTTP

15. A hunt finds nothing malicious but reveals that scheduled-task events are not collected from Linux servers. How should the result be recorded?

(A) As a failed hunt that should be deleted from the hunting log
(B) As proof that Linux servers are not affected by that technique
(C) As a data gap with an owner and plan: a valid hunt outcome
(D) As a reason to stop hunting on Linux until a new SIEM is bought

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 7 · RESPOND · LESSON 4 · 45 MIN

Incident Response Lifecycle and Evidence Handling

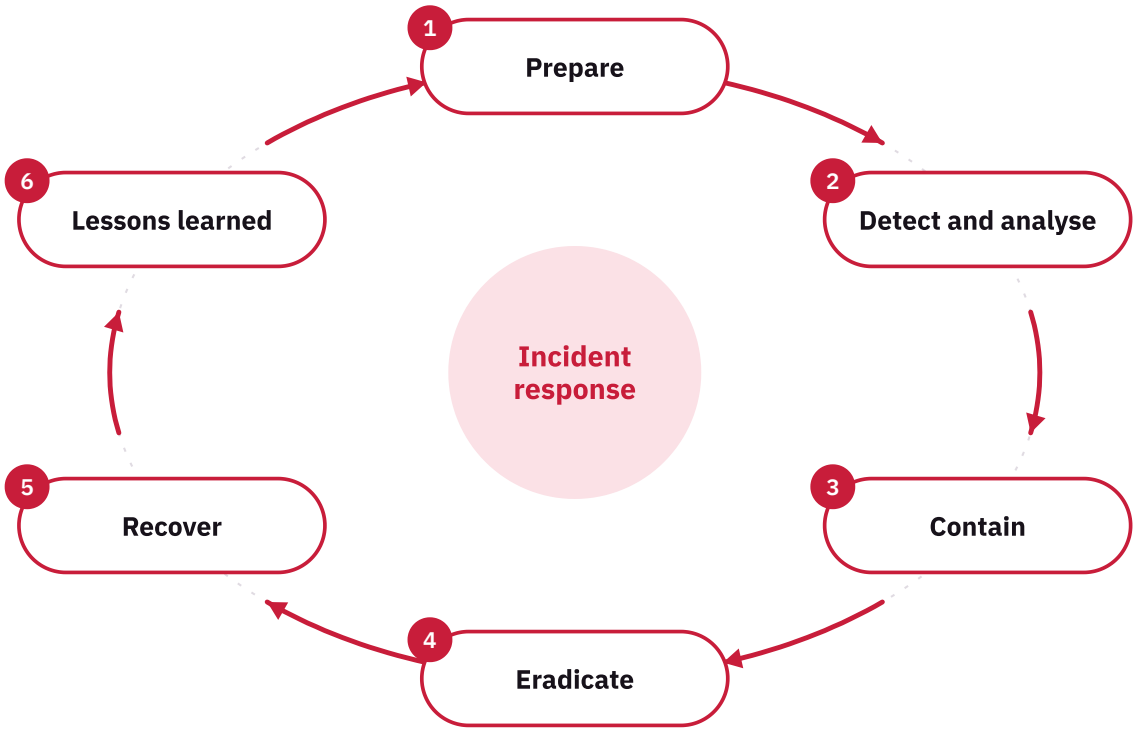
Run incidents through a disciplined lifecycle and preserve evidence that will stand up to scrutiny

- Apply the incident response lifecycle from preparation to lessons learned.
- Choose containment actions with an understanding of their side-effects.
- Collect and handle evidence using order of volatility, hashing and chain of custody.
- Use a reusable IR playbook template and test it in a tabletop exercise.

Incident response is where every earlier layer is tested at once. The classic lifecycle from **NIST SP 800-61** has four phases: preparation; detection and analysis; containment, eradication and recovery; and post-incident activity. **Revision 3 (April 2025)** re-frames incident response around the six NIST CSF 2.0 functions: preparation lives in Govern, Identify and Protect, handling in Detect, Respond and Recover, and improvement runs through all of them. The operational phases below remain the backbone of most playbooks; use the CSF view to connect them to governance and risk.

Copyright © ZyeemZia

Incident response lifecycle



1. **Prepare** — Plans, playbooks, tools, contacts, exercises
2. **Detect and analyse** — Validate, scope, classify severity
3. **Contain** — Stop spread and further damage
4. **Eradicate** — Remove attacker access and artefacts
5. **Recover** — Restore and monitor services
6. **Lessons learned** — Review, improve, track actions

Lessons learned feed straight back into preparation; in practice teams also loop between analysis and containment several times as the scope grows.

Phase activities and outputs

PHASE	KEY ACTIVITIES	OUTPUT
Prepare	Roles, on-call, out-of-band communications, legal and regulator contacts, tooling access tested	Approved IR plan and playbooks
Detect and analyse	Validate alert, build timeline, scope affected users and hosts, assign severity	Incident record with scope and severity
Contain	Isolate hosts, revoke sessions, block indicators, segment networks	Spread stopped; evidence preserved
Eradicate	Remove persistence, reset credentials, patch the entry point	Attacker access removed and verified

Copyright © ZyeemZia

PHASE	KEY ACTIVITIES	OUTPUT
Recover	Restore from clean sources, heightened monitoring, staged return to service	Services restored under watch
Lessons learned	Blameless review, root cause, improvement actions with owners	Action log and updated playbooks

Severity levels

SEV1

Critical

Business-critical services down, confirmed data theft or active ransomware. Executive and legal engagement now.

SEV2

High

Confirmed compromise of important systems or accounts, contained to a limited scope.

SEV3

Medium

Confirmed malicious activity on non-critical assets, no evidence of spread.

SEV4

Low

Policy violation or blocked attempt needing follow-up but no compromise.

The regulatory clock: one example regime (EU NIS2)



T0

Aware of a significant incident

Start the incident record and the reporting clock

T + 24 H

Early warning

To the national CSIRT or authority; suspected malicious or cross-border?

T + 72 H

Incident notification

Initial assessment of severity, impact and indicators

ON REQUEST

Intermediate reports

Status updates the authority asks for

T + 1 MONTH

Final report

Root cause, mitigations, cross-border impact

Reporting deadlines start long before the investigation is finished, so legal and communications contacts belong in preparation. Other regimes differ (for example financial-sector rules, data-protection breach notices or securities disclosure); check the obligations that apply to you.

Containment options and their side-effects

ACTION	EFFECT	SIDE-EFFECT TO WEIGH
Isolate host via EDR	Stops network activity except management	User loses work; attacker may notice
Disable account and revoke sessions	Stops credential use everywhere	Service accounts may break dependent systems
Block indicators at edge, DNS and email	Cuts known command-and-control	Attackers often have backup infrastructure

Copyright © ZyeemZia

ACTION	EFFECT	SIDE-EFFECT TO WEIGH
Isolate a network segment	Stops lateral spread across many hosts	Large business and possibly safety impact
Take a service offline	Removes the attack surface entirely	Direct outage; needs business owner decision

Evidence handling determines whether findings can be trusted by executives, insurers, regulators or courts. Collect the most volatile data first, following the order of volatility: memory and running state, then network state, then temporary files, then disk, then remote logs and archives. Work on verified copies, record cryptographic hashes at collection, keep a **chain of custody** showing who held each item and when, and note the time zone of every source.

Collecting evidence from a compromised laptop

1. **Decide before acting** Agree with the incident lead whether memory is needed, because isolation or shutdown may change it.
2. **Capture volatile data** Memory image and running processes, network connections and logged-on users through EDR.
3. **Collect triage artefacts** Event logs, autoruns, browser history, prefetch and the suspicious files.
4. **Hash and label** SHA-256 every item at collection and give it a unique evidence ID.
5. **Record custody** Log who collected what, when, from where, and where it is stored.
6. **Store securely** Write-protected evidence store with restricted, logged access.

Hashing evidence and recording custody

IR workstation · Linux shell

```
$ sha256sum HR-LT-0193_mem.raw HR-LT-0193_triage.zip | tee IR-2026-031.sha256
9b2f6c41d8e07a5b3c19f0e2d4a68b7c15e3f9a0d2c4b6e8f1a3c5d7e9b0a2c4  HR-LT-0193_mem.raw
4e7a1c9b3d5f0e2a8c6b4d1f3e5a7c9b2d4f6a8c0e1b3d5f7a9c2e4b6d8f0a1c  HR-LT-0193_triage.zip
# Custody log entry IR-2026-031 / E-01
# 2026-03-14T10:02Z | memory image | collected by A. Osei via EDR | stored evidence-vault/IR-2026-031 | seal 55821
$ sha256sum -c IR-2026-031.sha256
HR-LT-0193_mem.raw: OK
HR-LT-0193_triage.zip: OK
```

Re-verify hashes whenever evidence is copied or handed over. A matching hash proves the copy is identical to what was collected.

CASE STUDY · RANSOMWARE TABLETOP AT A REGIONAL HOSPITAL

A 600-bed hospital runs a tabletop exercise. Scenario: at 03:20 on a Sunday, EDR auto-isolates two radiology workstations for shadow-copy deletion. At 03:45 the picture archiving system becomes unavailable and file shares on two clinical servers show renamed files. The attacker entered six days earlier through a contractor's VPN account without MFA. Backups exist: nightly snapshots on the same storage array and a weekly immutable offline copy.

1. Who must be woken in the first 30 minutes, and who makes the call on isolating clinical systems?
2. Which containment actions come first, and what patient-safety trade-offs do they carry?

Copyright © ZyeemZia

3. Which backup can be trusted for recovery, and what must happen before restoring?

4. What should the lessons-learned review examine?

Model answer: module answer key.

TEMPLATE

Incident response playbook

Define, for one incident type, who does what in each phase, with the decisions that need approval.

PHASE	ACTION	OWNER	TOOLS AND EVIDENCE	DECISION OR APPROVAL	TIME TARGET
Contain	*Isolate affected hosts and disable compromised accounts*	*SOC Tier 2*	*EDR console, identity provider audit log*	*Clinical systems need the duty clinical lead's approval*	*30 minutes from SEV1 declaration*
Recover	*Restore file servers from immutable backup into an isolated network*	*Infrastructure lead*	*Backup console, restore checklist, hash verification*	*Incident lead confirms eradication complete*	*Per service recovery-time objective*

Copyright © ZyeemZia

SCENARIO · DECIDE · RESTORE NOW?

Twelve hours into a ransomware incident, the CEO asks the team to restore all file servers from last night's backups immediately so staff can work on Monday. Scoping shows the attacker had access for at least five days and the persistence mechanism is not yet found. What should the incident lead advise?

(A) Restore immediately as requested, because business continuity always overrides security concerns during an incident of this kind.

(B) Restore only after persistence is removed and credentials reset, from backups verified clean, into an isolated network first.

(C) Refuse any restoration until a full forensic investigation of every system has been completed and reported.

(D) Restore from a backup taken one month ago to be sure no attacker artefacts are included.

Circle your choice. Answer and feedback: module answer key.

Key terms

Chain of custody
A documented record of who collected, handled, transferred and stored each item of evidence, and when.

Containment
Incident response actions that stop an attack spreading or causing further damage while evidence is preserved.

Order of volatility
The principle of collecting evidence from the most short-lived sources, such as memory, before more persistent ones such as disk.

Key takeaways

- Run incidents through a defined lifecycle; NIST SP 800-61r3 links it to the CSF 2.0 functions.
- Classify severity early and weigh every containment action against its business and safety side-effects.
- Collect evidence in order of volatility, hash at collection and keep a chain of custody.
- Know your regulatory reporting clocks before an incident; restore only after eradication, from trusted backups.

KNOWLEDGE CHECK

16. Which evidence should normally be collected first from a running compromised server?

(A) Memory and current network connections
(B) A full forensic image of the system disk
(C) Archived logs from the central log store
(D) Backup tapes from the previous month

17. Why must a SHA-256 hash be recorded at the moment evidence is collected?

(A) It encrypts the evidence so only the incident team can open the files later
(B) It lets anyone later prove that the evidence has not changed since collection
(C) It compresses the evidence so it can be transferred to the vault more quickly
(D) It removes personal data from the evidence before it is shared with insurers

18. During containment, disabling a compromised service account would stop a nightly billing run. What is the best approach?

(A) Disable the account immediately because security always takes precedence over every business process
(B) Leave the account active and unmonitored until billing completes, then disable it in the morning
(C) Delete the account and recreate it with the same password so the billing job keeps working
(D) Agree the trade-off with the business owner and contain with compensating controls

Copyright © ZyeemZia

19. In NIST SP 800-61 terms, which phase includes removing persistence mechanisms and resetting compromised credentials?

    (A) Detection and analysis
    (B) Preparation
    (C) Containment, eradication and recovery
    (D) Post-incident activity

20. Snapshots on the same storage array as the encrypted file shares are offered for recovery. What is the main concern?

    (A) Snapshots are always slower to restore than a full offline backup copy
    (B) Snapshots cannot hold file permissions, so access rights would be lost
    (C) An attacker with array or admin access may have deleted or encrypted them too
    (D) Snapshots are only valid for databases and cannot restore file shares

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 7 · RESPOND · LESSON 5 · 35 MIN

Metrics and Continuous Improvement

Measure detection and response honestly and turn every incident into a better defence

- Calculate MTTD, MTTR, dwell time and detection coverage from incident data.
- Present metrics without the distortions of averages and gaming.
- Run a blameless lessons-learned review that produces tracked improvements.

Executives fund what they can see. Well-chosen metrics show whether detection and response are improving, where the bottlenecks are and what investment would change them. Badly chosen metrics reward the wrong behaviour, such as closing alerts quickly instead of correctly. Every metric needs a **precise definition**, a data source and an owner.

Core detection and response metrics

MEASURE	FORMULA	WHAT IT TELLS YOU
Mean time to detect (MTTD)	`Σ (detection time − compromise start time) ÷ number of incidents`	How long attackers operate before you notice. Start times come from the investigation timeline.
Mean time to acknowledge (MTTA)	`Σ (first analyst action − alert time) ÷ number of alerts`	Queue and staffing health in the SOC.
Mean time to contain (MTTC)	`Σ (containment time − detection time) ÷ number of incidents`	How fast you stop the spread once you know.
Mean time to respond (MTTR)	`Σ (resolution time − detection time) ÷ number of incidents`	End-to-end response effort; define 'resolution' explicitly.
Dwell time	`Detection time − initial compromise time`	Per-incident exposure window; report the median and the worst case.
Detection coverage	`Techniques with a tested, flowing detection ÷ techniques in the threat model × 100`	Breadth of detection against the threats that matter to you.

WATCH OUT · WHICH MTTR?

MTTR is used for mean time to respond, recover, repair and resolve, and organisations start the clock at different points. Publish a metrics dictionary that fixes each start and stop event. Comparisons across teams or years are meaningless if the definition changed.

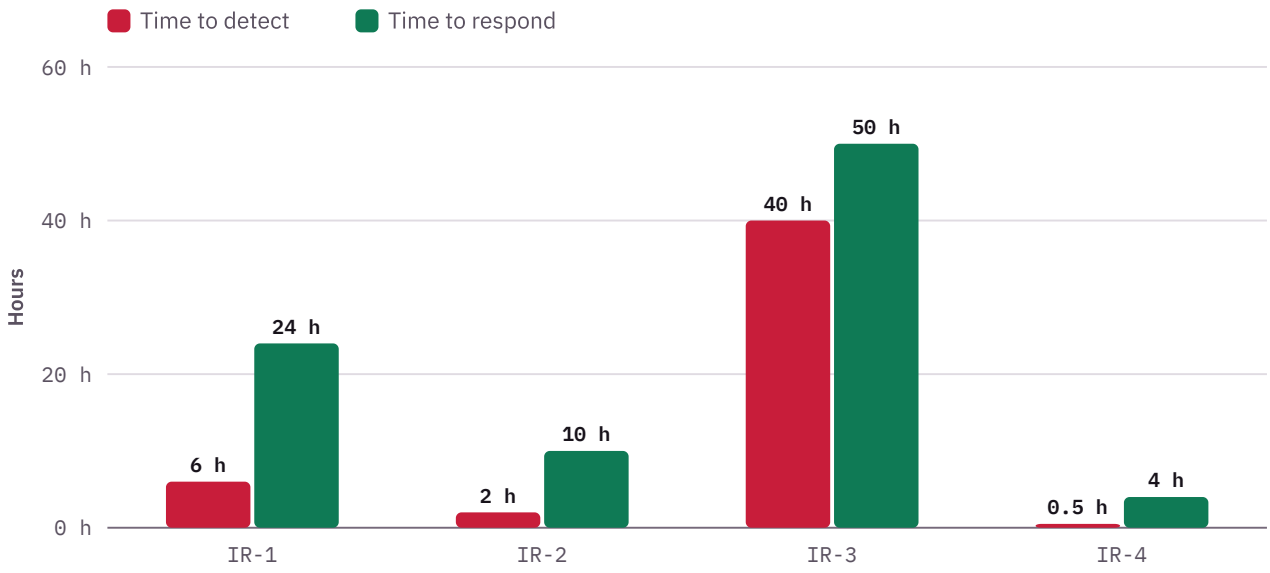
Worked example: four incidents (hours from compromise)

INCIDENT	DETECTED AT	RESOLVED AT	TIME TO DETECT	TIME TO RESPOND
IR-1	6	30	6	24
IR-2	2	12	2	10
IR-3	40	90	40	50

Copyright © ZyeemZia

INCIDENT	DETECTED AT	RESOLVED AT	TIME TO DETECT	TIME TO RESPOND
IR-4	0.5	4.5	0.5	4

One outlier drives the mean



Illustrative data from the worked example. IR-3 alone lifts mean time to detect to 12.1 hours while the median is 4 hours, so report both and investigate the outlier.

EXAMPLE · READING THE WORKED EXAMPLE

MTTD = (6 + 2 + 40 + 0.5) ÷ 4 = **12.1 hours**. MTTR = (24 + 10 + 50 + 4) ÷ 4 = **22 hours**. Yet the median time to detect is only (2 + 6) ÷ 2 = **4 hours**: one slow incident (IR-3) drags the mean up. Report medians and the 90th percentile alongside means, and look closely at the outliers, because that is where the process failed.

A balanced metrics set

METRIC	AUDIENCE	GOOD DIRECTION	GAMING RISK
MTTD and median dwell time	Board, CISO	Down	Late timelines that understate start time
MTTC	CISO, SOC lead	Down	Premature containment claims
Detection coverage of priority techniques	CISO, detection engineering	Up	Counting rules whose data is not flowing
Alert precision per use case	Detection engineering	Up	Disabling hard but valuable rules
Post-incident actions closed on time	Risk committee	Up	Closing actions without verifying them

A blameless lessons-learned review

1. **Schedule quickly** Hold the review within two weeks while memories and logs are fresh.
2. **Build the timeline** Reconstruct events from evidence, not from memory, with times in UTC.

Copyright © ZyeemZia

3. **Ask how, not who** Explore why decisions made sense at the time and which conditions allowed the failure.
4. **Identify improvements** Detection, prevention, process, people and tooling gaps.
5. **Assign and track** Each action has an owner, a due date and a verification method.
6. **Close the loop** Update playbooks, detections and training; re-test in the next exercise.

SCENARIO · DECIDE · MTTR WENT UP

After a quarter of detection-engineering work, the board report shows MTTR rose from 9 to 14 hours, and a board member asks whether the SOC is getting worse. Coverage of priority techniques rose from 41% to 68%, and median dwell time fell from 9 days to 2 days. How should the CISO respond?

(A) Promise to bring MTTR back under 9 hours next quarter by closing incidents faster.

(B) Stop reporting MTTR to the board because it no longer reflects the SOC's real performance now that detection has changed so much.

(C) Explain that new detections now catch harder intrusions earlier, and show MTTR with dwell time and coverage, split by severity.

(D) Reduce the number of new detections so that fewer complex incidents enter the queue.

Circle your choice. Answer and feedback: module answer key.

Metrics hygiene

☐ Every metric has a written definition with start and stop events

☐ Means are reported with medians and 90th percentiles

☐ Coverage counts only detections with flowing data and a recent test

☐ Metrics are segmented by severity and incident type

☐ Trends are shown over at least four quarters

☐ Lessons-learned actions are tracked to verified closure

REFLECT

Pick one metric your team reports today. What behaviour does it reward, and what would an analyst do differently if they were trying to make it look good rather than be good?

Key terms

MTTD
Mean time to detect: the average time from the start of a compromise to its detection.

MTTR
Mean time to respond (or resolve): the average time from detection to resolution, as defined in the organisation's metrics dictionary.

Dwell time
The time an attacker is present in an environment before detection, measured per incident.

Copyright © ZyeemZia

Key takeaways

- Define every metric precisely (start and stop events) and publish a metrics dictionary.
- Report medians and percentiles beside means; outliers show where the process failed.
- Balance speed metrics with quality, coverage and dwell time so nobody games the numbers.
- Blameless reviews ask how, not who, and produce owned, verified improvement actions.

KNOWLEDGE CHECK

21. Three incidents were detected 4, 8 and 30 hours after compromise. What is the MTTD?

(A) 8 hours
(B) 14 hours
(C) 12 hours
(D) 30 hours

22. Why should the median be reported alongside mean time to detect?

(A) The median is always lower, which makes the SOC's performance look better
(B) Regulators only accept medians, so means cannot be shown to auditors
(C) The median includes incidents that were never detected, unlike the mean
(D) A few extreme incidents can distort the mean and hide typical performance

23. A team reports 90% detection coverage, but a third of the counted rules have had no data for a month. What is the problem?

(A) Coverage is overstated because rules without flowing data detect nothing
(B) Coverage is understated because silent rules are still technically enabled
(C) Coverage is correct because rules are counted regardless of data volume
(D) Coverage cannot be calculated when any rule has been silent for a month

24. Which practice best defines a blameless post-incident review?

(A) Asking why decisions made sense at the time and which conditions allowed failure
(B) Avoiding any discussion of mistakes so that nobody in the team feels uncomfortable
(C) Keeping the review confidential to senior managers to protect reputations
(D) Identifying the individual responsible and recording it in their file

25. What is the risk of using 'alerts closed per analyst per hour' as a performance target?

(A) It slows analysts down because they must record their time for every alert
(B) It increases false positives because closed alerts automatically trigger new ones
(C) It rewards fast closure over correct investigation, so real threats get dismissed
(D) It prevents automation because playbooks cannot close alerts on their own

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 7 · RESPOND

Answer key

Knowledge checks

1. C Timeline problems almost always trace back to clock drift or mixed time zones. NTP and UTC timestamps fix this.

2. D Flows describe conversations, not content. Byte counts, peers and timing are exactly what they record.

3. B Without an active timeout a multi-hour session would not appear until it closed, hiding beacons and large transfers.

4. B Long, rarely searched retention belongs in low-cost immutable storage. Keeping it hot is expensive; keeping it on devices risks loss and tampering.

5. C Many alerts carry only an IP address. DHCP records link that address to a device at the time of the event.

6. D Spraying tries one or two passwords across many accounts, so distinct-user counts per source reveal it. Per-account counts catch brute force instead.

7. A Absence rules fire when expected data stops, protecting against silent blind spots.

8. A Detection-as-code brings peer review, history and portability. It does not remove the need for data or guarantee quality.

9. C Enrichment joins events with context such as asset inventory, identity attributes and threat intelligence before correlation.

10. B A rule without data detects nothing. Honest coverage metrics combine rule existence with source health.

11. D Enrichment is read-only and low-risk. The other actions have significant business impact and warrant approval or high confidence.

12. D Allow lists for critical assets stop automation from causing self-inflicted outages, whatever the source of a bad indicator.

13. A Hunts work best with focused, behaviour-based, testable statements. Broad or confirmation-seeking hunts rarely produce useful results.

14. B Automated beacons tend to have consistent spacing. Human browsing is irregular. Neither statistic says anything about bytes or encryption.

15. C Finding a blind spot is a useful result; it must be owned and closed. Absence of data is not evidence of absence of attack.

16. A Memory and live network state disappear on reboot or isolation. Disk images, archives and backups persist and can follow.

17. B A hash is a fingerprint, not encryption or compression. Matching hashes over time demonstrate integrity.

18. D Containment decisions weigh impact. Scoping the account's use and adding monitoring can contain risk while the business decides. Reusing the password defeats the purpose.

19. C Removing the attacker's footholds is eradication, part of the combined containment, eradication and recovery phase.

20. C Backups that share administrative control and storage with production are often destroyed by ransomware operators. Immutable, separate copies are trusted.

21. B (4 + 8 + 30) ÷ 3 = 42 ÷ 3 = 14 hours. The median would be 8 hours, showing the effect of one slow detection.

22. D Means are sensitive to outliers. The median shows typical performance while outliers are examined separately.

23. A Honest coverage requires both the rule and its data. Silent sources should reduce the figure.

24. A Blameless does not mean ignoring mistakes; it means examining systemic causes so people share information honestly.

25. C Throughput targets encourage superficial triage. Quality measures such as precision and missed-incident reviews must balance them.

Scenarios & case studies

> **Scenario · Half the logging budget**
> **B** is best. Best. High-value sources stay instantly searchable while bulky but still useful data remains available at lower cost.

> **Scenario · Three silent days**
> **A** is best. Best. It turns silent failure into an alert and makes coverage figures honest.

> **Scenario · A beacon with a ten-day-old domain**
> **D** is best. Best. A hunt that finds likely malicious activity hands over to IR immediately and also produces lasting detection value.

Copyright © ZyeemZia

Case study · Ransomware tabletop at a regional hospital
Wake the incident lead, SOC on-call, infrastructure lead, the clinical lead or duty manager with authority over patient-care systems, communications, and legal or privacy. Isolation decisions for clinical systems are made jointly by the incident lead and the clinical authority, because downtime procedures must start first. Containment: disable the contractor account and revoke its sessions, block remote access for third parties pending review, isolate affected segments while keeping life-critical devices on their own protected network, and activate paper-based downtime procedures. The same-array snapshots may be encrypted or deleted by the attacker and are suspect; the weekly immutable offline copy is the trusted recovery source, but only after the six-day intrusion is scoped, persistence removed and credentials reset, otherwise restored systems will be re-infected. Restore into an isolated network and scan before reconnecting. Lessons learned should examine MFA gaps for third-party access, why six days of activity went undetected, backup architecture and restore time, the clarity of clinical decision rights, and communication with staff and patients.

Scenario · Restore now?
B is best. Best. Restoring into an environment the attacker still controls invites immediate re-encryption, and recent backups may contain the attacker's tools.

Scenario · MTTR went up
C is best. Best. More, earlier detection of harder incidents raises response effort per incident while cutting attacker time in the network, the outcome that matters.

Copyright © ZyeemZia

08

MODULE 8 · ZEROTRUST

ZeroTrust — Zero Trust Architecture, Automation & Capstone

Wrap every layer in per-session, evidence-based access decisions, automate policy safely and prove expert readiness.

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Design a zero trust architecture using the NIST SP 800-207 components, tenets and deployment models.
- Combine identity, device and data signals with continuous verification and micro-segmentation.
- Assess maturity and build a phased, measurable zero trust roadmap including legacy systems.
- Automate policy deployment and audit with APIs, Python, Ansible and policy-as-code, and govern AI assistance.
- Solve a multi-layer expert lab and plan a capstone across the full Defence-in-Depth Stack.

LESSONS

1. Zero Trust Architecture and NIST SP 800-207 · 40 min
2. Identity, Device and Data Controls with Micro-segmentation · 40 min
3. Zero Trust Maturity and Roadmap · 40 min
4. Security Automation, Policy-as-Code and AI-Assisted Operations · 45 min
5. Mock Expert Lab, Exam Strategy and Capstone · 50 min

MODULE 8 · ZEROTRUST · LESSON 1 · 40 MIN

Zero Trust Architecture and NIST SP 800-207

The tenets, logical components and deployment approaches that turn zero trust from a slogan into a design

- State the zero trust tenets and explain why network location no longer implies trust.
- Describe the roles of the policy engine, policy administrator and policy enforcement point.
- Compare the deployment approaches and models defined in NIST SP 800-207.

ZeroTrust wraps every other layer of the ZCIE Security Defence-in-Depth Stack. It is not a product and not a single control: it is an architecture in which no subject, device or network location is trusted by default, and every access to a resource is decided per session using current evidence. **NIST SP 800-207** gives the most widely used vendor-neutral vocabulary for that architecture. NIST's companion practice guide, **SP 1800-35** (finalised in 2025), shows how the same components were assembled in a range of example builds, which is useful when you map products to roles.

The seven tenets, in summary

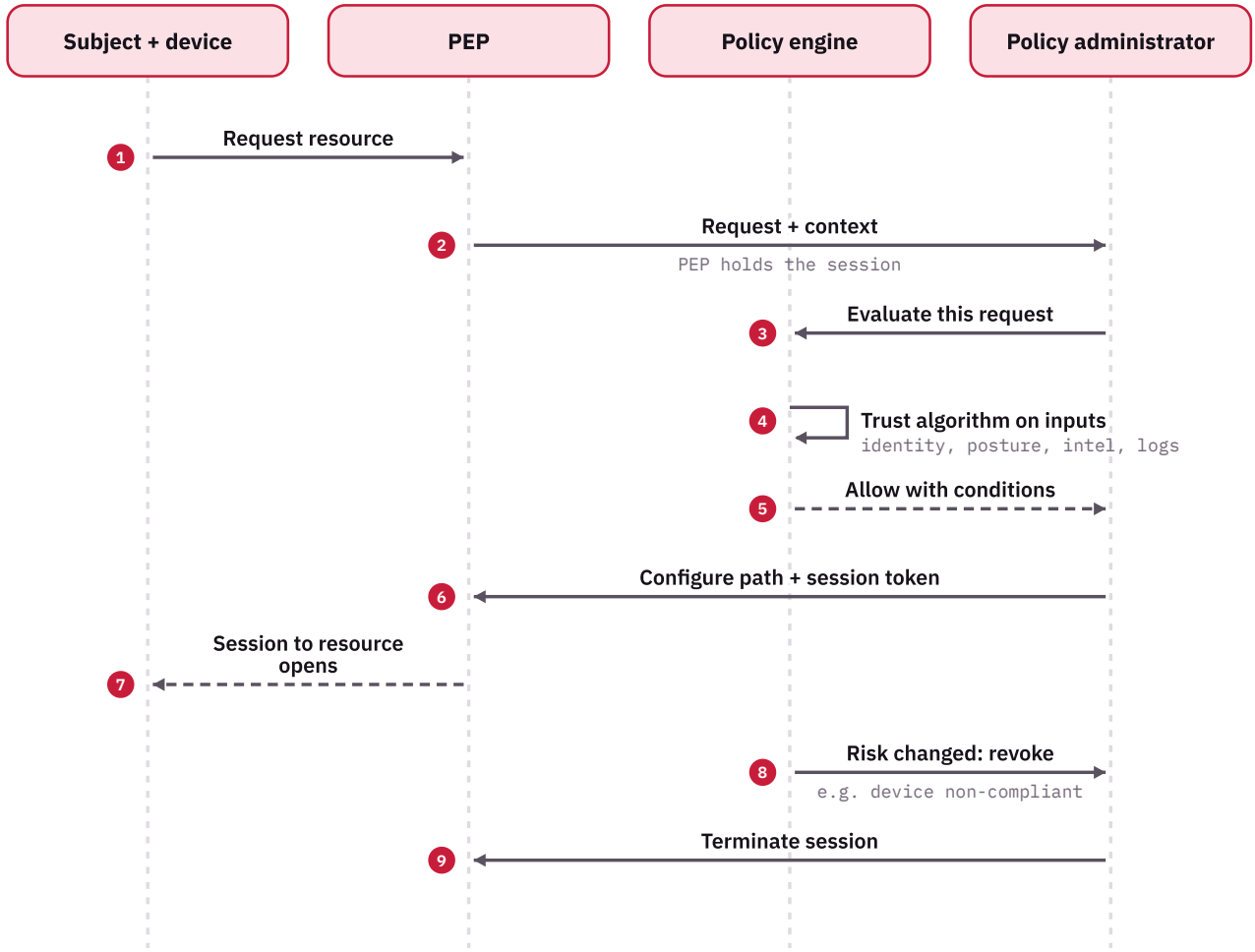
- All data sources and computing services are treated as **resources**.
- All communication is secured **regardless of network location**.
- Access to each resource is granted **per session**.
- Access is decided by **dynamic policy** using identity, application, device state and other attributes.
- The enterprise **monitors the integrity and posture** of all owned and associated assets.
- Authentication and authorisation are **dynamic and strictly enforced** before access is allowed.
- The enterprise **collects as much information as possible** about assets, network and communications and uses it to improve.

Logical components of a zero trust architecture

Control plane	`Policy engine (PE): makes the decision` `Policy administrator (PA): executes it` `Together: policy decision point`
Data plane	`Subject and device` `Policy enforcement point (PEP)` `Enterprise resource`
Policy inputs	`Identity management` `Device posture and diagnostics` `Threat intelligence` `Activity logs and SIEM` `Data access policies` `PKI` `Compliance requirements`

Copyright © ZyeemZia

How one access decision is made



The engine decides, the administrator turns the decision into configuration, and only the PEP touches the traffic. The same path runs in reverse when a signal changes mid-session.

Component responsibilities

COMPONENT	RESPONSIBILITY	TYPICAL IMPLEMENTATIONS
Policy engine (PE)	Grants, denies or revokes access using policy and a trust algorithm	Identity provider conditional access, ZTNA policy service
Policy administrator (PA)	Establishes or shuts down the path, issues session tokens	ZTNA broker, access proxy control plane
Policy enforcement point (PEP)	Enables, monitors and terminates connections	Agent, gateway, reverse proxy, micro-segmentation enforcer
Policy information sources	Feed context to the PE	EDR, device management, SIEM, threat intelligence, data catalogue

DEFINITION · TRUST ALGORITHM

The logic the policy engine uses to reach a decision. NIST describes **criteria-based** algorithms (every condition must be met) and **score-based** ones (a confidence score must exceed a threshold), and **singular** algorithms that judge each request alone versus **contextual** ones that also consider recent history of the subject.

Copyright © ZyeemZia

Deployment approaches in SP 800-207

EIG

Enhanced identity governance

Identity and its attributes drive access decisions; strong where users reach SaaS and cloud resources directly.

MSEG

Micro-segmentation

Resources are placed in small segments protected by gateways or host enforcement, and policy controls the flows between them.

SDP

Network infrastructure and software-defined perimeters

An overlay network brokers connections so resources stay hidden until access is approved.

Deployment models

MODEL	HOW IT WORKS	GOOD FIT
Device agent and gateway	Agent on the device talks to a gateway in front of each resource	Managed devices, private apps
Enclave gateway	Gateway protects a group of resources at an enclave boundary	Legacy systems that cannot host agents
Resource portal	A portal acts as the PEP for users, often without an agent	Unmanaged devices, web applications
Application sandboxing	Trusted applications run compartmentalised on the device	High-assurance access from shared devices

Perimeter model versus zero trust

Perimeter model

- Inside the network means trusted
- Access decided once at the edge or VPN
- Flat internal networks
- Visibility focused on north-south traffic

Zero trust

- Location confers no trust
- Access decided per session and re-evaluated
- Resources individually protected
- Visibility of identity, device and east-west flows

SCENARIO · DECIDE · THE 'ZERO TRUST PRODUCT'

A vendor tells your CIO that buying its gateway will make the company 'zero trust compliant'. The CIO asks for your view. What is the best response?

(A) Map the product to the PE, PA and PEP roles and the seven tenets, find the pillars it leaves uncovered, and judge it as one component.

(B) Agree, because a gateway that authenticates every user before granting access satisfies the main requirement of a zero trust design.

(C) Reject the product outright, because zero trust can only be built from open-source components.

(D) Ask the vendor for a compliance certificate and approve the purchase once one is provided.

Circle your choice. Answer and feedback: module answer key.

Key terms

Policy engine (PE)

The NIST SP 800-207 component that decides whether to grant, deny or revoke access to a resource.

Policy administrator (PA)

The component that executes the policy engine's decision by establishing or shutting down the session path.

Copyright © ZyeemZia

Policy enforcement point (PEP)
The component in the data path that enables, monitors and terminates connections between a subject and a resource.

Key takeaways

- Zero trust is an architecture, not a product: no subject, device or location is trusted by default.
- The policy engine decides, the policy administrator executes and the PEP enforces in the data path.
- Trust algorithms are criteria-based or score-based, singular or contextual.
- Choose deployment approaches (identity governance, micro-segmentation, SDP) and models (agent/gateway, enclave, portal, sandbox) per resource.

KNOWLEDGE CHECK

1. Which component in NIST SP 800-207 actually terminates an active session when the policy engine revokes access?

   (A) The policy engine, which closes the connection directly at the resource
   (B) The policy enforcement point, instructed by the policy administrator
   (C) The SIEM, which sends a reset packet to the subject's device
   (D) The identity provider, which deletes the user's account immediately

2. A policy engine allows access only when every condition (managed device, compliant patch level, MFA, approved country) is met. What kind of trust algorithm is this?

   (A) Score-based
   (B) Contextual only
   (C) Network-based
   (D) Criteria-based

3. Which deployment approach best fits an organisation whose users mainly reach SaaS applications directly from the internet?

   (A) Enhanced identity governance
   (B) Micro-segmentation with gateways
   (C) Enclave gateways per data centre
   (D) Software-defined perimeter overlays

4. A plant has legacy controllers that cannot run agents or modern authentication. Which deployment model fits best?

   (A) A device agent installed on every controller
   (B) An enclave gateway in front of the controllers
   (C) Application sandboxing on each controller
   (D) A resource portal on each controller's interface

5. Which statement reflects the tenet that communication is secured regardless of network location?

   (A) Traffic inside the data centre can stay unencrypted because the perimeter firewall protects it
   (B) Only traffic leaving the country needs encryption under a zero trust architecture
   (C) Network location replaces identity as the main factor in every access decision
   (D) Traffic inside the data centre is authenticated and encrypted like traffic on the internet

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 8 · ZEROTRUST · LESSON 2 · 40 MIN

Identity, Device and Data Controls with Micro-segmentation

Feed access decisions with strong signals, verify continuously and shrink every blast radius

- Combine identity, device and data signals in access policy.
- Design continuous verification that reacts to changing risk during a session.
- Plan and implement micro-segmentation using network, host and workload-native methods.

Zero trust decisions are only as good as the signals behind them. The Identity module built strong authentication; here the question is how identity, device and data signals combine **at decision time** and how they keep flowing **after** access is granted. Then we apply the same thinking to east-west traffic with micro-segmentation, so a compromised workload can reach only what it truly needs.

Controls and signals by pillar

PILLAR	KEY CONTROLS	SIGNALS FOR THE POLICY ENGINE
Identity	Phishing-resistant MFA, least privilege, just-in-time admin	Sign-in risk, authentication strength, group and role
Device	Management, encryption, EDR, patch compliance	Compliance state, EDR risk score, certificate
Network	Micro-segmentation, encrypted transport, ZTNA	Source context, segment, flow anomalies
Application and workload	Per-app access, workload identity, secure pipelines	Workload identity, vulnerability status
Data	Classification, labelling, encryption, DLP	Sensitivity label, location, volume of access

Continuous verification in practice

SIGNAL CHANGE DURING A SESSION	EXAMPLE	POLICY RESPONSE
Device falls out of compliance	EDR stops reporting on the laptop	Block sensitive apps until healthy
Identity risk rises	Leaked-credential alert for the user	Revoke sessions and require re-authentication
Location anomaly	Same session token used from two countries	Terminate session and investigate token theft
Unusual data behaviour	Bulk download of restricted files	Step-up authentication or block download
Account change	User removed from the group by HR process	Access ends on the next evaluation, not next login

INSIGHT · REVOCATION MUST BE FAST

Long-lived tokens undermine continuous verification: if a session token lasts eight hours, a risk change at minute five is ignored for the rest of the day. Use short token lifetimes plus event-driven revocation, for example through the OpenID Shared Signals Framework and its Continuous Access Evaluation Profile, so identity providers and applications share risk events in near real time.

Copyright © ZyeemZia

Data-centric controls make sensitivity a first-class policy input. Classify and label data, encrypt it at rest and in transit, and let access policy depend on the label: a managed, compliant laptop may download *Confidential* files; an unmanaged browser session may only view them. Data loss prevention then enforces the same labels at the endpoint, gateway and SaaS layers.

Ways to micro-segment

Network-based

- VLANs, VRFs, ACLs and internal firewalls
- No host changes needed
- Coarse; rule sprawl on IP addresses
- Good for OT and legacy

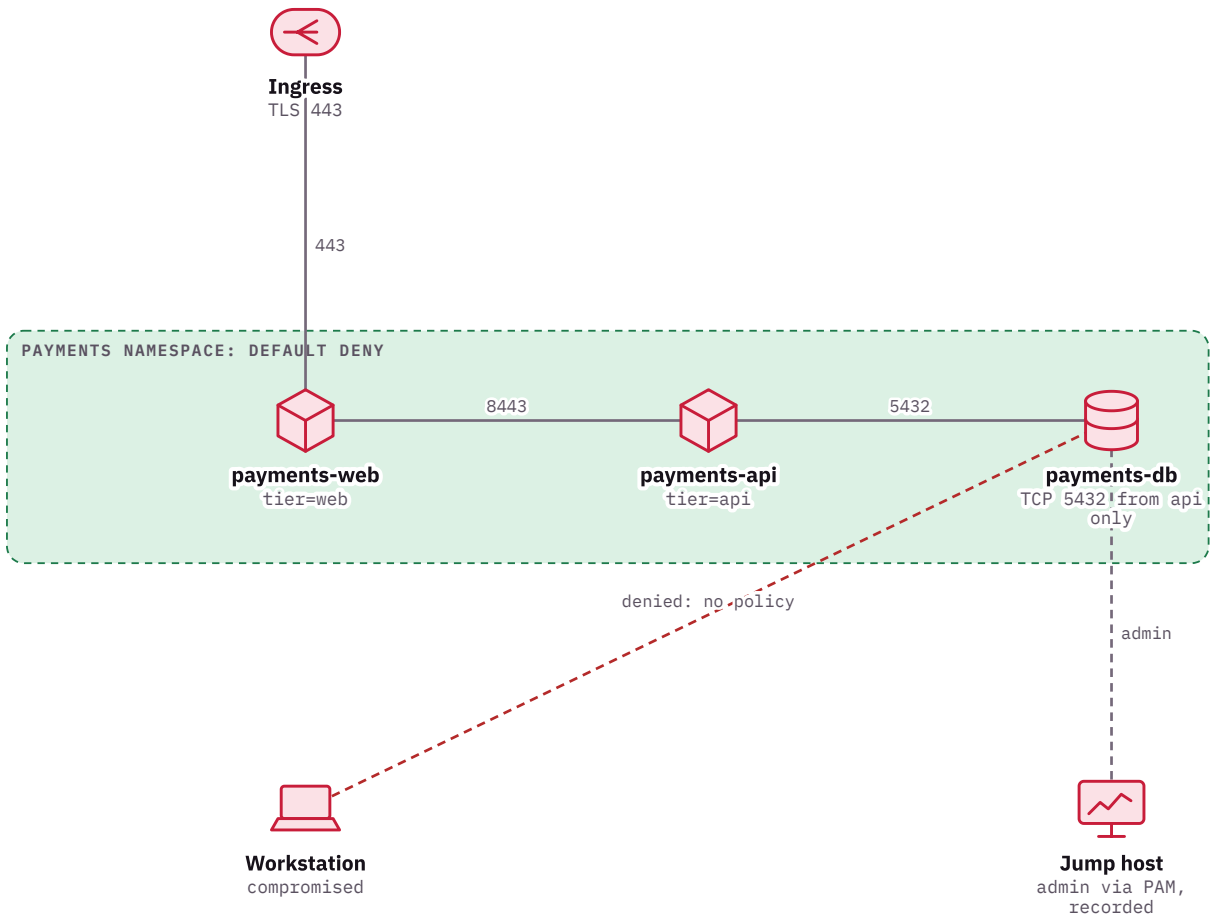
Host-based

- Agents program each host's firewall
- Policy follows labels, not IPs
- Fine-grained, works across clouds
- Needs agent coverage

Workload-native

- Cloud security groups, container network policies
- Service mesh with mutual TLS workload identity
- Built into the platform
- Different model per platform

Micro-segments around a payments service



Each arrow that exists is an explicit allow rule tied to labels, and everything else is denied. A compromised workstation can still route to the database's address, but no policy admits it; administration arrives only through the recorded jump host.

Rolling out micro-segmentation

1. **Discover** Run in visibility mode to map real flows between applications for several weeks.

Copyright © ZyeemZia

2. **Label** Tag workloads by environment, application, tier and data sensitivity.
3. **Ring-fence crown jewels** Write allow policies around the most critical applications first.
4. **Simulate** Run policies in test mode and review what would have been blocked.
5. **Enforce in waves** Turn on enforcement application by application with rollback ready.
6. **Operate** Route new flows through change control and alert on policy violations.

Workload-native segmentation for a payments database

Kubernetes · NetworkPolicy (YAML)

```yaml
apiVersion: networking.k8s.io/v1
kind: NetworkPolicy
metadata:
  name: payments-db-ingress
  namespace: payments
spec:
  podSelector:
    matchLabels:
      app: payments-db
  policyTypes:
  - Ingress
  ingress:
  - from:
    - podSelector:
        matchLabels:
          app: payments-api
    ports:
    - protocol: TCP
      port: 5432
```

Only pods labelled `payments-api` *in the same namespace may reach the database on TCP 5432. Network policies are enforced only when the cluster's network plugin supports them; pair this with a namespace-wide default-deny policy.*

PRO TIP · START WITH THE PROTOCOLS ATTACKERS LOVE

A quick, high-value first step in a flat network is to block workstation-to-workstation SMB, RDP and remote management, and to restrict administrative protocols to hardened jump hosts. It cuts the main lateral-movement paths used in ransomware attacks without waiting for full application mapping.

SCENARIO · DECIDE · THREE THOUSAND SERVERS, ONE FLAT NETWORK

A manufacturer's data centre has 3,000 servers on a few large VLANs. After a competitor suffered ransomware, the board wants micro-segmentation within a year. Application documentation is poor. Where should you start?

(A) Write a complete rule set for all 3,000 servers from the existing application documentation and enforce it over one long weekend.

(B) Re-address every server into hundreds of small VLANs before deciding on any access policy.

(C) Wait until a full application inventory is complete, then begin designing segments.

(D) Map flows first, restrict admin and workstation-to-workstation protocols now, then ring-fence the crown jewels.

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

REFLECT

Which three flows in your environment would an attacker most want to use after compromising one workstation? How would identity, device and segmentation controls each make those flows harder?

Key terms

Micro-segmentation
Dividing an environment into small zones, down to individual workloads, with policy controlling each allowed flow between them.

Device posture
The security state of a device, such as management, encryption, EDR health and patch level, used as an access input.

Continuous verification
Re-evaluating access during a session as identity, device, behaviour and threat signals change.

Key takeaways

- Access decisions combine identity, device, network, workload and data signals at decision time.
- Continuous verification needs short token lifetimes and event-driven revocation, not one check at login.
- Make data sensitivity a policy input: labels decide download, view-only or block.
- Micro-segment by network, host or workload-native means; map flows first, cut admin and workstation-to-workstation protocols early, then ring-fence crown jewels.

KNOWLEDGE CHECK

6. A user's laptop stops reporting EDR telemetry mid-session. Under continuous verification, what should happen?

   (A) Nothing changes until the user's session expires at the end of the working day
   (B) The user's account is deleted because an agent failure indicates malicious intent
   (C) Access to sensitive applications is restricted until the device is healthy again
   (D) The laptop is automatically reimaged remotely before the user can save their work

7. Why do long-lived session tokens weaken a zero trust design?

   (A) They require stronger encryption, which slows down every application request
   (B) They prevent users from accessing more than one application at a time
   (C) They force the policy engine to evaluate every packet instead of each session
   (D) Risk changes after issue are ignored until the token expires or is revoked

8. Which micro-segmentation method writes policy based on workload labels and follows workloads across clouds?

   (A) VLANs and access control lists
   (B) A perimeter firewall cluster
   (C) Host-based agent enforcement
   (D) Static routes between subnets

Copyright © ZyeemZia

9. In the network policy example, which traffic is allowed to the payments database?

   (A) TCP 5432 from pods labelled payments-api in the payments namespace

   (B) Any TCP traffic from any pod in any namespace of the cluster

   (C) TCP 5432 from every pod in the payments namespace regardless of label

   (D) All traffic from payments-api pods on every port and protocol

10. What is the purpose of running segmentation policies in simulation mode before enforcement?

    (A) To let attackers trigger the policy so their techniques can be studied

    (B) To see which legitimate flows would be blocked before enforcement

    (C) To measure how much bandwidth the new policies will consume on each link

    (D) To satisfy auditors who require every policy to be disabled at first

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 8 · ZEROTRUST · LESSON 3 · 40 MIN

Zero Trust Maturity and Roadmap

Assess where you are, choose where to go next and deliver zero trust in measurable stages

- Assess maturity across pillars and cross-cutting capabilities.
- Build a phased zero trust roadmap with measurable outcomes.
- Handle legacy and operational technology that cannot meet modern controls.

No organisation becomes zero trust in a single project. It moves pillar by pillar from implicit trust towards dynamic, automated decisions. A maturity model gives a shared language for where you are and what 'next' looks like; the **CISA Zero Trust Maturity Model** (version 2) is widely used for this and complements the architecture in NIST SP 800-207.

Maturity stages

STAGE	WHAT IT LOOKS LIKE
Traditional	Manual configuration, static policies, trust based on network location, siloed tools
Initial	Some automation, first cross-pillar policies, MFA and inventories under way
Advanced	Centralised visibility, identity and device signals in most decisions, automated responses for common cases
Optimal	Fully automated, dynamic, just-in-time access with continuous monitoring across all pillars

Pillars and cross-cutting capabilities

ID
Identity
Phishing-resistant authentication, lifecycle governance and least privilege.

DEV
Devices
Inventory, compliance and risk of every device used for access.

NET
Networks
Segmentation, encrypted traffic and resilience.

APP
Applications and workloads
Per-application access, secure development and workload identity.

DATA
Data
Inventory, classification, encryption and access monitoring.

VIS
Visibility and analytics
Telemetry from all pillars feeding detection and decisions.

AUTO
Automation and orchestration
Policy and response executed by machines, consistently.

GOV
Governance
Policies, ownership and measurement that keep the programme on course.

Copyright © ZyeemZia

Current versus 12-month target maturity by pillar



Illustrative assessment for a mid-sized organisation. Targets move each pillar one stage at a time, and the weakest pillars (networks and data) set the pace for the whole programme.

A three-horizon roadmap

1. **Foundations (0 to 6 months)** Consolidate identity, phishing-resistant MFA for admins and remote access, complete asset inventory, central logging of identity and EDR.
2. **Expansion (6 to 18 months)** Device posture in access decisions, ZTNA replacing VPN for priority apps, ring-fence crown-jewel applications, data classification for key repositories.
3. **Optimisation (18 to 36 months)** Continuous evaluation with automated revocation, label-driven data policy, automated response, micro-segmentation at scale.
4. **Every horizon** Measure outcomes per pillar, review risk, and adjust the plan with the executive sponsor.

Roadmap horizons

MONTH 0
Assess
Maturity per pillar, crown jewels, sponsor

0–6 MONTHS
Foundations
One identity plane, phishing-resistant MFA for admins and remote access, inventories, central logs

6–18 MONTHS
Expansion
Posture in access decisions, ZTNA for priority apps, crown jewels ring-fenced

18–36 MONTHS
Optimisation
Continuous evaluation, label-driven data policy, segmentation at scale

Each horizon ends with measured outcomes, not purchases; the plan is reviewed with the executive sponsor before the next horizon starts.

Copyright © ZyeemZia

Legacy and operational technology

CONSTRAINT	COMPENSATING APPROACH
Cannot run agents	Enclave gateway or network-based segmentation in front of the system
No modern authentication	Privileged access gateway with MFA and session recording in front of it
Cannot be patched	Strict allow-list flows, protocol-aware inspection, heightened monitoring
Safety-critical availability	Monitor-only controls and change windows agreed with operations

INSIGHT · PUT CRYPTO AGILITY ON THE ROADMAP

Post-quantum migration is a multi-year change to the same identity, network and application pillars. With NIST's ML-KEM, ML-DSA and SLH-DSA standards published in 2024, build a **cryptographic inventory** (which protocols, libraries, certificates and devices use RSA or elliptic-curve algorithms), prioritise long-lived sensitive data and internet-facing TLS and VPN endpoints, prefer hybrid key exchange where it is supported, and ask suppliers for their roadmaps. NIST's draft transition guidance proposes deprecating today's quantum-vulnerable public-key algorithms around 2030 and disallowing them around 2035; check the current official timetable for your sector.

WATCH OUT · HOW ZERO TRUST PROGRAMMES FAIL

Buying products before defining the architecture; trying to change every pillar at once; ignoring legacy and OT until the end; no executive sponsor to settle conflicts between teams; and forgetting **break-glass** access, so an identity-provider outage locks everyone out of the tools needed to fix it.

TEMPLATE ### Zero trust maturity tracker

Track current and target maturity per pillar, with the initiatives, dependencies and evidence that prove progress.

PILLAR	CURRENT STAGE	TARGET STAGE AND DATE	KEY INITIATIVES	DEPENDENCIES	OWNER	EVIDENCE OF PROGRESS
Devices	*Initial*	*Advanced by Q4 2027*	*Posture signals in access policy; block unmanaged devices from admin portals*	*EDR coverage above 98%; device management for Linux*	*Endpoint engineering lead*	*Percentage of sign-ins evaluated with device posture*

CASE STUDY · ZERO TRUST ROLLOUT AT A NATIONAL TELECOM

Copyright © ZyeemZia

A telecom with 22,000 staff, 9,000 contractors, two core network data centres and a large OSS/BSS estate wants to adopt zero trust after a contractor account was used to reach billing systems over the remote-access VPN. Network operations relies on legacy element managers that support only local passwords. The identity team runs two directories after a merger. The board wants visible progress within nine months.

1. Which outcomes should the first nine months target, and why?

2. How should contractor access change?

3. How do you protect legacy element managers that cannot use modern authentication?

4. How will you show the board that risk is falling?

Model answer: module answer key.

SCENARIO · DECIDE · ZERO TRUST 'DONE' IN TWELVE MONTHS

The board asks the CISO to 'complete zero trust' within twelve months and to report a single completion percentage. What is the best response?

(A) Accept the deadline and report the percentage of planned zero trust products purchased and deployed as the completion figure each quarter.

(B) Decline to give any timeline because zero trust can never be finished.

(C) Propose a phased roadmap with outcome metrics per pillar and commit to specific maturity targets for twelve months, not completion.

(D) Report completion as the percentage of staff who have finished zero trust awareness training.

Circle your choice. Answer and feedback: module answer key.

Roadmap readiness

☐ Executive sponsor named with authority across network, identity and application teams

☐ Crown-jewel applications and data identified and owned

☐ Current maturity assessed for every pillar with evidence

☐ Break-glass accounts defined, protected and tested

☐ Legacy and OT systems listed with compensating approaches

☐ Outcome metrics agreed for each horizon

Key terms

Maturity model
A staged description of capability levels used to assess the current state and plan the next steps of a programme.

Crown jewels
The applications and data whose compromise would cause the greatest harm, prioritised for the strongest controls.

Copyright © ZyeemZia

Break-glass account
A tightly protected emergency account that allows administrators to regain access when normal authentication fails.

Key takeaways

- Use a maturity model (for example CISA ZTMM v2) to describe where each pillar is and what 'next' means.
- Deliver in horizons with outcome metrics, starting from the attack paths you actually face.
- Protect legacy and OT with enclave gateways, privileged access gateways and allow-listed flows.
- Plan break-glass access and crypto agility from the start; report progress as outcomes, never as purchases.

KNOWLEDGE CHECK

11. At which maturity stage do identity and device signals feed most access decisions, with automated responses for common cases?

(A) Initial
(B) Traditional
(C) Advanced
(D) Optimal

12. Legacy network element managers support only local passwords. What is the best compensating control?

(A) Long, complex local passwords shared through the team's encrypted chat channel
(B) Moving the element managers onto the corporate Wi-Fi so they are easier to reach
(C) Disabling logging on the element managers to reduce their attack surface
(D) A privileged access gateway with MFA, password vaulting and session recording

13. Why must break-glass access be designed into a zero trust programme?

(A) Auditors require at least one account that bypasses all logging for emergencies
(B) An outage of the identity provider or policy engine could otherwise lock administrators out
(C) Break-glass accounts replace MFA for administrators during normal operations
(D) Zero trust products will not install without a pre-created emergency account

14. What is the most convincing evidence of progress to give a board?

(A) Outcome metrics, such as privileged sessions using phishing-resistant MFA
(B) The number of zero trust products deployed across the organisation this year
(C) The number of policy documents that mention zero trust in their titles
(D) The total budget spent on zero trust initiatives compared with last year

15. Which first-horizon initiative best addresses an incident in which a contractor's VPN account reached billing systems?

(A) Move contractors to per-app ZTNA with strong MFA and time-bound access
(B) Increase the VPN concentrator's capacity so contractor sessions can be inspected
(C) Require contractors to change their VPN passwords every thirty days from now on
(D) Block contractors from using the VPN outside normal business hours only

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 8 · ZEROTRUST · LESSON 4 · 45 MIN

Security Automation, Policy-as-Code and AI-Assisted Operations

Deploy and audit security policy through code and pipelines, and use AI assistance with firm guardrails

- Use APIs, Python and Ansible to audit and deploy security policy consistently.
- Express security rules as policy-as-code and enforce them in a pipeline.
- Define guardrails for AI-assisted security operations.

Zero trust at scale is impossible by hand. Thousands of rules, devices and identities change every week, and the **AUTO** capability of the maturity model depends on treating policy as code: stored in version control, tested, reviewed and deployed by pipelines, with continuous checks for drift. This lesson shows the building blocks and the guardrails that keep automation from becoming a new risk.

Security automation stack

Governance	`Change approval` `Audit trail` `Separation of duties`
Pipeline	`Version control` `Linting and tests` `Staged deployment`
Policy-as-code	`Rule checks` `Compliance tests` `Drift detection`
Orchestration	`Ansible playbooks` `Python scripts` `SOAR workflows`
Interfaces	`REST APIs` `NETCONF and RESTCONF` `Cloud provider APIs`
Targets	`Firewalls` `Network devices` `Cloud and SaaS controls`

Auditing firewall rules through an API

Automation host · Python 3

```
import os, requests
API = "https://fw-manager.corp.example/api/v1"
HDR = {"Authorization": f"Bearer {os.environ['FW_API_TOKEN']}"}
resp = requests.get(f"{API}/policies/edge/rules", headers=HDR, timeout=15)
resp.raise_for_status()
rules = resp.json()["rules"]
risky = [r for r in rules if r["action"] == "allow"
         and r["source"] == r["destination"] == r["service"] == "any"]
unused = [r for r in rules if r.get("hit_count", 0) == 0]
for r in risky:
    print(f"ANY-ANY {r['id']:>6} {r['name']}")
print(f"{len(risky)} any-any rules, {len(unused)} rules with zero hits")
```

The token comes from the environment, never from the script. TLS verification stays on (the default). Read-only audits like this are the safest first automation and build trust for later write operations.

Copyright © ZyeemZia

Deploying a management-plane ACL with Ansible

Automation host · Ansible playbook (YAML)

```
- name: Enforce management-plane ACL on edge routers
  hosts: edge_routers
  gather_facts: false
  connection: ansible.netcommon.network_cli
  tasks:
    - name: Push ACL rendered from a version-controlled template
      ansible.netcommon.cli_config:
        config: "{{ lookup('ansible.builtin.template', 'templates/mgmt_acl.j2') }}"
      register: push
    - name: Record the result for the change ticket
      ansible.builtin.debug:
        msg: "{{ inventory_hostname }} changed={{ push.changed }}"
```

The inventory sets each device's network OS. Run the playbook against a lab group first, then a canary group of routers, before the full estate. The same template feeds both deployment and the audit that checks for drift.

Policy-as-code: rules every firewall change must pass

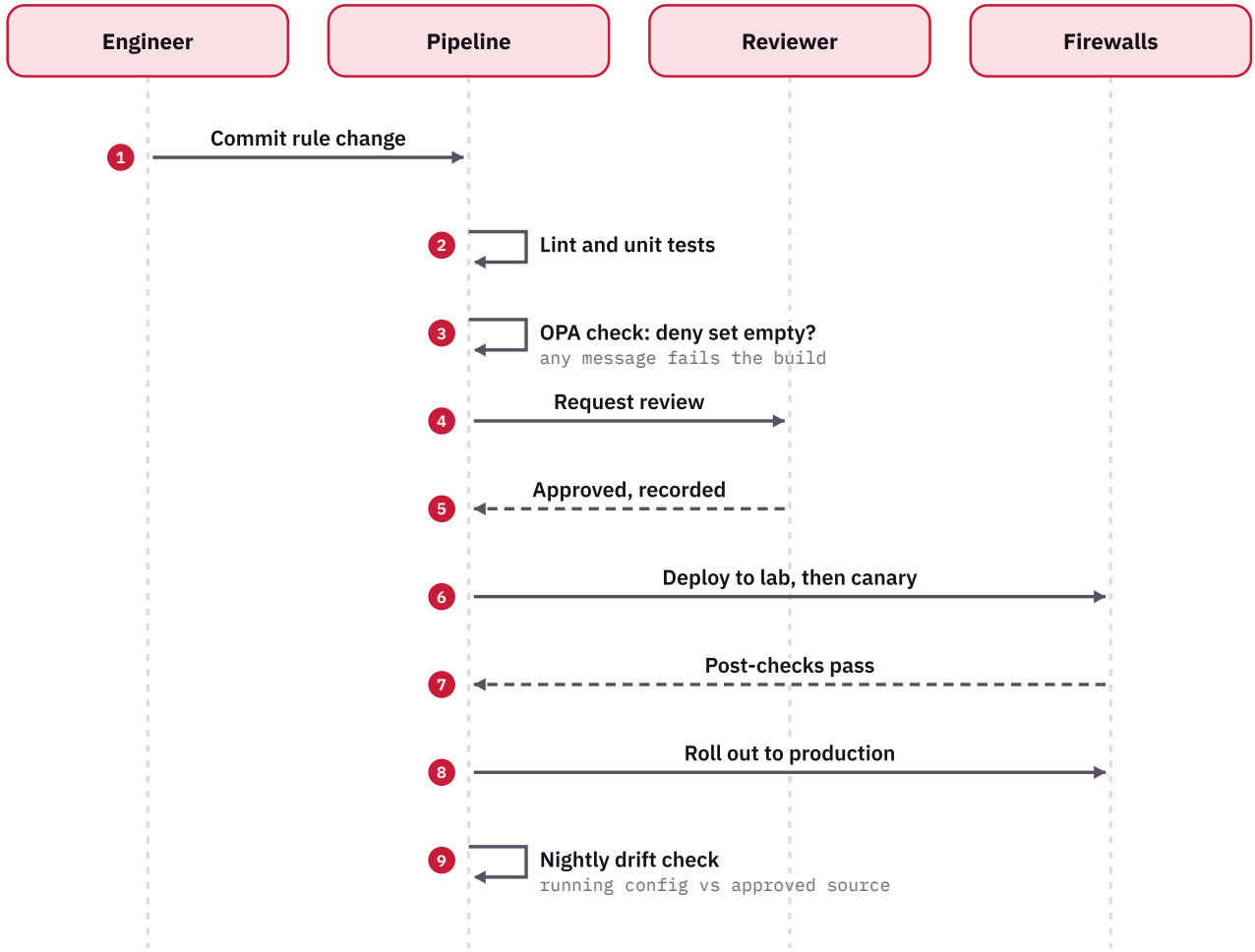
Pipeline · Open Policy Agent (Rego)

```
package firewall.review
deny contains msg if {
    some r in input.rules
    r.action == "allow"
    r.source == "any"
    r.destination == "any"
    msg := sprintf("rule %v allows any to any", [r.id])
}
deny contains msg if {
    some r in input.rules
    r.action == "allow"
    not r.ticket
    msg := sprintf("rule %v has no change ticket", [r.id])
}
```

The pipeline evaluates the proposed rule set as input and fails the build if `deny` *contains any message. Policies are tested and reviewed like any other code.*

Copyright © ZyeemZia

A policy-as-code pipeline with gates



Machines enforce the rules that never change (tests, OPA policy, staging), a person approves intent, and drift detection catches anyone who bypasses the pipeline.

WATCH OUT · AUTOMATION MULTIPLIES MISTAKES TOO

A wrong rule pushed by hand breaks one device; pushed by a pipeline it breaks hundreds. Store credentials in a secrets vault, give automation accounts least-privilege API scopes, stage deployments, keep tested rollback, and alert when the running configuration drifts from the approved source.

AI-assisted security operations can summarise long alert histories, draft hunting queries, explain unfamiliar scripts, suggest triage steps and write first drafts of incident reports. Used well, it shortens the path from alert to understanding. Used carelessly, it leaks sensitive data, invents facts, or takes actions based on content an attacker controls. Expert teams adopt it under explicit guardrails.

Guardrails for AI assistance in the SOC

HITL

Human in the loop

Assistants recommend; people approve any containment, blocking or account action.

PRIV

Least privilege

Tool access is read-only by default and scoped to the data the task needs.

DATA

Data handling

Only approved services may process incident data; secrets and personal data are redacted where possible.

Copyright © ZyeemZia

GRND

Grounding

Outputs cite the specific events, logs or documents they rely on, so analysts can verify them.

INJ

Untrusted input

Emails, web pages and logs may contain instructions planted by attackers; they are treated as data, never as commands.

EVAL

Evaluation

Accuracy is tested against known cases before and after changes, and errors are tracked.

LOG

Audit

Prompts, outputs and resulting actions are logged for review.

SCENARIO · DECIDE · LETTING AN ASSISTANT BLOCK IPS

An analyst proposes connecting an AI assistant to the firewall API so it can read incoming alerts and automatically block any IP address it judges malicious. What is the best response?

A Let the assistant recommend blocks with cited evidence, and route them through the existing SOAR approval and allow-list guardrails before any change is made.

B Approve it, because automated blocking is faster than any human and attackers move quickly.

C Ban AI assistance in the SOC entirely, because any use creates unacceptable risk.

D Allow it only at night, when fewer analysts are available to review alerts manually.

Circle your choice. Answer and feedback: module answer key.

Automation readiness

☐ Source of truth for policy kept in version control

☐ Automation credentials in a secrets vault with least-privilege scopes

☐ Policy-as-code checks run on every proposed change

☐ Lab and canary stages before production deployment

☐ Tested rollback for every automated change type

☐ Drift detection comparing running and approved configuration

☐ AI assistance limited to recommendations with logged, approved actions

Key terms

Policy-as-code

Expressing security and compliance rules as machine-evaluated code that is versioned, tested and enforced in pipelines.

Prompt injection

Instructions hidden in content processed by an AI system that attempt to make it act against its operator's intent.

Copyright © ZyeemZia

Key takeaways

- Treat security policy as code: version control, tests, review, staged deployment and drift detection.
- Start with read-only audits, then automate changes with least-privilege credentials from a vault.
- Pipelines multiply mistakes as well as fixes, so stage through lab and canary groups with tested rollback.
- AI assistance recommends with cited evidence; humans approve actions, and processed content is treated as untrusted data.

KNOWLEDGE CHECK

16. Why is a read-only rule audit usually the best first automation project?

(A) It requires no API access, so it can run on any workstation in the company
(B) It delivers value and builds trust without any risk of changing production
(C) It replaces the need for change control because it does not modify devices
(D) It automatically fixes risky rules, so engineers no longer need to review them

17. In the Rego example, what happens when a proposed rule allows traffic and has no ticket field?

(A) The rule is allowed because only any-to-any rules are checked by the policy
(B) Open Policy Agent adds a ticket number automatically and approves it
(C) The deny set contains a message, so the pipeline fails the change
(D) The rule is deployed but flagged for review after the next audit cycle

18. Which practice most reduces the blast radius of a faulty automated change?

(A) Running the automation only from a senior engineer's laptop
(B) Deploying all changes at once so problems appear immediately
(C) Disabling logging during deployment to improve automation speed
(D) Staged deployment to lab and canary groups with tested rollback

19. An AI assistant summarising a phishing email suggests disabling the CFO's account, citing text inside the email. What is the main risk?

(A) The email content may contain planted instructions, so the suggestion must be verified independently
(B) The assistant cannot read email headers, so its summary will always be incomplete and misleading
(C) AI assistants are not able to recommend actions involving executive accounts
(D) The CFO's account will be disabled automatically once the summary is saved

20. What does drift detection compare?

(A) The current alert volume against last year's alert volume in the SIEM
(B) The firewall vendor's latest software release against the installed version
(C) The running configuration against the approved configuration in version control
(D) The number of rules on one firewall against the number on its peer

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 8 · ZEROTRUST · LESSON 5 · 50 MIN

Mock Expert Lab, Exam Strategy and Capstone

Bring all eight layers together under time pressure, then plan your capstone defence

- Work through a multi-layer incident and design lab under exam-style constraints.
- Apply a structured strategy to scenario and log-interpretation questions.
- Plan a capstone that demonstrates the full Defence-in-Depth Stack.

The expert assessment does not test layers in isolation. It gives you an organisation, a set of evidence and a list of tasks that cut across the **Architect, Perimeter, Tunnel, Identity, Detect, Cloud, Respond** layers and the **ZeroTrust** wrapper. This mock lab uses a fictional firm, Kestrel Financial Services: 4,500 staff, two data centres, 60 branches on SD-WAN, a cloud landing zone and a dozen SaaS platforms. Allow eight hours and write down your evidence for every task.

Mock lab tasks

LAYER	TASK	POINTS	EVIDENCE EXPECTED
Architect	Produce a zone and trust-boundary diagram for the payments platform	10	Diagram with zones, flows and control points
Perimeter	Rewrite the edge policy to remove any-any rules and add application-based controls	10	Rule set diff and test results
Tunnel	Replace pre-shared keys on partner tunnels with certificates	8	Tunnel status and certificate details
Identity	Enforce phishing-resistant MFA and block legacy authentication	10	Policy export and sign-in log samples
Detect	Write and tune two detections for the evidence pack	12	Use-case cards and test alerts
Cloud	Fix public storage and open management ports; add guardrails	10	Posture report before and after
Respond	Build the incident timeline and contain the intrusion	25	Timeline, actions, evidence log
ZeroTrust	Propose a 12-month roadmap for the payments platform	15	Maturity tracker and outcome metrics

Copyright © ZyeemZia

Lab evidence pack: what happened overnight?

```
Kestrel SIEM · normalised events (UTC)

2026-05-11T01:58:12Z idp   signin user=svc-backup src=198.51.100.23 result=success auth=legacy-
basic mfa=none
2026-05-11T02:01:47Z edr   host=BKP-SRV-02 user=svc-backup proc=powershell.exe
parent=wsmprovhost.exe
2026-05-11T02:03:05Z edr   host=BKP-SRV-02 proc=7z.exe cmd="a -p archive01.7z D:\Exports\Clients\"
2026-05-11T02:04:02Z dns   client=10.40.8.15 q=upload.quickfiles-drop.example rcode=NOERROR
first_seen=true
2026-05-11T02:06:15Z swg   src=10.40.8.15 host=upload.quickfiles-drop.example category=file-sharing
action=allow
2026-05-11T02:41:55Z fw    src=10.40.8.15 dst=203.0.113.77:443 bytes_out=46.8GB duration=2147s
2026-05-11T03:10:30Z idp   signin user=svc-backup src=198.51.100.23 result=success auth=legacy-
basic mfa=none
```

BKP-SRV-02 is 10.40.8.15. Read the sequence as a story: valid account through legacy authentication without MFA, remote PowerShell, password-protected archive of client exports, first-seen file-sharing domain and a 46.8 GB upload.

The overnight story in UTC

01:58
Legacy sign-in, no MFA
svc-backup from 198.51.100.23

02:01
Remote PowerShell
WinRM session on BKP-SRV-02

02:03
Encrypted archive
Client exports packed with a password

02:04
First-seen domain
upload.quickfiles-drop.example resolved

02:06–02:41
46.8 GB upload
File-sharing category allowed for a server

03:10
Second sign-in
Same account, same source: still active

Building the timeline first turns seven log lines into an intrusion with a start, a goal and a gap you can still close: the attacker came back at 03:10.

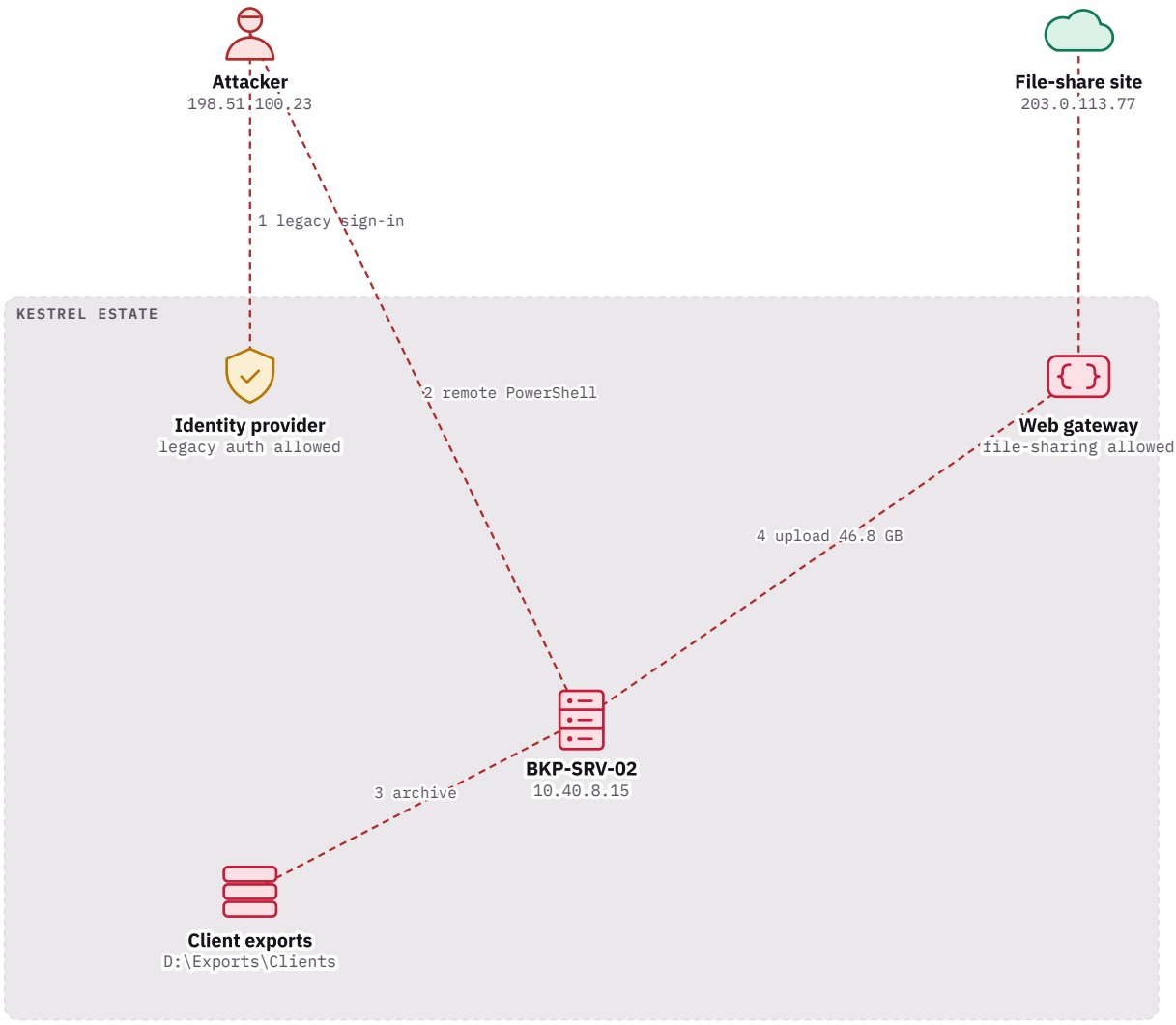
Mapping the evidence

TIME	OBSERVATION	ATT&CK	CONTROL THAT FAILED OR WAS MISSING
01:58	Service account signs in with legacy authentication, no MFA	T1078 Valid Accounts	Legacy authentication not blocked; service account usable interactively

Copyright © ZyeemZia

TIME	OBSERVATION	ATT&CK	CONTROL THAT FAILED OR WAS MISSING
02:01	Remote PowerShell session on the backup server	T1021.006 Windows Remote Management	Admin protocols not restricted to jump hosts
02:03	Password-protected archive of client exports	T1560.001 Archive via Utility	No detection for archiving sensitive shares
02:06 to 02:41	46.8 GB uploaded to a first-seen file-sharing site	T1567.002 Exfiltration to Cloud Storage	File-sharing category allowed for servers; no upload DLP

Kestrel attack path and the missing controls



Every red hop matches a row in the mapping table. Blocking legacy authentication closes hop 1, restricting admin protocols closes hop 2, and server egress rules plus upload DLP close hop 4.

Copyright © ZyeemZia

SCENARIO · DECIDE · FIRST CONTAINMENT MOVE IN THE MOCK LAB

It is 03:15 and the second sign-in has just happened. You have authority to act. Which action set comes first?

(A) Reimage BKP-SRV-02 immediately so the attacker loses their foothold before more data leaves.

(B) Disable svc-backup and revoke its sessions, block legacy auth and the upload domain, and isolate BKP-SRV-02 preserving evidence.

(C) Email all staff to warn them about a possible data breach and ask them to change their passwords.

(D) Raise the alert to SEV1 and wait for the morning change advisory board to approve the containment actions before doing anything.

Circle your choice. Answer and feedback: module answer key.

A method for an eight-hour expert lab

1. **Read everything first** Spend the first 20 minutes reading all tasks and evidence; note dependencies between them.
2. **Map tasks to layers** Use the Defence-in-Depth Stack to see which tasks share data and which must come first.
3. **Verify the starting state** Check what is already configured before changing it; record baseline evidence.
4. **Secure the points** Do high-value and prerequisite tasks first; do not sink an hour into a two-point task.
5. **Verify every task** Show proof: a show command, a log entry, a test alert, a screenshot of policy.
6. **Reserve review time** Keep the last 30 minutes to re-check evidence, save configurations and complete documentation.

Exam question types and how to approach them

QUESTION TYPE	SIGNAL IN THE STEM	APPROACH
Log interpretation	A block of events or headers	Build the timeline first, then map each line to a layer and technique
FIRST action	'What should you do first?'	Prefer actions that stop harm and preserve evidence over cleanup or reporting
BEST design	Constraints on cost, latency or legacy	Choose the option that meets every stated constraint, not the most powerful
Root cause	'Why did the control not stop it?'	Identify the layer and the exact mechanism that was bypassed or absent
Metric calculation	Times, counts or rates	Write the formula, substitute carefully, check units

Habits of expert candidates

- Read the last line of the stem first so you know what is being asked.
- Underline constraints: latency, budget, unmanaged devices, legacy, regulation.
- Eliminate options that are illegal, unsafe, destroy evidence or ignore a stated constraint.
- Prefer layered, proportionate answers over a single heroic control.
- Be wary of absolute options containing 'always', 'never' or 'all'.
- Never change an answer without a concrete reason found in the stem.

Copyright © ZyeemZia

Capstone deliverables

ARCH

Reference architecture

Zones, trust boundaries and control points for a realistic organisation, mapped to every stack layer.

POL

Policy set

Representative firewall, VPN, identity, SSE and segmentation policies with rationale.

DET

Detection and response pack

Five use-case cards, two SOAR playbooks with guardrails and one IR playbook.

ZT

Zero trust roadmap

Maturity assessment, three-horizon plan and outcome metrics.

DEF

Oral defence

A 20-minute presentation and questions on trade-offs and residual risk.

TEMPLATE

Capstone planning sheet

Plan your capstone layer by layer so every design decision has evidence and every gap is owned.

STACK LAYER	CURRENT GAP	DESIGN DECISION	CONTROL AND CONFIGURATION EVIDENCE	DETECTION AND RESPONSE COVERAGE	RESIDUAL RISK AND OWNER
Identity	*Service accounts allow legacy authentication*	*Block legacy auth; service accounts restricted to named hosts*	*Conditional access export; sign-in logs*	*Alert on any legacy-auth attempt; playbook to disable and rotate*	*Two vendor appliances still need basic auth; ops lead accepts until Q2*

Copyright © ZyeemZia

Capstone submission checklist

☐ Every stack layer appears in the architecture with at least one control
☐ Each policy has a stated purpose and a test or verification result
☐ Detections map to ATT&CK and include known false positives
☐ Automation includes approvals, allow lists and rollback
☐ The zero trust roadmap has dated targets and outcome metrics
☐ Residual risks are named, owned and accepted by the right person
☐ No real customer data, credentials or internal addresses are included

REFLECT

Looking back across all eight layers, where is your own organisation thinnest today? Write the first three actions you would take in the next 90 days and the evidence that would show they worked.

Key terms

Defence in depth
Layering independent controls so that the failure or bypass of one does not expose the protected asset.

Compensating control
An alternative control that reduces risk when the preferred control cannot be implemented.

Residual risk
The risk that remains after controls are applied, which must be owned and formally accepted.

Key takeaways

- Expert labs cut across every layer: read all tasks first, map them to the stack and secure high-value points.
- For log questions, build the timeline, then map each event to a technique and a missing control.
- FIRST-action answers stop harm and preserve evidence; BEST-design answers meet every stated constraint.
- A strong capstone shows each layer, its evidence, its detections and the residual risk someone has accepted.

KNOWLEDGE CHECK

21. In the mock lab evidence, which single missing control would most likely have prevented the initial access?

(A) Allowing the file-sharing category only for workstations and never for servers
(B) Blocking legacy authentication so the account could not sign in without MFA
(C) Collecting DNS logs from the backup server subnet at a higher sampling rate
(D) Adding the upload domain to the response policy zone after the incident

22. Which ATT&CK technique best describes the 46.8 GB upload to a file-sharing site?

(A) T1560.001 Archive via Utility
(B) T1071.004 Application Layer Protocol: DNS
(C) T1490 Inhibit System Recovery
(D) T1567.002 Exfiltration to Cloud Storage

Copyright © ZyeemZia

23. A question asks for the FIRST action during an active intrusion. Which kind of answer is usually strongest?

(A) One that rebuilds affected systems from scratch
(B) One that notifies every employee immediately
(C) One that stops harm while preserving evidence
(D) One that schedules a full audit for next month

24. A design question states that branch users need low latency, the budget is fixed and IoT devices cannot run agents. How should you choose between options?

(A) Pick the option meeting every stated constraint, even if another is more powerful
(B) Pick the option with the most security features, because security outweighs constraints
(C) Pick the cheapest option, because the budget is the only constraint that is fixed
(D) Pick the option that uses agents, because agents provide the best posture data

25. Why must residual risk in a capstone be named and owned?

(A) Residual risk must be zero before a design can be submitted for assessment
(B) Someone with authority must knowingly accept what the controls do not remove
(C) Naming residual risk transfers it automatically to the cyber insurance provider
(D) Owners of residual risk are responsible for fixing it within thirty days

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 8 · ZEROTRUST

Answer key

Knowledge checks

1. B The PE decides, the PA communicates the decision and the PEP enforces it in the data path.

2. D All conditions must be satisfied, which is the criteria-based approach. A score-based algorithm combines factors into a confidence value.

3. A When resources are SaaS, identity and its attributes are the main point of control.

4. B Enclave gateways place enforcement in front of a group of resources that cannot protect themselves.

5. D Zero trust removes implicit trust from location; internal links are treated as hostile networks.

6. C Policy reacts proportionately to the changed signal. Waiting for expiry ignores it; deleting accounts or reimaging is disproportionate.

7. D Continuous verification needs tokens that are short-lived or revocable on risk events.

8. C Host-based agents program each host's firewall from labels, independent of IP addressing and location.

9. A The pod selector restricts sources to payments-api pods in the policy's namespace, and the port rule restricts to TCP 5432.

10. B Simulation reveals undocumented dependencies so they can be allowed or challenged before enforcement.

11. C Advanced shows centralised visibility and broad use of signals with some automation. Optimal is fully dynamic and automated across all pillars.

12. D The gateway adds strong authentication, accountability and credential protection in front of systems that cannot provide them.

13. B Centralising decisions creates a dependency; protected, monitored emergency access is needed to recover from its failure.

14. A Outcome metrics show changed risk. Product counts, documents and spend show activity, not effect.

15. A Per-application access removes the network reach that was abused; the other options leave it in place.

16. B Read-only automation proves value safely. It still needs API access and does not fix anything by itself.

17. C The second rule adds a message for any allow rule without a ticket, and the pipeline treats a non-empty deny set as failure.

18. D Staging limits how many devices a mistake can affect before it is caught, and rollback restores service quickly.

19. A Content under attacker control is untrusted input. Recommendations based on it need independent verification and human approval.

20. C Drift is any difference between what is running and what was approved, often caused by manual changes.

21. B The intrusion began with a legacy-auth sign-in that bypassed MFA. Other controls would have limited later stages but not the entry.

22. D The upload of data to a web storage service is exfiltration to cloud storage. Archiving happened earlier, and DNS and recovery inhibition are not shown.

23. C Containment with evidence preservation comes before rebuilding, broad communication or audits.

24. A Expert design questions reward meeting all constraints. Agent-based options fail the IoT constraint.

25. B Every design leaves some risk. Accountability means the right person accepts it explicitly, with review.

Scenarios & case studies

> **Scenario · The 'zero trust product'**
> **A** is best. Best. Zero trust is an architecture; products fill roles within it. Mapping exposes gaps and integration needs.

> **Scenario · Three thousand servers, one flat network**
> **D** is best. Best. It delivers early risk reduction, builds the dependency map that later policy needs and focuses enforcement where impact is highest.

Copyright © ZyeemZia

Case study · Zero trust rollout at a national telecom
The first horizon should target the attack path that was actually used: consolidate or federate the two directories into one identity plane, enforce phishing-resistant MFA for all remote and privileged access, and move contractors from the VPN to per-application ZTNA with device or browser-isolation conditions and time-bound access tied to contracts. Ring-fence billing and other crown-jewel systems so they are reachable only through brokered access. Legacy element managers sit behind a privileged access gateway that enforces MFA, records sessions and vaults the local passwords, inside an enclave whose flows are allow-listed. Report outcome metrics to the board: percentage of remote and privileged sessions using phishing-resistant MFA, number of contractors still on VPN, crown-jewel applications ring-fenced, and median time to revoke leaver access, alongside maturity stage per pillar.

Scenario · Zero trust 'done' in twelve months
C is best. Best. Zero trust is a continuing journey; specific, measured targets set honest expectations and still show progress.

Scenario · Letting an assistant block IPs
A is best. Best. It captures the speed benefit while keeping human approval, protected allow lists and audit, and it limits the impact of manipulated alert content.

Scenario · First containment move in the mock lab
B is best. Best. It removes the attacker's access path, stops further exfiltration and preserves the evidence needed to scope what was taken.

Copyright © ZyeemZia

REFERENCE

Glossary

A

AAA Authentication, authorisation and accounting: the framework for controlling and recording access. (Identity)

ALE Annualised loss expectancy: single loss expectancy multiplied by the annual rate of occurrence. (Architect)

App connector A lightweight component near private applications that makes outbound-only connections to a ZTNA broker. (Cloud)

Application identification Classifying traffic by application using decoders, signatures and handshake data rather than port numbers. (Perimeter)

Asymmetric routing Forward and return packets of one flow taking different paths, breaking stateful inspection. (Perimeter)

Authenticator The switch or wireless controller that controls the port and relays EAP to the authentication server. (Identity)

B

Behavioural detection Detection based on sequences of actions that indicate attacker intent, rather than on a single known pattern. (Detect)

Blast radius The set of systems an attacker or failure can affect from a given foothold. (Architect)

BOLA Broken object level authorisation: an API flaw where the server does not verify that the caller may access the specific object requested. (Cloud)

Break-glass account A tightly protected emergency account that allows administrators to regain access when normal authentication fails. (ZeroTrust)

C

CASB Cloud access security broker: visibility and control over SaaS use through API integration and inline proxies. (Cloud)

Certificate pinning An application accepting only specific certificates or keys, which causes interception to fail. (Perimeter)

Chain of custody A documented record of who collected, handled, transferred and stored each item of evidence, and when. (Respond)

Change of authorisation (CoA) A RADIUS extension (RFC 5176) that lets the server change or end an active session. (Identity)

CNAPP Cloud-native application protection platform: a consolidated platform combining posture, workload, identity and code-scanning functions. (Cloud)

Compensating control An alternative control that reduces risk when the preferred control cannot be implemented. (ZeroTrust)

Consent phishing Tricking a user into granting a malicious application OAuth permissions to their data. (Cloud)

Containment Incident response actions that stop an attack spreading or causing further damage while evidence is preserved. (Respond)

Continuous verification Re-evaluating access during a session as identity, device, behaviour and threat signals change. (ZeroTrust)

Correlation rule SIEM logic that combines one or more events, counts, sequences or baselines to decide when to raise an alert. (Respond)

CRL Certificate revocation list: a signed list of revoked certificate serial numbers published by a CA. (Tunnel)

Crown jewels The applications and data whose compromise would cause the greatest harm, prioritised for the strongest controls. (ZeroTrust)

CSPM Cloud security posture management: continuous comparison of cloud configuration with policy and benchmarks. (Cloud)

D

Defence in depth Layering independent controls so that one failure does not lead to full compromise. (Architect)

Detonation Running a suspicious file or URL inside an isolated sandbox to observe its behaviour. (Detect)

Device posture The security state of a device, such as management, encryption, EDR health and patch level, used as an access input. (ZeroTrust)

DKIM DomainKeys Identified Mail: a cryptographic signature over selected headers and the body, verified with a public key published in DNS. (Detect)

DMARC alignment The requirement that the domain validated by SPF or DKIM matches the domain in the visible From header. (Detect)

Downloadable ACL An access list defined on the NAC server and pushed to the switch for a specific session. (Identity)

DPD Dead peer detection: liveness checks that remove SAs to an unreachable peer. (Tunnel)

Dwell time The time an attacker is present in an environment before detection, measured per incident. (Respond)

Copyright © ZyeemZia

E

EAP-TLS An EAP method using certificates on both client and server for mutual authentication. (Identity)

EDR Endpoint detection and response: continuous recording of endpoint activity with behavioural detection and remote response actions. (Detect)

Encrypted Client Hello A TLS extension that encrypts the server name and other handshake details from observers. (Perimeter)

ESP Encapsulating Security Payload, IP protocol 50, providing confidentiality and integrity. (Tunnel)

F

Fail-open A failure mode in which an inline device passes traffic uninspected when it fails, protecting availability at the cost of security. (Detect)

G

Group tag A numeric identifier assigned at authentication and used to enforce group-to-group policy. (Identity)

H

Honeytoken A fake credential, key or record with no legitimate use, planted so that any attempt to use it reveals an intruder. (Detect)

Hot retention The period during which logs are fully indexed and quickly searchable for alerting and investigation. (Respond)

I

IKEv2 The Internet Key Exchange protocol version 2 (RFC 7296), which authenticates peers and negotiates IPsec security associations. (Tunnel)

Intrusion prevention system (IPS) An inline inspection engine that can drop, reset or modify traffic in real time based on rules, models or reputation. (Detect)

IPFIX IP Flow Information Export: the IETF standard protocol for exporting flow records, evolved from NetFlow version 9. (Respond)

L

Local breakout Sending branch traffic for internet and SaaS directly from the branch, usually to a nearby security edge, instead of backhauling it. (Cloud)

M

MAB MAC Authentication Bypass: using a device's MAC address as its identity when it cannot run 802.1X. (Identity)

Macro-segmentation Separating large environments, such as production and guest, using VRFs or firewalls. (Architect)

Maturity model A staged description of capability levels used to assess the current state and plan the next steps of a programme. (ZeroTrust)

Micro-segmentation Policy between individual workloads or user groups, often using identity tags or host firewalls. (Architect)

MITRE ATT&CK A public knowledge base of adversary tactics and techniques observed in real intrusions. (Architect)

MTTD Mean time to detect: the average time from the start of a compromise to its detection. (Respond)

MTTR Mean time to respond (or resolve): the average time from detection to resolution, as defined in the organisation's metrics dictionary. (Respond)

N

NAT exemption A rule that prevents translation for selected traffic, typically between VPN-connected private networks. (Perimeter)

NAT-T NAT traversal: wrapping ESP in UDP 4500 so it can pass NAT devices. (Tunnel)

NHRP Next Hop Resolution Protocol, used to map overlay tunnel addresses to underlay public addresses. (Tunnel)

NIST CSF 2.0 An outcome-based cybersecurity framework with six functions: Govern, Identify, Protect, Detect, Respond and Recover. (Architect)

Normalisation Mapping fields from different log formats into one common schema so events can be searched and correlated together. (Respond)

O

OCSP Online Certificate Status Protocol: a real-time query for the revocation status of one certificate. (Tunnel)

Order of volatility The principle of collecting evidence from the most short-lived sources, such as memory, before more persistent ones such as disk. (Respond)

P

PAT Port address translation: many inside hosts share one public address using unique source ports. (Perimeter)

PEAP An EAP method that builds a TLS tunnel with a server certificate and carries an inner, usually password-based, method. (Identity)

PFS Perfect forward secrecy: deriving each new key from a fresh DH exchange so one compromise does not expose other sessions. (Tunnel)

Phishing-resistant MFA Authentication that cryptographically binds to the genuine service so captured credentials cannot be replayed. (Identity)

Playbook A defined sequence of response steps, with conditions and approvals, for a specific type of alert or incident. (Respond)

Copyright © ZyeemZia

Policy administrator (PA) The component that executes the policy engine's decision by establishing or shutting down the session path. (ZeroTrust)

Policy Decision Point The policy engine and administrator that evaluate requests and instruct enforcement points. (Architect)

Policy Enforcement Point The component that allows or blocks a session based on a policy decision. (Architect)

Policy enforcement point (PEP) The component in the data path that enables, monitors and terminates connections between a subject and a resource. (ZeroTrust)

Policy engine (PE) The NIST SP 800-207 component that decides whether to grant, deny or revoke access to a resource. (ZeroTrust)

Policy-as-code Expressing security and compliance rules as machine-evaluated code that is versioned, tested and enforced in pipelines. (ZeroTrust)

Posture assessment Checking an endpoint's security state before and during network access. (Identity)

Precision The proportion of alerts that turn out to be true positives: TP / (TP + FP). (Detect)

Profile (CSF) A description of current or target cybersecurity outcomes, used to identify gaps. (Architect)

Prompt injection Instructions hidden in content processed by an AI system that attempt to make it act against its operator's intent. (ZeroTrust)

Protective DNS A recursive resolver that refuses or redirects lookups for malicious or high-risk domains and logs every query. (Detect)

R

RADIUS A UDP-based AAA protocol (RFC 2865) used mainly for network access, including 802.1X. (Identity)

Residual risk The risk that remains after controls are applied, which must be owned and formally accepted. (ZeroTrust)

Response policy zone (RPZ) A DNS zone whose records instruct a resolver to rewrite answers, for example to NXDOMAIN or a sinkhole address. (Detect)

Risk-based alerting Accumulating risk points on users or hosts from many weak signals and alerting when a threshold is exceeded. (Respond)

S

SASE Secure access service edge: wide-area networking and security delivered together as a cloud service. (Cloud)

Security association (SA) A set of agreed keys and parameters protecting traffic in one direction (Child SA) or the IKE control channel (IKE SA). (Tunnel)

Security group A stateful, per-interface virtual firewall in a cloud network, usually allow-only. (Cloud)

Security zone A group of interfaces sharing a trust level; policy is written between zones. (Perimeter)

Shadowed rule A rule that never matches because an earlier, broader rule already handles its traffic. (Perimeter)

Shared responsibility model The division of security duties between a cloud provider and its customer, which varies by IaaS, PaaS and SaaS. (Cloud)

SOAR Security orchestration, automation and response: tooling that executes response playbooks across security systems through APIs. (Respond)

SPF Sender Policy Framework: a DNS TXT record listing the hosts authorised to send mail for an envelope domain. (Detect)

SPI Security Parameter Index: a value in each ESP packet identifying which SA protects it. (Tunnel)

Split-brain An HA failure in which both units believe they are active at the same time. (Perimeter)

SSE Security service edge: the cloud-delivered security services of SASE (SWG, CASB, ZTNA, often FWaaS and DLP) without the networking. (Cloud)

SSPM SaaS security posture management: continuous checking of SaaS tenant settings against a security baseline. (Cloud)

Stateful inspection Tracking connection state so return traffic is allowed only when it matches an existing session. (Perimeter)

Supplicant The endpoint software that presents credentials in 802.1X. (Identity)

Suppression A tuning entry that silences a specific rule for a specific source or destination while leaving it active elsewhere. (Detect)

T

TACACS+ A TCP-based AAA protocol (RFC 8907) that separates authentication, authorisation and accounting; used for device administration. (Identity)

Tactic In ATT&CK, the adversary's goal at a stage of an intrusion, such as Credential Access. (Architect)

Threat hunting Proactive, hypothesis-driven searching for malicious activity that existing detections have not flagged. (Respond)

TLS inspection Decrypting, inspecting and re-encrypting TLS traffic at a firewall or proxy under a defined policy. (Perimeter)

Traffic selector The address and port ranges a Child SA is permitted to protect. (Tunnel)

Copyright © ZyeemZia

V

VTI Virtual tunnel interface: a routable interface whose traffic is protected by IPsec. (Tunnel)

X

XDR Extended detection and response: correlation and response across endpoint, identity, email, network and cloud telemetry. (Detect)

Z

Zero trust A security model in which no implicit trust is granted by network location; every access request is verified. (Architect)

ZTNA Zero trust network access: brokered, per-application access granted after identity, device and context checks, with applications hidden from the internet. (Cloud)

Copyright © ZyeemZia

CAPSTONE

Capstone: Zero-trust security architecture for a regulated organisation

Design, build in a lab and document a defence-in-depth architecture for a fictional bank or hospital: segmented network, NGFW edge, VPN and ZTNA access, 802.1X/NAC, detection stack, SASE for branches and a SIEM/SOAR incident workflow.

Deliverables

☐ Threat model and risk register (ATT&CK-mapped)

☐ Segmentation and zone design

☐ NGFW policy set with TLS-inspection decisions

☐ Site-to-site and remote-access design (VPN vs ZTNA) with a post-quantum migration plan

☐ 802.1X/NAC design with posture and guest flows

☐ Detection design: IPS, email/DNS/web controls, EDR

☐ SASE/SSE design for branches and SaaS

☐ SIEM use cases and two SOAR playbooks

☐ Incident response tabletop and lessons learned

☐ Zero-trust maturity roadmap and policy-as-code example

Self-assessment rubric

CRITERION	DEVELOPING	PROFICIENT	EXCELLENT
Architecture	○ Flat network	○ Zoned design	○ Risk-driven, zero-trust aligned
Perimeter	○ Any-any rules	○ Least-privilege policy	○ Audited, app/user-aware policy
VPN & access	○ Shared secrets, weak crypto	○ Correct IPsec/TLS	○ PKI-based, crypto-agile, ZTNA where it fits
Identity	○ Passwords only	○ 802.1X and MFA	○ Posture, dynamic segmentation, phishing-resistant MFA
Detection	○ Default signatures	○ Tuned detections	○ Layered, ATT&CK-mapped coverage
Cloud	○ Not addressed	○ Basic controls	○ SASE/SSE integrated with policy
Response	○ No process	○ IR plan	○ Automated playbooks with metrics
Automation	○ Manual	○ Scripts	○ Policy-as-code with tests

Copyright © ZyeemZia

CAPSTONE

Planning pages

Sketch your design, timeline or architecture here.

Copyright © ZyeemZia

EXAM PREPARATION

Practice exam · 60 questions

The official online exam draws 45 questions at random from a separate, secret bank that tests the same skills, with a 90-minute limit and a 85% pass mark. Practise with these questions first: time yourself, mark your answers, then check the key and read every explanation, including for the questions you got right.

Architect — Security Architecture & Threat Landscape

1. A threat-intelligence feed reports that a crime group is mass-exploiting a flaw in the remote-access portal model your company runs. Your patch is scheduled for next week's maintenance window. What should the security architect do FIRST?

   (A) Keep the scheduled window but raise the portal's logging level to debug until then

   (B) Add a second-factor prompt to the portal login and leave the patch on its current schedule

   (C) Patch or mitigate now as an emergency change, then hunt for signs of prior compromise

   (D) Move the portal to a new public IP address so automated scanners lose track of it

2. During an incident review, investigators find the attacker authenticated to a branch file server using a help-desk account, then used the same credentials to reach a headquarters database. Which ATT&CK tactic does the second step represent, and which control would most directly have limited it?

   (A) Lateral Movement; segmentation plus tiered admin accounts that cannot cross zones

   (B) Initial Access; a stricter perimeter firewall policy on the internet edge routers

   (C) Exfiltration; data-loss prevention rules on outbound web traffic to the internet

   (D) Reconnaissance; hiding server names from internal DNS so they cannot be discovered

3. A risk register lists: (A) likelihood 5, impact 2; (B) likelihood 2, impact 5; (C) likelihood 4, impact 4; (D) likelihood 3, impact 3. With qualitative scoring of likelihood × impact, which should the roadmap address first, all else equal?

   (A) A, because likelihood 5 is the highest single rating

   (B) B, because impact 5 is the highest single rating

   (C) D, because balanced risks are the most predictable

   (D) C, with a score of 16

4. A hospital wants to report its security posture to the board using NIST CSF 2.0 and build a three-year plan. Which approach best uses the framework?

   (A) Purchase a product mapped to each of the six functions and report coverage as a percentage

   (B) Build current and target profiles and plan the gap by risk, with Govern setting owners

   (C) Request formal CSF certification from an accredited auditor before planning any changes

   (D) Adopt the highest implementation tier everywhere so that every gap is closed at once

5. An ALE study estimates a ransomware event with SLE 2,000,000 and ARO 0.1. A proposed segmentation project costs 60,000 per year and is expected to reduce ARO to 0.04. What is the expected annual net value of the project?

   (A) 120,000 per year

   (B) 60,000 per year

   (C) 140,000 per year

   (D) 200,000 per year

6. A data centre has one large server VLAN. Flow analysis shows only 40 distinct application dependencies between server groups. The team wants the fastest meaningful reduction in ransomware blast radius with low outage risk. Which plan is best?

   (A) Deploy host-based micro-segmentation agents on every server with deny-all in one weekend change

   (B) Split the servers into more VLANs and keep inter-VLAN routing unfiltered for simplicity

   (C) Rely on endpoint protection on the servers and postpone network segmentation until next year

   (D) Build macro-segments from the flow data, run permit-and-log first, then enforce deny in waves

Copyright © ZyeemZia

7. In a zero-trust design based on NIST SP 800-207, a contractor connects to an internal application through an identity-aware proxy that checks the contractor's identity and device state on every session. Which statement correctly maps the components?

   (A) The proxy is the enforcement point; the engine weighing identity and device signals decides

   (B) The contractor's laptop is the Policy Decision Point because it holds the credentials

   (C) The application server is the Policy Enforcement Point because it is the one that receives the request

   (D) The certificate authority is the Policy Engine because it signs the device certificates

Perimeter — Next-Generation Firewalls

8. A firewall log shows: `action=allow rule=ANY-OUT app=ssl dst=203.0.113.200:443 bytes_out=4.1GB bytes_in=12MB user=unknown` from a server in the database zone at 02:00. What is the MOST significant concern?

   (A) The user field is unknown, which shows the identity agent on the firewall needs a restart

   (B) The SSL application label means the firewall's signature database is outdated

   (C) A database server sending gigabytes out over TLS at night via a catch-all rule

   (D) The session used port 443, which should always be blocked from server zones

9. A new rule permitting `App-Team → web01 TCP 8443` has zero hits after a week, yet the team says they use the service daily. The rule is number 140. Rule 37 permits `App-Subnets → DMZ-Servers any`. What is the best action?

   (A) Move rule 140 to the top of the policy and leave rule 37 unchanged, since both permit the traffic

   (B) Delete rule 140 because zero hits proves the service is no longer used

   (C) Enable IPS on rule 140 so that its hit counter starts to increment

   (D) Recognise rule 140 as shadowed by rule 37, then narrow or remove rule 37 with its owner

10. After enabling outbound TLS inspection, users reach most sites, but a payroll SaaS provider that requires mutual-TLS client certificates fails for everyone. What is the most appropriate fix?

    (A) Import every user's client certificate and private key into the firewall's certificate store

    (B) Exempt the payroll provider's destinations from decryption and keep inspecting the rest

    (C) Configure the firewall to ignore certificate errors on all decrypted sessions

    (D) Disable TLS inspection globally until the payroll provider changes its design

11. A published server at 10.20.0.10 is translated to public 203.0.113.10. A rule permitting `untrust → dmz, destination 10.20.0.10, HTTPS` has no hits, and a deny log shows traffic to 203.0.113.10:443 hitting the default rule. What is the most likely explanation?

    (A) The server is not listening on TCP 443 and is resetting every new connection attempt from outside

    (B) The static NAT entry is missing, so the traffic never reaches the firewall

    (C) Policy here matches the pre-NAT public destination, so the rule must use 203.0.113.10

    (D) IPS has blocked the traffic and recorded it as a default-rule deny

12. An active/active firewall pair drops about half of the new TCP sessions to a server farm. Captures show SYNs through FW-A and SYN-ACKs returning through FW-B. What change best solves this?

    (A) Make routing symmetric or use session-owner forwarding across the pair

    (B) Increase the TCP half-open session timeout on both firewalls so the SYN-ACK has time to arrive

    (C) Disable state synchronisation so each unit acts independently

    (D) Raise the IPS profile to strict on the server-farm rules

Copyright © ZyeemZia

13. During a firewall HA test, both control links are cut. Both units become active and users report intermittent connectivity and duplicate IP warnings. What design change prevents this?

    (A) Enable preemption so that the higher-priority unit always wins the active-role election

    (B) Reduce the heartbeat interval so failures are detected more quickly

    (C) Add a second, physically diverse heartbeat path between the units

    (D) Disable configuration synchronisation between the two units

14. A capture on the firewall's DMZ interface shows: `10.10.4.21 > 10.20.0.15.8443 Flags [S]` followed immediately by `10.20.0.15.8443 > 10.10.4.21 Flags [R.]`. The firewall log shows the session allowed. What should the engineer conclude?

    (A) The server itself refused the connection; check its service and host firewall

    (B) The firewall injected the reset because an IPS signature matched the first packet of the flow

    (C) Asymmetric routing caused the SYN-ACK to return through another device

    (D) The TLS inspection policy rejected the server's certificate during the handshake

15. A quarterly audit finds 900 rules with zero hits in 12 months, many with no owner. The business fears outages if they are removed. Which approach best balances risk and availability?

    (A) Delete all 900 rules in a single change, because a year of zero hits proves they are unused

    (B) Leave the rules in place but add a comment marking them as possibly unused

    (C) Convert the 900 rules into a single broad rule so behaviour does not change

    (D) Disable them in logged batches, observe, then delete

Tunnel — VPN Technologies

16. A site-to-site tunnel log shows: `IKE_SA_INIT received from peer; sending notify NO_PROPOSAL_CHOSEN`. The local side offers AES-GCM-256/PRF-SHA384/DH group 20; the peer offers AES-CBC-256/SHA-256/DH group 14. What is the best resolution?

    (A) Change the pre-shared key on both sides and restart negotiation

    (B) Agree a common proposal, ideally by upgrading the peer to AES-GCM-256 with DH group 19 or 20

    (C) Correct the traffic selectors so that both peers' protected subnets mirror each other exactly

    (D) Enable NAT traversal on both peers to move IKE traffic to UDP 4500

17. A route-based VPN shows the IKE SA READY. `show crypto ipsec sa` reports `#pkts encaps: 0, #pkts decaps: 15320`. Users at the local site cannot reach the remote site. Where is the fault most likely to be?

    (A) At the remote peer, which is not routing its return traffic back into the tunnel interface

    (B) Locally: traffic is not being routed into the tunnel interface, or it is NATed before encryption

    (C) In the ISP path, which is silently dropping inbound ESP packets arriving from the remote peer

    (D) In IKE_AUTH, where the certificates failed mutual authentication

18. A tunnel establishes normally but fails exactly every 8 hours, re-establishing after about a minute. Logs at the failure show the CREATE_CHILD_SA exchange rejected. One peer's Child SA lifetime is 28,800 seconds. What should be checked first?

    (A) Whether the IKE SA lifetimes match exactly, to the second, on both of the peers

    (B) Whether the certificate on the remote peer expires in eight hours

    (C) Whether the tunnel MTU is large enough for the rekey messages

    (D) Whether the PFS DH group used for Child SA rekeys is configured identically on both peers

Copyright © ZyeemZia

19. Hub logs show: `Certificate chain verified to CORP-ROOT-CA` then `OCSP request to http://ocsp.corp.example timed out` then `Sending AUTHENTICATION_FAILED`. Eleven branches are down. What is the best immediate action?

    (A) Restore the OCSP responder or its reachability, using a documented, time-boxed CRL fallback if needed

    (B) Disable revocation checking permanently on the hub so this kind of outage can never recur

    (C) Reissue certificates to all eleven branches from the issuing CA

    (D) Switch all branches to a shared pre-shared key until the PKI is redesigned

20. A company with 180 branches needs branch-to-branch voice calls without hairpinning through the hub, and wants to add branches without touching every other branch's configuration. Which design fits best?

    (A) A full mesh of static policy-based tunnels, with mirrored crypto ACLs maintained at every site

    (B) A single policy-based tunnel from each branch to the hub with no spoke-to-spoke paths

    (C) A dynamic overlay using mGRE, NHRP and certificate-based IKEv2 that builds on-demand spoke-to-spoke tunnels

    (D) Remote-access VPN clients installed on each branch's phones and call servers

21. A partner's policy-based VPN works for subnet 10.3.0.0/16 but not for newly added 10.4.0.0/16. Your logs show `TS_UNACCEPTABLE` when traffic from 10.4.0.0/16 triggers negotiation. What is the cause?

    (A) The partner's Diffie-Hellman group no longer matches after the subnet change

    (B) The IKE SA lifetime expired and was not renewed correctly

    (C) ESP traffic for the new subnet is blocked by the ISP

    (D) The new subnet pair is missing from the crypto ACLs

22. After a weekend power outage, a branch router cannot bring up its certificate-based tunnel. The log says `peer certificate not yet valid`. The hub's certificate was issued three months ago. What is the most likely cause?

    (A) The hub's certificate was revoked by the issuing CA during the weekend outage

    (B) The branch router's clock is wrong and NTP has not resynchronised it

    (C) The branch's RSA private key was lost during the power outage

    (D) The IKEv2 proposal on the hub was changed during the weekend

23. Remote-access VPN users on a hotel network can connect with the TLS-based client but not with the IKEv2 client. Both use the same gateway and MFA. What is the most likely reason?

    (A) IKEv2 cannot support MFA, so user authentication always fails on that client type

    (B) The IKEv2 client requires the user to be on the corporate LAN

    (C) The hotel blocks UDP 500 and 4500, which IKEv2 needs, but allows TCP 443

    (D) The TLS-based client is negotiating a weaker cipher suite that hotel firewalls happen to permit

Identity — Identity & Network Access Control

24. A switch shows `Status: Unauthorized`, `dot1x: Authc Failed`, `mab: Authc Failed` for a new IP camera. The NAC server log shows `Access-Reject: endpoint MAC not found in any identity group`. What is the correct fix?

    (A) Profile and register the camera with a narrow IoT policy

    (B) Change the port to `authentication open` permanently so the camera works without registration

    (C) Install an 802.1X supplicant on the camera using the default admin password

    (D) Assign the camera to the employee VLAN so it can reach the video server

25. A penetration test captured PEAP exchanges from staff laptops connecting to a fake SSID with the same name. What is the root cause, and what is the best long-term remedy?

    (A) The RADIUS shared secret was weak; rotate it to a longer random value on every access point

    (B) The SSID was broadcast; hide it so attackers cannot copy the name

    (C) Missing server validation; enforce it, then adopt EAP-TLS

    (D) The switch did not support CoA; upgrade access switches to enable it

Copyright © ZyeemZia

26. An EDR platform flags ransomware behaviour on a laptop connected to an 802.1X port. The SOC wants it restricted within seconds without visiting the site. Which capability makes this possible?

    (A) A RADIUS change-of-authorisation request sent by the NAC server

    (B) A shorter DHCP lease so that the laptop must renew its address within minutes

    (C) A periodic reauthentication timer set to eight hours on every access port

    (D) A port-security limit allowing only one MAC address per port

27. Which configuration best protects core-router administration?

    (A) RADIUS with a shared 'netadmin' account whose password is changed quarterly

    (B) Local accounts on every device with identical strong passwords tracked in a shared spreadsheet by the team

    (C) SSH key authentication with one key pair shared across the whole network team

    (D) Named TACACS+ accounts with command authorisation, accounting and MFA

28. A RADIUS assessment flags that network devices accept Access-Accept packets without a Message-Authenticator attribute for PAP-based logins. What risk does this create, and what is the fix?

    (A) Users' passwords travel in clear text; move every network device to TACACS+ immediately

    (B) On-path forgery of accepts via MD5 collisions; require Message-Authenticator and patch both ends

    (C) Accounting records may be lost; increase the RADIUS server timeout and retries

    (D) Dynamic VLANs will fail; add Tunnel attributes to every authorisation profile

29. An NAC policy maps posture 'unknown' to full employee access 'to avoid help-desk calls'. The MDM integration fails for six hours and nobody notices. What is the main design flaw?

    (A) The posture check runs too frequently and overloads the MDM platform's API during business hours

    (B) It fails open, so any device missing posture data gets full access

    (C) The MDM integration should be replaced with manual device approval

    (D) Full employee access should be applied only to wired connections

30. The SOC sees 30 denied push prompts for one user followed by an approval from an unfamiliar country. A VPN session is now active. Which response is best?

    (A) Reset the password only, because the active session will end automatically when the user logs off

    (B) Block the country at the gateway and keep monitoring the active session

    (C) Increase the push-prompt timeout so the user has more time to read it

    (D) Contain the session, verify the user, move to phishing-resistant MFA

Detect — Detect — Threat Detection & Prevention

31. An inline IPS at the internet edge fails during a firmware upgrade and all internet access stops for 40 minutes. The design document does not mention failure behaviour. What should the security architect change FIRST?

    (A) Move the IPS to a SPAN port permanently so that it can never interrupt internet traffic again

    (B) Disable firmware upgrades on the IPS so that the device stays on its current software version

    (C) Replace the IPS with a reputation-only DNS filter so that no inline device is needed at the edge

    (D) Decide fail-open or fail-closed per link, add bypass or clustering, and test failover

32. A Suricata `threshold.config` contains `suppress gen_id 1, sig_id 1000201` with no `track` or `ip` parameters. What is the effect, and why is it a concern?

    (A) The rule only fires once per day for each source, which delays detection of repeated attacks

    (B) The rule is converted to a drop rule, which may block legitimate traffic in IPS mode

    (C) The signature is silenced for all traffic, so coverage is lost everywhere, not for one source

    (D) The rule is ignored by the parser, so the suppression has no effect and noise continues

Copyright © ZyeemZia

33. Headers on a reported message show `spf=fail smtp.mailfrom=bank.example; dkim=pass header.d=bank.example; dmarc=pass header.from=bank.example`. The message was forwarded by a university alias. What explains the results?

(A) The message is spoofed because any SPF failure means DMARC must also fail

(B) Forwarding broke SPF, but the intact aligned DKIM signature let DMARC pass

(C) DMARC passed because the university alias is listed in the bank's SPF record

(D) DKIM passed only because the forwarder re-signed the message with its own key

34. The SOC sees hundreds of NXDOMAIN responses per minute from one laptop for names such as `qk3vz8lw1p.example` and `t9m2xr0hya.example`. What is the most likely explanation and best next step?

(A) DGA malware; contain the laptop through EDR and check whether any generated name resolved

(B) A misconfigured search suffix on the laptop; push a corrected DHCP option to the whole subnet

(C) A browser prefetching links from a busy news site; tune the alert to ignore NXDOMAIN responses

(D) A DNS server outage upstream; fail over the laptop to a public resolver until it recovers

35. A rule detects 18 of 20 simulated attacks in a purple-team exercise. In production it raised 900 alerts last month, of which 30 were true positives. Which statement is correct?

(A) Recall is 90% but precision is about 3%, so the rule needs tuning rather than removal

(B) Precision is 90% but recall is about 3%, so the rule misses most of the real attacks it sees

(C) Both recall and precision are about 90%, so the alert volume is acceptable

(D) Recall cannot be calculated because purple-team tests are not real attacks

36. An EDR alert shows `excel.exe` spawning `powershell.exe` with an encoded command, followed by a connection to a first-seen domain. The host is a finance laptop. Which response is most appropriate?

(A) Delete the Excel file from the user's mailbox and close the alert because the attachment was the cause

(B) Ask the user to reboot the laptop so that any malicious process in memory is cleared before work

(C) Add the domain to the proxy block list and wait to see whether the alert repeats tomorrow

(D) Isolate the laptop, collect triage data, block the domain and scope other hosts for the pattern

37. A database row containing a fake customer record with a unique email address is planted in the CRM. Weeks later, that address receives a phishing email. What does this most likely indicate?

(A) The email gateway is misconfigured, because it delivers mail to unknown recipients

(B) CRM data has been exfiltrated or exposed, because the honeytoken had no legitimate use

(C) The phishing campaign is random, because attackers guess addresses at large scale

(D) The CRM backup is corrupted, because fake records should never leave the database

38. Managed laptops resolve almost nothing through the corporate resolver, yet browse normally. The protective DNS policy is therefore ineffective. What is the best corrective set?

(A) Lower the corporate resolver's cache TTL so that laptops are forced to query it more often throughout the day

(B) Publish DNSSEC signatures for the corporate zones so that browsers prefer the corporate resolver automatically

(C) Set browser DoH policy to the corporate resolver, block public DoH and DoT endpoints, and alert on bypass

(D) Block all outbound UDP traffic from laptops so that every DNS lookup must use the corporate resolver over TCP

Cloud — Cloud — Cloud, SASE & SSE

39. A cloud database subnet ACL allows inbound TCP 5432 from the application subnet and has an explicit outbound deny-all. The security groups are correct. Applications time out. What is the fix?

(A) Add an inbound security group rule allowing ephemeral ports from the application subnet

(B) Add an outbound ACL rule allowing TCP ephemeral ports back to the application subnet

(C) Change the database security group to reference the subnet ACL instead of the app group

(D) Remove the security groups, because subnet ACLs and security groups cannot be combined

Copyright © ZyeemZia

40. Staff are copying files from the corporate tenant of a SaaS storage platform to personal accounts on the same platform. Blocking the platform is not acceptable. Which control addresses this most directly?

(A) Tenant restrictions on the inline proxy allowing only corporate-tenant sign-ins
(B) API-mode CASB scanning the corporate tenant weekly for files shared with outsiders
(C) URL filtering that blocks the platform's domain for everyone except the IT department
(D) A DNS policy that sinkholes the platform's personal sign-in page for managed laptops

41. A company must give 300 freelance translators on personal laptops access to one internal web portal. No agents may be installed. Which design is best?

(A) Issue full-tunnel remote-access VPN profiles and restrict them with a large access list
(B) Expose the portal directly on the internet behind a web application firewall only
(C) Build site-to-site IPsec tunnels to the home routers of each of the 300 translators working from home
(D) Publish the portal through agentless browser-based ZTNA with MFA and session controls

42. After moving 60 branches to direct-to-cloud access through a security service edge, a payroll SaaS rejects all branch logins. It worked last week. What is the most likely cause?

(A) The SD-WAN appliances are dropping TLS 1.3 handshakes to all SaaS providers
(B) The branch users' MFA tokens expired because their time zones changed
(C) The SaaS allow-lists the old data-centre egress IPs, and traffic now leaves from the PoP
(D) The security edge blocks every application in the human resources category

43. An API returns another customer's order when a client changes `orderId` in the URL. The token is valid and correctly scoped. The team proposes adding a WAF signature. Why is that insufficient?

(A) The flaw is broken object level authorisation, which only an ownership check in the service can fix
(B) The flaw is server-side request forgery, which only an egress firewall placed in front of the API can fix
(C) The flaw is an expired token, which only a shorter token lifetime at the identity provider can fix
(D) The flaw is rate limiting, which only a stricter per-client quota at the gateway can fix

44. SaaS audit logs show that a 'calendar helper' app, granted mail read permissions by 40 users, is downloading mailbox contents. Passwords for all 40 users were reset yesterday. What should happen next?

(A) Reset the 40 passwords again and force MFA re-registration for each affected user before their next sign-in
(B) Block the app's publisher domain at the web gateway so users cannot reach its website
(C) Ask the 40 users to remove the app from their own account settings within a week
(D) Revoke the app's consent and tokens tenant-wide and require admin approval for such permissions

45. A posture tool keeps finding storage buckets made public by different teams, and each is fixed within a day. Which improvement gives the greatest risk reduction?

(A) A daily report of public buckets emailed to the cloud centre of excellence
(B) A faster posture scan interval so findings appear within five minutes
(C) An organisation-level guardrail that prevents public access from being enabled
(D) A training module on storage permissions for every cloud engineer

Respond — Respond — Visibility, SIEM, SOAR & Incident Response

46. An investigator finds that firewall and EDR events for the same connection differ by exactly one hour. What is the most likely cause, and how should it be fixed?

(A) The SIEM ingests firewall logs in hourly batches; switch the firewall export to real-time streaming
(B) One source logs local time without a zone; standardise on UTC with explicit offsets
(C) EDR agents buffer events for an hour on purpose; reduce the agent buffer setting on every host
(D) NTP servers drift by an hour each day; replace them with a GPS-backed time source

Copyright © ZyeemZia

47. A sign-in log shows 2,400 failures from one IP against 1,600 different usernames in 50 minutes, followed by one success for `j.ahmed` and a new MFA method registered two minutes later. Which interpretation is best?

    (A) Spraying led to a valid login and MFA persistence; revoke sessions and remove the new method

    (B) A brute-force attack against j.ahmed succeeded; lock that account, reset its password and close the case

    (C) A misconfigured application is retrying stored credentials; fix the app's service account

    (D) Users mistyped passwords after a policy change; the success shows the change has settled

48. Flow records show an internal server sending 300-byte HTTPS requests to the same external IP every 600 seconds, plus or minus 3 seconds, for nine days. Which hunting conclusion is most justified?

    (A) The traffic is encrypted, so flow records cannot support any conclusion about its nature

    (B) The small request size proves it is a benign health check that can be excluded from future hunts permanently

    (C) The regular, low-jitter pattern suggests beaconing and should be investigated with endpoint data

    (D) The nine-day duration proves an active data exfiltration that must be reported to regulators

49. A SOAR playbook isolated 140 endpoints in four minutes after a threat feed wrongly listed a widely used software update domain. Which design change best prevents a repeat?

    (A) Faster rollback scripts so that wrongly isolated endpoints can be released within a few minutes of the error

    (B) Rate limits and approval gates on bulk isolation, plus a protected allow list of critical domains

    (C) Removing all threat feeds so that the playbook relies only on internal intelligence

    (D) Running the playbook only at night so that fewer users notice any wrongly isolated hosts

50. During a ransomware incident, an engineer proposes powering off the affected file server to stop encryption. The incident lead wants memory evidence. What is the best approach?

    (A) Power off immediately, because memory evidence is never useful in ransomware cases

    (B) Leave the server running and connected so the attacker does not realise they were seen

    (C) Take a disk image first, then capture memory once the disk image has been hashed and verified

    (D) Isolate the server through EDR to stop spread, capture memory, then decide on shutdown

51. Four incidents had dwell times of 3, 5, 7 and 85 days. The board report shows mean dwell time only. What should the security lead change?

    (A) Remove the 85-day incident from the data because it is not representative of normal performance

    (B) Report the mean of 25 days as the headline figure because it is the most conservative number

    (C) Stop reporting dwell time because the figures vary too much between incidents to be useful

    (D) Report the median (6 days) and the outlier separately, and investigate why one case took 85 days

52. A hunt based on the hypothesis 'attackers use scheduled tasks for persistence on Linux servers' finds no evidence, but reveals that cron changes are not logged. What is the correct outcome?

    (A) Record a data gap with an owner and plan to collect cron changes, then re-run the hunt

    (B) Record that Linux servers are free of scheduled-task persistence for this quarter

    (C) Close the hunt as unsuccessful and remove the hypothesis from the hunting backlog

    (D) Write a detection for cron persistence and mark the technique as fully covered

53. An insurer asks the incident team to prove that a memory image analysed last week is identical to the one collected during containment. What provides that proof?

    (A) A screenshot of the analysis tool showing the file name and size of the memory image

    (B) An email from the analyst stating that the image was stored on an encrypted drive

    (C) Matching SHA-256 hashes recorded at collection and re-verified, plus a custody log

    (D) The EDR console's record that a memory collection job completed successfully

Copyright © ZyeemZia

ZeroTrust — ZeroTrust — Zero Trust Architecture, Automation & Capstone

54. In a ZTNA deployment, the identity provider evaluates conditional access, a broker sets up the session and an agent on the laptop tunnels traffic to an app connector. Which NIST SP 800-207 role does the broker play?

    (A) Policy engine, deciding whether access is allowed using the trust algorithm

    (B) Policy administrator, establishing the session path on the policy engine's decision

    (C) Policy information point, supplying device posture and threat intelligence to the engine

    (D) Enterprise resource, hosting the application that the subject is trying to reach over the tunnel

55. A user's session token is reused from another country ten minutes after a legitimate sign-in. Access tokens are valid for eight hours, and the applications do not support event-driven revocation. What is the most important improvement?

    (A) Require users to sign in again every morning so that tokens issued the day before become invalid

    (B) Shorten token lifetimes and adopt continuous access evaluation so risk events revoke sessions

    (C) Block all sign-ins from outside the home country so that stolen tokens cannot be replayed abroad

    (D) Encrypt the session tokens with a longer key so that they cannot be copied from the user's browser

56. A Kubernetes namespace has a NetworkPolicy allowing `app: payments-api` pods to reach `app: payments-db` on TCP 5432, but a test pod with no labels can still connect to the database. What is the most likely reason?

    (A) The cluster's network plugin does not enforce NetworkPolicy, so policies have no effect

    (B) NetworkPolicy only applies to egress traffic, so ingress traffic to the database is never affected

    (C) Unlabelled pods are exempt from NetworkPolicy and must be blocked by a namespace firewall

    (D) The policy needs a higher priority number before it overrides the default allow rule

57. A pipeline uses policy-as-code to block firewall changes without a ticket. An engineer bypasses the pipeline and adds a rule directly on the device. Which control detects this?

    (A) A stricter Rego policy in the pipeline that also checks the engineer's job title

    (B) A longer peer-review period for changes submitted through the version control system

    (C) A higher API rate limit on the firewall manager so that scripts cannot overload it

    (D) Drift detection comparing running configuration with the approved source of truth

58. A zero trust programme wants to protect legacy SCADA engineering workstations that cannot run agents or support MFA. Which approach is best?

    (A) Install a ZTNA agent on each workstation using the compatibility mode offered for older operating systems

    (B) Exempt them from the zero trust programme because operational technology is out of scope

    (C) Put them in an enclave reached only via a privileged access gateway with MFA and session recording

    (D) Connect them to the corporate network so that they can receive identity provider policies directly

59. An AI assistant integrated with the SOC reads incoming phishing emails and suggests response actions. One email contains hidden text instructing the assistant to recommend allow-listing the sender's domain. What guardrail matters most?

    (A) Increase the assistant's context window so that it can read the entire email thread and attachments before answering

    (B) Treat processed content as untrusted data and require human approval for any allow-list or block action

    (C) Train analysts to copy each assistant recommendation into the ticket without changing its wording

    (D) Allow the assistant to apply allow-list changes only for domains that it has seen at least twice

60. Six months into a zero trust roadmap, the board asks for proof of progress. Which metric set is most meaningful?

    (A) Number of zero trust products purchased, licences deployed and vendor training sessions completed by staff so far

    (B) Number of policy documents updated, steering meetings held and architecture diagrams produced this year

    (C) Share of privileged sessions using phishing-resistant MFA, apps behind ZTNA, and time to revoke leaver access

    (D) Total zero trust budget spent, headcount added to the programme and consultants engaged so far

Copyright © ZyeemZia

EXAM PREPARATION

Practice exam answers & explanations

1. C Active exploitation of an internet-facing device is high likelihood and high impact. Patching closes the hole and hunting addresses earlier compromise. Logging, MFA and IP changes do not remove the vulnerability.

2. A Moving between internal systems with stolen credentials is Lateral Movement; segmentation and admin tiering limit it. The other tactics occur at different stages and their controls do not address internal credential reuse.

3. D C scores 16; A and B score 10; D scores 9. The method multiplies both dimensions rather than taking the highest single value.

4. B CSF is outcome-based; profiles and risk-driven gap plans are its intended use. It does not prescribe products, offers no certification and tiers should match risk rather than being maximised everywhere.

5. B ALE before = 200,000; after = 80,000; reduction 120,000; minus 60,000 cost = 60,000 net. 120,000 ignores the control cost and 200,000 is the original ALE.

6. D Evidence-driven macro-segmentation with staged enforcement reduces blast radius quickly and safely. Big-bang micro-segmentation risks outages; VLANs without filtering enforce nothing; relying on one layer is not depth.

7. A The proxy sits in the path and enforces; the policy engine and administrator decide. The laptop is the subject, the application is the resource and the CA supplies credentials.

8. C Large outbound volume from a database server via a catch-all rule is a classic exfiltration signal and a policy gap. An unknown user on a server is normal, SSL is a valid classification and port 443 is not inherently malicious.

9. D Rule 37 matches first, so rule 140 is shadowed. The real problem is the broad rule 37; moving 140 alone keeps the excessive access. Deleting or adding IPS misreads the evidence.

10. B A forward proxy cannot present the user's client certificate, so mutual-TLS destinations must bypass decryption. Collecting private keys or ignoring errors creates serious risks; global disablement removes all visibility.

11. C The deny on the public address shows the rule's destination is not matching; this platform evaluates the original destination. A server reset or IPS block would produce different logs, and traffic clearly reaches the firewall.

12. A FW-B has no session for the SYN-ACK and drops it. Symmetric routing or owner forwarding fixes it. Timeouts, disabling sync and IPS settings do not address asymmetry.

13. C This is split-brain; redundant, diverse heartbeat paths prevent it. Preemption and faster heartbeats do not help when the units cannot see each other, and config sync is unrelated.

14. A The RST comes from the server's address right after the SYN and the session was allowed, so the server refused it. An IPS reset would appear in threat logs; asymmetry would show no reply; TLS has not started yet.

15. D Staged disablement with observation removes risk without surprise outages. Mass deletion risks rare annual flows; commenting changes nothing; merging into a broad rule increases exposure.

16. B NO_PROPOSAL_CHOSEN in IKE_SA_INIT means no overlapping crypto suite. PSKs are checked in IKE_AUTH, selectors at Child SA creation, and NAT-T is unrelated.

17. B Decaps are increasing, so the peer is sending and ESP arrives. Nothing is encrypted locally, pointing to local routing or NAT. The IKE SA is up, so authentication succeeded.

18. D The failure aligns with the Child SA rekey, where PFS is applied in IKEv2. IKE SA lifetimes need not match exactly; certificate expiry would not recur every eight hours; MTU is not the classic cause.

19. A The chain is valid; the revocation service is unreachable. Restore it, with a controlled CRL fallback if needed. Permanent disablement or a shared PSK weakens security; reissuing does not fix OCSP.

20. C Dynamic overlays give on-demand direct paths and add spokes with no config change elsewhere. A static full mesh needs about 16,000 tunnels; hub-only adds latency; remote-access clients are not a site design.

21. D TS_UNACCEPTABLE indicates traffic selectors outside the peer's policy. DH problems surface in IKE_SA_INIT, lifetimes do not cause selector errors and ISP filtering does not generate this notify.

22. B 'Not yet valid' means the local clock is earlier than the certificate's start date, which happens when a clock resets. Revocation, key loss or proposal changes give different errors.

23. C Restrictive networks often allow only TCP 443. IKEv2 supports MFA via EAP, works remotely and cipher strength is not what hotels filter.

24. A The reject is due to an unknown MAC; registration plus narrow policy fixes it safely. Permanent open mode removes control, using default passwords is insecure and the employee VLAN grants excessive access.

Copyright © ZyeemZia

25. C Clients accepted any server, allowing an evil twin to capture credentials. Validation fixes the gap and EAP-TLS removes passwords. The shared secret, SSID broadcast and CoA are not involved.

26. A CoA (RFC 5176) lets the server push quarantine policy immediately. DHCP leases and timers are slow, and port security does not quarantine.

27. D Named, authorised, accounted and MFA-protected access gives control and evidence. Shared accounts or keys destroy accountability, and local accounts do not scale.

28. B This is the BlastRADIUS forgery risk; requiring Message-Authenticator and patching mitigates it. The other options describe unrelated problems or fixes.

29. B 'Unknown' should lead to restricted access; otherwise every outage or unmanaged device silently gains full access. Frequency, manual approval and wired-only access do not address the fail-open logic.

30. D This is an MFA-fatigue compromise; contain the session, confirm with the user and fix the authenticator weakness. A password reset may leave the session alive; geo-blocking is bypassable; longer timeouts help the attacker.

31. D Failure behaviour must be a deliberate, documented and tested design decision with bypass or redundancy. Giving up prevention, freezing upgrades or removing inspection trades one risk for a bigger one.

32. C A suppress entry without track and ip silences the signature entirely. Expert tuning scopes suppression to the specific approved source and records a ticket and review date.

33. B DMARC needs either SPF or DKIM to pass with alignment. The forwarder's IP is not authorised, so SPF fails, but the bank's DKIM signature survived, so DMARC passes.

34. A Bursts of failed lookups for random-looking names are typical of DGA malware searching for a live command server. Any successful resolution shows where it connected. Sending the host to a public resolver would bypass protection.

35. A Recall = 18/20 = 90%. Precision = 30/900, about 3.3%. The rule catches attacks but is too noisy, which calls for tuning. Controlled tests are the normal way to estimate recall.

36. D An office application launching an encoded script interpreter that then calls a new domain is a strong compromise indicator (T1059.001). Containment, evidence collection, indicator blocking and scoping belong together; rebooting destroys volatile evidence.

37. B The record exists only in the CRM, so mail to its unique address strongly suggests the data left the system. That is the purpose of a data honeytoken.

38. C The laptops are using encrypted DNS directly. Browser policy plus blocking known DoH and DoT endpoints restores control, and bypass detection catches the rest. TTLs and DNSSEC do not affect resolver choice.

39. B Subnet ACLs are stateless, so return traffic needs its own outbound rule. Security groups are stateful and already allow the reply.

40. A Tenant restriction distinguishes corporate and personal instances on the same domain in real time. API scanning sees only the corporate tenant, and domain or DNS blocks would also break the corporate tenant.

41. D Agentless ZTNA publishes one application to unmanaged devices with identity checks, without giving network access or exposing the portal openly.

42. C When egress moves to the PoP, source IPs change. Registering dedicated PoP egress addresses with the SaaS provider fixes it; the other causes would affect far more than one app.

43. A This is API1, BOLA. The WAF cannot know who owns which order; the service must check ownership on every request.

44. D OAuth grants survive password resets. Tenant-wide revocation stops the access immediately, and admin consent prevents repeat grants.

45. C Preventive guardrails remove the exposure window completely. Faster detection and training still leave public data reachable for some time.

46. B An exact one-hour offset points to time-zone or daylight-saving handling, not drift or batching. UTC with explicit offsets everywhere removes it.

47. A Many distinct users from one source is spraying (T1110.003); the success and new MFA method show valid-account use and persistence. Response must revoke sessions and the attacker's MFA method, not just lock the account.

48. C Regular timing and consistent size are classic beacon indicators, but benign software can behave similarly. Endpoint data identifies the process before drawing firm conclusions.

49. B Guardrails stop the damage before it happens: allow lists protect known-good infrastructure, and limits plus approvals prevent mass action on one indicator. Rollback helps but only after harm.

50. D Network isolation halts spread without losing volatile evidence. Memory comes before disk in the order of volatility, and leaving the server connected allows more damage.

51. D The mean of 25 days is skewed by one outlier; the median of 6 shows typical performance. The outlier is where the lessons are, so it must be explained, not hidden.

52. A No data means no conclusion. A documented, owned data gap is a valid hunt result; a detection without data cannot be counted as coverage.

53. C A recorded hash compared over time proves integrity, and the custody log proves who handled it. Names, sizes and statements do not.

Copyright © ZyeemZia

54. B The broker executes the decision by setting up or tearing down the path and session credentials, which is the policy administrator role. The identity provider's conditional access acts as the policy engine.

55. B Token theft is defeated by limiting token value over time and revoking on risk signals. Geoblocking is easily bypassed through local proxies, and encryption does not stop replay of a stolen token.

56. A Once a pod is selected by an ingress policy, unlisted sources are denied, provided the network plugin enforces policy. If the plugin does not, nothing is enforced. Kubernetes NetworkPolicy has no priority numbers.

57. D Policy-as-code only sees changes that go through the pipeline. Drift detection compares what is running with what was approved, exposing manual changes.

58. C Enclave gateways and privileged access gateways are the standard compensating approach for systems that cannot protect themselves. Exemption leaves the highest-impact systems unprotected.

59. B This is prompt injection through attacker-controlled content. Treating that content as data and keeping humans in control of configuration changes neutralises the attempt.

60. C Outcome metrics show that access decisions have changed and risk has fallen. Purchases, documents and spend measure activity, not effect.

Copyright © ZyeemZia

ZYEEMZIA™ ACADEMY

Your certification path

Each ZyeemZia™ track stands on its own. Together they form a networking ladder from first network to expert design, plus paths in leadership, artificial intelligence, cybersecurity, IT service management and IT support. Take the next step at the sites below.

Networking ladder

ASSOCIATE
ZCNA
ZyeemZia™ Certified Network Associate
zcna.zyeemzia.com

→

PROFESSIONAL
ZCNP
ZyeemZia™ Certified Network Professional
zcnp.zyeemzia.com

→

EXPERT
ZCIE
ZyeemZia™ Certified Internetwork Expert
zcie.zyeemzia.com

→

EXPERT
ZCIE Security
ZyeemZia™ Certified Internetwork Expert — Security
zcie-security.zyeemzia.com

→

DESIGN EXPERT
ZCDE
ZyeemZia™ Certified Design Expert
zcde.zyeemzia.com

Leadership & management

PROFESSIONAL
ZPMP
ZyeemZia™ Project Management Professional
zpmp.zyeemzia.com

PROFESSIONAL
ZEPMS
ZyeemZia™ Engineering Project Management Specialization
zepms.zyeemzia.com

PROFESSIONAL
ZHRLS
ZyeemZia™ Human Resource Management and Leadership Specialization
zhrls.zyeemzia.com

Artificial intelligence

PROFESSIONAL
ZAIG
ZyeemZia™ AI Governance
zaig.zyeemzia.com

PROFESSIONAL
ZMLS
ZyeemZia™ Machine Learning Specialization
zmls.zyeemzia.com

ARCHITECT
ZAIA
ZyeemZia™ Artificial Intelligence Architecture
zaia.zyeemzia.com

Cybersecurity

PROFESSIONAL
ZCSS
ZyeemZia™ Cybersecurity Specialization
zcss.zyeemzia.com

EXPERT
ZCSTG
ZyeemZia™ Cyber Security – Technology and Governance
zcstg.zyeemzia.com

Copyright © ZyeemZia

IT service management

MASTER

ZITIL Master

ZyeemZia™ Information Technology Infrastructure Library Master

zitil.zyeemzia.com

IT operations & support

ASSOCIATE

ZITSS

ZyeemZia™ IT Support Specialization

zitss.zyeemzia.com

Copyright © ZyeemZia

ZyeemZia™

ZCIE Security

Certified Internetwork Expert — Security

CERTIFICATE OF ACHIEVEMENT

This certifies that

_____

has successfully completed all modules of the ZyeemZia™ Certified Internetwork Expert — Security track and passed the ZCIE Security certification exam

- Security architecture
- Firewalls, VPN & PKI
- Identity & NAC
- Threat detection & SASE
- Zero trust & incident response

ISSUED _____

CREDENTIAL ID _____

Earn the official certificate online at zcie-security.zyeemzia.com: complete every lesson and pass the official exam. Anyone can verify your credential ID at zcie-security.zyeemzia.com/#verify. This page is for your printed record.

Copyright © ZyeemZia

NOTES

My notes

Copyright © ZyeemZia